Київський столичний університет імені Бориса Грінченка

Володимир Соколов

ТЕХНОЛОГІЇ БЕЗПЕКИ БЕЗПРОВОДОВИХ І МОБІЛЬНИХ МЕРЕЖ

Навчальний посібник

для здобувачів другого (освітнього) рівня вищої освіти
спеціальності 125/F5 «Кібербезпека та захист інформації»
галузі знань 12/F «Інформаційні технології»

Київ — 2027

УДК 004.056:621.39(075.8)
ББК 32.884
С594

Препринт

Соколов В. Ю. Технології безпеки безпроводових і мобільних мереж : навчальний посібник для здобувачів другого (освітнього) рівня вищої освіти. Київ, КСУБГ, 2027, 236 с. — 17 розділів.

Навчальний посібник охоплює теоретичні основи та практичні аспекти технологій безпеки безпроводових і мобільних мереж. Розглянуто безпроводові й мобільні мережі як об'єкт захисту, властивості радіоканалу та простір загроз; нормативно-правове й стандартизаційне забезпечення в Україні та Європейському Союзі; математичні та інформаційно-теоретичні основи оцінювання захищеності; моделювання загроз і управління ризиками; безпеку фізичного рівня та криптографічні механізми; безпеку мереж IEEE 802.11, технологій ближньої дії (Bluetooth, NFC, RFID, IEEE 802.15.4), стільникових мереж 2G–4G і сигнальної інфраструктури, мереж 5G; безпеку мобільних платформ і архітектуру нульової довіри; безпеку Інтернету речей і малопотужних мереж; безпеку самоорганізованих, комірчастих і відомчих мереж; безпеку супутникових, навігаційних і безпілотних систем; моніторинг та виявлення вторгнень; стійкість, неперервність і відновлення; управління безпекою та напрями наукових досліджень.

Кожен розділ завершується висновками та питаннями для самоперевірки, серед яких — дослідницькі завдання, придатні як відправна точка для наукової статті чи фрагмента дисертаційного дослідження. Посібник призначено для магістрантів галузі знань 12/F «Інформаційні технології» спеціальності 125/F5 «Кібербезпека та захист інформації», а також буде корисним науковим і науково-педагогічним працівникам, фахівцям із захисту інформації та кібербезпеки.

© Володимир Соколов, 2027
© Київський столичний університет імені Бориса Грінченка, 2027

Зміст

Основні терміни та скорочення **1**

Вступ **3**

1 Безпроводові та мобільні мережі як об'єкт захисту: архітектури, властивості радіоканалу й простір загроз **7**
1.1 Поняття та класифікація безпроводових і мобільних мереж . 7
1.2 Фізичні властивості радіоканалу та їхні безпекові наслідки . 9
1.3 Архітектурні моделі та домени довіри 12
1.4 Мобільність, ідентичність і приватність 14
1.5 Модель порушника 16
1.6 Простір загроз і поверхня атаки 17
1.7 Український контекст: мережі зв'язку в умовах війни 19
1.8 Термінологічний апарат і структура курсу 20
Висновки до розділу 21
Питання для самоперевірки 22

2 Нормативно-правове та стандартизаційне забезпечення безпеки безпроводових і мобільних мереж **25**
2.1 Структура нормативного поля 25
2.2 Законодавство України 27
2.3 Право Європейського Союзу 29
2.4 Міжнародні та галузеві стандарти 32
2.5 Оцінювання відповідності та сертифікація 33
2.6 Порівняльний аналіз вимог України та ЄС 34
2.7 Кейс: визначення застосовних вимог 35
Висновки до розділу 37
Питання для самоперевірки 37

3 Математичні та інформаційно-теоретичні основи оцінювання захищеності безпроводових каналів **39**
3.1 Постановка задачі оцінювання захищеності безпроводової ланки 39
3.2 Інформаційно-теоретична секретність 40
3.3 Просторові моделі: стохастична геометрія 42
3.4 Теорія статистичного виявлення 43

3.5 Моделі глушіння та розширення спектра 44
3.6 Ентропійні міри приватності 46
3.7 Комбінаторні оцінки стійкості 47
3.8 Марковська модель доступності безпроводової ланки 48
3.9 Розгорнутий приклад комплексного розрахунку 49
Висновки до розділу 51
Питання для самоперевірки 51

4 Моделювання загроз і управління ризиками безпроводових і мобільних мереж 53
4.1 Процес управління ризиками 53
4.2 Методології моделювання загроз 55
4.3 Дерева атак 56
4.4 Кількісне оцінювання ризику 58
4.5 Специфіка ризиків мобільних операторів 59
4.6 Ризики мобільних пристроїв в організації 61
4.7 Невизначеність оцінок і ймовірнісне моделювання 61
4.8 Ризики безпроводових мереж в умовах воєнного стану 62
4.9 Кейс: оцінювання ризиків безпроводової мережі університетського кампусу 63
Висновки до розділу 65
Питання для самоперевірки 65

5 Безпека фізичного рівня: секретність каналу, протидія радіоелектронному подавленню та автентифікація передавачів 67
5.1 Місце безпеки фізичного рівня в системі захисту 67
5.2 Конфіденційність на фізичному рівні 69
5.3 Генерування ключів із характеристик каналу 70
5.4 Протидія глушінню 71
5.5 Прихованість зв'язку 73
5.6 Ідентифікація передавачів за фізичними ознаками 73
5.7 Безпечне вимірювання відстані й позиціювання 75
5.8 Побічні випромінювання та атаки на сенсори 77
5.9 Безпека фізичного рівня в сучасних стандартах 78
5.10 Кейс: захист каналу керування малого безпілотного літального апарата 79
Висновки до розділу 79
Питання для самоперевірки 80

6 Криптографічні механізми безпроводових і мобільних мереж 83
6.1 Вимоги до криптографії в безпроводовому середовищі 83
6.2 Уроки історичних помилок 84
6.3 Сучасні набори алгоритмів 86
6.4 Ієрархії ключів і функції виведення 88
6.5 Автентифіковане шифрування 90
6.6 Протоколи автентифікації та узгодження ключів 90
6.7 Легковагова криптографія 92
6.8 Постквантовий перехід 93
6.9 Національні криптографічні стандарти України 94
6.10 Кейс: криптографічний профіль корпоративних безпроводових мереж 95
Висновки до розділу 96
Питання для самоперевірки 96

7 Безпека безпроводових локальних мереж IEEE 802.11 99
7.1 Архітектура IEEE 802.11 з погляду безпеки 99
7.2 Еволюція механізмів захисту 100
7.3 Чотиристоронє рукостискання і атаки на нього 101
7.4 WPA3 і протокол SAE 102
7.5 Корпоративна автентифікація: IEEE 802.1X і RADIUS 103
7.6 Атаки на канальний рівень і кадри керування 104
7.7 Приватність клієнтів 105
7.8 Небезпечні успадковані функції 105
7.9 Публічні мережі, портали та відкрите шифрування 106
7.10 Методика захищеного проєктування корпоративної мережі . 107
Висновки до розділу 108
Питання для самоперевірки 108

8 Безпека технологій ближньої дії: Bluetooth, NFC, RFID та IEEE 802.15.4 111
8.1 Спільні особливості безпеки технологій ближньої дії 111
8.2 Bluetooth і Bluetooth Low Energy 112
8.3 Безконтактні технології: NFC та RFID 115
8.4 Атаки ретрансляції та безпека відстані 116
8.5 Мережі IEEE 802.15.4, Zigbee і Thread 116
8.6 Кейс: захист системи контролю доступу організації 118
Висновки до розділу 119
Питання для самоперевірки 120

9 Безпека стільникових мереж 2G–4G та сигнальної інфраструктури 123
9.1 Еволюція архітектури безпеки 123
9.2 Автентифікація і керування ідентифікаторами 124
9.3 Атаки на радіоінтерфейс 125
9.4 Безпека сигнальної інфраструктури 127
9.5 Приватність і законне перехоплення 129
9.6 Український контекст 130
9.7 Кейс: захист абонентів оператора від сигнальних і радіоатак . 130
Висновки до розділу 131
Питання для самоперевірки 131

10 Безпека мереж 5G та приватність абонентів 133
10.1 Архітектурні зміни та їх безпекові наслідки 133
10.2 Приховування ідентифікатора абонента 134
10.3 Автентифікація та її формальний аналіз 135
10.4 Безпека сервісного ядра та міжоператорської взаємодії 136
10.5 Мережеві зрізи 137
10.6 Відкрита архітектура радіодоступу 138
10.7 Перспективи 6G 138
10.8 Кейс: безпека приватної мережі 5G промислового підприємства 138
Висновки до розділу 139
Питання для самоперевірки 140

11 Безпека мобільних платформ, керування мобільністю та нульова довіра 143
11.1 Модель безпеки мобільних платформ 143
11.2 Безпека мобільних застосунків 144
11.3 Цільові атаки на мобільні пристрої 145
11.4 Автентифікація користувачів 146
11.5 Керування корпоративною мобільністю 147
11.6 Архітектура нульової довіри 148
11.7 Кейс: захищений мобільний доступ до ресурсів організації . 150
Висновки до розділу 150
Питання для самоперевірки 151

12 Безпека Інтернету речей та малопотужних безпроводових мереж 153
12.1 Особливості безпеки Інтернету речей 153
12.2 Класи загроз і ботнети 154
12.3 Малопотужні глобальні мережі 155
12.4 Фізична безпека та атаки за побічними каналами 157

12.5 Механізми захисту та регуляторні вимоги 158
12.6 Промисловий Інтернет речей 159
12.7 Кейс: захист безпроводової сенсорної мережі комунального підприємства 159
Висновки до розділу 160
Питання для самоперевірки 160

13 Безпека самоорганізованих, комірчастих і відомчих безпроводових мереж 163
13.1 Особливості самоорганізованих мереж як об'єкта захисту . . 163
13.2 Атаки на маршрутизацію та контрзаходи 164
13.3 Безпека сенсорних і комірчастих мереж 165
13.4 Відомчі та тактичні радіомережі 166
13.5 Управління довірою в децентралізованому середовищі 167
13.6 Кейс: захищена радіомережа екстреної служби 168
Висновки до розділу 169
Питання для самоперевірки 169

14 Безпека супутникового зв'язку, навігації та безпілотних систем 171
14.1 Глобальні навігаційні супутникові системи 171
14.2 Безпека супутникового зв'язку 174
14.3 Безпека безпілотних систем 175
14.4 Український контекст 176
14.5 Кейс: захист безпілотної системи моніторингу критичної інфраструктури 177
Висновки до розділу 177
Питання для самоперевірки 178

15 Моніторинг, радіомоніторинг та виявлення вторгнень у безпроводових мережах 181
15.1 Завдання та джерела моніторингу 181
15.2 Виявлення вторгнень і аномалій 182
15.3 Радіомоніторинг та аналіз спектра 183
15.4 Локалізація джерел радіовипромінювання 184
15.5 Машинне навчання та його вразливості 185
15.6 Організація моніторингу безпеки 185
15.7 Кейс: моніторинг безпеки безпроводової інфраструктури підприємства 186
Висновки до розділу 187
Питання для самоперевірки 187

16 Стійкість, неперервність та відновлення безпроводових і мобільних мереж 189
16.1 Поняття стійкості безпроводової мережі 189
16.2 Кількісні моделі стійкості 190
16.3 Реагування на інциденти 191
16.4 Відновлення та неперервність 192
16.5 Національний роумінг та енергетична автономність 192
16.6 Уроки українського досвіду 193
16.7 Кейс: план стійкості мобільного оператора 194
Висновки до розділу 195
Питання для самоперевірки 195

17 Управління безпекою безпроводових мереж, DevSecOps і напрями наукових досліджень 197
17.1 Система управління інформаційною безпекою 197
17.2 Вимірювання безпеки та метрики 198
17.3 Безпечне розроблення та DevSecOps 199
17.4 Економіка безпеки 200
17.5 Методологія наукових досліджень 200
17.6 Перспективні напрями досліджень 201
17.7 Кейс: побудова програми безпеки безпроводових мереж організації 201
Висновки до розділу 202
Питання для самоперевірки 203

Список використаних джерел 205

Додаток. Завдання для самостійної роботи 227

Основні терміни та скорочення

БпЛА	безпілотний літальний апарат
ЕОМ	електронна обчислювальна машина
ІКС	інформаційно-комунікаційна система
IoT	Інтернет речей (Internet of Things)
КЗІ	криптографічний захист інформації
КСЗІ	комплексна система захисту інформації
НД ТЗІ	нормативний документ системи технічного захисту інформації
НКЕК	Національна комісія, що здійснює державне регулювання у сферах електронних комунікацій, радіочастотного спектра та надання послуг поштового зв'язку
НСД	несанкціонований доступ
ОІД	об'єкт інформаційної діяльності
ОКІ	об'єкт критичної інфраструктури
ПЕМВН	побічні електромагнітні випромінювання і наводки
РЕБ	радіоелектронна боротьба
СУІБ	система управління інформаційною безпекою
ТЗІ	технічний захист інформації
AKA	Authentication and Key Agreement 'автентифікація й узгодження ключів'
AOA	Angle of Arrival 'кут приходу сигналу'
BLE	Bluetooth Low Energy 'Bluetooth з низьким енергоспоживанням'
EAP	Extensible Authentication Protocol 'розширюваний протокол автентифікації'

GNSS	Global Navigation Satellite System ‘глобальна навігаційна супутникова система’
IMSI	International Mobile Subscriber Identity ‘міжнародний ідентифікатор абонента’
IDS/IPS	Intrusion Detection / Prevention System ‘системи виявлення / запобігання вторгненням’
LPWAN	Low-Power Wide-Area Network ‘малопотужна глобальна мережа’
MFA	Multi-Factor Authentication ‘багатофакторна автентифікація’
MTTD	Mean Time to Detect ‘середній час виявлення’
MTTR	Mean Time to Respond/Repair ‘середній час реагування/відновлення’
NFC	Near-Field Communication ‘зв’язок ближнього поля’
OSNMA	Open Service Navigation Message Authentication ‘автентифікація навігаційних повідомлень’
RFID	Radio-Frequency Identification ‘радіочастотна ідентифікація’
RTO/RPO	Recovery Time/Point Objective ‘цільовий час/точка відновлення’
SAE	Simultaneous Authentication of Equals ‘одночасна автентифікація рівних’
SEPP	Security Edge Protection Proxy ‘проксі захисту межі безпеки’
SIEM	Security Information and Event Management ‘керування подіями та інформацією безпеки’
SOC	Security Operations Center ‘центр забезпечення кібербезпеки’
SS7	Signalling System No. 7 ‘система сигналізації № 7’
SUCI	Subscription Concealed Identifier ‘прихований ідентифікатор абонента’
TDOA	Time Difference of Arrival ‘різниця часу приходу’
UWB	Ultra-Wideband ‘надширокосмугова технологія’
ZTA	Zero Trust Architecture ‘архітектура нульової довіри’

Вступ

Безпроводові та мобільні мережі стали основним середовищем доступу до інформаційних ресурсів. Через радіоканал проходить переважна частина абонентського трафіку, керування промисловими й енергетичними об'єктами, обмін даними сенсорів, робота безпілотних платформ, навігація й синхронізація часу критичної інфраструктури. Захист таких мереж принципово відрізняється від захисту провідних систем: середовище поширення сигналу є спільним і широкомовним, обмежити фізичний доступ до нього неможливо, абонент постійно змінює точку підключення й домен довіри, а значна частина пристроїв має жорсткі обмеження ресурсів і тривалий життєвий цикл без оновлень.

Досвід України останніх років зробив ці питання предметом не лише академічного інтересу. Кібератаки на операторів зв'язку, масоване застосування засобів радіоелектронної боротьби проти навігаційних систем, руйнування інфраструктури й тривалі знеструмлення, масове використання безпілотних систем перетворили безпеку безпроводових і мобільних мереж на питання національної стійкості. Одночасно змінилося нормативне поле: оновлено законодавство про кібербезпеку та критичну інфраструктуру, триває гармонізація з європейськими вимогами.

Мета і завдання навчальної дисципліни

Мета курсу — формування в магістрантів знань, умінь і навичок із застосування теоретичних основ та технологій забезпечення безпеки безпроводових і мобільних мереж для захисту інформаційних ресурсів.

Завдання курсу — отримання теоретичних знань та практичних умінь з дослідження й застосування технологій безпеки безпроводових і мобільних мереж та набуття таких компетентностей:

- здатність застосовувати сучасні технології безпеки під час проєктування та експлуатації захищених безпроводових і мобільних мереж;
- здатність оцінювати захищеність і знаходити раціональні рішення щодо захисту безпроводових і мобільних мереж;
- здатність до вдосконалення й наукового дослідження засобів і технологій забезпечення безпеки безпроводових і мобільних мереж.

Структура посібника

Матеріал згруповано у чотири логічні блоки.

Блок I. Засади (розділи 1–4) формує понятійний апарат: безпроводові й мобільні мережі як об'єкт захисту, властивості радіоканалу та простір загроз; нормативно-правове й стандартизаційне поле; математичні та інформаційно-теоретичні основи оцінювання захищеності; моделювання загроз і управління ризиками.

Блок II. Механізми та технології захисту радіоінтерфейсів (розділи 5–10) присвячено власне засобам: безпеці фізичного рівня, криптографічним механізмам, безпеці мереж IEEE 802.11, технологій ближньої дії, стільникових мереж 2G–4G і сигнальної інфраструктури, мереж 5G.

Блок III. Платформи, пристрої та спеціалізовані мережі (розділи 11–14) охоплює безпеку мобільних платформ і архітектуру нульової довіри, безпеку Інтернету речей і малопотужних мереж, безпеку самоорганізованих, комірчастих і відомчих мереж, безпеку супутникових, навігаційних і безпілотних систем.

Блок IV. Операційна безпека та управління (розділи 15–17) охоплює моніторинг і виявлення вторгнень, стійкість, неперервність і відновлення, а також управління безпекою, практики безпечного розроблення й методологію наукових досліджень.

Як працювати з посібником

Посібник розраховано на здобувачів другого (освітнього) рівня вищої освіти, які вже володіють базовими знаннями з інформаційної безпеки, комп'ютерних мереж і криптографії. Виклад побудовано як систематизація на рівні моделей, доказових аргументів і критичного аналізу чинних рішень, а не як первинне ознайомлення з предметом. Формули супроводжуються поясненням позначень і числовими прикладами, які варто відтворити самостійно.

Питання для самоперевірки наприкінці кожного розділу неоднорідні: частина перевіряє відтворення матеріалу, частина потребує аналізу й порівняння, а завершальні питання сформульовано як дослідницькі завдання — вони можуть слугувати відправною точкою для наукової статті або фрагмента дисертаційного дослідження. Магістрантові рекомендується опрацьовувати їх у зв'язці з власною темою.

Посилання на джерела наведено в квадратних дужках; повний список подано наприкінці видання. Перевагу віддано чинним нормативним документам, національним та міжнародним стандартам, галузевим специфікаціям і рецензованим науковим працям. Усі нормативні акти й специфікації слід перевіряти на чинність редакції на момент використання: сфера безпроводових технологій і кібербезпеки змінюється швидко.

Термінологічне зауваження

У виданні послідовно вживається термін **безпроводові** (мережі, канали, технології) як український відповідник англійського *wireless*. Англомовні терміни, що не мають усталеного українського відповідника, наводяться в дужках мовою оригіналу при першому вживанні.

РОЗДІЛ 1

Безпроводові та мобільні мережі як об'єкт захисту: архітектури, властивості радіоканалу й простір загроз

Безпроводові та мобільні мережі стали основним середовищем доступу до інформаційних ресурсів: через радіоканал проходить переважна частина абонентського трафіку, керування промисловими й енергетичними об'єктами, обмін даними сенсорів і безпілотних платформ. Водночас саме радіоканал є тією ланкою, де класичні уявлення про захищений периметр перестають працювати: сигнал поширюється в усіх напрямках, його можна прийняти, заглушити або підробити без фізичного підключення до мережі, а сам абонент постійно змінює точку підключення, провайдера й домен довіри. Розділ формує системне бачення безпроводових і мобільних мереж як об'єкта захисту: дає класифікацію технологій, аналізує фізичні властивості радіоканалу та їхні безпекові наслідки, описує архітектурні моделі й домени довіри, формулює властивості безпеки, специфічні для мобільного середовища, і будує модель порушника та простір загроз, на які спиратимуться всі наступні розділи посібника. Окремо розглянуто український контекст — досвід функціонування мереж зв'язку в умовах повномасштабної війни.

1.1 Поняття та класифікація безпроводових і мобільних мереж

1.1.1 Базові означення

Безпроводова мережа — це електронна комунікаційна мережа, у якій щонайменше один сегмент передавання даних між вузлами реалізовано через середовище без спрямовувальних провідників: радіоканал, оптичний канал у вільному просторі чи інфрачервоний канал. У цьому посібнику основну увагу приділено *радіомережам*, оскільки саме вони становлять абсолютну більшість практичних систем і саме для них характерна найширша поверхня атаки. **Мобільна мережа** — безпроводова мережа, яка забезпечує збереження сеансу зв'язку та доступності абонента під час його переміщення, зокрема між зонами обслуговування різних базових станцій (передавання обслуговування, handover) і різних операторів (роумінг). Відповідно до Закону України «Про електронні комунікації» [34] радіочастотний ресурс є обмеженим національним ресурсом, а його використання підлягає державному регулюванню, яке здійснює Національна комісія, що здійснює державне регулювання у сферах електронних комунікацій, радіочастотного спектра та надання послуг поштового зв'язку (НКЕК) [35]. Міжнародний рівень розподілу смуг частот задає Регламент радіозв'язку МСЕ [238].

Важливо розрізняти три рівні об'єкта захисту. *Радіоінтерфейс* — фізичний і канальний рівні безпроводової ланки (модуляція, доступ до середовища, шифрування кадрів). *Мережа доступу* — сукупність базових станцій або точок доступу, контролерів і транспортних ліній, що з'єднують їх з ядром. *Ядро мережі та сервісна інфраструктура* — функції автентифікації, керування мобільністю, маршрутизації, тарифікації, сигналізації між операторами. Атака може бути спрямована на будь-який із цих рівнів, а засоби захисту одного рівня, як правило, не компенсують слабкості іншого.

1.1.2 Класифікація за масштабом і призначенням

Традиційна класифікація за радіусом дії (персональні, локальні, міські, глобальні мережі) з погляду безпеки доповнюється ознаками моделі керування (централізоване операторське, корпоративне, самоорганізоване), моделі довіри між вузлами і характеру трафіку (абонентський, машинний, керувальний). Узагальнення наведено в табл. 1.1; технологічні подробиці кожного класу розглянуто в розділах 7–14.

Таблиця 1.1 — Класи безпроводових і мобільних мереж та їхні безпекові характеристики

Клас	Типові технології	Радіус	Модель довіри та ключові ризики
Персональні (WPAN)	Bluetooth, BLE, UWB, NFC	0,1–100 м	спарювання «пристрій–пристрій»; слабкі методи асоціації, відстеження за ідентифікаторами
Локальні (WLAN)	IEEE 802.11 (Wi-Fi 4–7)	30–300 м	корпоративна або домашня; спільні паролі, підроблені точки доступу, деавтентифікація
Стільникові (WWAN)	GSM, UMTS, LTE, 5G NR	0,1–35 км	операторська з SIM/USIM; фальшиві базові станції, сигналізація між операторами
Малопотужні глобальні (LPWAN)	LoRaWAN, NB-IoT, LTE-M	1–15 км	серверна; обмежені ресурси пристроїв, статичні ключі, повторення кадрів
Самоорганізовані (MANET, mesh)	IEEE 802.11s, тактичні радіомережі, BLE Mesh	змінний	розподілена; атаки на маршрутизацію, Sybil, чорні діри
Супутникові та безпілотні	GNSS, VSAT, LEO-системи, канали БпЛА	10–36 000 км	односпрямовані або глобальні; підміна навігаційного сигналу, глушіння, перехоплення

З таблиці видно принципову рису: зі збільшенням радіуса дії зростає не лише кількість потенційних зловмисників у зоні досяжності, а й кількість незалежних адміністративних доменів, через які проходить трафік. Для персональної мережі модель довіри замикається на двох пристроях, для стільникової — охоплює абонента, оператора доступу, оператора ядра, роумінгових партнерів і постачальників обладнання.

1.1.3 Покоління мобільного зв'язку як еволюція моделі безпеки

Еволюцію мобільних мереж зручно розглядати як поступове виправлення архітектурних прорахунків безпеки. Системи першого покоління (аналогові) не мали криптографічного захисту взагалі: перехоплення розмов і клонування ідентифікаторів абонентських терміналів були масовим явищем. Друге покоління (GSM) запровадило SIM-картку, автентифікацію абонента за принципом «виклик–відповідь» і шифрування радіоінтерфейсу, але автентифікація була однобічною, а криптоалгоритми — закритими і, як згодом з'ясувалося, слабкими [64]. Третє покоління (UMTS) усунуло найсерйознішу ваду — додало взаємну автентифікацію та захист цілісності сигналізації [54]. Четверте покоління (LTE) розділило ключі за рівнями та функціями й побудувало ієрархію ключів [57, 141]. П'яте покоління (5G) вперше зашифрувало постійний ідентифікатор абонента під час реєстрації, запровадило єдину рамку автентифікації для 3GPP- та не-3GPP-доступу, захищену взаємодію між операторами та сервісно-орієнтовану архітектуру ядра [58, 53]. Концептуальні вимоги до мереж IMT-2020 та IMT-2030 (6G) сформульовано в рекомендаціях MCE [241, 242]; у документах щодо IMT-2030 безпека, стійкість і довіра визначені як наскрізні характеристики системи, а не додаткові функції. Докладно ці покоління розглянуто в розділах 9 і 10.

Показово, що кожне покоління зберігає зворотну сумісність із попередніми, тож термінал, який підтримує 5G, здебільшого вміє працювати і в GSM. Для порушника це означає можливість **атаки зниження версії** (downgrade): примусити абонента перейти до найслабшого з підтримуваних протоколів і атакувати вже його. Цей висновок має загальний характер для безпроводових технологій — аналогічну проблему має перехідний режим WPA2/WPA3 у Wi-Fi і режими спарювання різних версій Bluetooth.

1.2 Фізичні властивості радіоканалу та їхні безпекові наслідки

1.2.1 Широкомовна природа середовища

Головна властивість радіоканалу, що визначає всю специфіку захисту, — **широкомовність**: сигнал передавача поширюється в просторі й доступний будь-якому приймачу, розташованому в зоні, де потужність сигналу перевищує чутливість приймача. На відміну від провідної мережі, для перехоплення не потрібні ні фізичний доступ до кабелю, ні порушення цілісності лінії, ні взаємодія з інфраструктурою: пасивний приймач не випромінює і принципово не виявляється засобами мережевого моніторингу. Звідси перше фундаментальне положення: *у безпроводовій мережі конфіденційність не може забезпечуватися обмеженням доступу до середовища і має забезпечуватися криптографічно або методами безпеки фізичного рівня* (роз-

діли 5 і 6). Класичну демонстрацію наслідків неврахування цього положення дали Борисов, Голдберг і Вагнер, показавши множинні вади протоколу WEP, розробники якого вважали шифрування кадрів еквівалентом «провідної приватності» [88].

Друга властивість — **спільність середовища**: усі передавачі в одній смузі частот конкурують за ресурс. Будь-який передавач, що випромінює з достатньою потужністю, здатен порушити приймання, тобто доступність безпроводової ланки *принципово* не може бути гарантована криптографічними засобами. Третя властивість — **відкритість сигналізації**: службові кадри (маяки точок доступу, системна інформація базових станцій, кадри пошуку і керування) передаються відкрито, бо без них термінал не зможе знайти мережу. Відкрита сигналізація дає порушнику змогу пасивно ідентифікувати мережі, термінали й абонентів, а активно — підробляти службові повідомлення.

1.2.2 Енергетичний бюджет лінії та дальність перехоплення

Кількісною мірою досяжності сигналу є енергетичний бюджет радіолінії. У вільному просторі потужність на вході приймача визначає рівняння Фріїса [240]:

$$P_r = P_t\, G_t\, G_r \left(\frac{\lambda}{4\pi d}\right)^2, \tag{1.1}$$

де P_t — потужність передавача; G_t, G_r — коефіцієнти підсилення антен передавача і приймача; λ — довжина хвилі; d — відстань. Для реальних умов (забудова, приміщення, рослинність) використовують логарифмічно-відстанну модель втрат поширення з лог-нормальним затуханням [240, 149]:

$$PL(d)\,[\text{дБ}] = PL(d_0) + 10\, n\, \lg\frac{d}{d_0} + X_\sigma, \tag{1.2}$$

де $PL(d_0)$ — втрати на опорній відстані d_0; n — показник втрат (2 — вільний простір, 2,7–3,5 — міська забудова, 4–6 — приміщення з перешкодами); X_σ — гауссова випадкова величина з нульовим середнім і середньоквадратичним відхиленням σ (дБ), що описує затінення.

Нехай легітимний приймач має чутливість S_B і антену з підсиленням G_B, а приймач порушника — чутливість S_E і підсилення G_E. Тоді з (1.2) (за $X_\sigma = 0$) відношення максимальних відстаней приймання дорівнює

$$\frac{d_E}{d_B} = 10^{\dfrac{(G_E - G_B) + (S_B - S_E)}{10\, n}}, \tag{1.3}$$

де всі величини подано в дБ (дБм). Формула (1.3) пояснює, чому оцінка «мережу видно лише в межах будівлі» є хибною. Для точки доступу з потужністю 20 дБм, штатними антенами по 2 дБі і клієнтом із чутливістю -82 дБм допустимі втрати становлять 106 дБ. Порушник зі спрямованою антеною 24 дБі і малошумним підсилювачем (чутливість -95 дБм) має запас 141 дБ, тобто на 35 дБ більше. За $n = 2{,}7$ отримуємо $d_E/d_B = 10^{35/27} \approx 19{,}8$: якщо клієнти працюють на відстані до 50 м, перехоплення можливе приблизно з 1 км. За прямої видимості ($n = 2$) відношення зростає до $10^{35/20} \approx 56$. Натурні експерименти з атакою типу «war driving» в українських містах підтверджують, що мережі IEEE 802.11 фіксуються з автомобіля, що рухається, на відстанях, значно більших за проєктну зону обслуговування [17].

1.2.3 Пропускна здатність і енергетична асиметрія атаки

Максимальну швидкість безпомилкової передачі визначає формула Шеннона [259]

$$C = B \log_2\!\left(1 + \frac{S}{N + J}\right), \tag{1.4}$$

де B — ширина смуги; S — потужність корисного сигналу; N — потужність шуму; J — потужність завади, створюваної порушником. Формула (1.4) показує механізм атаки глушіння: збільшуючи J, порушник зменшує пропускну здатність, а після того як відношення сигнал/(шум+завада) опуститься нижче порогу демодуляції, — повністю блокує ланку. Важлива **енергетична асиметрія**: завада має перевищити сигнал лише *на вході приймача*, тому постановник завад, розташований ближче до приймача, ніж легітимний передавач, досягає мети з потужністю, у багато разів меншою за потужність передавача. Особливо вразливі системи, де корисний сигнал на вході приймача надзвичайно слабкий, — супутникові навігаційні системи, сигнал яких на поверхні Землі лежить нижче рівня теплового шуму (розділ 14). Методи протидії — розширення спектра, стрибкоподібна зміна частоти, адаптивні антенні решітки — розглянуто в розділі 5.

1.2.4 Мобільність, багатопроменевість і відбиток пристрою

Радіоканал між двома точками є випадковим процесом: багатопроменеве поширення, завмирання і доплерівський зсув роблять характеристику каналу унікальною для конкретної пари позицій. Ця властивість має двоїсте значення. З одного боку, вона ускладнює приймання і вимагає складних механізмів адаптації. З іншого — канальна характеристика, спільна для двох легітимних сторін і некорельована з каналом порушника, віддаленого більш ніж на половину довжини хвилі, може слугувати джерелом спільної секретної випадковості для генерування ключів (розділ 5). Аналогічно

недосконалості аналогових трактів передавачів (зсув частоти генератора, дисбаланс квадратурних складових, перехідні процеси) утворюють **радіочастотний відбиток** пристрою, придатний для його ідентифікації незалежно від заявлених у кадрах адрес. Для захисника це засіб виявлення підроблених точок доступу й базових станцій, для порушника — засіб відстеження абонента навіть за рандомізованих MAC-адрес.

1.3 Архітектурні моделі та домени довіри

1.3.1 Інфраструктурна, самоорганізована та комірчаста моделі

В **інфраструктурній** моделі кінцеві вузли взаємодіють лише через точку доступу або базову станцію, пов'язану з провідною інфраструктурою. Керування доступом, автентифікація і політики безпеки централізовані, що спрощує адміністрування, але робить точку доступу привабливою ціллю для підміни. У **самоорганізованій** (ad hoc) моделі вузли взаємодіють безпосередньо й самі виконують функції маршрутизаторів; централізованого довіреного елемента немає, тому автентифікація, розподіл ключів і захист маршрутизації мають бути розподіленими (розділ 13). **Комірчаста** (mesh) модель поєднує обидва підходи: магістраль із безпроводово пов'язаних вузлів-ретрансляторів обслуговує кінцевих клієнтів, а атака на один вузол магістралі може вплинути на маршрути для всієї мережі.

1.3.2 Узагальнена архітектура мобільної мережі

На рис. 1.1 наведено узагальнену архітектуру стільникової мережі з виділенням доменів довіри. Абонентське обладнання (UE) складається з мобільного пристрою і захищеного елемента (UICC з застосунком USIM або вбудованого eSIM), що зберігає довготривалий секретний ключ абонента. Мережа радіодоступу (RAN) містить базові станції, які в 5G можуть бути розділені на централізований та розподілений блоки. Транспортна мережа (backhaul) пов'язує RAN з ядром. Обслуговувальна мережа (serving network) виконує функції керування мобільністю, домашня мережа (home network) зберігає профіль і ключ абонента та ухвалює остаточне рішення про автентифікацію. У роумінгу обслуговувальна і домашня мережі належать різним операторам і взаємодіють через міжоператорську сигналізацію [53, 254].

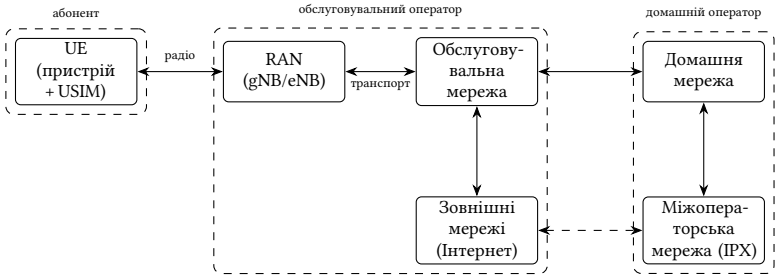


Рис. 1.1 — Узагальнена архітектура мобільної мережі та домени довіри (за [53])

Архітектура на рис. 1.1 має кілька наслідків для безпеки. По-перше, радіоінтерфейс є єдиним сегментом, до якого порушник має доступ без будь-яких повноважень, тому він історично захищається найретельніше. По-друге, транспортна мережа RAN–ядро часто проходить через орендовані канали, радіорелейні лінії або спільну інфраструктуру і тривалий час не шифрувалася; сучасні специфікації вимагають захисту цього сегмента за допомогою IPsec [57, 58, 189]. По-третє, міжоператорська сигналізація історично будувалася на принципі взаємної довіри закритого «клубу» операторів, що зробило її головною вадою мобільних мереж другого–четвертого поколінь (розділ 9). По-четверте, домашня мережа є кінцевим арбітром автентифікації, і компрометація її баз ключів абонентів нівелює всі механізми захисту радіоінтерфейсу.

1.3.3 Корпоративні безпроводові мережі

Корпоративна мережа Wi-Fi будується за схожою логікою, але в межах одного адміністративного домену: точки доступу (автономні або керовані контролером), сервер автентифікації (RADIUS) з інтеграцією в каталог користувачів, система виявлення вторгнень у безпроводовому ефірі (WIDS/WIPS) і шлюз до провідної мережі. Протокол IEEE 802.1X [175] з розширюваним протоколом автентифікації EAP [65] забезпечує індивідуальну автентифікацію користувачів і генерування унікальних ключів для кожного сеансу (розділ 7). Критично важливим є те, що безпроводовий сегмент корпоративної мережі не повинен розглядатися як довірений: відповідно до принципів архітектури нульової довіри [250] автентифікація в Wi-Fi є лише першою умовою, а доступ до ресурсів має контролюватися окремо з урахуванням стану пристрою і контексту запиту.

1.4 Мобільність, ідентичність і приватність

1.4.1 Ідентифікатори в мобільному середовищі

Мобільний абонент одночасно має кілька ідентифікаторів різних рівнів: постійний ідентифікатор підписки (IMSI у 2G–4G, SUPI у 5G), номер абонента (MSISDN), ідентифікатор обладнання (IMEI/PEI), тимчасові ідентифікатори, які призначає мережа (TMSI, GUTI, 5G-GUTI), апаратні адреси безпроводових інтерфейсів (MAC-адреси Wi-Fi і Bluetooth), ідентифікатори застосунків і рекламні ідентифікатори операційної системи. Кожен із них може бути використаний для **зв'язування** (linking) дій абонента в часі та просторі. На відміну від стаціонарної мережі, де ідентифікатор здебільшого пов'язаний з точкою підключення, у мобільній мережі ідентифікатор *рухається разом із людиною*, тому його розкриття еквівалентне розкриттю маршрутів її переміщення.

Проблема ускладнюється тим, що мережа мусить знати, кому належить термінал, ще до встановлення захищеного контексту: у першому повідомленні реєстрації пристрій повинен якось себе назвати. У GSM, UMTS і LTE за певних умов (перша реєстрація, втрата синхронізації тимчасового ідентифікатора) термінал передавав IMSI відкритим текстом, чим і користуються пристрої перехоплення ідентифікаторів — «IMSI-кетчери», фальшиві базові станції, що запитують постійний ідентифікатор [97, 141]. У 5G цю ваду усунуто шифруванням ідентифікатора відкритим ключем домашньої мережі (SUCI) [58], однак низка досліджень показала, що зв'язування можливе і через інші канали — лічильники послідовності, повідомлення про помилки синхронізації, характеристики радіопередавача (розділ 10).

1.4.2 Властивості безпеки мобільного середовища

Класична тріада «конфіденційність–цілісність–доступність» для безпроводових і мобільних мереж доповнюється низкою специфічних властивостей. Їх систематизовано в табл. 1.2; для кожної властивості вказано основні механізми забезпечення та розділи посібника, де вони розглядаються детально.

Таблиця 1.2 — Властивості безпеки безпроводових і мобільних мереж

Властивість	Зміст і типові механізми	Розділи
Конфіденційність трафіку	шифрування радіоінтерфейсу, наскрізне шифрування, безпека фізичного рівня	5–7
Цілісність і автентичність	коди автентифікації повідомлень, AEAD, захист службових кадрів	6, 7
Взаємна автентифікація	AKA, 802.1X/EAP, SAE, спарювання з підтвердженням	7–10
Конфіденційність ідентичності	тимчасові ідентифікатори, SUCI, рандомізація MAC-адрес	9, 10
Неспостережуваність місця	захист від відстеження за ідентифікаторами та радіовідбитком	5, 11
Незв'язуваність	неможливість пов'язати два сеанси одного абонента	10, 12
Доступність	стійкість до глушіння, резервування, захист від сигнальних атак	5, 16
Безпека позиціювання	захищене визначення місця і відстані (GNSS, UWB)	8, 14
Підзвітність	журналювання, законне перехоплення з контролем, аудит	15, 17

Властивості з табл. 1.2 можуть суперечити одна одній. Законне перехоплення і підзвітність оператора вимагають можливості пов'язати трафік з абонентом, тоді як приватність вимагає незв'язуваності; сильна автентифікація пристрою за апаратним ключем полегшує його відстеження; агресивне резервування каналів для доступності збільшує поверхню атаки. Проєктування захисту безпроводової системи завжди є пошуком компромісу, який має бути явно обґрунтований (розділ 4).

1.4.3 Роумінг і перехід між мережами

Під час роумінгу абонент довіряє обслуговувальній мережі, з якою в нього немає прямих договірних відносин. Модель безпеки 3GPP розв'язує цю проблему делегуванням: домашня мережа генерує автентифікаційні вектори і передає обслуговувальній мережі лише похідні ключі, не розкриваючи довготривалого ключа абонента. У 5G домашня мережа отримує ще й криптографічне підтвердження того, що абонент справді був автентифікований у конкретній обслуговувальній мережі, що обмежує можливості шахрайства з тарифікацією [58]. Передавання обслуговування між базовими станціями вимагає швидкого перенесення ключового контексту; для цього використовують механізм похідних ключів із «прямою» і «зворотною» ізоляцією, щоб компрометація однієї базової станції не розкривала ключів попередніх і наступних станцій (розділ 9). Для Wi-Fi аналогічні задачі розв'язують механізми швидкого переходу IEEE 802.11r і кешування ключів [171].

Окремий клас задач утворює **перехід між технологіями**: смартфон автоматично перемикається між стільниковою мережею, домашнім і публічним Wi-Fi, дзвінками через Wi-Fi (VoWiFi), супутниковим каналом. Кожен перехід — це нова модель довіри й новий набір атак. Зокрема, автоматичне підключення до відомих мереж Wi-Fi за іменем (SSID) дає змогу порушникові розгорнути точку доступу-двійника («злий двійник», Evil Twin) і перехопити трафік. Методи виявлення таких атак в умовах щільної міської забудови досліджено, зокрема, в роботі [3].

1.5 Модель порушника

1.5.1 Від мережевого до радіопорушника

Класична модель Долева–Яо [112] припускає, що порушник повністю контролює мережу: перехоплює, видаляє, змінює і вставляє будь-які повідомлення, але не може зламати криптографічні примітиви. Для безпроводових мереж ця модель одночасно надто сильна і надто слабка. Надто сильна, бо реальний радіопорушник не може *вилучити* повідомлення з ефіру: легітимний приймач, що перебуває в зоні дії передавача, отримає сигнал незалежно від волі порушника, якщо той не створить завади. Надто слабка — бо модель не враховує фізичних можливостей: оцінювання відстані й напрямку на передавач, ідентифікацію за радіовідбитком, вибіркове глушіння окремих кадрів, ретрансляцію сигналу з мінімальною затримкою (атаки ретрансляції на системи безключового доступу), підміну сигналів навігаційних систем.

Тому для безпроводових систем доцільно використовувати *багатовимірну* модель порушника, яка задається кортежем

$$\mathcal{A} = \langle \Pi,\ \Lambda,\ \Phi,\ K,\ R \rangle, \tag{1.5}$$

де Π — позиція порушника щодо системи (зовнішній, абонент, інсайдер оператора, постачальник обладнання, суб'єкт міжоператорської взаємодії); Λ — рівні, на яких він діє (фізичний, канальний, мережевий, сигнальний, прикладний); Φ — фізичні можливості (потужність і смуга передавача, чутливість приймача, кількість антен і рознесених приймачів, мобільність); K — апріорні знання (ключі, ідентифікатори, конфігурація мережі, топологія); R — ресурси (час, кошти, обчислювальна потужність, доступ до спеціалізованого обладнання). Типові профілі порушників наведено в табл. 1.3.

Таблиця 1.3 — Типові профілі порушника безпроводових і мобільних мереж

Профіль	Позиція і рівні	Характерні можливості й атаки
Пасивний спостерігач	зовнішній; фізичний, канальний	приймання в розширеній зоні, аналіз метаданих, відстеження ідентифікаторів
Активний радіопорушник	зовнішній; фізичний, канальний	підроблені точки доступу і базові станції, деавтентифікація, глушіння, ретрансляція
Скомпрометований абонент	абонент; мережевий, прикладний	атаки на інших абонентів у спільній мережі, зловживання спільним паролем
Сигнальний порушник	учасник міжоператорської взаємодії	запити місцезнаходження, перехоплення SMS, переадресація викликів через SS7/Diameter
Інсайдер оператора	внутрішній; усі рівні	доступ до ядра, баз ключів, систем керування; руйнування інфраструктури
Державний порушник (APT)	будь-яка; усі рівні	поєднання наведених можливостей, атаки на постачальників, тривала прихована присутність

1.5.2 Загальні вимоги до моделі порушника

Модель порушника має бути явною і відповідати призначенню системи. Для домашньої мережі Wi-Fi прийнятно обмежитися зовнішнім пасивним і активним порушником у межах зони досяжності; для мережі оператора критичних електронних комунікацій — необхідно враховувати інсайдера і державного порушника з тривалою присутністю. Відповідно до Загальних вимог до кіберзахисту об'єктів критичної інфраструктури [14] і вимог нормативних документів системи технічного захисту інформації [23] модель порушника є обов'язковим елементом проєктної документації на систему захисту. Формалізацію моделей загроз і методи оцінювання ризиків розглянуто в розділі 4; для узгодження опису технік атак доцільно використовувати бази знань MITRE ATT&CK (зокрема матрицю для мобільних пристроїв) [206] і MITRE FiGHT для мереж 5G [207].

1.6 Простір загроз і поверхня атаки

1.6.1 Багаторівнева поверхня атаки

Поверхню атаки безпроводової мобільної системи зручно подавати у вигляді рівнів, на кожному з яких діють власні класи загроз (рис. 1.2). Нижній рівень — радіочастотний: глушіння, підміна сигналів, перехоплення, радіорозвідка. Канальний рівень: підроблені кадри керування, деавтентифікація, атаки на протоколи встановлення ключів, повторне використання одноразових чисел. Рівень мережі доступу і ядра: фальшиві базові станції, атаки зниження версії, атаки на протоколи мобільності. Сигнальний рівень: зловживання протоколами SS7, Diameter, GTP та інтерфейсами між мережевими функціями 5G. Рівень пристрою: шкідливе програмне забезпечення,

вразливості прошивок радіомодулів, фізичний доступ. Прикладний рівень: небезпечні застосунки, перехоплення облікових даних, соціальна інженерія через SMS і голосові дзвінки. Уздовж усіх рівнів проходить вертикаль *ланцюга постачання*: компоненти, прошивки й оновлення, що надходять від постачальників обладнання.

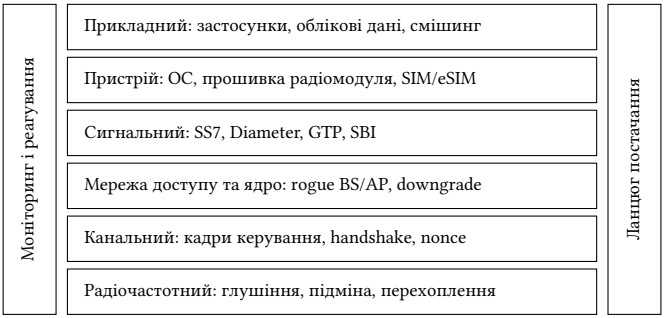


Рис. 1.2 — Багаторівнева поверхня атаки безпроводової мобільної системи

1.6.2 Композиція загроз

Реальні атаки рідко обмежуються одним рівнем. Типовий сценарій перехоплення трафіку абонента LTE поєднує глушіння смуги 5G або LTE (радіочастотний рівень), розгортання фальшивої базової станції GSM (рівень доступу), примусове зниження версії й використання слабкого шифрування або відсутності взаємної автентифікації (канальний рівень) і, нарешті, перехоплення одноразових кодів у SMS (прикладний рівень). Сценарій стеження поєднує пасивне приймання ідентифікаторів, запити до сигнальної мережі та кореляцію з даними застосунків. Тому оцінювання захищеності має здійснюватися за *ланцюгами атак*, а не за окремими вразливостями.

Імовірність успіху композитної атаки з m послідовних етапів оцінюють добутком

$$P_{\text{атаки}} = \prod_{j=1}^{m} p_j\left(\mathcal{A}, X\right), \tag{1.6}$$

де p_j — імовірність успіху j-го етапу для порушника з профілем $\mathcal{A}$ за наявності заходів захисту X. Формула (1.6) припускає незалежність етапів; її застосування та уточнення на графах атак розглянуто в розділах 3 і 4. Практичний висновок: захід, який обриває будь-який обов'язковий етап (наприклад, заборона використання 2G у терміналі або заміна SMS-кодів на криптографічну автентифікацію), знижує ризик усього ланцюга, незалежно від стійкості інших етапів.

1.6.3 Основні класи загроз

Узагальнюючи міжнародні огляди [291, 209, 136] і галузеві оцінки [122, 123], виділимо основні класи загроз безпроводовим і мобільним мережам:

1. *Перехоплення і аналіз трафіку* — пасивне приймання даних і метаданих, у тому числі зашифрованих (аналіз розмірів і часових характеристик кадрів дає змогу визначати застосунки та дії користувача).
2. *Підміна інфраструктури* — підроблені точки доступу, базові станції, маяки BLE, сигнали навігаційних систем.
3. *Атаки на протоколи автентифікації та встановлення ключів* — підбір паролів у режимі офлайн, повторне встановлення ключів, атаки зниження версії, атаки на спарювання.
4. *Порушення доступності* — глушіння, атаки на канальний рівень (деавтентифікація, зловживання механізмами енергозбереження), сигнальні атаки на відмову в обслуговуванні, фізичне руйнування інфраструктури.
5. *Відстеження та деанонімізація* — зв'язування ідентифікаторів, визначення місцезнаходження через сигнальну мережу, радіовідбиток пристроїв.
6. *Компрометація пристроїв* — шкідливе програмне забезпечення, вразливості радіомодулів (зокрема атаки «без взаємодії» через прийняті пакети), фізичний доступ.
7. *Атаки на ядро та сигнальну мережу* — зловживання міжоператорськими протоколами, компрометація мережевих функцій, систем керування й тарифікації.
8. *Атаки на ланцюг постачання* — закладки в обладнанні і програмному забезпеченні, компрометація оновлень, залежність від постачальників з країн високого ризику.

Порівняльний аналіз механізмів автентифікації та протоколів обміну ключами в безпроводових мобільних мережах, виконаний українськими дослідниками, підтверджує, що найвразливішими залишаються перехідні режими сумісності та процедури первинного підключення [18].

1.7 Український контекст: мережі зв'язку в умовах війни

Повномасштабна збройна агресія проти України перетворила безпеку безпроводових і мобільних мереж на питання національної стійкості. Можна виділити кілька ключових уроків, що безпосередньо стосуються предмета посібника.

Фізична стійкість як складова безпеки. Масовані ракетні удари по енергетичній інфраструктурі призвели до тривалих знеструмлень, під час яких

базові станції працювали від акумуляторів обмеженої ємності. Доступність мобільного зв'язку виявилася залежною не стільки від захищеності протоколів, скільки від енергетичної автономності вузлів і резервування транспортних каналів. Це повернуло до центру уваги модель відмов зі спільної причини і метрики стійкості (розділ 16).

Кібератаки на операторів. 12 грудня 2023 р. найбільший мобільний оператор України «Київстар» зазнав руйнівної кібератаки, унаслідок якої близько 24 млн абонентів на кілька днів залишилися без мобільного зв'язку та доступу до Інтернету. За повідомленнями Служби безпеки України, зловмисники перебували в інфраструктурі оператора щонайменше з травня 2023 р., а атака супроводжувалася знищенням тисяч віртуальних серверів і робочих станцій [2]. Інцидент показав, що найбільш руйнівний сценарій для мобільної мережі — не атака на радіоінтерфейс, а компрометація інформаційно-технологічної інфраструктури оператора з подальшим знищенням систем, і що механізми відновлення (резервні копії, ізольовані середовища, взаємодія з іншими операторами) є не менш важливими, ніж механізми запобігання. Урокам інциденту і механізмам національного роумінгу присвячено розділ 16.

Радіоелектронна боротьба. Масштабне застосування засобів радіоелектронної боротьби (РЕБ) на фронті і в прикордонних регіонах призвело до постійного глушіння і підміни сигналів глобальних навігаційних супутникових систем, що впливає на цивільну авіацію, морське судноплавство, синхронізацію мереж зв'язку та роботу безпілотних систем. Безпека позиціювання і навігації стала самостійним напрямом досліджень (розділ 14).

Мобільні пристрої як джерело розвідувальної інформації. Використання мобільних телефонів у зоні бойових дій створює ризики визначення місцезнаходження за радіовипромінюванням і даними мережі. Це зумовило розвиток організаційних заходів радіодисципліни і технічних засобів радіомоніторингу (розділ 15).

Регуляторна відповідь. Оновлене законодавство про кібербезпеку [39] і критичну інфраструктуру [38] віднесло постачальників електронних комунікацій до об'єктів, для яких обов'язковими є вимоги кіберзахисту, а координацію реагування на інциденти здійснюють Держспецзв'язку [6] та CERT-UA [93]. Одночасно Україна гармонізує регулювання з правом ЄС, зокрема з Директивою NIS 2 [109] і рекомендаціями щодо кібербезпеки мереж 5G [210] (розділ 2).

1.8 Термінологічний апарат і структура курсу

Для узгодженості викладу в посібнику використано такі базові терміни. **Радіоінтерфейс** — сукупність протоколів фізичного і канального рівнів, що забезпечують обмін даними між терміналом і точкою доступу чи базовою

станцією. **Термінал** (абонентське обладнання) — пристрій кінцевого користувача разом із захищеним елементом, що зберігає облікові дані. **Точка доступу** і **базова станція** — елементи інфраструктури, які забезпечують підключення терміналів до мережі в технологіях WLAN і стільникового зв'язку відповідно. **Підроблена точка доступу** (rogue AP) — точка доступу, не санкціонована адміністратором мережі; окремий випадок — **точка доступу-двійник**, що імітує легітимну мережу. **Фальшива базова станція** — пристрій, що імітує базову станцію оператора для перехоплення ідентифікаторів, трафіку чи зниження версії протоколу. **Глушіння** (jamming) — навмисне створення радіозавад з метою порушення доступності. **Підміна** (spoofing) — передавання сигналів чи кадрів від імені іншої сторони. Загальні терміни інформаційної безпеки вживаються відповідно до глосарію [262] та національних стандартів [11].

Структура курсу відображає рух від загального до конкретного. Теоретико-нормативні засади (розділи 2–4) формують нормативну базу, математичний апарат і методи оцінювання ризиків. Механізми захисту радіоінтерфейсів і мереж (розділи 5–10) охоплюють безпеку фізичного рівня, криптографію, Wi-Fi, технології ближньої дії та мобільні мережі від GSM до 5G. Розділи 11–14 присвячено мобільним платформам і застосункам, Інтернету речей і спеціалізованим мережам. Операційна безпека (розділи 15, 16) і управління безпекою (розділ 17) завершують курс. Методологічною основою, як і для курсу в цілому, є зведення знань CyBOK [292] та фундаментальні праці з безпеки інформаційних систем [66] і безпроводових комунікацій [80].

Висновки до розділу

Безпроводові й мобільні мережі відрізняються від провідних не технологічними деталями, а фундаментальними властивостями середовища: широкомовністю, спільністю ресурсу, відкритістю сигналізації та мобільністю абонентів. Широкомовність робить пасивне перехоплення непомітним, а дальність перехоплення, як показує модель енергетичного бюджету (1.3), може в десятки разів перевищувати проєктну зону обслуговування; тому конфіденційність має забезпечуватися криптографічно або методами фізичного рівня. Спільність ресурсу і енергетична асиметрія атаки означають, що доступність радіоланки принципово не гарантується криптографією і вимагає фізичних методів протидії, резервування та моніторингу ефіру. Мобільність породжує специфічні властивості безпеки — конфіденційність ідентичності, незв'язуваність, неспостережуваність місця — і багатодоменну модель довіри з делегуванням автентифікації між домашньою та обслуговувальною мережами. Еволюція поколінь мобільного зв'язку від GSM до 5G демонструє послідовне усунення архітектурних вад, проте зворотна су-

місність зберігає можливість атак зниження версії. Модель Долева–Яо для радіосередовища слід розширювати фізичними можливостями порушника, а оцінювати захищеність — за ланцюгами атак, що перетинають кілька рівнів поверхні атаки. Український досвід, зокрема кібератака на «Київстар» і масштабне застосування засобів РЕБ, показує, що стійкість мобільних мереж визначається не лише протоколами, а й захищеністю IT-інфраструктури оператора, енергетичною автономністю та готовністю до відновлення.

Питання для самоперевірки

1. Дайте означення безпроводової та мобільної мережі. Які три рівні об'єкта захисту виділяють у мобільній мережі і чому засоби захисту одного рівня не компенсують слабкостей іншого?
2. Порівняйте класи безпроводових мереж (табл. 1.1) за моделлю довіри. Як зі зростанням радіуса дії змінюється кількість адміністративних доменів?
3. Які архітектурні вади GSM було усунуто в UMTS, LTE і 5G? Чому зворотна сумісність створює загрозу атак зниження версії?
4. Поясніть, чому в безпроводовій мережі конфіденційність не може забезпечуватися обмеженням доступу до середовища.
5. Користуючись формулою (1.3), обчисліть відношення дальностей приймання для порушника з антеною 18 дБі і чутливістю -92 дБм, якщо легітимний клієнт має антену 0 дБі і чутливість -80 дБм, а $n = 3{,}0$.
6. Що таке енергетична асиметрія атаки глушіння? Використовуючи (1.4), поясніть, чому глушіння сигналів супутникової навігації потребує малої потужності.
7. Які безпекові наслідки має унікальність характеристики радіоканалу і радіочастотного відбитка передавача? Наведіть приклади їх використання захисником і порушником.
8. Опишіть домени довіри мобільної мережі (рис. 1.1). Які сегменти історично були найменш захищеними і чому?
9. Перелічіть ідентифікатори мобільного абонента. Чому розкриття постійного ідентифікатора в мобільній мережі є загрозою приватності фізичної особи?
10. Які властивості безпеки, специфічні для мобільного середовища, доповнюють тріаду «конфіденційність–цілісність–доступність»? Наведіть приклад конфлікту двох властивостей.

11. У чому обмеженість моделі Долева–Яо для безпроводових мереж? Запропонуйте параметри моделі (1.5) для порушника, що атакує корпоративну мережу Wi-Fi з автостоянки біля офісу.
12. Складіть ланцюг атаки на перехоплення одноразового SMS-коду абонента LTE і оцініть за (1.6) ефект заборони 2G у терміналі.
13. Які уроки для безпеки мобільних мереж випливають з кібератаки на «Київстар» у грудні 2023 р.?
14. Дослідницьке: запропонуйте метрику «ефективної зони перехоплення» безпроводової мережі з урахуванням лог-нормального затінення X_σ і обґрунтуйте методику її експериментального вимірювання.
15. Дослідницьке: сформулюйте модель порушника для мобільної мережі в умовах воєнного стану, що враховує РЕБ, фізичне руйнування інфраструктури та кібератаки на оператора, і визначте, які з властивостей табл. 1.2 у ній є пріоритетними.

РОЗДІЛ 2

Нормативно-правове та стандартизаційне забезпечення безпеки безпроводових і мобільних мереж

Безпека безпроводових і мобільних мереж регулюється одночасно на кількох рівнях, які мають різну природу: міжнародний розподіл радіочастотного спектра, законодавство про електронні комунікації та кібербезпеку, технічні регламенти на радіообладнання, галузеві технічні специфікації, схеми оцінювання відповідності та сертифікації. Для фахівця важливо не лише знати окремі документи, а й розуміти, як вони взаємодіють: які вимоги є обов'язковими, а які добровільними; хто є суб'єктом зобов'язань — оператор, виробник обладнання чи власник корпоративної мережі; як вимоги трансформуються в конкретні технічні заходи. Розділ систематизує нормативне поле України, Європейського Союзу та міжнародних організацій стандартизації, аналізує механізми оцінювання відповідності й завершується кейсом визначення застосовних вимог для оператора мобільного зв'язку та виробника радіообладнання. Технічний зміст згаданих специфікацій розкрито в розділах 7–13.

2.1 Структура нормативного поля

2.1.1 Рівні регулювання

Нормативне забезпечення безпеки безпроводових і мобільних мереж доцільно подавати як ієрархію з п'яти рівнів (рис. 2.1).

Міжнародний рівень формує Міжнародний союз електрозв'язку (МСЕ). Регламент радіозв'язку має статус міжнародного договору і визначає розподіл смуг частот між радіослужбами, процедури координації та захисту від шкідливих завад [238]. Рекомендації МСЕ-Т серії X задають загальні архітектури безпеки телекомунікацій, зокрема рекомендація X.805, яка вводить три рівні безпеки (інфраструктура, послуги, застосунки), три площини (керування, контролю, користувача) і вісім вимірів безпеки [244].

Наднаціональний рівень для України визначається зобов'язаннями за Угодою про асоціацію з ЄС [48] і статусом держави-кандидата. Право ЄС у сфері електронних комунікацій, кібербезпеки, захисту персональних даних і вимог до радіообладнання є орієнтиром для гармонізації національного законодавства.

Національний законодавчий рівень становлять закони України та підзаконні акти Кабінету Міністрів, Держспецзв'язку і НКЕК.

Рівень стандартів містить міжнародні, європейські й національні стандарти (ISO/IEC, IEC, ETSI, CEN-CENELEC, ДСТУ), які набувають обов'язковості через посилання в технічних регламентах або договорах.

Галузевий рівень формують технічні специфікації консорціумів і галузевих асоціацій: 3GPP (стільникові мережі), IEEE (локальні й персональні мережі), Wi-Fi Alliance і Bluetooth SIG (сертифікація сумісності), GSMA (міжоператорська взаємодія та безпека обладнання), O-RAN Alliance. Формально ці документи добровільні, але на практиці вони є умовою входу на ринок: обладнання, не сумісне зі специфікаціями 3GPP, не може працювати в мережі оператора.

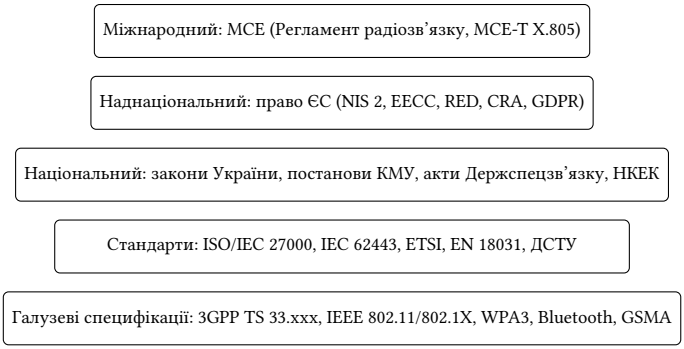


Рис. 2.1 — Рівні нормативного забезпечення безпеки безпроводових і мобільних мереж (деталізація вимог зростає згори донизу)

2.1.2 Суб'єкти зобов'язань

Друга вісь аналізу — *хто* несе зобов'язання. Для безпроводових і мобільних мереж можна виділити чотири категорії суб'єктів. **Постачальники електронних комунікаційних мереж і послуг** (оператори) відповідають за безпеку та цілісність мереж, захист інформації про споживачів, повідомлення про інциденти й функціонування в особливий період. **Виробники та імпортери радіообладнання** відповідають за відповідність обладнання суттєвим вимогам технічних регламентів, у тому числі вимогам кібербезпеки. **Власники та розпорядники інформаційно-комунікаційних систем**, до складу яких входять безпроводові сегменти, відповідають за захист інформації в цих системах, зокрема за створення комплексних систем захисту інформації для державних інформаційних ресурсів. **Регулятори та органи сертифікації** встановлюють вимоги, здійснюють нагляд і оцінюють відповідність. Одна організація може належати до кількох категорій: наприклад, оператор мобільного зв'язку одночасно є постачальником послуг, об'єктом критичної інфраструктури і власником корпоративних ІКС.

2.2 Законодавство України

2.2.1 Електронні комунікації та радіочастотний ресурс

Базовим актом є Закон України «Про електронні комунікації» [34], що набрав чинності з 1 січня 2022 р. і замінив закони «Про телекомунікації» та «Про радіочастотний ресурс України». Закон імплементує підходи Європейського кодексу електронних комунікацій [108] і визначає: правовий режим радіочастотного спектра як обмеженого національного ресурсу; повноваження незалежного регулятора — НКЕК [35]; обов'язки постачальників електронних комунікаційних мереж і послуг щодо забезпечення безпеки та цілісності мереж; вимоги до захисту інформації про споживачів, трафік і місцезнаходження кінцевого обладнання; особливості функціонування мереж в умовах надзвичайного і воєнного стану. Для безпроводових мереж суттєвим є і розподіл повноважень: НКЕК відповідає за регулювання ринку та радіочастотного спектра, а питання захисту інформації й кіберзахисту належать до компетенції Держспецзв'язку [6].

Вимоги до радіообладнання, що вводиться в обіг в Україні, встановлює Технічний регламент радіообладнання [46], розроблений на основі Директиви 2014/53/ЄС [111]. Регламент визначає суттєві вимоги (безпека, електромагнітна сумісність, ефективне використання спектра), процедури оцінювання відповідності та маркування. Порядок розроблення і застосування технічних регламентів, у тому числі визнання результатів оцінювання відповідності, визначають закони «Про технічні регламенти та оцінку відповідності» [43] і «Про стандартизацію» [42]. Важливо, що суттєві вимоги кібербезпеки, запроваджені в ЄС делегованим регламентом 2022/30 [100], потребують відповідного оновлення національного регламенту, що є одним із напрямів гармонізації.

2.2.2 Кібербезпека та критична інфраструктура

Закон України «Про основні засади забезпечення кібербезпеки України» [39] визначає об'єкти кіберзахисту, суб'єктів національної системи кібербезпеки і їхні повноваження. Електронні комунікаційні мережі, які використовуються для задоволення потреб суспільства і держави, належать до об'єктів кіберзахисту, а постачальники електронних комунікацій, що належать до об'єктів критичної інфраструктури, зобов'язані виконувати вимоги щодо кіберзахисту, повідомляти про кіберінциденти та взаємодіяти з урядовою командою реагування CERT-UA [93]. Закон України «Про критичну інфраструктуру» [38] виділяє електронні комунікації як один із життєво важливих секторів, установлює порядок категоризації об'єктів та вимоги до їхнього захисту. Загальні вимоги до кіберзахисту об'єктів критичної інфраструктури [14] охоплюють організаційні та технічні заходи: управління ризиками, керування доступом, захист мережевої інфраструктури, мо-

ніторинг, реагування на інциденти, забезпечення неперервності. Стратегічні пріоритети сформульовано в Стратегії кібербезпеки України [41], яка, зокрема, передбачає розвиток захищених мереж зв'язку та протидію кіберзагрозам у секторі електронних комунікацій.

Досвід кібератак на мобільних операторів (розділ 1) і необхідність наближення до Директиви NIS 2 [109] зумовили оновлення законодавства про кібербезпеку, спрямоване на розширення кола суб'єктів, посилення відповідальності керівництва, запровадження ризик-орієнтованого підходу та чітких строків повідомлення про інциденти.

2.2.3 Захист інформації та персональних даних

Закон України «Про захист інформації в інформаційно-комунікаційних системах» [36] встановлює, що інформація, яка є власністю держави, або інформація з обмеженим доступом, вимога щодо захисту якої встановлена законом, має оброблятися в системах із комплексною системою захисту інформації (КСЗІ) з підтвердженою відповідністю. Правила забезпечення захисту інформації в інформаційних, електронних комунікаційних та інформаційно-комунікаційних системах [32] деталізують ці вимоги, а порядок створення КСЗІ визначено в НД ТЗІ 3.7-003-05 [25]. Для безпроводових сегментів таких систем принципове значення має питання, чи виходить інформація з обмеженим доступом за межі контрольованої зони: радіоканал, на відміну від кабелю, не можна вважати таким, що перебуває в межах контрольованої зони, тому для передавання такої інформації потрібні засоби криптографічного захисту, що мають позитивний експертний висновок, — порядок їх розроблення та експлуатації регламентує Держспецзв'язку [31]. Національні криптографічні стандарти — блоковий шифр «Калина» [8], функція гешування «Купина» [9], потоковий шифр «Струмок» [10], цифровий підпис на еліптичних кривих [7] — розглянуто в розділі 6.

Закон України «Про захист персональних даних» [37] поширюється на дані про місцезнаходження, ідентифікатори пристроїв і метадані з'єднань, які в мобільних мережах дають змогу ідентифікувати фізичну особу. Закон «Про електронні комунікації» [34] додатково встановлює спеціальний режим для інформації про трафік і місцезнаходження кінцевого обладнання споживачів: її обробка можлива лише у визначених законом випадках. У ЄС аналогічний режим встановлюють Загальний регламент захисту даних [245] і Директива про приватність в електронних комунікаціях [110], яка, зокрема, обмежує обробку даних про місцезнаходження, крім даних про трафік, згодою абонента або анонімізацією.

2.3 Право Європейського Союзу

2.3.1 Директива NIS 2 і Європейський кодекс електронних комунікацій

До набрання чинності Директивою NIS 2 безпеку публічних мереж електронних комунікацій у ЄС регулювали статті 40–41 Європейського кодексу електронних комунікацій [108]. Директива (ЄС) 2022/2555 [109] перенесла ці вимоги до загальної рамки кібербезпеки, вилучивши відповідні статті з Кодексу з 18 жовтня 2024 р. Постачальники публічних електронних комунікаційних мереж і загальнодоступних послуг належать до сектору цифрової інфраструктури і підпадають під дію Директиви незалежно від розміру. Для них діють:

- обов'язок уживати відповідних і пропорційних технічних, операційних та організаційних заходів управління ризиками (ст. 21), серед яких політики аналізу ризиків, оброблення інцидентів, неперервність діяльності й кризове управління, безпека ланцюга постачання, безпека під час придбання, розроблення й обслуговування систем, оцінювання ефективності заходів, кібергігієна та навчання, використання криптографії та шифрування, безпека персоналу й керування доступом, багатофакторна автентифікація та захищені канали зв'язку;
- обов'язок багатоетапного повідомлення про значні інциденти (ст. 23): раннє попередження — протягом 24 год, повідомлення про інцидент — протягом 72 год, остаточний звіт — не пізніше одного місяця;
- персональна відповідальність органів управління за затвердження заходів і нагляд за їх виконанням (ст. 20);
- адміністративні штрафи для суттєвих суб'єктів — до 10 млн євро або 2 % загального світового річного обороту залежно від того, яка сума більша.

Графік повідомлення про інцидент можна подати як систему обмежень на моменти подання звітів t_1, t_2, t_3 відносно моменту t_0, коли суб'єкту стало відомо про значний інцидент:

$$t_1 - t_0 \le 24 \text{ год}, \qquad t_2 - t_0 \le 72 \text{ год}, \qquad t_3 - t_2 \le 1 \text{ міс}. \tag{2.1}$$

Обмеження (2.1) мають прямі технічні наслідки для мобільного оператора: система моніторингу повинна забезпечувати середній час виявлення (MTTD) і час первинної класифікації інциденту, сумарно менші за 24 год, з запасом на узгодження рішення про повідомлення. Інакше кажучи, регуляторна вимога трансформується в цільовий показник ефективності центру забезпечення кібербезпеки (розділ 15).

2.3.2 Кібербезпека мереж 5G

Особливу увагу ЄС приділяє мережам 5G як критичній інфраструктурі майбутньої цифрової економіки. Рекомендація Комісії (ЄС) 2019/534 [102] започаткувала скоординований підхід: кожна держава-член провела національну оцінку ризиків, на основі яких групою співпраці NIS підготовлено скоординовану оцінку ризиків [211] і набір заходів з їх зниження — «інструментарій» (EU 5G Toolbox) [210]. Інструментарій поділяє заходи на *стратегічні* (посилення ролі регуляторів, оцінювання профілю ризику постачальників, обмеження щодо постачальників високого ризику для ключових елементів мережі, диверсифікація постачальників, підтримка стійкості ланцюга постачання) і *технічні* (застосування базових вимог безпеки, безпечна конфігурація мережі, контроль доступу до функцій керування, захищене оновлення програмного забезпечення, моніторинг, сертифікація обладнання). Ключова ідея — ризики 5G визначаються не лише технічними вразливостями протоколів, а й *профілем постачальника*: залежністю від законодавства третьої країни, яке може зобов'язати постачальника співпрацювати зі спецслужбами, і концентрацією на одному постачальнику. Аналітичні матеріали ENISA щодо загроз 5G [123] деталізують технічну частину цієї оцінки (розділ 10).

2.3.3 Вимоги до радіообладнання та продуктів із цифровими елементами

Директива 2014/53/ЄС про радіообладнання (RED) [111] у статті 3(3) передбачала можливість встановлення додаткових суттєвих вимог, зокрема: (d) радіообладнання не повинно шкодити мережі або її функціонуванню чи зловживати мережевими ресурсами; (e) радіообладнання повинно містити засоби захисту персональних даних і приватності користувача; (f) радіообладнання повинно підтримувати функції захисту від шахрайства. Делегований регламент (ЄС) 2022/30 [100] зробив ці вимоги обов'язковими для радіообладнання, здатного до взаємодії через Інтернет, для іграшок, обладнання для догляду за дітьми та носимих пристроїв, що обробляють персональні дані, і для обладнання, яке дає змогу переказувати гроші чи віртуальні активи. Регламент застосовується з 1 серпня 2025 р. Презумпцію відповідності забезпечують гармонізовані стандарти серії EN 18031, зокрема EN 18031-1 для обладнання, під'єднаного до Інтернету [119]. Стандарт формулює вимоги до механізмів керування доступом, автентифікації, захищеного оновлення, захищеного зберігання й передавання, стійкості до атак на відмову, журналювання, а також вимоги до документування рішень виробника за допомогою дерев рішень.

Регламент (ЄС) 2024/2847 — Акт про кіберстійкість (CRA) [247] — встановлює горизонтальні вимоги кібербезпеки до всіх продуктів із цифровими елементами протягом їхнього життєвого циклу: безпека за замовчува-

нням, відсутність відомих експлуатованих вразливостей на момент випуску, захищене оновлення, оброблення вразливостей, специфікація складу програмного забезпечення. Зобов'язання щодо повідомлення про активно експлуатовані вразливості застосовуються з вересня 2026 р., основні вимоги — з грудня 2027 р. Для безпроводових пристроїв CRA у перспективі стає основною рамкою, поглинаючи кібербезпекові вимоги RED. Базовим галузевим стандартом для споживчих пристроїв Інтернету речей є ETSI EN 303 645 [129]: заборона універсальних паролів за замовчуванням, політика розкриття вразливостей, захищене оновлення, захищене зберігання параметрів безпеки, захищений зв'язок, мінімізація відкритих поверхонь атаки (розділ 12).

Хронологію ключових актів ЄС, що впливають на безпеку безпроводових і мобільних мереж, подано на рис. 2.2. Видно, що за десятиліття регулювання змістилося від вимог до окремих послуг і даних до вимог щодо всього життєвого циклу продуктів і ланцюга постачання.

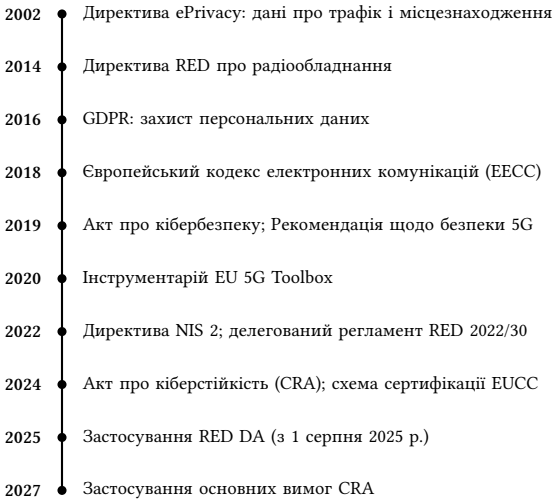


Рис. 2.2 — Хронологія актів ЄС, що визначають вимоги до безпеки безпроводових і мобільних мереж

2.3.4 Сертифікація кібербезпеки в ЄС

Регламент (ЄС) 2019/881 — Акт про кібербезпеку [246] — заснував європейську рамку сертифікації кібербезпеки продуктів, послуг і процесів ІКТ з трьома рівнями довіри: «базовий», «суттєвий» і «високий». Першою прийнятою схемою є EUCC, заснована на Загальних критеріях

(ISO/IEC 15408) [101, 180]. Для телекомунікаційного обладнання обговорюється схема для мереж 5G, що має спиратися на методологію оцінювання безпеки 3GPP і галузеву схему GSMA (підрозділ 2.5).

2.4 Міжнародні та галузеві стандарти

2.4.1 Системи управління інформаційною безпекою

Загальну рамку управління безпекою задають стандарти серії ISO/IEC 27000, прийняті в Україні як ДСТУ EN ISO/IEC 27001:2023 [11] і ДСТУ EN ISO/IEC 27002:2023 [12]. Для телекомунікаційних організацій розроблено галузевий стандарт ISO/IEC 27011 [183] (ідентичний рекомендації MCE-T X.1051), що доповнює заходи ISO/IEC 27002 специфічними для операторів: захист комунікаційних споруд і необслуговуваних об'єктів (контейнерів базових станцій), захист від несанкціонованого перехоплення, керування безпекою взаємоз'єднання з іншими операторами, реагування на інциденти, що впливають на надання послуг. Управління ризиками здійснюється відповідно до ISO/IEC 27005 [182] і ISO 31000 [178], неперервність — відповідно до ISO 22301 [176]. Рамка NIST CSF 2.0 [220] з функціями «Керувати», «Ідентифікувати», «Захищати», «Виявляти», «Реагувати», «Відновлювати» зручна для побудови профілів цільового стану та самооцінювання (розділ 17).

2.4.2 Технічні специфікації безпроводових і мобільних технологій

Технічні вимоги до механізмів безпеки конкретних технологій містяться в галузевих специфікаціях. Для стільникових мереж основою є серія 3GPP TS 33: архітектура безпеки 3G [54], LTE [57] і 5G [58], вимоги до функцій безпеки GSM [64]. Для локальних мереж — стандарт IEEE 802.11 [171] (у тому числі механізми RSN, SAE, захист кадрів керування), IEEE 802.1X [175] і програма сертифікації Wi-Fi Alliance WPA3 [286]. Для персональних мереж і Інтернету речей — специфікація ядра Bluetooth [86] та стандарт IEEE 802.15.4 [173]. Практичні настанови з безпечного налаштування і використання дає серія спеціальних публікацій NIST: SP 800-153 щодо WLAN [271], SP 800-121 щодо Bluetooth [227], SP 800-187 щодо LTE [97], SP 800-124 щодо керування мобільними пристроями в організаціях [164]. Відповідність основних документів класам мереж подано в табл. 2.1.

Таблиця 2.1 — Основні нормативні документи та специфікації за класами безпроводових мереж

Клас мереж	Технічні специфікації	Настанови, регуляторні вимоги
Стільникові 2G–5G	3GPP TS 43.020, 33.102, 33.401, 33.501; TS 33.117 (SCAS)	ЗУ «Про електронні комунікації», NIS 2, EU 5G Toolbox, NIST SP 800-187, GSMA FS.11, NESAS
WLAN	IEEE 802.11-2024, 802.1X-2020; WPA3; RFC 3748	NIST SP 800-153, КМУ № 373, НД ТЗІ, ISO/IEC 27002
WPAN	Bluetooth Core, IEEE 802.15.4	NIST SP 800-121, RED DA, EN 18031
IoT і LPWAN	LoRaWAN, 3GPP (NB-IoT, LTE-M), 802.15.4	ETSI EN 303 645, EN 18031, CRA, IEC 62443
Мобільні пристрої та застосунки	ОС-платформи, OWASP MASVS	NIST SP 800-124, OWASP Mobile Top 10, GDPR, ЗУ «Про захист персональних даних»

Характерна риса галузевих специфікацій — їхня *опційність* усередині обов'язкового: стандарт визначає механізм, але залишає реалізації вибір, чи вмикати його. Так, захист цілісності користувацької площини в LTE не передбачений взагалі, а в 5G є опційним і залежить від політики оператора; захист кадрів керування в Wi-Fi є обов'язковим лише для WPA3; шифрування ідентифікатора абонента в 5G може бути вимкнене використанням «нульової» схеми. Тому відповідність стандарту не тотожна захищеності: необхідно аналізувати *профіль* увімкнених механізмів у конкретній мережі.

2.5 Оцінювання відповідності та сертифікація

2.5.1 Методологія SECAM і схема NESAS

Для телекомунікаційного обладнання 3GPP розробило методологію забезпечення безпеки SECAM [50]: вимоги безпеки до кожного класу мережевих продуктів (базові станції, функції ядра 5G) формулюються в специфікаціях SCAS — загальний каталог [55] і специфічні каталоги для окремих функцій. GSMA реалізувала методологію у схемі NESAS [153], яка має дві складові: аудит процесів розроблення і супроводження продуктів у виробника та тестування конкретного продукту акредитованою лабораторією на відповідність вимогам SCAS. Схема не гарантує відсутності вразливостей, але забезпечує мінімальний базовий рівень і прозорість процесів виробника, що особливо важливо в контексті вимог щодо безпеки ланцюга постачання.

2.5.2 Загальні критерії та криптографічні модулі

Для продуктів, від яких вимагається вищий рівень довіри, застосовують оцінювання за Загальними критеріями (ISO/IEC 15408) [180] на відповідність профілям захисту: наприклад, для мобільних пристроїв, клієнтів

WLAN, точок доступу. Криптографічні модулі в США та низці інших держав оцінюють на відповідність FIPS 140-3 [218]. В Україні засоби криптографічного захисту для інформації, що підлягає захисту відповідно до закону, мають проходити державну експертизу в порядку, установленому Держспецзв'язку [31], а системи захисту в цілому — державну експертизу КСЗІ [25]. Критерії оцінювання захищеності інформації в комп'ютерних системах від несанкціонованого доступу встановлює НД ТЗІ 2.5-004-99 [24].

2.5.3 Кількісне оцінювання рівня відповідності

Для практичного аналізу стану відповідності організації або продукту множині вимог доцільно використовувати кількісні показники. Нехай $\mathcal{R} = \{r_1, \dots, r_N\}$ — множина застосовних вимог, $w_i > 0$ — вага вимоги r_i (визначається її критичністю: обов'язкова законодавча вимога, вимога стандарту, рекомендація), $c_i \in [0;1]$ — ступінь виконання вимоги (0 — не виконано, 0,5 — частково, 1 — повністю). Тоді **зважений індекс розриву відповідності** дорівнює

$$G = 1 - \frac{\sum_{i=1}^{N} w_i\, c_i}{\sum_{i=1}^{N} w_i}, \qquad G \in [0;1]. \tag{2.2}$$

Індекс (2.2) є адитивною згорткою і тому компенсаторний: повне виконання багатьох другорядних вимог може замаскувати невиконання критичної. Для обов'язкових вимог доцільно використовувати додаткову блокувальну умову

$$\min_{i:\, r_i \in \mathcal{R}_{\text{обов}}} c_i = 1, \tag{2.3}$$

тобто відповідність визнається лише за повного виконання кожної обов'язкової вимоги, незалежно від значення G. Такий двоступеневий підхід (блокувальні вимоги + зважений індекс для решти) узгоджується з логікою оцінювання ризиків (розділ 4) і дає змогу пріоритизувати усунення розривів за критерієм «зменшення G на одиницю витрат».

2.6 Порівняльний аналіз вимог України та ЄС

Порівняння ключових аспектів регулювання безпеки мобільних і безпроводових мереж в Україні та ЄС наведено в табл. 2.2. Воно показує, що концептуально національне законодавство рухається в напрямку, заданому правом ЄС, проте зберігаються відмінності в механізмах: національна система значною мірою спирається на обов'язкову державну експертизу і вимоги до засобів захисту, тоді як європейська — на ризик-орієнтований підхід, відповідальність керівництва і сертифікацію продуктів за єдиними схемами.

Таблиця 2.2 — Порівняння підходів України та ЄС до регулювання безпеки мобільних і безпроводових мереж

Аспект	Україна	ЄС
Рамковий акт	ЗУ «Про електронні комунікації», ЗУ «Про основні засади забезпечення кібербезпеки»	EECC, Директива NIS 2
Регулятор	НКЕК (ринок, спектр), Держспецзв'язку (захист, кіберзахист)	національні регулятори, компетентні органи NIS 2, ENISA
Повідомлення про інциденти	CERT-UA, строки — відповідно до підзаконних актів	24 год / 72 год / 1 міс.
Ланцюг постачання	загальні вимоги КМУ № 518, обмеження щодо держави-агресора	EU 5G Toolbox, оцінювання профілю ризику постачальника
Радіообладнання	Технічний регламент радіообладнання (без кібербезпекових вимог ст. 3(3)(d–f))	RED + делегований регламент 2022/30, EN 18031; CRA
Оцінювання продуктів	державна експертиза КЗІ та КСЗІ	EUCC, NESAS/SCAS, профілі захисту
Приватність	ЗУ «Про захист персональних даних», спецрежим даних про трафік	GDPR, Директива ePrivacy

Основні напрями гармонізації, які випливають з порівняння: запровадження кібербезпекових вимог до радіообладнання, аналогічних RED DA і CRA; формалізація оцінювання профілю ризику постачальників обладнання для мереж 5G; перехід від обов'язкової експертизи засобів до ризик-орієнтованої відповідальності суб'єкта з визнанням європейських сертифікатів; уніфікація строків і форматів повідомлення про інциденти. Одночасно український досвід функціонування мереж в умовах війни — національний роумінг, взаємне резервування операторів, захист від фізичного руйнування — є внеском, який може бути корисним і для ЄС (розділ 16).

2.7 Кейс: визначення застосовних вимог

2.7.1 Оператор мобільного зв'язку

Розглянемо оператора мобільного зв'язку, що надає послуги 2G/4G і розгортає мережу 5G, має корпоративну мережу Wi-Fi в офісах і віднесений до об'єктів критичної інфраструктури. Процедура визначення застосовних вимог складається з таких кроків.

1. *Ідентифікація ролей*: постачальник електронних комунікаційних мереж і послуг (ЗУ «Про електронні комунікації»); об'єкт критичної інфраструктури та об'єкт кіберзахисту (ЗУ «Про критичну інфраструктуру», ЗУ «Про основні засади забезпечення кібербезпеки»); опера-

тор персональних даних (ЗУ «Про захист персональних даних»); власник корпоративних ІКС.

2. *Формування реєстру вимог*: для кожної ролі — перелік обов'язкових вимог (закони, постанови КМУ, акти регуляторів) і добровільних (стандарти, галузеві настанови).
3. *Відображення на технічні заходи*: наприклад, вимога захисту сигнального обміну відображається на розгортання сигнального міжмережевого екрана для SS7 і Diameter відповідно до настанов GSMA FS.11 [152]; вимога захисту транспортної мережі — на IPsec між базовими станціями та ядром; вимога захисту від перехоплення в роумінгу 5G — на SEPP із захистом N32 [58].
4. *Оцінювання розриву*: розрахунок індексу (2.2) з перевіркою блокувальної умови (2.3).
5. *Планування*: пріоритизація заходів за ризиком і вартістю, включення до плану розвитку мережі з урахуванням вимог щодо постачальників обладнання.

Числовий приклад. Нехай реєстр містить 40 вимог: 12 обов'язкових із вагою 3, 18 вимог стандартів із вагою 2 і 10 рекомендацій із вагою 1 (сума ваг — 82). Обов'язкові вимоги виконано: 10 — повністю, 2 — частково; вимоги стандартів: 12 — повністю, 4 — частково, 2 — не виконано; рекомендації: 5 — повністю, 5 — не виконано. Зважена сума виконання: $3\,(10+2\cdot 0{,}5)+2\,(12+4\cdot 0{,}5)+1\cdot 5 = 33+28+5 = 66$, звідки $G = 1-66/82 \approx 0{,}195$. Попри помірне значення індексу, блокувальна умова (2.3) не виконана через дві частково реалізовані обов'язкові вимоги, тож першочерговими є саме вони, навіть якщо усунення розривів у вимогах стандартів дало б більше зменшення G.

2.7.2 Виробник безпроводового пристрою для ринку ЄС

Український виробник розумних лічильників із модулями Wi-Fi і LTE-M планує постачання на ринок ЄС. Застосовні вимоги: Директива RED [111] та делегований регламент 2022/30 [100] (обладнання під'єднане до Інтернету, обробляє персональні дані про споживання), що передбачає оцінювання за EN 18031-1 і EN 18031-2; у перспективі — CRA [247]; як кращу практику — ETSI EN 303 645 [129]; для інтеграції в енергетичні системи — IEC 62443 [170]. Практичні наслідки для конструкції: унікальні облікові дані для кожного пристрою замість спільного пароля; захищене завантаження і підписані оновлення; шифрування даних при передаванні; механізми захисту від зловживання мережевими ресурсами; документований процес оброблення вразливостей і період підтримки оновленнями. Показово, що вимоги RED DA стосуються не лише самого радіомодуля, а всієї поведінки

пристрою в мережі, тобто безпека безпроводового пристрою розглядається як властивість системи, а не окремого компонента.

Висновки до розділу

Нормативне забезпечення безпеки безпроводових і мобільних мереж є багаторівневим: міжнародні регламенти МСЕ визначають використання спектра, право ЄС і національне законодавство встановлюють обов'язки суб'єктів, стандарти і галузеві специфікації конкретизують технічні механізми, а схеми оцінювання відповідності забезпечують перевірність. В Україні ключовими актами є закони «Про електронні комунікації», «Про основні засади забезпечення кібербезпеки України», «Про критичну інфраструктуру», «Про захист інформації в інформаційно-комунікаційних системах» і «Про захист персональних даних», а також постанови КМУ щодо захисту інформації, кіберзахисту об'єктів критичної інфраструктури та Технічний регламент радіообладнання. У ЄС поле визначають Директива NIS 2 з жорсткими строками повідомлення про інциденти й відповідальністю керівництва, інструментарій безпеки 5G з оцінюванням профілю ризику постачальників, делегований регламент до RED і Акт про кіберстійкість, що запроваджують кібербезпекові вимоги до радіообладнання на етапі виведення на ринок. Галузеві специфікації 3GPP, IEEE і галузевих альянсів визначають механізми, але залишають широкий простір опційності, тому відповідність стандарту не тотожна захищеності конкретної мережі. Для практики оцінювання корисний двоступеневий підхід: блокувальні обов'язкові вимоги плюс зважений індекс розриву відповідності. Гармонізація українського регулювання з європейським у частині вимог до радіообладнання, оцінювання постачальників і повідомлення про інциденти є актуальним завданням, а досвід стійкості мереж в умовах війни — вагомим внеском України у спільний європейський простір.

Питання для самоперевірки

1. Назвіть п'ять рівнів нормативного забезпечення безпеки безпроводових і мобільних мереж і наведіть по два документи кожного рівня.
2. Які чотири категорії суб'єктів зобов'язань виділяють у сфері безпроводових і мобільних мереж? Чому один суб'єкт може належати до кількох категорій?
3. Які питання регулює Закон України «Про електронні комунікації» і як розподілено повноваження між НКЕК та Держспецзв'язку?
4. Чому радіоканал не можна вважати таким, що перебуває в межах контрольованої зони? Які наслідки це має для передавання інформації з обмеженим доступом?

5. Які заходи управління ризиками вимагає стаття 21 Директиви NIS 2? Які з них мають особливе значення для мобільних операторів?
6. Користуючись співвідношеннями (2.1), визначте вимоги до MTTD центру забезпечення кібербезпеки оператора, якщо на узгодження рішення про повідомлення відводиться 6 год.
7. Поясніть концепцію профілю ризику постачальника в інструментарії безпеки 5G ЄС. Чому технічна сертифікація обладнання не знімає цього ризику?
8. Які суттєві вимоги встановлює статтею 3(3)(d–f) Директива RED і на яке обладнання поширюється делегований регламент 2022/30?
9. Чим Акт про кіберстійкість відрізняється від вимог RED DA за сферою дії та життєвим циклом продукту?
10. Опишіть методологію SECAM і схему NESAS. Що гарантує і чого не гарантує проходження оцінювання за NESAS?
11. Наведіть три приклади опційних механізмів безпеки у специфікаціях 3GPP і IEEE 802.11. Чому відповідність стандарту не тотожна захищеності?
12. Обчисліть індекс (2.2) для прикладу з підрозділу 2.7, якщо обидві частково виконані обов'язкові вимоги буде виконано повністю. Чи виконується тепер умова (2.3)?
13. Порівняйте за табл. 2.2 підходи України та ЄС і запропонуйте три першочергові кроки гармонізації.
14. Дослідницьке: запропонуйте некомпенсаторну модель агрегування показників відповідності, яка враховувала б залежності між вимогами (наприклад, вимога шифрування має сенс лише за виконання вимоги керування ключами), і порівняйте її з (2.2).
15. Дослідницьке: розробіть методику відображення вимог EN 18031-1 на технічні заходи для пристрою Інтернету речей з інтерфейсами Wi-Fi і BLE та критерії перевірки їх виконання.

РОЗДІЛ 3

Математичні та інформаційно-теоретичні основи оцінювання захищеності безпроводових каналів

Розділ 1 показав, що безпроводовий канал має фізичні властивості, які прямо визначають можливості порушника: дальність перехоплення, енергетичну асиметрію глушіння, унікальність радіоканалу і радіовідбитка. Щоб перейти від якісних міркувань до обґрунтованих проєктних рішень, потрібен формальний апарат, який дає змогу відповісти на запитання: *скільки* інформації може отримати перехоплювач; *з якою ймовірністю* він опиниться в зоні приймання; *яку потужність* потрібно порушникові для блокування ланки і який запас забезпечує розширення спектра; *наскільки достовірними* є сигнали системи виявлення вторгнень; *як швидко* можна підібрати пароль або дочекатися повторення одноразового числа; *наскільки анонімним* є абонент за наявних ідентифікаторів. Розділ систематизує відповідний апарат — теорію інформації, стохастичну геометрію, теорію статистичного виявлення, моделі глушіння і розширення спектра, ентропійні міри приватності, комбінаторні оцінки стійкості та марковські моделі доступності — і завершується розгорнутим числовим прикладом. Матеріал є математичним ядром посібника.

3.1 Постановка задачі оцінювання захищеності безпроводової ланки

Розглянемо безпроводову ланку між легітимним передавачем (за традицією — Аліса), легітимним приймачем (Боб) і порушником (Єва), який може бути пасивним (перехоплює) або активним (глушить, підробляє, ретранслює). Стан ланки описується кортежем

$$\mathcal{L} = \langle \gamma_B,\ \gamma_E,\ J,\ \mathcal{M},\ \mathcal{K} \rangle,$$

де γ_B, γ_E — відношення сигнал/шум у каналах Аліса–Боб і Аліса–Єва (у загальному випадку випадкові величини через завмирання і мобільність); J — потужність завади порушника на вході приймача Боба; $\mathcal{M}$ — застосовані механізми захисту (криптографія, розширення спектра, спрямовані антени, штучний шум); $\mathcal{K}$ — ключовий матеріал та його стійкість.

Захищеність ланки характеризується вектором показників, кожен з яких відповідає певній властивості безпеки: мірою інформаційної витоку (конфіденційність), імовірністю підробки (автентичність), імовірністю блокування або часом недоступності (доступність), мірою анонімності (приватність). Задача оцінювання полягає в обчисленні цих показників за заданої

моделі порушника (1.5), а задача синтезу — у виборі механізмів $\mathcal{M}$ і параметрів, що забезпечують цільові значення показників за обмежень на ресурси (потужність, смугу, затримку, вартість). Принципово, що частина показників визначається *фізикою* (як-от γ_E), а частина — *обчислювальною складністю* (стійкість ключів), і ці два світи потребують різного апарату, який доповнює один одного.

3.2 Інформаційно-теоретична секретність

3.2.1 Досконала секретність і канал з перехопленням

Шеннон [260] визначив **досконалу секретність** як статистичну незалежність шифротексту C і повідомлення M: $I(M;C)=0$, і довів, що вона досяжна лише за умови $H(K)\ge H(M)$, тобто ключ має бути не коротшим за повідомлення (шифр Вернама з одноразовим ключем). Ця умова робить досконалу секретність непрактичною для високошвидкісних каналів.

Вайнер [287] запропонував інший погляд, придатний саме для безпроводового середовища: якщо канал до перехоплювача гірший (шумніший) за канал до легітимного приймача, то можна передавати інформацію так, що Боб декодує її з довільно малою ймовірністю помилки, а Єва не отримує про неї майже жодної інформації — *без використання спільного ключа*. Модель **каналу з перехопленням** (wiretap channel) наведено на рис. 3.1. Кодер Аліси перетворює повідомлення M на послідовність X^n; Боб спостерігає Y^n, Єва — Z^n. Вимоги до коду: надійність $\Pr\{\hat{M}\neq M\}\to 0$ і секретність $\frac{1}{n}I(M;Z^n)\to 0$ (слабка секретність) або $I(M;Z^n)\to 0$ (сильна секретність). Максимальна швидкість, за якої обидві вимоги виконуються, називається **секретною пропускною здатністю** C_s. Для загального випадку широкомовного каналу з конфіденційними повідомленнями результат узагальнили Чісар і Кьорнер [104].

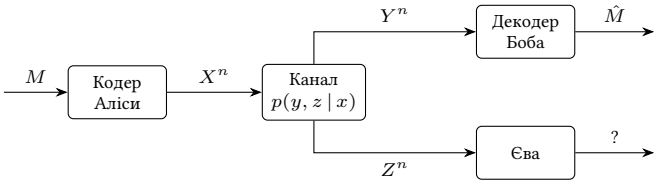


Рис. 3.1 — Модель каналу з перехопленням (за [287, 104])

3.2.2 Гауссів канал з перехопленням

Для гауссового каналу з перехопленням з обмеженням середньої потужності Люн-Ян-Чеонг і Геллман [196] отримали

$$C_s = \Big[\log_2\big(1+\gamma_B\big) - \log_2\big(1+\gamma_E\big)\Big]^+, \tag{3.1}$$

де $[x]^+ = \max(x, 0)$; γ_B, γ_E — відношення сигнал/шум у каналах Боба і Єви (біт/с/Гц на одиницю смуги). Секретна пропускна здатність додатна лише тоді, коли Боб має кращий канал ($\gamma_B > \gamma_E$). Наприклад, для $\gamma_B = 20$ дБ (100) і $\gamma_E = 10$ дБ (10) маємо $C_s = \log_2 101 - \log_2 11 = 6{,}658 - 3{,}459 = 3{,}20$ біт/с/Гц, тобто близько половини пропускної здатності каналу Боба може бути використано для передавання, секретного в інформаційно-теоретичному сенсі.

Формула (3.1) містить ключовий для інженерії висновок: секретність досягається *перевагою* каналу, і тому засоби, що збільшують цю перевагу, — спрямовані антени і формування діаграми спрямованості, штучний шум у напрямку, ортогональному до каналу Боба, керування потужністю, кооперативні ретранслятори — є засобами захисту конфіденційності (розділ 5). Водночас порушник зі спрямованою антеною і малошумним підсилювачем (див. приклад у розділі 1) легко отримує $\gamma_E > \gamma_B$, тому в загальному випадку безпека фізичного рівня є доповненням, а не заміною криптографії.

3.2.3 Секретність у каналах із завмиранням

У безпроводових каналах γ_B і γ_E змінюються випадково. Для каналів із релеєвським завмиранням миттєві відношення сигнал/шум мають експоненційний розподіл із середніми $\bar\gamma_B$, $\bar\gamma_E$. Якщо Аліса не знає миттєвого стану каналу Єви і передає з фіксованою секретною швидкістю R_s, основним показником стає **імовірність переривання секретності** $P_{\text{out}}(R_s) = \Pr\{C_s < R_s\}$. Для незалежних релеєвських каналів [85]

$$P_{\text{out}}(R_s) = 1 - \frac{\bar\gamma_B}{\bar\gamma_B + 2^{R_s}\,\bar\gamma_E}\,\exp\!\left(-\frac{2^{R_s}-1}{\bar\gamma_B}\right). \tag{3.2}$$

За $R_s = 0$ формула дає ймовірність того, що секретна пропускна здатність дорівнює нулю: $\Pr\{C_s = 0\} = \bar\gamma_E/(\bar\gamma_B + \bar\gamma_E)$. Звідси важливий висновок: *завмирання допомагає секретності.* Навіть якщо в середньому Єва має такий самий канал, як Боб ($\bar\gamma_E = \bar\gamma_B$), у половині випадків канал Боба кращий, і секретне передавання можливе; у детермінованому гауссовому каналі за $\gamma_E = \gamma_B$ секретність недосяжна.

Для $\bar\gamma_B = 100$ і $\bar\gamma_E = 10$ маємо $\Pr\{C_s = 0\} = 10/110 = 0{,}091$. Для $R_s = 1$ біт/с/Гц: $\bar\gamma_B/(\bar\gamma_B + 2\bar\gamma_E) = 100/120 = 0{,}833$, $\exp(-1/100) = 0{,}990$, отже $P_{\text{out}}(1) = 1 - 0{,}825 = 0{,}175$. Залежність P_{out} від R_s для двох значень $\bar\gamma_E$ показано на рис. 3.2: переривання секретності швидко зростає зі збільшенням швидкості, а зменшення якості каналу Єви на 5 дБ приблизно вдвічі знижує ймовірність переривання на малих швидкостях.

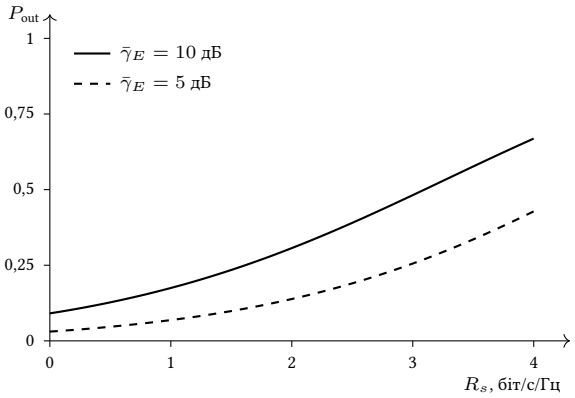


Рис. 3.2 — Імовірність переривання секретності за релеєвського завмирання ($\bar{\gamma}_B = 20$ дБ), розраховано за (3.2)

3.2.4 Генерування ключів із каналу

Інший спосіб використати фізику — **узгодження секретного ключа** через спільну випадковість каналу. Якщо Аліса й Боб спостерігають корельовані величини (наприклад, оцінки коефіцієнтів взаємного каналу $h_{AB} \approx h_{BA}$ за принципом взаємності), а Єва, віддалена більш ніж на половину довжини хвилі, спостерігає слабко корельовану величину, то вони можуть через відкрите обговорення виділити спільний секрет. Верхньою межею швидкості генерування ключа є умовна взаємна інформація

$$C_K \le \min\bigl\{ I(X;Y),\ I(X;Y \mid Z) \bigr\}, \tag{3.3}$$

де X, Y, Z — спостереження Аліси, Боба і Єви. Практичні схеми складаються з квантування вимірювань, узгодження розбіжностей (виправлення помилок) і посилення секретності (гешування з утратою частини бітів). Обмеження підходу — низька швидкість генерування в статичних середовищах (мало ентропії в каналі) і вразливість до активного порушника, що впливає на канал; детально схеми розглянуто в розділі 5.

3.3 Просторові моделі: стохастична геометрія

Формули попереднього підрозділу припускають, що Єва перебуває у відомому місці. У реальних сценаріях положення перехоплювачів невідоме, і доцільно моделювати їх як випадковий точковий процес. Найуживанішою моделлю є однорідний пуассонівський процес з інтенсивністю λ_E (середня кількість перехоплювачів на одиницю площі) [158]. Кількість перехоплювачів у області площею A має розподіл Пуассона з параметром $\lambda_E A$, отже

ймовірність відсутності перехоплювачів у колі радіусом r навколо передавача

$$P_0(r) = \exp\bigl(-\lambda_E\,\pi r^2\bigr). \tag{3.4}$$

Для міської території з $\lambda_E = 100$ км$^{-2}$ (10^{-4} м$^{-2}$) і радіуса приймання $r = 50$ м маємо $\lambda_E \pi r^2 = 0{,}785$ і $P_0 = 0{,}456$: з імовірністю $0{,}544$ у зоні приймання перебуває хоча б один потенційний перехоплювач. Оскільки радіус приймання порушника відповідно до (1.3) може бути в десятки разів більшим, ніж радіус обслуговування, ймовірність *відсутності* перехоплювача для реальних радіусів практично дорівнює нулю. Цей результат формалізує положення розділу 1: для безпроводових мереж у населених пунктах слід виходити з гіпотези, що перехоплення відбувається завжди.

Поєднання пуассонівської моделі з моделлю втрат поширення дає змогу обчислювати ймовірність безпечного зв'язку в мережі — наприклад, імовірність того, що вузол має хоча б одного сусіда, з яким можливий секретний зв'язок, або середню кількість таких сусідів [232]. Ці результати використовуються для обґрунтування щільності розгортання вузлів і вибору потужності передавачів у самоорганізованих і сенсорних мережах (розділи 13, 14).

3.4 Теорія статистичного виявлення

3.4.1 Критерій Неймана–Пірсона

Виявлення атак у безпроводовому середовищі — глушіння, підроблених точок доступу, аномальних кадрів — зводиться до перевірки статистичних гіпотез: H_0 — атаки немає, H_1 — атака є. Детектор обчислює статистику T за спостереженнями і порівнює її з порогом τ. Якість детектора характеризують імовірність виявлення $P_D = \Pr\{T > \tau \mid H_1\}$ і ймовірність хибної тривоги $P_{FA} = \Pr\{T > \tau \mid H_0\}$. Згідно з лемою Неймана–Пірсона [188] оптимальним за фіксованого P_{FA} є детектор відношення правдоподібності

$$\Lambda(\mathbf{x}) = \frac{p(\mathbf{x} \mid H_1)}{p(\mathbf{x} \mid H_0)} \underset{H_0}{\overset{H_1}{\gtrless}} \tau. \tag{3.5}$$

Залежність P_D від P_{FA} за зміни порогу — **робоча характеристика приймача** (ROC) — є основним інструментом порівняння детекторів. Для гауссових спостережень із відстанню між гіпотезами d (відношення різниці середніх до стандартного відхилення) $P_D = Q\bigl(Q^{-1}(P_{FA}) - d\bigr)$, де $Q(\cdot)$ — доповнювальна функція стандартного нормального розподілу.

3.4.2 Проблема базової частоти

Для систем виявлення вторгнень вирішальним є не P_D і P_{FA} самі собою, а *частка істинних тривог серед усіх тривог.* За теоремою Баєса, якщо апріорна ймовірність атаки в спостережуваному інтервалі дорівнює π,

$$\Pr\{H_1 \mid \text{тривога}\} = \frac{P_D\,\pi}{P_D\,\pi + P_{FA}\,(1-\pi)}. \tag{3.6}$$

Аксельссон [75] назвав ігнорування цього співвідношення *хибою базової частоти.* Нехай безпроводова система виявлення вторгнень аналізує поведінку клієнтів за інтервалами по 1 хв і має $P_D = 0{,}95$, $P_{FA} = 0{,}01$, а реальні атаки трапляються в одному інтервалі з тисячі ($\pi = 10^{-3}$). Тоді за (3.6) частка істинних тривог дорівнює $0{,}00095/(0{,}00095 + 0{,}00999) = 0{,}087$: понад 91 % тривог — хибні. Для практично корисної частки істинних тривог 50 % за того самого π потрібно $P_{FA} \le 9{,}5 \cdot 10^{-4}$, тобто на порядок менше. Висновок для проєктування: для рідкісних атак потрібно або різко знижувати P_{FA} (кореляція кількох незалежних ознак, підтвердження радіопеленгацією), або підвищувати π через попередню фільтрацію (аналіз лише подій, що вже мають ознаки аномалії). Цей висновок безпосередньо використовується в розділі 15.

3.4.3 Виявлення глушіння

Сю, Траппе та співавтори [288] показали, що жодна окрема ознака — рівень сигналу, частка успішно доставлених кадрів, частка зайнятості каналу — не дає змоги надійно відрізнити глушіння від природних причин погіршення зв'язку (перевантаження, завмирання, віддаленість). Надійне виявлення потребує *узгодженої перевірки кількох ознак*: наприклад, низька частка доставлених кадрів за високої потужності прийнятого сигналу свідчить про глушіння, а низька частка за низької потужності — про природне погіршення. Експериментальні дослідження стійкості маяків BLE, мереж ZigBee і Wi-Fi до різних типів глушіння, виконані з участю автора посібника [267, 268, 266], підтверджують, що ефективність атаки і, відповідно, ознаки її виявлення суттєво залежать від механізму доступу до середовища конкретної технології.

3.5 Моделі глушіння та розширення спектра

3.5.1 Відношення завада/сигнал

Ефективність глушіння визначає **відношення завада/сигнал** на вході приймача. З моделі (1.2) за однакового показника втрат n

$$\frac{J}{S}\,[\text{дБ}] = \big(P_J - P_S\big) + \big(G_J - G_S\big) + 10\,n\,\lg\frac{d_S}{d_J}, \tag{3.7}$$

де P_J, P_S — потужності передавачів завади і сигналу (дБм); G_J, G_S — підсилення їхніх антен у напрямку приймача (дБі); d_J, d_S — відстані від постановника завад і від легітимного передавача до приймача. Формула (3.7) кількісно виражає енергетичну асиметрію: для базової станції потужністю 30 дБм на відстані 5 км і постановника завад потужністю 20 дБм на відстані 1 км від абонента за $n = 3$ маємо $J/S = -10 + 30\lg 5 = -10 + 20{,}97 \approx 11$ дБ, тобто завада, у 10 разів слабша на виході передавача, на вході приймача перевищує корисний сигнал більш ніж у 10 разів.

3.5.2 Класи постановників завад

За стратегією поведінки розрізняють кілька класів постановників завад [288, 234]; їхні характеристики наведено в табл. 3.1.

Таблиця 3.1 — Класи постановників завад та їх характеристики

Клас	Стратегія	Виявлюваність і протидія
Постійний	безперервне випромінювання шуму або випадкових символів у смузі	легко виявляється; висока енерговитрата; протидія — зміна частоти, пеленгація
Оманливий	безперервне передавання коректних кадрів або преамбул, що займають канал	маскується під трафік; протидія — аналіз вмісту, автентифікація
Випадковий	чергування періодів випромінювання і сну	компроміс між ефективністю та енергією; ускладнює виявлення
Реактивний	випромінювання лише після виявлення початку кадру жертви	мінімальна енергія, важко виявити; протидія — розширення спектра, короткі кадри
Вибірковий	глушіння лише кадрів певного типу (підтвердження, службові)	дуже ефективний; протидія — захист службових кадрів, рандомізація
Слідкувальний	відстеження стрибків частоти й глушіння поточного каналу	протидія — висока швидкість стрибків, криптографічна послідовність

3.5.3 Виграш від обробки і запас стійкості

Системи з розширенням спектра [265] розподіляють сигнал вузької смуги B на широку смугу B_{ss} за допомогою псевдовипадкової послідовності (пряме розширення, DSSS) або стрибків частоти (FHSS). Приймач, що знає

послідовність, стискає сигнал назад, а заваду, некорельовану з послідовністю, розподіляє по всій смузі. **Виграш від обробки** і **запас стійкості до завад** визначаються як

$$G_p = 10\lg\frac{B_{ss}}{B}, \qquad M_J = G_p - \left(L_{\text{сис}} + \left(\tfrac{S}{N}\right)_{\min}\right), \tag{3.8}$$

де $L_{\text{сис}}$ — втрати в реальній системі; $(S/N)_{\min}$ — мінімальне відношення сигнал/шум після стиснення, потрібне для прийнятної якості. Система працездатна, доки $J/S < M_J$. Для відкритого сигналу GPS L1 C/A зі швидкістю елементів коду 1,023 Мчип/с і швидкістю даних 50 біт/с $G_p = 10\lg(1{,}023\cdot 10^6/50) \approx 43$ дБ. За $L_{\text{сис}} = 2$ дБ і $(S/N)_{\min} = 10$ дБ маємо $M_J \approx 31$ дБ. Проте потужність сигналу GPS на поверхні Землі становить близько -130 дБм, тому для порушення приймання достатньо завади -99 дБм. Для постановника завад потужністю 1 Вт (30 дБм) з ізотропною антеною допустимі втрати поширення — 129 дБ, що у вільному просторі на частоті 1575 МГц відповідає відстані близько 43 км за прямої видимості. Цей розрахунок пояснює, чому глушіння супутникової навігації є масовим явищем і чому для критичних застосувань потрібні адаптивні антенні решітки та альтернативні джерела позиціювання й часу (розділ 14).

3.5.4 Стрибки частоти проти вибіркового глушіння

Для системи зі стрибками частоти по N каналах і постановника завад, що одночасно глушить k каналів, імовірність ураження одного стрибка $p = k/N$. Якщо кадр передається за m стрибків, а завадостійке кодування виправляє втрату до e стрибків, то ймовірність втрати кадру

$$P_{\text{втр}} = \sum_{i=e+1}^{m} \binom{m}{i} p^{\,i}\,(1-p)^{m-i}. \tag{3.9}$$

Для Bluetooth класичного з $N = 79$ каналами і постановника завад, що перекриває 10 каналів, $p = 0{,}127$; для однослотового пакета без завадостійкого кодування втрата становить 12,7 %, що з урахуванням повторних передавань лише знижує пропускну здатність. Адаптивна стрибкоподібна зміна частоти, що виключає уражені канали з послідовності, додатково зменшує p. Навпаки, для технологій із фіксованим каналом (наприклад, мережа ZigBee на одному каналі IEEE 802.15.4) навіть вузькосмуговий постановник завад блокує мережу повністю, що підтверджують експерименти [268].

3.6 Ентропійні міри приватності

3.6.1 Анонімна множина та ентропія

Приватність абонента мобільної мережі оцінюють через невизначеність порушника щодо його ідентичності чи місцезнаходження. **Анонімна мно-**

жина — множина суб'єктів, серед яких порушник не може розрізнити справжнього. Якщо порушник приписує i-му суб'єкту ймовірність p_i, то ступінь анонімності вимірюють ентропією

$$H = -\sum_{i} p_i \log_2 p_i, \qquad d = \frac{H}{\log_2 N}, \tag{3.10}$$

де N — розмір анонімної множини, $d \in [0;1]$ — нормований ступінь анонімності (1 — рівномірний розподіл, 0 — порушник точно знає суб'єкта). Модель k-анонімності [276] вимагає, щоб кожен запис у знеособлених даних (наприклад, у наборі даних про місцезнаходження) був нерозрізнюваним щонайменше з $k-1$ іншими.

3.6.2 Відбитки пристроїв і рандомізація адрес

Для протидії відстеженню сучасні мобільні операційні системи рандомізують MAC-адреси Wi-Fi і Bluetooth. Однак інші ознаки — набір підтримуваних швидкостей і розширень у кадрах пошуку, послідовні номери кадрів, часові інтервали між запитами, радіочастотні характеристики — утворюють **відбиток** пристрою. Якщо ці ознаки мають сумарну ентропію H_f біт (за незалежності ознак ентропії додаються), то серед N пристроїв очікувана кількість пристроїв з таким самим відбитком, як у цільового, дорівнює приблизно

$$\bar{k} \approx 1 + (N-1)\,2^{-H_f}. \tag{3.11}$$

Для $N = 10\,000$ пристроїв у зоні спостереження (торговельний центр) і $H_f = 12$ біт маємо $\bar{k} \approx 3{,}4$: рандомізація MAC-адреси зменшує анонімну множину до кількох пристроїв, і відстеження з урахуванням часової послідовності спостережень стає надійним. Емпіричні дослідження [200] підтвердили, що механізми рандомізації в багатьох реалізаціях можна обійти саме через такі ознаки і через помилки реалізації. Для ефективного захисту необхідно одночасно зменшувати H_f (уніфікація вмісту службових кадрів) і скорочувати тривалість спостереження одного псевдоніма.

3.7 Комбінаторні оцінки стійкості

3.7.1 Повторення одноразових значень

Багато безпроводових протоколів використовують одноразові значення (вектори ініціалізації, лічильники) для потокових шифрів чи режимів лічильника. Повторення одноразового значення з тим самим ключем у потоковому шифрі розкриває XOR двох відкритих текстів. Якщо одноразове значення має довжину b біт і вибирається випадково, то за парадоксом днів

народження ймовірність хоча б одного повторення серед q значень

$$P_{\text{кол}}(q) \approx 1 - \exp\!\left(-\frac{q(q-1)}{2^{\,b+1}}\right), \qquad q_{1/2} \approx 1{,}177 \cdot 2^{\,b/2}. \tag{3.12}$$

Для 24-бітового вектора ініціалізації протоколу WEP $q_{1/2} \approx 1{,}177 \cdot 4096 \approx 4800$ кадрів, тобто за інтенсивного трафіку повторення виникає за лічені секунди. Саме тому довжина одноразових значень у сучасних протоколах становить 48 біт і більше, а їх неповторюваність забезпечується лічильником, а не випадковим вибором (розділи 6, 7).

3.7.2 Підбір паролів у режимі офлайн

Для мереж із автентифікацією на основі спільного пароля (WPA2-Personal) порушник, що перехопив рукостискання, може перевіряти кандидатів у режимі офлайн без взаємодії з мережею. Час повного перебору множини кандидатів $\mathcal{D}$

$$T = \frac{|\mathcal{D}|}{R}, \tag{3.13}$$

де R — швидкість перевірки (кандидатів за секунду). У WPA2 ключ виводиться з пароля функцією PBKDF2 з 4096 ітераціями HMAC-SHA1, тому швидкість перевірки на одному сучасному графічному процесорі — порядку 10^6 кандидатів за секунду. Оцінки для типових класів паролів наведено в табл. 3.2.

Таблиця 3.2 — Оцінка часу перебору паролів WPA2-Personal за $R = 10^6$ с$^{-1}$

Клас пароля	$\lvert\mathcal{D}\rvert$	Час перебору
Словник поширених паролів	10^9	$\approx$ 17 хв
8 цифр	10^8	$\approx$ 2 хв
8 символів $[a\text{–}z, 0\text{–}9]$	$2{,}8 \cdot 10^{12}$	$\approx$ 33 доби
10 символів $[a\text{–}z, A\text{–}Z, 0\text{–}9]$	$8{,}4 \cdot 10^{17}$	$\approx$ 27 000 років
12 символів $[a\text{–}z, A\text{–}Z, 0\text{–}9]$	$3{,}2 \cdot 10^{21}$	$\approx 10^8$ років

Таблиця показує, що для паролів, вибраних людиною, реальним є лише словниковий сценарій, а стійкість визначає ентропія пароля, а не його довжина. Протокол SAE у WPA3 принципово змінює модель: кожна перевірка кандидата вимагає взаємодії з точкою доступу, тобто атака стає онлайновою, і R обмежується частотою спроб, яку контролює захисник (розділ 7).

3.8 Марковська модель доступності безпроводової ланки

Доступність ланки в умовах атак і відмов зручно описувати ланцюгом Маркова з неперервним часом. Розглянемо три стани базової станції: N — нормальна робота; J — деградація внаслідок глушіння (часткова пропускна

здатність η); D — відмова внаслідок знеструмлення чи пошкодження. Переходи: $N \to J$ з інтенсивністю λ_J (атаки глушіння), $J \to N$ з інтенсивністю μ_J (зміна частоти, придушення джерела), $N \to D$ з інтенсивністю λ_D, $D \to N$ з інтенсивністю μ_D. Рівняння балансу дають стаціонарний розподіл

$$\pi_J = \frac{\lambda_J}{\mu_J}\,\pi_N, \qquad \pi_D = \frac{\lambda_D}{\mu_D}\,\pi_N, \qquad \pi_N = \Bigl(1 + \frac{\lambda_J}{\mu_J} + \frac{\lambda_D}{\mu_D}\Bigr)^{-1}, \tag{3.14}$$

а ефективна доступність з урахуванням деградації $A_{\text{еф}} = \pi_N + \eta\,\pi_J$.

Для $\lambda_J = 0{,}5$, $\mu_J = 6$, $\lambda_D = 0{,}1$, $\mu_D = 2$ доба$^{-1}$ і $\eta = 0{,}3$ маємо $\lambda_J/\mu_J = 0{,}083$, $\lambda_D/\mu_D = 0{,}05$, звідки $\pi_N = 0{,}882$, $\pi_J = 0{,}074$, $\pi_D = 0{,}044$ і $A_{\text{еф}} = 0{,}904$. Подвоєння швидкості реагування на глушіння ($\mu_J = 12$) підвищує $A_{\text{еф}}$ до $0{,}928$, а подвоєння швидкості відновлення живлення ($\mu_D = 4$) — до $0{,}925$. Модель дає кількісний аргумент на користь автоматизованих механізмів адаптації частоти і моніторингу ефіру порівняно з інвестиціями лише в резервне живлення — або навпаки, залежно від співвідношення інтенсивностей у конкретному регіоні. Моделі стійкості мобільних мереж розвинено в розділі 16.

3.9 Розгорнутий приклад комплексного розрахунку

Розглянемо корпоративну безпроводову мережу філії, розташованої у багатоповерховому офісному центрі міста: 12 точок доступу Wi-Fi (потужність 20 дБм), клієнти на відстанях до 40 м, датчики доступу BLE, резервний LTE-канал; модель порушника — зовнішній активний радіопорушник зі спрямованою антеною 24 дБі і приймачем із чутливістю -95 дБм, що може розміщуватися на відстані до 1 км.

Крок 1. Досяжність перехоплення. За (1.3) при $n = 2{,}7$ відношення дальностей ≈ 20, отже зона перехоплення — близько 800 м. За (3.4) з $\lambda_E = 100$ км$^{-2}$ ймовірність відсутності потенційного перехоплювача в такій зоні нехтовно мала ($\exp(-201)$). Висновок: конфіденційність має бути повністю криптографічною.

Крок 2. Секретність фізичного рівня. Середнє $\bar{\gamma}_B = 25$ дБ; порушник на відстані 800 м зі спрямованою антеною отримує $\bar{\gamma}_E \approx 12$ дБ. За (3.2) при $R_s = 0$ ймовірність нульової секретної пропускної здатності $\bar{\gamma}_E/(\bar{\gamma}_B + \bar{\gamma}_E) = 15{,}8/(316{+}15{,}8) = 0{,}048$. Методи безпеки фізичного рівня (формування діаграми спрямованості) можуть бути корисним додатковим бар'єром, але не заміною шифрування.

Крок 3. Стійкість автентифікації. Мережа використовує WPA2-Personal із паролем з 10 символів, складеним співробітниками за шаблоном «назва компанії + рік». Реальна ентропія такого пароля — не більше 20 біт, тобто $|\mathcal{D}| \approx 10^6$ і $T \approx 1$ с. Перехід на WPA3-SAE переводить атаку в онлайно-

вий режим; перехід на WPA3-Enterprise з EAP-TLS усуває спільний секрет узагалі.

Крок 4. Виявлення атак. WIDS із $P_D = 0{,}9$, $P_{FA} = 0{,}005$ за $\pi = 5\cdot 10^{-4}$ дає частку істинних тривог $0{,}083$. Додавання незалежного підтвердження за радіовідбитком з $P'_D = 0{,}95$, $P'_{FA} = 0{,}02$ (правило «обидві ознаки») знижує сумарну P_{FA} до 10^{-4} за $P_D = 0{,}855$, і частка істинних тривог зростає до $0{,}81$.

Крок 5. Стійкість до глушіння. Постановник завад 27 дБм на відстані 150 м від клієнта, точка доступу — 20 дБм на відстані 25 м, $n = 3$: за (3.7) $J/S = 7 + 30\lg(25/150) = 7 - 23{,}3 = -16{,}3$ дБ; завада нижча за сигнал, і з урахуванням порогу демодуляції модуляцій низького порядку зв'язок зберігається зі зниженою швидкістю. Постановник завад, розміщений на відстані 30 м, дає $J/S = +4{,}6$ дБ і блокує ланку. Для датчиків BLE з адаптивними стрибками частоти по 37 каналах даних і постановника, що перекриває смугу 20 МГц (близько 10 каналів), $p \approx 0{,}27$; за (3.9) з $m = 4$ і $e = 1$ втрата повідомлення $P_{\text{втр}} \approx 0{,}30$, що вимагає або збільшення надлишковості кодування, або повторних передавань.

Крок 6. Доступність. Для точки доступу з параметрами марковської моделі попереднього підрозділу $A_{\text{еф}} = 0{,}904$; наявність резервного LTE-каналу з незалежною (у першому наближенні) доступністю $0{,}98$ дає сумарну доступність $1 - (1 - 0{,}904)(1 - 0{,}98) = 0{,}998$.

Результати зведено в табл. 3.3.

Таблиця 3.3 — Зведення результатів розрахунку для корпоративної безпроводової мережі

Показник	Значення	Висновок
Зона перехоплення	≈ 800 м	перехоплення слід вважати гарантованим
$\Pr\{C_s = 0\}$	$0{,}048$	безпека фізичного рівня — лише додатковий бар'єр
Час підбору пароля WPA2	≈ 1 с	обов'язковий перехід на SAE або 802.1X/EAP-TLS
Частка істинних тривог WIDS	$0{,}083 \to 0{,}81$	потрібна кореляція незалежних ознак
J/S за постановника на 30 м	$+4{,}6$ дБ	потрібні моніторинг ефіру й резервний канал
Сумарна доступність	$0{,}998$	резервування через незалежну технологію ефективне

Наведений приклад ілюструє загальну методологію: показники захищеності безпроводової ланки обчислюються за явними моделями з явними припущеннями, результати різних моделей узгоджуються між собою, а рішення про заходи захисту обґрунтовуються кількісно. Найважливіше — чу-

тливість: частку істинних тривог визначає P_{FA}, стійкість автентифікації — ентропія пароля, доступність — незалежність резервного каналу.

Висновки до розділу

Формальний апарат оцінювання захищеності безпроводових каналів поєднує інформаційно-теоретичні, ймовірнісно-просторові, статистичні та комбінаторні моделі. Теорія каналу з перехопленням показує, що секретність без спільного ключа досяжна за перевагою каналу легітимного приймача, а завмирання, як не парадоксально, їй сприяє; проте реалістичні можливості порушника зі спрямованими антенами обмежують практичну цінність цих результатів роллю додаткового бар'єра. Стохастична геометрія формалізує положення про те, що в населеному середовищі перехоплення слід вважати гарантованим. Теорія статистичного виявлення разом із теоремою Баєса пояснює, чому системи виявлення вторгнень у безпроводовому ефірі генерують переважно хибні тривоги і чому необхідна кореляція незалежних ознак. Моделі глушіння і розширення спектра дають змогу кількісно оцінити енергетичну асиметрію атаки, запас стійкості систем із розширенням спектра і ефективність стрибків частоти проти вибіркових постановників завад, а розрахунок для GPS пояснює масовість глушіння навігації. Ентропійні міри приватності показують обмеженість рандомізації MAC-адрес за наявності багатовимірних відбитків пристроїв. Комбінаторні оцінки пояснюють неминучість повторення коротких одноразових значень і вразливість паролів, вибраних людиною, до офлайнового перебору. Марковські моделі пов'язують інтенсивності атак і відновлення з доступністю. Головний методологічний висновок: жодна модель не є самодостатньою, і наукова цінність оцінювання визначається явністю припущень, аналізом чутливості та узгодженістю результатів незалежних моделей.

Питання для самоперевірки

1. Сформулюйте умову досконалої секретності Шеннона. Чому вона непрактична для високошвидкісних безпроводових каналів?
2. Опишіть модель каналу з перехопленням Вайнера. Чим відрізняються вимоги слабкої і сильної секретності?
3. За формулою (3.1) обчисліть секретну пропускну здатність для $\gamma_B = 15$ дБ і $\gamma_E = 12$ дБ. Як зміниться результат, якщо Єва використає антену з підсиленням на 6 дБ більше?
4. Доведіть, що для релеєвських каналів $\Pr\{C_s = 0\} = \bar{\gamma}_E/(\bar{\gamma}_B + \bar{\gamma}_E)$. Чому завмирання сприяє секретності?
5. Обчисліть за (3.2) імовірність переривання секретності для $\bar{\gamma}_B = 15$ дБ, $\bar{\gamma}_E = 15$ дБ і $R_s = 0{,}5$ біт/с/Гц.

6. Від чого залежить швидкість генерування ключа з каналу (3.3)? Чому в статичному середовищі вона низька?
7. Для $\lambda_E = 50$ км$^{-2}$ визначте радіус, за якого ймовірність відсутності перехоплювача становить 0,9. Порівняйте його з типовою дальністю перехоплення Wi-Fi.
8. Поясніть хибу базової частоти. Яку P_{FA} потрібно забезпечити, щоб за $\pi = 10^{-4}$ і $P_D = 0{,}9$ частка істинних тривог становила 0,5?
9. Чому окрема ознака не дає змоги надійно виявити глушіння? Запропонуйте правило узгодженої перевірки двох ознак.
10. За формулою (3.7) визначте мінімальну потужність постановника завад на відстані 500 м, достатню для отримання $J/S = 10$ дБ щодо базової станції 43 дБм на відстані 3 км ($n = 3{,}5$, антени однакові).
11. Обчисліть виграш від обробки для системи DSSS зі швидкістю елементів 11 Мчип/с і швидкістю даних 1 Мбіт/с. Який запас стійкості вона має за $L_{\text{сис}} = 2$ дБ і $(S/N)_{\min} = 7$ дБ?
12. За формулою (3.12) оцініть кількість кадрів до першого повторення 48-бітового випадкового одноразового значення з імовірністю 0,5. Чому в протоколах використовують лічильник?
13. Чому протокол SAE змінює модель атаки підбором пароля? Використовуючи (3.13), оцініть час онлайнового перебору словника 10^6 паролів за обмеження 10 спроб на хвилину.
14. Дослідницьке: розробіть марковську модель доступності мобільної мережі регіону, що враховує корельовані знеструмлення кількох базових станцій, і порівняйте її з моделлю (3.14).
15. Дослідницьке: запропонуйте методику експериментального оцінювання ентропії відбитка H_f мобільних пристроїв за кадрами пошуку Wi-Fi і обґрунтуйте вимоги до обсягу вибірки.

РОЗДІЛ 4

Моделювання загроз і управління ризиками безпроводових і мобільних мереж

Нормативні вимоги (розділ 2) визначають, *що* має бути захищено, а математичний апарат (розділ 3) — *як* кількісно оцінити окремі властивості ланки. Між ними лежить процес, що пов'язує активи, загрози, вразливості й заходи в єдину систему рішень, — управління ризиками. Для безпроводових і мобільних мереж цей процес має низку особливостей: активами є не лише дані та системи, а й радіочастотний ресурс, ідентифікатори абонентів, дані про місцезнаходження, сигнальні зв'язки з іншими операторами; загрози реалізуються на кількох рівнях одночасно; значна частина ризиків пов'язана з ланцюгом постачання обладнання і з пристроями, які організація не контролює. Розділ розглядає процес управління ризиками відповідно до міжнародних стандартів, методології моделювання загроз (STRIDE, LINDDUN, дерева атак, бази знань MITRE), методи кількісного оцінювання ризику та економічного обґрунтування заходів і завершується кейсом для безпроводової мережі університетського кампусу.

4.1 Процес управління ризиками

4.1.1 Загальна схема

Процес управління ризиками інформаційної безпеки відповідно до ISO/IEC 27005 [182] і ISO 31000 [178] складається з етапів встановлення контексту, оцінювання ризиків (ідентифікація, аналіз, оцінка), оброблення ризиків, прийняття залишкових ризиків, а також наскрізних процесів комунікації та моніторингу (рис. 4.1). NIST SP 800-30 [214] деталізує оцінювання ризиків через ланцюг «джерело загрози → подія загрози → вразливість → несприятливий вплив» і вводить поняття рівнів оцінювання: організаційного, рівня бізнес-процесів і рівня інформаційних систем. Каталог методів оцінювання ризиків — від мозкового штурму й аналізу сценаріїв до дерев відмов і методу Монте-Карло — подано в IEC 31010 [169].

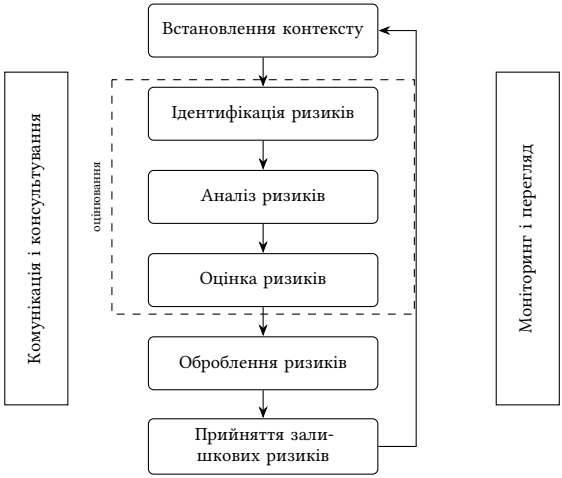


Рис. 4.1 — Процес управління ризиками інформаційної безпеки (за [182, 178])

4.1.2 Встановлення контексту для безпроводових і мобільних мереж

На етапі встановлення контексту визначають межі системи, критерії оцінювання та прийняття ризиків, ролі й відповідальність. Для безпроводових мереж межі системи принципово не збігаються з фізичними межами об'єкта: зона радіопокриття виходить за стіни будівлі, пристрої користувачів переміщуються між мережами, частина функцій виконується оператором зв'язку або хмарним контролером. Тому межі доцільно визначати *функціонально* — через потоки даних і домени довіри (розділ 1).

Специфічними активами безпроводових і мобільних мереж є:

- *радіочастотний ресурс* — доступність смуг частот, на яких працює мережа; порушення доступності ресурсу (глушіння, завади) не залежить від захищеності протоколів;
- *ключовий матеріал і облікові дані* — довготривалі ключі абонентів у SIM/USIM і в центрах автентифікації, сертифікати серверів автентифікації, паролі мереж Wi-Fi, ключі спарювання Bluetooth;
- *ідентифікатори та дані про місцезнаходження* — IMSI/SUPI, MAC-адреси, історія підключень, які мають самостійну цінність для порушника незалежно від вмісту трафіку;
- *сигнальні зв'язки* — інтерфейси з роумінговими партнерами і міжоператорськими мережами;
- *інфраструктура доступу* — базові станції, точки доступу, контролери, транспортні лінії, системи живлення;

- *пристрої користувачів* — корпоративні й особисті смартфони, ноутбуки, пристрої Інтернету речей.

Критерії впливу мають враховувати не лише фінансові втрати, а й вплив на безпеку людей (порушення екстреного зв'язку), виконання обов'язків перед регулятором (повідомлення про інциденти в строки NIS 2), приватність абонентів і репутацію.

4.2 Методології моделювання загроз

4.2.1 STRIDE

Методологія STRIDE [263] класифікує загрози за порушеною властивістю: підміна (Spoofing) — автентичність; модифікація (Tampering) — цілісність; відмова від авторства (Repudiation) — неспростовність; розкриття інформації (Information disclosure) — конфіденційність; відмова в обслуговуванні (Denial of service) — доступність; підвищення привілеїв (Elevation of privilege) — авторизація. Моделювання виконують на діаграмі потоків даних, для кожного елемента якої (процес, сховище, потік, зовнішня сутність) систематично перевіряють застосовні категорії. Для безпроводових систем діаграму слід доповнювати *радіоканалами* як окремими потоками, що перетинають межу довіри, і *фізичними* елементами (антени, радіомодулі). Приклади загроз кожної категорії наведено в табл. 4.1.

Таблиця 4.1 — Категорії STRIDE у безпроводових і мобільних мережах

Категорія	Приклади загроз
Підміна	точка доступу-двійник; фальшива базова станція; підміна MAC-адреси; підроблені маяки BLE; підміна сигналів GNSS
Модифікація	ін'єкція кадрів; атаки на агрегацію і фрагментацію кадрів Wi-Fi; модифікація незахищеної цілісністю користувацької площини LTE
Відмова від авторства	відсутність журналів гостьової мережі; спільний пароль, що не дає змоги встановити користувача
Розкриття інформації	перехоплення трафіку; розкриття IMSI; аналіз метаданих; відстеження за ідентифікаторами
Відмова в обслуговуванні	глушіння; деавтентифікація; сигнальні атаки на ядро; розряджання батарей пристроїв IoT
Підвищення привілеїв	експлуатація вразливостей прошивок радіомодулів і точок доступу; зловживання профілями керування пристроями

4.2.2 LINDDUN: загрози приватності

Оскільки для мобільних мереж загрози приватності мають самостійне значення, STRIDE доцільно доповнювати методологією LINDDUN [107], що охоплює: зв'язуваність (Linkability), ідентифіковуваність (Identifiability), неспростовність як загрозу приватності (Non-repudiation), виявлюваність

(Detectability), розкриття інформації (Disclosure), необізнаність суб'єкта (Unawareness) і невідповідність вимогам (Non-compliance). Наприклад, постійний ідентифікатор BLE-маяка фітнес-браслета створює загрози зв'язуваності та ідентифіковуваності, навіть якщо вміст повідомлень зашифровано; сам факт випромінювання пристрою в певному місці (виявлюваність) може бути критичним для військовослужбовця. Українські дослідники запропонували розширення STRIDE для офлайн-застосунків аварійного зв'язку на основі BLE mesh-мереж, додавши категорії шкоди стороннім особам і фізичної компрометації, які набувають значення в умовах катастроф [29].

4.2.3 Бази знань про техніки атак

Для узгодженого опису поведінки порушника використовують бази знань, що систематизують тактики й техніки. Матриця MITRE ATT&CK для мобільних пристроїв [206] містить, зокрема, техніки мережевих ефектів — перехоплення незашифрованого трафіку, зниження версії до незахищених протоколів, маніпуляцію з сигналізацією, придушення зв'язку. База MITRE FiGHT [207] розширює цей підхід на мережі 5G, охоплюючи атаки на радіодоступ, ядро, міжоператорські інтерфейси і віртуалізовану інфраструктуру. Для оцінювання мережевого обладнання 3GPP визначило перелік загроз і критичних активів для кожного класу продуктів [51], а ENISA зіставила загрози мереж 5G із заходами, передбаченими специфікаціями 3GPP, показавши, які з них є обов'язковими, а які — опційними [124]. Використання цих баз забезпечує повноту моделі загроз і сумісність з інструментами моніторингу (розділ 15).

4.3 Дерева атак

4.3.1 Структура та обчислення атрибутів

Дерево атак [257] — ієрархічна модель, корінь якої відповідає меті порушника, внутрішні вузли — підцілям, а листя — елементарним діям. Вузли бувають двох типів: «АБО» (для досягнення підцілі достатньо однієї з дочірніх) і «І» (потрібні всі дочірні). Листю приписують атрибути — імовірність успіху, вартість, час, потрібну кваліфікацію, — які поширюються вгору за правилами, що залежать від типу вузла. Для імовірності успіху за незалежності подій:

$$p_{\text{І}} = \prod_{k} p_k, \qquad p_{\text{АБО}} = 1 - \prod_{k} \bigl(1 - p_k\bigr), \tag{4.1}$$

для мінімальної вартості атаки:

$$c_{\text{I}} = \sum_k c_k, \qquad c_{\text{АБО}} = \min_k c_k. \tag{4.2}$$

Огляд розширень — дерев атак і захисту, графів атак, байєсівських мереж — наведено в [193]. Для безпроводових систем особливо корисні дерева атак і захисту, у яких контрзаходи подано як окремі вузли, що зменшують імовірність успіху відповідних листків.

4.3.2 Приклад: перехоплення трафіку корпоративної мережі Wi-Fi

На рис. 4.2 наведено дерево атак для мети G «перехоплення трафіку корпоративної мережі Wi-Fi». Розглянуто три альтернативні шляхи: A1 — атака на спільний пароль (захоплення рукостискання I офлайн-підбір); A2 — точка доступу-двійник (деавтентифікація клієнтів I прийняття клієнтом фальшивого сервера автентифікації); A3 — компрометація легітимної точки доступу (заводський пароль АБО вразливість прошивки).

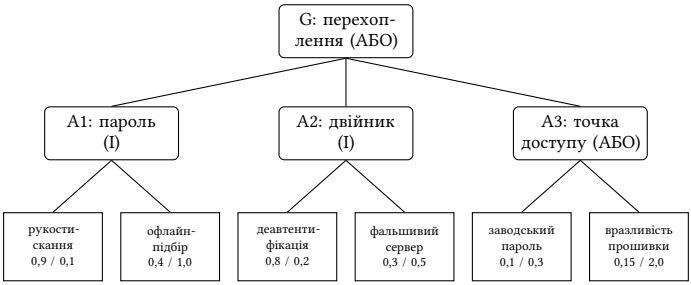


Рис. 4.2 — Дерево атак на корпоративну мережу Wi-Fi (у листі: імовірність успіху / вартість в умовних одиницях)

За (4.1) маємо $p_{A1} = 0{,}9 \cdot 0{,}4 = 0{,}36$, $p_{A2} = 0{,}8 \cdot 0{,}3 = 0{,}24$, $p_{A3} = 1 - 0{,}9 \cdot 0{,}85 = 0{,}235$ і для кореня $p_G = 1 - 0{,}64 \cdot 0{,}76 \cdot 0{,}765 = 0{,}628$. За (4.2) мінімальні вартості: $c_{A1} = 1{,}1$, $c_{A2} = 0{,}7$, $c_{A3} = 0{,}3$, $c_G = 0{,}3$ — найдешевшим шляхом є використання заводського пароля адміністратора точки доступу, хоча він не найімовірніший.

Оцінимо ефект заходів. Перехід на WPA3-Enterprise з EAP-TLS усуває спільний пароль ($p_{A1} = 0$). Примусова перевірка сертифіката сервера автентифікації через профіль конфігурації, що встановлюється системою керування пристроями, знижує імовірність прийняття фальшивого сервера з 0,3 до 0,03, а обов'язковий захист кадрів керування (IEEE 802.11w) робить деавтентифікацію неефективною ($0{,}8 \to 0{,}2$): $p_{A2} = 0{,}006$. Зміна заводських паролів і регулярне оновлення прошивок знижують листя A3 до 0,01 і 0,05: $p_{A3} = 0{,}06$. Тоді $p_G = 1 - 1 \cdot 0{,}994 \cdot 0{,}94 = 0{,}065$ — зменшення майже в

10 разів. Показово, що найбільший внесок у залишкову ймовірність тепер дає А3, тобто пріоритет захисту змістився з радіоінтерфейсу на керування інфраструктурою.

4.4 Кількісне оцінювання ризику

4.4.1 Ризик як математичне сподівання втрат

Базова кількісна модель визначає ризик як математичне сподівання втрат за множиною сценаріїв:

$$R(X) = \sum_{i=1}^{n} p_i(X)\, L_i, \qquad p_i(X) = p_i^0 \prod_{j \in X} \bigl(1 - e_{ij}\bigr), \tag{4.3}$$

де p_i^0 — імовірність (або річна частота) реалізації i-го сценарію без заходів; L_i — втрати за сценарієм; X — множина впроваджених заходів; $e_{ij} \in [0;1]$ — ефективність заходу j щодо сценарію i. Мультиплікативна модель ефективності припускає незалежність дії заходів; для заходів, що перекривають одне одного (наприклад, два механізми виявлення одного типу атак), вона дає завищену оцінку ефекту.

У практиці широко використовують річні показники: очікувані втрати від однієї події SLE $=$ AV $\cdot$ EF (вартість активу на фактор впливу), річна частота подій ARO і очікувані річні втрати ALE $=$ SLE $\cdot$ ARO. Методологія FAIR [144] деталізує ці величини через частоту подій загрози, уразливість (імовірність того, що подія загрози призведе до втрат), первинні та вторинні втрати, а для подання невизначеності використовує розподіли й моделювання методом Монте-Карло [167]. Для оцінювання комплексних збитків від інцидентів, що охоплюють прямі, непрямі та репутаційні втрати, доцільно використовувати методику, запропоновану в [45].

4.4.2 Оцінювання вразливостей: CVSS і EPSS

Технічну серйозність вразливостей оцінюють за системою CVSS v4.0 [138]. Для безпроводових технологій особливо важливою є базова метрика *вектора атаки*: значення «суміжний» (Adjacent) означає, що атака можлива лише з тієї самої фізичної чи логічної мережі, — саме так класифікують більшість вразливостей Wi-Fi і Bluetooth. Це знижує бал порівняно з мережевими вразливостями, але для безпроводового середовища таке зниження може вводити в оману: «суміжність» у радіоканалі досягається з вулиці або з сусіднього поверху (розділ 1), тобто за змістом наближається до віддаленої атаки. Тому в середовищних метриках для безпроводових систем варто коригувати оцінку з урахуванням реальної зони досяжності. Імовірність експлуатації вразливостей у найближчі 30 діб оцінює система EPSS [139];

поєднання CVSS, EPSS і вартості активу дає змогу пріоритизувати усунення вразливостей відповідно до моделі (4.3).

4.4.3 Економічне обґрунтування заходів

Доцільність заходу захисту оцінюють показником **рентабельності інвестицій у безпеку** (ROSI):

$$\mathrm{ROSI}_j = \frac{\Delta\mathrm{ALE}_j - C_j}{C_j}, \qquad \Delta\mathrm{ALE}_j = \mathrm{ALE}(X) - \mathrm{ALE}\big(X \cup \{j\}\big), \tag{4.4}$$

де C_j — річна вартість заходу (з урахуванням амортизації, ліцензій, персоналу). Захід економічно виправданий, якщо $\mathrm{ROSI}_j > 0$. Важливо, що $\Delta\mathrm{ALE}_j$ залежить від уже впроваджених заходів X: заходи мають оцінюватися послідовно, у порядку спадання ROSI, з перерахунком після кожного кроку. Модель Гордона–Лоба [151] показує, що для широкого класу функцій імовірності порушення оптимальні інвестиції в захист певного інформаційного набору не перевищують $1/e \approx 37\,\%$ очікуваних втрат від нього. Ця межа слугує корисним орієнтиром для перевірки адекватності бюджету безпеки.

Суто фінансові показники не охоплюють усіх аспектів. Заходи, обов'язкові за законодавством (розділ 2), впроваджуються незалежно від ROSI; заходи, що забезпечують виявлення атак, мають цінність, яку важко виразити через ΔALE (зменшення невизначеності, можливість реагування); для ризиків, пов'язаних з безпекою людей, застосовують принцип «настільки низько, наскільки це практично досяжно». Тому ROSI є інструментом ранжування, а не остаточного рішення.

4.5 Специфіка ризиків мобільних операторів

4.5.1 Ризики ланцюга постачання

Для оператора мобільного зв'язку одним із найвагоміших є ризик, пов'язаний з постачальниками обладнання і програмного забезпечення. Інструментарій безпеки 5G ЄС [210] пропонує оцінювати *профіль ризику постачальника* за чинниками, що не зводяться до технічних вразливостей: імовірність втручання держави третьої країни (законодавство, що зобов'язує співпрацювати зі спецслужбами; відсутність незалежного судового контролю), корпоративна структура і власність, практика забезпечення безпеки продуктів, спроможність забезпечувати постачання й підтримку в кризових умовах. Формалізацію можна подати зваженим показником $S_v = \sum_k w_k s_{vk}$, де $s_{vk} \in [0;1]$ — оцінка постачальника v за чинником k. Однак такий показник необхідно доповнювати блокувальними умовами (аналогічними (2.3)): наприклад, постачальник, що підпадає під юрис-

дикцію держави-агресора, виключається незалежно від сумарної оцінки. Для зниження ризику концентрації рекомендується диверсифікація: використання різних постачальників для RAN і ядра, для різних регіонів.

4.5.2 Сигнальні та регуляторні ризики

Специфічними для операторів є ризики, пов'язані з сигнальними мережами: несанкціоновані запити місцезнаходження абонентів, перехоплення SMS, шахрайство з тарифікацією через SS7 і Diameter (розділ 9). Ці ризики мають дві особливості: їхні джерела перебувають за межами контролю оператора (в інших мережах), а шкоди зазнають переважно абоненти, а не оператор. Звідси необхідність оцінювати вплив на абонентів як окрему категорію втрат і враховувати регуляторні наслідки — порушення вимог щодо захисту даних про трафік і місцезнаходження [34, 245].

4.5.3 Реєстр ризиків

Результати оцінювання оформлюють у **реєстрі ризиків**, де для кожного ризику зазначають сценарій, активи, джерела загроз, наявні заходи, оцінки імовірності та впливу, рівень ризику, рішення щодо оброблення (зниження, уникнення, передача, прийняття) і власника ризику. Фрагмент реєстру ризиків мобільного оператора наведено в табл. 4.2 (оцінки за шкалою 1–5; рівень — добуток).

Таблиця 4.2 — Фрагмент реєстру ризиків мобільного оператора

Сценарій	Ймов.	Вплив	Рівень	Рішення
Руйнівна кібератака на IT-інфраструктуру з тривалою прихованою присутністю	3	5	15	зниження: сегментація, EDR, ізольовані резервні копії
Запити місцезнаходження абонентів через SS7 з мереж роумінгових партнерів	4	3	12	зниження: сигнальний міжмережевий екран
Фальшиві базові станції GSM у районах масових заходів	3	3	9	зниження: виявлення, поступове вимкнення 2G
Масштабне знеструмлення базових станцій	4	4	16	зниження: резервне живлення, національний роумінг
Закладка в програмному забезпеченні обладнання RAN	2	5	10	уникнення: виключення постачальників високого ризику
Компрометація облікових записів адміністраторів через фішинг	3	4	12	зниження: апаратні ключі FIDO2, PAM

Порядкова шкала з множенням балів проста, але має відомі методологічні вади: добуток порядкових величин не має кількісного змісту, а сценарії з однаковим «рівнем» можуть мати на порядки різні очікувані втрати [167]. Тому для ризиків із найвищими рівнями доцільно переходити до кількісної моделі (4.3) з інтервальними оцінками.

4.6 Ризики мобільних пристроїв в організації

Мобільні пристрої, що використовуються для доступу до ресурсів організації, створюють окрему групу ризиків. NIST SP 800-124 [164] виділяє, зокрема, такі загрози: шкідливі та вразливі застосунки; атаки через мережеві з'єднання (підроблені точки доступу, фальшиві базові станції); фізичні загрози (втрата, крадіжка); вразливості операційної системи і прошивок; зловживання хмарними сервісами синхронізації; загрози ланцюга постачання пристроїв. Особливості ризиків мобільних пристроїв: організація часто не є власником пристрою (модель BYOD) і не може повністю контролювати його конфігурацію; пристрій постійно підключається до недовірених мереж; на ньому співіснують особисті й робочі дані; значна частина атак спрямована на користувача (фішинг через SMS і месенджери).

Моделі оброблення цих ризиків — від повного керування корпоративним пристроєм до контейнеризації робочих даних на особистому пристрої — розглянуто в розділі 11. З погляду оцінювання ризиків важливо, що для BYOD частина заходів принципово недоступна (наприклад, примусове шифрування всього пристрою чи повне стирання), тому залишковий ризик має прийматися явно, з урахуванням категорії даних, до яких надається доступ.

4.7 Невизначеність оцінок і ймовірнісне моделювання

4.7.1 Інтервальні оцінки

Точкові оцінки p_i і L_i у моделі (4.3) створюють ілюзію точності. Експерт, який стверджує, що річна частота атак точкою доступу-двійником дорівнює 4, насправді має на увазі інтервал — наприклад, від 1 до 10 з довірою 90 %. Сучасна практика кількісного оцінювання ризиків [167, 144] вимагає подавати оцінки саме як *каліброві інтервали*, а обчислення виконувати методом Монте-Карло. Для величин, що охоплюють кілька порядків (втрати від інцидентів), природним є лог-нормальний розподіл. Якщо експерт задав 90-відсотковий інтервал $[a; b]$ для втрат, параметри розподілу $\ln L \sim \mathcal{N}(\mu, \sigma^2)$ дорівнюють

$$\mu = \frac{\ln a + \ln b}{2}, \qquad \sigma = \frac{\ln b - \ln a}{2 \cdot 1{,}645}, \qquad \mathrm{E}[L] = e^{\mu + \sigma^2/2}. \tag{4.5}$$

Наприклад, для втрат від компрометації кластера контролерів з інтервалом $[500;\ 8000]$ тис. грн маємо $\mu = \ln 2000 = 7{,}60$, $\sigma = \ln 16/3{,}29 = 0{,}843$ і $\mathrm{E}[L] = 2000 \cdot e^{0{,}355} \approx 2850$ — математичне сподівання суттєво перевищує медіану 2000 через «важкий хвіст» розподілу. Використання медіани замість середнього систематично занижує ризик саме для найруйнівніших сценаріїв.

4.7.2 Криві перевищення втрат

Результатом моделювання методом Монте-Карло є не одне число, а **крива перевищення втрат** $\bar{F}(\ell) = \Pr\{L_\Sigma > \ell\}$ — імовірність того, що сумарні річні втрати перевищать рівень ℓ. На одній діаграмі з кривою перевищення подають *криву толерантності до ризику*, яку задає керівництво (наприклад, «імовірність втрат понад 5 млн грн на рік не повинна перевищувати 5 %»). Ризик прийнятний, якщо крива перевищення всюди лежить нижче кривої толерантності. Такий спосіб подання усуває вади порядкових матриць: він адитивний, інтерпретований і дає змогу порівнювати сценарії з різною природою втрат. Для малих організацій достатньо моделі з кількома десятками сценаріїв і кількома тисячами ітерацій, яку можна реалізувати навіть в електронній таблиці.

4.7.3 Байєсове оновлення оцінок

Частоти атак на безпроводову мережу змінюються з часом, і оцінки необхідно оновлювати за даними моніторингу. Якщо апріорну частоту подій описано гамма-розподілом з параметрами (α, β) (середнє α/β), а за період спостереження тривалістю t зареєстровано k подій, то апостеріорний розподіл також є гамма-розподілом з параметрами $(\alpha + k,\ \beta + t)$. Наприклад, за апріорної оцінки 4 атаки двійником на рік з невизначеністю, що відповідає $(\alpha, \beta) = (2;\ 0{,}5)$, і 1 зареєстрованої атаки за 2 роки спостереження апостеріорне середнє становить $(2 + 1)/(0{,}5 + 2) = 1{,}2$ на рік. Цей механізм пов'язує процес управління ризиками з системою моніторингу (розділ 15): кожна виявлена (або не виявлена за тривалий період) подія коригує модель.

4.8 Ризики безпроводових мереж в умовах воєнного стану

Воєнний стан докорінно змінює модель порушника і структуру ризиків. По-перше, з'являються *кінетичні* загрози інфраструктурі: руйнування базових станцій, вузлів комутації, ліній живлення. По-друге, державний порушник застосовує засоби радіоелектронної боротьби та радіорозвідки в масштабах, недоступних кримінальним групам. По-третє, *сам факт радіовипромінювання* стає загрозою: пеленгація передавача дає змогу визначити місце розташування і спрямувати ураження.

Для оцінювання ризику виявлення передавача засобами радіорозвідки використовують таку модель. Нехай передавач працює сеансами тривалістю τ з інтенсивністю ν сеансів за годину, а система радіорозвідки виявляє сеанс, що потрапив у зону її чутливості, з імовірністю q за сеанс. Тоді за незалежності ймовірність залишитися невиявленим протягом часу T (год)

$$P_{\text{невияв}}(T) = (1-q)^{\nu T} \approx e^{-q\,\nu\,T}. \tag{4.6}$$

За $q = 0{,}05$, $\nu = 6$ год$^{-1}$ і $T = 24$ год маємо $P_{\text{невияв}} \approx e^{-7{,}2} \approx 7 \cdot 10^{-4}$: передавач, що регулярно виходить в ефір, майже гарантовано буде виявлений протягом доби. Зменшення ν (радіодисципліна), зменшення q (знижена потужність, спрямовані антени, розширення спектра, стрибки частоти) і скорочення τ є засобами зниження цього ризику; кожен з них має ціну у пропускній здатності чи оперативності зв'язку. Ця модель застосовна не лише до тактичних радіомереж, а й до мобільних телефонів і пристроїв Інтернету речей, що перебувають у зоні бойових дій.

Інші специфічні ризики воєнного стану: примусове відключення чи перенавантаження мереж на окупованих або деокупованих територіях; спроби підключення абонентів до мереж держави-агресора та перехоплення їхнього трафіку; атаки на абонентів через фальшиві базові станції поблизу лінії зіткнення; компрометація ланцюга постачання обладнання; вербування або примус персоналу операторів. У реєстрі ризиків ці сценарії мають розглядатися з урахуванням критерію впливу на безпеку людей, а заходи — узгоджуватися з вимогами щодо функціонування мереж в умовах воєнного стану [34] і з планами неперервності (розділ 16).

4.9 Кейс: оцінювання ризиків безпроводової мережі університетського кампусу

4.9.1 Опис системи

Університет має кампус із кількох корпусів і гуртожитків, безпроводову мережу на 400 точок доступу під керуванням кластера контролерів, корпоративну мережу для працівників із автентифікацією IEEE 802.1X, мережу для здобувачів освіти та гостей, окрему мережу для систем Інтернету речей (контроль доступу, відеоспостереження) і значну частку особистих пристроїв. Модель порушника охоплює зовнішнього радіопорушника в межах кампусу, зловмисного користувача мережі та кримінальні групи, що поширюють шкідливе програмне забезпечення. Оцінки втрат наведено в тисячах гривень на рік.

4.9.2 Сценарії та початковий ризик

Виділено п'ять сценаріїв:

1. S1 — викрадення облікових даних через точку доступу-двійник через відсутність перевірки сертифіката сервера автентифікації на клієнтах: ARO $= 4$, SLE $= 60$, ALE $= 240$;
2. S2 — компрометація адміністративної мережі зі спільним паролем через офлайн-підбір: ARO $= 0{,}5$, SLE $= 400$, ALE $= 200$;
3. S3 — глушіння або деавтентифікація під час дистанційного тестування і сесій: ARO $= 2$, SLE $= 50$, ALE $= 100$;
4. S4 — поширення шкідливого програмного забезпечення з особистих пристроїв: ARO $= 1$, SLE $= 300$, ALE $= 300$;
5. S5 — компрометація кластера контролерів через вразливості й слабку конфігурацію: ARO $= 0{,}1$, SLE $= 2000$, ALE $= 200$.

Сумарні очікувані річні втрати $\mathrm{ALE}_0 = 1040$.

4.9.3 Вибір заходів

Розглядаються чотири заходи: C1 — EAP-TLS для працівників, примусова перевірка сертифіката через профілі конфігурації та відмова від спільних паролів в адміністративних мережах ($C = 120$; S1: $e = 0{,}9$; S2: $e = 0{,}8$); C2 — безпроводова система запобігання вторгненням разом з обов'язковим захистом кадрів керування ($C = 150$; S1: $e = 0{,}5$; S3: $e = 0{,}4$); C3 — сегментація мереж для особистих пристроїв і контроль доступу до мережі з перевіркою стану ($C = 180$; S4: $e = 0{,}7$; S5: $e = 0{,}3$); C4 — керування вразливостями та безпечна конфігурація контролерів ($C = 60$; S5: $e = 0{,}6$). Результати послідовного розрахунку за (4.3) і (4.4) наведено в табл. 4.3.

Таблиця 4.3 — Послідовне обґрунтування заходів для мережі кампусу

Крок	C_j	$\Delta\mathrm{ALE}_j$	ROSI	ALE після	Рішення
C1	120	376	2,13	664	впровадити
C3	180	270	0,50	394	впровадити
C4	60	84	0,40	310	впровадити
C2	150	52	−0,65	258	див. текст

Після C1 ризик сценарію S1 знижується до 24, S2 — до 40. Захід C3 знижує S4 з 300 до 90 і S5 з 200 до 140. Захід C4, оцінений *після* C3, знижує S5 з 140 до 56; якби його оцінювали першим, ΔALE становило б 120, що ілюструє залежність ефекту від порядку впровадження. Захід C2 має від'ємне ROSI: знижуючи S1 з 24 до 12 і S3 зі 100 до 60, він дає лише 52 одиниці зменшення втрат за вартості 150.

Сумарна вартість ризику (очікувані втрати плюс витрати на заходи) для C1+C3+C4 становить $310 + 360 = 670$ проти 1040 без заходів; додавання C2 збільшує її до $258 + 510 = 768$. Бюджет на заходи C1, C3, C4 (360) узгоджується з орієнтиром Гордона–Лоба ($0{,}37 \cdot 1040 \approx 385$). Водночас рішення щодо

С2 не може ухвалюватися лише за ROSI: безпроводова система запобігання вторгненням забезпечує виявлення атак, яких модель не враховує (нові типи атак, підроблені точки доступу в мережі Інтернету речей), дає дані для розслідування інцидентів і для виконання вимог щодо моніторингу. Раціональним компромісом може бути поетапне впровадження — спочатку захист кадрів керування (дешевий, вбудований у сучасні точки доступу), потім функції виявлення на базі наявних точок доступу без окремих сенсорів. Підходи до ризик-орієнтованого виявлення кібератак у безпроводових мережах з урахуванням стійкості моделей машинного навчання розглянуто в [27], а метод комплексного оцінювання ризиків для розподілених систем — у [26].

Висновки до розділу

Управління ризиками безпроводових і мобільних мереж ґрунтується на загальних стандартах (ISO/IEC 27005, ISO 31000, NIST SP 800-30), проте потребує врахування специфічних активів — радіочастотного ресурсу, ключового матеріалу, ідентифікаторів і даних про місцезнаходження, сигнальних зв'язків — і функціонального, а не фізичного визначення меж системи. Моделювання загроз доцільно здійснювати поєднанням методологій: STRIDE для безпекових властивостей, LINDDUN для приватності, дерев атак для кількісного аналізу шляхів досягнення мети порушника і баз знань MITRE ATT&CK і FiGHT для узгодженого опису технік. Приклад дерева атак на корпоративну мережу Wi-Fi показав, що впровадження EAP-TLS, перевірки сертифікатів і захисту кадрів керування знижує ймовірність досягнення мети майже в 10 разів, а найдешевшим шляхом атаки може бути не радіоінтерфейс, а слабке керування інфраструктурою. Кількісна модель ризику з мультиплікативною ефективністю заходів і показник ROSI дають змогу ранжувати заходи, але ефект кожного заходу залежить від уже впроваджених, а обов'язкові й детективні заходи потребують нефінансового обґрунтування. Для мобільних операторів ключовими є ризики ланцюга постачання, які оцінюються профілем ризику постачальника з блокувальними умовами, і сигнальні ризики, шкоди від яких зазнають абоненти. Порядкові матриці ризиків є зручним інструментом комунікації, але для найвагоміших ризиків необхідно переходити до кількісних моделей із явним поданням невизначеності.

Питання для самоперевірки

1. Опишіть етапи процесу управління ризиками за ISO/IEC 27005. Чим відрізняється підхід NIST SP 800-30?

2. Чому межі безпроводової системи доцільно визначати функціонально, а не фізично? Наведіть приклад.
3. Перелічіть специфічні активи безпроводових і мобільних мереж і для кожного наведіть загрозу, що не залежить від захищеності протоколів.
4. Побудуйте діаграму потоків даних для мережі Wi-Fi малого офісу і виконайте аналіз за STRIDE для радіоканалу між клієнтом і точкою доступу.
5. Які категорії загроз охоплює LINDDUN? Проаналізуйте за нею фітнес-браслет із BLE, що синхронізується зі смартфоном.
6. Для чого використовують бази MITRE ATT&CK Mobile і FiGHT? Наведіть по дві техніки з кожної, що стосуються радіоінтерфейсу.
7. Обчисліть для дерева атак рис. 4.2 імовірність і мінімальну вартість досягнення мети, якщо впроваджено лише WPA3-Personal (SAE), а решта листків не змінилася.
8. Чому мультиплікативна модель ефективності заходів (4.3) може завищувати ефект? Запропонуйте модель для двох заходів, що перекриваються.
9. Чому вектор атаки «суміжний» у CVSS може вводити в оману для безпроводових вразливостей? Як це врахувати в середовищних метриках?
10. Обчисліть ROSI заходу вартістю 200 тис. грн на рік, що знижує частоту інцидентів із SLE 500 тис. грн з 0,8 до 0,2 на рік.
11. Поясніть результат Гордона–Лоба і його практичне значення для обґрунтування бюджету безпеки.
12. Які чинники враховує профіль ризику постачальника в інструментарії безпеки 5G? Чому зважений показник потребує блокувальних умов?
13. Чим ризики мобільних пристроїв у моделі BYOD відрізняються від ризиків корпоративних пристроїв? Які заходи в BYOD принципово недоступні?
14. Дослідницьке: розробіть дерево атак і захисту для мети «визначення місцезнаходження абонента мобільної мережі» з урахуванням радіо- і сигнальних шляхів та оцініть ефект заборони 2G і сигнального міжмережевого екрана.
15. Дослідницьке: запропонуйте метод агрегування порядкових оцінок ризику, вільний від вад простого добутку балів, і порівняйте його результати з кількісною моделлю (4.3) на прикладі кейсу підрозділу 4.9.

РОЗДІЛ 5

Безпека фізичного рівня: секретність каналу, протидія радіоелектронному подавленню та автентифікація передавачів

Класична інженерія безпеки розглядає фізичний рівень як «трубу», що переносить біти, а всі властивості безпеки покладає на криптографію вищих рівнів. Для безпроводових систем такий підхід недостатній з трьох причин. По-перше, криптографія не захищає доступність: заглушений канал не передає ані зашифрованих, ані відкритих даних. По-друге, криптографія не захищає фізичні величини — відстань, місцезнаходження, час, — на яких ґрунтуються системи безключового доступу, навігація і синхронізація. По-третє, фізичний рівень містить ресурси, недоступні криптографії: випадковість радіоканалу, просторову вибірковість антенних решіток, унікальні недосконалості передавачів. Розділ систематизує методи безпеки фізичного рівня відповідно до структури галузі знань «Безпека фізичного рівня і телекомунікацій» зведення CyBOK[1] [292]: конфіденційність і генерування ключів, протидію глушінню, прихованість зв'язку, ідентифікацію передавачів за фізичними ознаками, безпечне вимірювання відстані й позиціювання. Математичні основи, на які спирається виклад, наведено в розділі 3.

5.1 Місце безпеки фізичного рівня в системі захисту

5.1.1 Цілі та обмеження

Методи безпеки фізичного рівня переслідують ті самі цілі, що й інші засоби захисту, — конфіденційність, цілісність, автентичність, доступність, — але досягають їх, використовуючи властивості середовища поширення і апаратури. Відповідність цілей і методів наведено в табл. 5.1.

[1]Матеріал розділу частково ґрунтується на CyBOK © Crown Copyright, The National Cyber Security Centre 2021, ліцензія Open Government Licence v3.0 (http://www.nationalarchives.gov.uk/doc/open-government-licence/). Виклад є авторським, з доповненнями й поглибленнями.

Таблиця 5.1 — Цілі та методи безпеки фізичного рівня

Ціль	Методи	Ключове припущення
Конфіденційність	кодування для каналу з перехопленням, формування діаграми спрямованості, штучний шум	перевага каналу легітимного приймача
Узгодження ключів	генерування ключів із характеристик каналу	взаємність каналу, декореляція з каналом порушника
Доступність	розширення спектра, стрибки частоти, неокординоване розширення, адаптивні антени	невідомість псевдовипадкової послідовності порушникові
Прихованість	передавання з низькою ймовірністю виявлення (LPD)	шум маскує сигнал
Автентичність пристрою	ідентифікація за радіочастотним відбитком	неможливість точно відтворити аналоговий тракт
Безпека відстані й місця	протоколи обмеження відстані, верифікована мультилатерація	скінченна швидкість поширення сигналу

Спільна риса методів — залежність від *фізичних припущень*, а не від обчислювальної складності. Це дає переваги (стійкість до квантових обчислень, відсутність потреби в попередньо розподілених ключах, мала обчислювальна вартість), але й обмеження: припущення можуть порушуватися порушником з кращим обладнанням (спрямовані антени, решітки приймачів), у статичному середовищі, за наявності прямої видимості. Тому в практичних системах методи фізичного рівня застосовують як *доповнення* до криптографії або як єдиний засіб там, де криптографія принципово безсила (доступність, вимірювання відстані).

5.1.2 Модель порушника фізичного рівня

Модель порушника (1.5) для фізичного рівня уточнюють такими параметрами: кількість і розташування приймальних і передавальних антен; максимальна потужність випромінювання та ширина смуги; час реакції (для реактивного глушіння і ретрансляції); знання про канали легітимних сторін. Порушник, що має решітку з великої кількості антен, розташованих поблизу легітимних пристроїв, здатен порушити більшість припущень методів конфіденційності фізичного рівня. Порушник з обмеженою потужністю не може подолати запас стійкості системи з розширенням спектра. Порушник, що не може передавати сигнал швидше за світло, не може змен-

шити виміряну відстань у протоколі обмеження відстані — це єдине фізичне обмеження, яке порушник не може обійти принципово.

5.2 Конфіденційність на фізичному рівні

5.2.1 Формування діаграми спрямованості

Відповідно до (3.1) секретна пропускна здатність визначається різницею якості каналів Боба і Єви. Передавач з N_t антенами може сформувати діаграму спрямованості в напрямку Боба, підвищуючи γ_B у N_t разів (виграш решітки) без збільшення потужності в інших напрямках. Якщо канал Єви відомий (наприклад, Єва — легітимний, але недовірений абонент), передавач може спрямувати нуль діаграми в її бік. Якщо канал Єви невідомий — доцільно використовувати штучний шум.

5.2.2 Штучний шум

Метод штучного шуму [146] полягає в тому, що передавач витрачає частку φ потужності P на корисний сигнал, спрямований уздовж вектора каналу Боба $\mathbf{h}$, а решту $(1-\varphi)P$ — на шум у підпросторі, ортогональному до $\mathbf{h}$. Боб шуму не отримує (його канал ортогональний шуму), тоді як Єва з каналом $\mathbf{g}$ отримує і сигнал, і шум. Для рівномірного розподілу шуму в (N_t-1)-вимірному підпросторі

$$\gamma_B = \frac{\varphi P\,\|\mathbf{h}\|^2}{\sigma_B^2}, \qquad \gamma_E = \frac{\varphi P\,|g_1|^2}{\dfrac{(1-\varphi)P}{N_t-1}\,\|\mathbf{g}_2\|^2 + \sigma_E^2}, \tag{5.1}$$

де g_1 — проєкція каналу Єви на напрям $\mathbf{h}/\|\mathbf{h}\|$; $\mathbf{g}_2$ — проєкція на ортогональний підпростір. Нехай $N_t = 4$, $P/\sigma^2 = 20$ дБ, $\|\mathbf{h}\|^2 = 4$ (виграш решітки), $|g_1|^2 = 1$, $\|\mathbf{g}_2\|^2 = 3$. Без штучного шуму ($\varphi = 1$) $\gamma_B = 400$, $\gamma_E = 100$ і $C_s = \log_2 401 - \log_2 101 = 1{,}99$ біт/с/Гц. За $\varphi = 0{,}5$ маємо $\gamma_B = 200$, а $\gamma_E = 50/(50+1) = 0{,}98$, звідки $C_s = \log_2 201 - \log_2 1{,}98 = 6{,}67$ біт/с/Гц — більш ніж утричі більше, попри вдвічі меншу потужність корисного сигналу. Ціна методу — потреба в точній оцінці каналу Боба (помилки оцінки призводять до «витоку» шуму до Боба) і в кількох антенах; порушник з кількома рознесеними антенами може частково компенсувати шум.

Розвитком ідеї є **кооперативне глушіння**: сторонні дружні вузли створюють шум, який Боб, знаючи його структуру або завдяки просторовому рознесенню, може компенсувати, а Єва — ні. Цей підхід розглядається для захисту зв'язку в мережах Інтернету речей і тактичних мережах, де окремі вузли мають обмежені можливості.

5.2.3 Практичне значення

Незважаючи на розвинену теорію, методи конфіденційності фізичного рівня поки що мало використовуються в масових стандартах. Причини: необхідність знати стан каналу Єви або принаймні його статистику; неможливість гарантувати секретність проти порушника з кращим обладнанням; складність сертифікації властивостей, що залежать від середовища. Найбільш перспективним вважається їх застосування в системах із великими антенними решітками (масивні MIMO в 5G і 6G), де виграш решітки і вузькі промені природно обмежують зону приймання, а також як додатковий шар захисту для пристроїв, неспроможних виконувати складну криптографію.

5.3 Генерування ключів із характеристик каналу

5.3.1 Принцип і етапи

Генерування ключів із каналу ґрунтується на трьох властивостях: *взаємності* (канал Аліса→Боб і Боб→Аліса однаковий у межах часу когерентності, якщо використовується та сама частота), *часовій мінливості* (канал змінюється через рух і зміни середовища, що дає свіжу випадковість) і *просторовій декореляції* (канал до пристрою, віддаленого на відстань понад половину довжини хвилі, статистично слабко пов'язаний з каналом Аліса–Боб). Теоретичні основи узгодження ключа через відкрите обговорення закладено в працях Маурера [203]; межу швидкості дає (3.3). Практичний процес складається з чотирьох етапів (рис. 5.1).

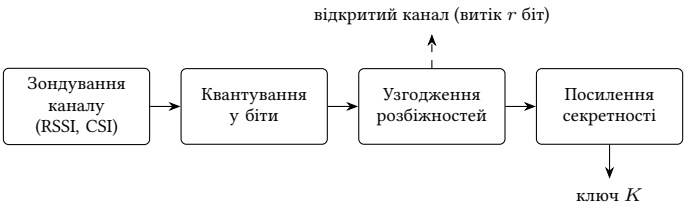


Рис. 5.1 — Етапи генерування секретного ключа з характеристик безпроводового каналу

Зондування: сторони почергово передають пробні сигнали і вимірюють параметри каналу — потужність прийнятого сигналу (RSSI) або детальну інформацію про стан каналу (CSI) по підносійних OFDM. *Квантування*: вимірювання перетворюють на біти, наприклад, порівнянням з порогами, що відсікають значення поблизу медіани (зменшує частку розбіжностей). *Узгодження*: сторони виправляють розбіжні біти протоколом виправлення помилок через відкритий канал (наприклад, передаючи синдроми коду), що

розкриває порушникові r біт інформації. *Посилення секретності*: до узгодженої послідовності застосовують універсальну геш-функцію, що стискає її до довжини, про яку порушник не має практично жодної інформації.

5.3.2 Оцінка довжини ключа

Якщо після квантування сторони мають n біт, мін-ентропія яких щодо спостережень Єви дорівнює $H_\infty(X^n \mid Z^n)$, то за лемою про залишкове гешування довжина секретного ключа з параметром статистичної відстані ε від рівномірного розподілу становить

$$\ell \le H_\infty\big(X^n \mid Z^n\big) - r - 2\log_2 \frac{1}{\varepsilon}. \tag{5.2}$$

Наприклад, для $n = 512$ біт з ентропією 0,6 біт на біт відносно Єви ($H_\infty \approx 307$), витоку при узгодженні $r = 100$ біт і $\varepsilon = 2^{-40}$ маємо $\ell \le 307 - 100 - 80 = 127$ біт. Отже, для отримання 128-бітового ключа потрібно близько 520 вимірювань, що за частоти зондування 50 Гц займає понад 10 с. Експериментальні дослідження [201, 186] показали, що в статичному середовищі ентропія каналу дуже мала і швидкість генерування падає до часток біта за секунду, тоді як у мобільних сценаріях вона сягає одиниць–десятків біт за секунду. Використання CSI за багатьма підносійними і багатьма антенами суттєво підвищує швидкість.

5.3.3 Атаки на генерування ключів

Основні атаки: *передбачуваність каналу* — у статичному середовищі або за прямої видимості порушник може змоделювати канал за геометрією; *активне втручання* — порушник рухає об’єкти, створює контрольовані завади або змінює власне положення так, щоб канал став передбачуваним (у [186] продемонстровано атаку, що робить значну частку бітів передбачуваною); *атака «людина посередині»* — канал сам собою не автентифікує сторін, тому узгодження ключа має поєднуватися з автентифікацією повідомлень протоколу; *близькість порушника* — на відстані менше половини довжини хвилі (6 см для 2,4 ГГц) кореляція каналів висока. Тому генерування ключів з каналу розглядають як механізм для ситуацій, коли попередньо розподілені ключі відсутні, або як спосіб періодичного оновлення ключів для додаткової стійкості. Застосування підходу в модулях безпеки пристроїв Інтернету речей обговорюється в розділі 12.

5.4 Протидія глушінню

5.4.1 Розширення спектра з попередньо розподіленим секретом

Класичні методи протидії глушінню — пряме розширення спектра і стрибки частоти [265] — забезпечують виграш від обробки (3.8) за умови, що по-

рушник не знає псевдовипадкової послідовності. Якщо послідовність відома (наприклад, визначена відкритим стандартом, як у GPS L1 C/A або в Bluetooth, де послідовність стрибків залежить від публічної адреси ведучого пристрою), слідкувальний постановник завад може концентрувати потужність у поточному каналі, і виграш від обробки нівелюється. Тому для систем, яким потрібна стійкість до цілеспрямованого глушіння, послідовність має генеруватися криптографічно з секретного ключа, як у військових радіостанціях і в захищених сервісах супутникової навігації.

5.4.2 Проблема «курки і яйця» та некоординоване розширення

Виникає замкнене коло: для стійкого до глушіння зв'язку потрібен спільний секрет, а для встановлення спільного секрету потрібен зв'язок, стійкий до глушіння. Якщо секрет попередньо розподілено між багатьма пристроями (наприклад, усіма приймачами широкомовної системи), компрометація одного пристрою розкриває послідовність для всіх. Для розв'язання цієї проблеми запропоновано **некоординовані** методи. У некоординованих стрибках частоти (UFH) [274] передавач і приймач незалежно й випадково обирають канали; повідомлення, розбите на фрагменти, передаються багаторазово, і частина фрагментів доходить, коли канали випадково збігаються; фрагменти пов'язані між собою і автентифіковані так, щоб порушник не міг вставити фальшиві. Некоординоване розширення спектра (UDSSS) [237] використовує набір відкритих кодів розширення, з якого передавач випадково обирає код для кожного повідомлення, а приймач перебирає коди після приймання. Порушник не знає, який код буде обрано, і не може ефективно глушити, доки не отримає повідомлення повністю, а тоді вже пізно. Ціна — суттєве зниження пропускної здатності та збільшення обчислень у приймачі, проте методи дають змогу встановити спільний ключ, після чого можна переходити до ефективного координованого розширення.

5.4.3 Просторові методи: адаптивні антенні решітки

Антенна решітка з M елементів може сформувати діаграму спрямованості з $M - 1$ нулем, спрямованими на джерела завад, зберігаючи приймання корисного сигналу з іншого напрямку. Глибина нулів у реальних системах становить 20–40 дБ. Для навігаційних приймачів застосовують антенні решітки з керованою діаграмою (CRPA): семиелементна решітка здатна одночасно придушувати до шести постановників завад, що перебувають у різних напрямках. Обмеження — розміри, вартість і те, що постановник завад, розташований у тому самому напрямку, що й джерело сигналу (для супутникової навігації — на висоті), не може бути придушений просторово.

5.4.4 Порівняння методів

Узагальнюючи, методи протидії глушінню доцільно поєднувати: розширення спектра з криптографічною послідовністю забезпечує виграш від обробки проти широкосмугових і слідкувальних постановників; адаптивні решітки — просторову вибірковість; адаптивна зміна частоти і кодування — підлаштування під поточну завадову обстановку; моніторинг ефіру — виявлення і локалізацію джерел завад для їх нейтралізації (розділ 15). Експериментальні дослідження стійкості маяків BLE і мереж ZigBee до різних типів глушіння [267, 268] показують, що для масових технологій ближньої дії, які не мають механізмів розширення спектра з секретною послідовністю, єдиними практичними засобами є виявлення атаки і резервування каналів.

5.5 Прихованість зв'язку

Для деяких застосувань важливо приховати не лише вміст, а й *сам факт* передавання: визначення, що передавач активний, дає порушникові інформацію про присутність і місце вузла (розділ 4). Системи з **низькою ймовірністю виявлення** (LPD) і **низькою ймовірністю перехоплення** (LPI) досягають цього, розподіляючи сигнал у широкій смузі з потужністю, нижчою за рівень шуму. Фундаментальний результат Баша, Гекеля і Таузлі [78] — *закон квадратного кореня*: у гауссовому каналі за n використань каналу можна надійно і приховано передати лише $O(\sqrt{n})$ біт, тобто швидкість прихованого передавання прямує до нуля:

$$K(n) = O\big(\sqrt{n}\big), \qquad \lim_{n\to\infty} \frac{K(n)}{n} = 0. \tag{5.3}$$

Інтуїтивно: щоб детектор енергії Єви не відрізнив присутність сигналу від шуму, сумарна енергія сигналу має зростати не швидше за стандартне відхилення енергії шуму, яке пропорційне $\sqrt{n}$. Закон має практичне значення для оцінювання ризиків радіовипромінювання: будь-який корисний обсяг даних за достатньо тривалий час стає виявлюваним, тому прихованість досягається обмеженням часу і обсягу передавань, а не лише зниженням потужності. Якщо Єва має невизначеність щодо рівня власного шуму або час передавання їй невідомий, прихована швидкість може бути ненульовою, що використовується в практичних схемах.

5.6 Ідентифікація передавачів за фізичними ознаками

5.6.1 Джерела відбитка

Кожен радіопередавач, навіть серійного виробництва, має унікальні недосконалості аналогового тракту: відхилення частоти опорного генератора,

дисбаланс синфазної та квадратурної складових, нелінійність підсилювача потужності, особливості перехідних процесів при вмиканні. Ці недосконалості утворюють **радіочастотний відбиток**, який дає змогу ідентифікувати пристрій незалежно від заявлених у кадрах ідентифікаторів [105]. Основні класи ознак наведено в табл. 5.2.

Таблиця 5.2 — Класи ознак радіочастотного відбитка передавача

Клас ознак	Приклади	Стійкість до підробки
Перехідні процеси	форма огинальної при вмиканні передавача, тривалість наростання	висока; потребує точного відтворення аналогової форми
Модуляційні	зсув частоти, помилка фази, дисбаланс I/Q, похибка вектора модуляції	середня; відтворюється генератором довільних сигналів
Спектральні	форма спектра, побічні випромінювання, нелінійні спотворення	середня
Позиційні та канальні	профіль каналу, кут приходу, затримка	залежить від розташування; змінюються з рухом

Показовим є результат Брика та співавторів [90]: за модуляційними ознаками вдалося розрізнити понад сотню однотипних мережевих карт IEEE 802.11 з точністю понад 99 %. Сучасні дослідження застосовують глибинне навчання безпосередньо до вибірок сигналу. Українські дослідники запропонували гібридний метод виявлення та атрибуції несанкціонованих точок доступу IEEE 802.11, що поєднує радіочастотні відбитки передавачів з поведінковим аналізом службових та інформаційних кадрів [33].

5.6.2 Метрики та обмеження

Якість ідентифікації характеризують імовірностями хибного прийняття (FAR) і хибного відхилення (FRR) як функціями порогу рішення; точку, де вони рівні, називають рівнем рівних помилок (EER). Для застосувань у безпеці важливо розрізняти *ідентифікацію* (визначення, який із відомих пристроїв передає) і *верифікацію* (перевірку заявленої ідентичності); друга задача простіша і має кращі показники.

Обмеження методу: відбиток залежить від температури, напруги живлення, старіння компонентів і від каналу, тому потребує періодичного оновлення еталонів; порушник з високоякісним генератором довільних сигналів може відтворити модуляційні ознаки іншого пристрою [105]; збирання еталонів вимагає контрольованих умов. Тому радіочастотний відбиток

доцільно використовувати як *додатковий фактор* автентифікації і як засіб виявлення аномалій — наприклад, для виявлення точки доступу-двійника, яка використовує правильні MAC-адресу й SSID, але інший передавач. З погляду приватності той самий механізм дає змогу відстежувати пристрої попри рандомізацію адрес (розділ 3).

5.7 Безпечне вимірювання відстані й позиціювання

5.7.1 Атаки ретрансляції

Багато систем ухвалюють рішення про доступ на підставі *близькості*: системи безключового доступу й запуску автомобілів, безконтактні платіжні картки, смарт-замки, які відмикаються за наближення смартфона. Якщо близькість визначають за самим фактом успішного обміну повідомленнями або за потужністю сигналу, порушник може здійснити **атаку ретрансляції**: один пристрій порушника розташовується біля ключа, другий — біля автомобіля, і вони ретранслюють сигнали, створюючи ілюзію близькості. Францільйон, Данев і Чапкун [142] продемонстрували такі атаки на системи десяти моделей автомобілів восьми виробників, у тому числі через ретрансляцію без демодуляції з мінімальною затримкою. Криптографічна автентифікація не допомагає: порушник не змінює повідомлень, лише переносить їх.

5.7.2 Протоколи обмеження відстані

Єдиний принциповий захист від ретрансляції — вимірювання часу поширення сигналу. Оскільки сигнал не може поширюватися швидше за світло, виміряний час обходу Δt дає верхню межу відстані:

$$d \le \frac{c\,(\Delta t - t_p)}{2}, \tag{5.4}$$

де c — швидкість світла; t_p — час обробки у довіреному пристрої. Похибка вимірювання часу 1 нс відповідає 15 см відстані, тому протоколи потребують широкосмугових сигналів (надширокосмугова технологія UWB) і обробки з наносекундною точністю. Протокол обмеження відстані Брендса–Чаума [89] складається з фази обміну зобов'язаннями, фази швидкого обміну бітами (верифікатор надсилає випадковий біт-виклик, довіритель миттєво відповідає бітом, що залежить від виклику і секрету; верифікатор вимірює час кожного раунду) і фази перевірки підписом. Часову діаграму наведено на рис. 5.2.

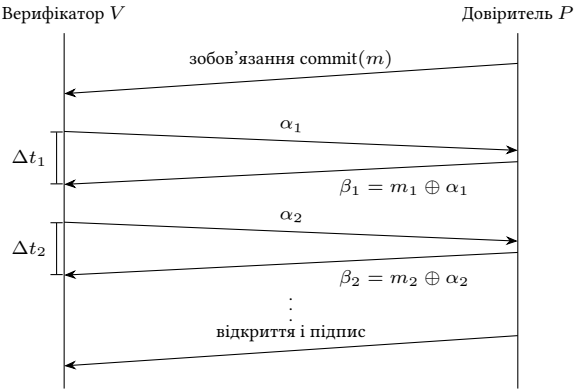


Рис. 5.2 — Фаза швидкого обміну бітами протоколу обмеження відстані (за [89])

5.7.3 Класи атак на протоколи обмеження відстані

Розрізняють три класичні атаки. *Шахрайство з відстанню* — нечесний довіритель, що перебуває далеко, намагається видати себе за близького (наприклад, відповідаючи до надходження виклику). *Мафіозне шахрайство* — зовнішній порушник намагається переконати верифікатора в близькості чесного, але віддаленого довірителя (ретрансляція з вгадуванням відповідей). *Терористичне шахрайство* — віддалений нечесний довіритель співпрацює з порушником поблизу, не розкриваючи йому свого довготривалого секрету. Для мафіозного шахрайства ймовірність успіху стратегії вгадування за n раундів становить $(1/2)^n$ для протоколу Брендса–Чаума і $(3/4)^n$ для протоколів із попередньою побудовою двох відповідей (за стратегії попереднього запиту). Для $n = 32$ маємо відповідно $2{,}3 \cdot 10^{-10}$ і $1{,}0 \cdot 10^{-4}$.

Окрім логічних атак, реальні реалізації вразливі до атак фізичного рівня: *раннє виявлення* (порушник визначає біт за першою частиною символу) і *пізнє зобов'язання* (порушник надсилає початок символу невизначеним і «доводить» його пізніше). Стандарт IEEE 802.15.4z [174] для UWB запровадив захищену часову мітку на основі криптографічно згенерованої послідовності, що протидіє таким атакам; на цьому механізмі ґрунтуються цифрові ключі автомобілів і точний пошук пристроїв у смартфонах. Специфікація Bluetooth версії 6.0 [86] запровадила функцію «зондування каналу» (Channel Sounding) для оцінювання відстані з вбудованими механізмами протидії атакам ретрансляції.

5.7.4 Безпечне позиціювання

Задача безпечного позиціювання — перевірити заявлене місцезнаходження пристрою або визначити його так, щоб порушник не міг сфальсифі-

кувати результат. Метод **верифікованої мультилатерації** [293] використовує кілька верифікаторів із протоколами обмеження відстані. Ключова властивість: порушник може лише *збільшити* виміряні відстані (затримавши відповідь), але не зменшити. Звідси випливає, що позицію всередині трикутника, утвореного трьома верифікаторами, неможливо сфальсифікувати: щоб «переміститися» всередині трикутника, порушник мав би зменшити хоча б одну з відстаней. Метод застосовний для перевірки положення вузлів у сенсорних мережах, для безпеки систем локального позиціювання та як концептуальна основа захисту супутникової навігації (розділ 14).

5.8 Побічні випромінювання та атаки на сенсори

5.8.1 Побічні електромагнітні випромінювання і наводки

Окрім навмисного радіовипромінювання, будь-який електронний пристрій створює **побічні електромагнітні випромінювання і наводки** (ПЕМВН) — ненавмисні сигнали, модульовані оброблюваною інформацією: випромінювання відеоінтерфейсів, клавіатур, ліній живлення, тактових генераторів. Класична проблема технічного захисту інформації (у зарубіжній літературі — TEMPEST) для безпроводових систем має два нові аспекти. По-перше, безпроводові пристрої містять чутливі приймачі й антени, які можуть бути використані як канал витоку інформації: мікроконтролер у пристрої Інтернету речей може модулювати випромінювання ненавмисним чином, і сигнал, що містить ключовий матеріал, поширюватиметься через антену радіомодуля. По-друге, програмно визначені радіоприймачі зробили засоби перехоплення ПЕМВН доступними широкому колу осіб [66].

В Україні вимоги щодо захисту від витоку інформації технічними каналами, зокрема через ПЕМВН, встановлюються нормативними документами системи технічного захисту інформації, а для об'єктів, де обробляється інформація з обмеженим доступом, — визначаються в межах створення комплексної системи захисту інформації [25]. Для безпроводових сегментів таких об'єктів ПЕМВН і навмисне радіовипромінювання розглядаються спільно: зона, у якій можливий перехоплення, має бути оцінена з урахуванням енергетичного бюджету (1.3), а засоби захисту включають екранування, просторове зашумлення, використання обладнання з підтвердженою відповідністю вимогам щодо ПЕМВН і організаційне обмеження використання безпроводових пристроїв у виділених приміщеннях.

5.8.2 Атаки впровадження сигналів у сенсори

Окремий клас становлять атаки, у яких порушник випромінює сигнал, що впливає на *сенсор*, а не на приймач зв'язку: акустичні сигнали, що резонують з МЕМС-гіроскопами і акселерометрами; електромагнітні наводки на проводи мікрофонів, що дають змогу «вводити» голосові команди в голо-

сових помічників; підміна сигналів систем радіолокації, лідарів, датчиків відстані в автомобілях. Спільна причина вразливості — сенсор довіряє фізичній величині, яку він вимірює, і не має механізму перевірки її автентичності. Методи протидії подібні до методів безпечного вимірювання відстані: рандомізація параметрів зондувального сигналу (порушник не може передбачити, який сигнал очікує сенсор), перевірка узгодженості показань кількох незалежних сенсорів, фізичне екранування і фільтрація поза робочим діапазоном. Для мобільних пристроїв, що містять десятки сенсорів, ці атаки відкривають шлях до обходу механізмів безпеки, які покладаються на показання сенсорів (визначення присутності користувача, розблокування за близькістю).

5.9 Безпека фізичного рівня в сучасних стандартах

Результати досліджень поступово входять до масових стандартів. У мережах 5G масивні антенні решітки базових станцій і вузькі промені зменшують зону, де сигнал конкретного абонента може бути прийнятий із достатньою якістю, що пасивно покращує конфіденційність; для 6G розглядаються інтелектуальні відбивальні поверхні, які можуть динамічно формувати середовище поширення так, щоб послаблювати сигнал у напрямках потенційних перехоплювачів. У локальних мережах IEEE 802.11 запроваджено захищене вимірювання відстані (механізми поправки 802.11az), що дає змогу визначати положення клієнта з автентифікацією вимірювальних кадрів і захистом від їх підробки; водночас розвиток технології безпроводового зондування середовища (Wi-Fi sensing) створює нові ризики приватності, оскільки зміни каналу можуть розкривати присутність і рухи людей у приміщенні. Технологія UWB відповідно до IEEE 802.15.4z [174] і функція зондування каналу в Bluetooth 6.0 [86] забезпечують захищене вимірювання відстані для цифрових ключів і пошуку пристроїв. У супутниковій навігації запроваджується автентифікація навігаційних повідомлень (розділ 14).

Спільна тенденція: механізми фізичного рівня стандартизуються не як самостійні засоби «секретності», а як *сервіси*, що надають вищим рівням перевірену фізичну інформацію — автентифіковану відстань, підтверджене місцезнаходження, ідентифікатор передавача. Така інтеграція дає змогу будувати політики доступу, що враховують фізичний контекст (наприклад, дозвіл операції лише за підтвердженої присутності пристрою в межах приміщення), і є природним розвитком принципу нульової довіри для безпроводового середовища.

5.10 Кейс: захист каналу керування малого безпілотного літального апарата

Розглянемо канал керування малим БпЛА в діапазоні 2,4 ГГц: наземна станція потужністю 20 дБм на відстані 3 км від апарата, стрибки частоти по 80 каналах шириною 1 МГц, мінімальне відношення сигнал/(шум+завада) для приймання — 6 дБ. Постановник завад потужністю 40 дБм (10 Вт) розташований на землі на відстані 1 км від апарата; поширення в умовах прямої видимості ($n = 2$).

Крок 1. Відношення завада/сигнал. За (3.7) з однаковими антенами $J/S = (40 - 20) + 20\lg 3 = 29{,}5$ дБ.

Крок 2. Ефект стрибків частоти. Проти загороджувальної завади, що рівномірно покриває всю смугу 80 МГц, стрибки частоти дають виграш $10\lg 80 = 19$ дБ (у кожному каналі — лише $1/80$ потужності завади). Ефективне $J/S = 29{,}5 - 19 = 10{,}5$ дБ, тобто $S/J = -10{,}5$ дБ, що значно нижче порогу 6 дБ: ланка блокується.

Крок 3. Спрямована антена наземної станції. Антена з підсиленням 12 дБі, спрямована на апарат, збільшує S на 12 дБ: $S/J = 1{,}5$ дБ — ще недостатньо.

Крок 4. Діаграма антени апарата. Антена апарата з діаграмою, що послаблює сигнали з нижньої півсфери спереду на 10 дБ (за умови, що наземна станція перебуває позаду, а постановник — попереду знизу), дає $S/J = 11{,}5$ дБ — вище порогу із запасом 5,5 дБ.

Крок 5. Зниження швидкості. Звуження смуги каналу з 1 МГц до 250 кГц за незмінної загальної смуги стрибків збільшує виграш ще на 6 дБ, що підвищує запас до 11,5 дБ ціною зменшення швидкості телеметрії.

Крок 6. Слідкувальний постановник. Якщо послідовність стрибків не є криптографічно захищеною і постановник здатен її передбачити, виграш кроку 2 зникає: $S/J = 11{,}5 - 19 = -7{,}5$ дБ, ланка блокується. Отже, криптографічна генерація послідовності стрибків є обов'язковою.

Узагальнення кейсу: стійкість ланки проти цілеспрямованого глушіння досягається *сукупністю* заходів — виграшем від обробки з секретною послідовністю, просторовою вибірковістю антен обох сторін, адаптацією швидкості, — а не будь-яким одним. Додаткові заходи — автономні режими польоту за втрати зв'язку, резервні частотні діапазони, ретрансляція через інший апарат, — а також загрози підміни навігаційних сигналів розглянуто в розділі 14.

Висновки до розділу

Безпека фізичного рівня доповнює криптографію в тих аспектах, де остання безсила або недостатня. Методи конфіденційності фізичного рівня — формування діаграми спрямованості, штучний шум, кооперативне глуші-

ння — здатні суттєво збільшити секретну пропускну здатність, але залежать від переваги каналу легітимного приймача, яку порушник з кращим обладнанням може нівелювати; тому вони є додатковим бар'єром, а не заміною шифрування. Генерування ключів із характеристик каналу дає змогу узгодити секрет без попереднього розподілу ключів, проте має низьку швидкість у статичному середовищі, вразливе до активного впливу на канал і потребує автентифікації протоколу. Протидія глушінню ґрунтується на виграші від обробки за секретною послідовністю розширення, просторовій вибірковості антенних решіток і адаптації; некоординовані методи розширення спектра розв'язують проблему встановлення першого ключа в умовах глушіння. Закон квадратного кореня показує фундаментальну межу прихованого зв'язку. Радіочастотний відбиток передавача є ефективним засобом виявлення підроблених пристроїв і додатковим фактором автентифікації, хоча його можна частково підробити і він створює ризики для приватності. Протоколи обмеження відстані на основі вимірювання часу поширення — єдиний принциповий захист від атак ретрансляції, а верифікована мультилатерація дає змогу безпечно перевіряти місцезнаходження; стандартизація захищеного вимірювання відстані в UWB і Bluetooth переводить ці результати в масову практику.

Питання для самоперевірки

1. Чому криптографія не може забезпечити доступність безпроводової ланки і безпеку вимірювання відстані? Які властивості фізичного рівня використовують для цих цілей?
2. Сформулюйте фізичні припущення, на яких ґрунтуються методи з табл. 5.1. Які можливості порушника порушують кожне з них?
3. Поясніть принцип методу штучного шуму. За (5.1) обчисліть C_s для $\varphi = 0{,}3$ за параметрів прикладу підрозділу 5.2.
4. Чому методи конфіденційності фізичного рівня мало використовуються в масових стандартах? Які технологічні зміни можуть розширити їх застосування?
5. Опишіть етапи генерування ключа з характеристик каналу. Яку роль відіграють взаємність, часова мінливість і просторова декореляція?
6. За (5.2) визначте мінімальну кількість вимірювань для отримання 256-бітового ключа за ентропії 0,5 біт на вимірювання, витоку 25 % при узгодженні та $\varepsilon = 2^{-64}$.
7. Які атаки можливі на генерування ключів із каналу? Чому канал сам собою не автентифікує сторін?

8. У чому полягає проблема «курки і яйця» для стійкого до глушіння зв'язку? Як її розв'язують некоординовані стрибки частоти та некоординоване розширення спектра?
9. Скільки постановників завад може придушити решітка з 7 елементів? Чому просторові методи неефективні проти завади з напрямку корисного сигналу?
10. Сформулюйте закон квадратного кореня для прихованого зв'язку і поясніть його значення для оцінювання ризиків радіовипромінювання.
11. Які недосконалості передавача утворюють радіочастотний відбиток? Чому модуляційні ознаки менш стійкі до підробки, ніж ознаки перехідних процесів?
12. Чому криптографічна автентифікація не захищає від атак ретрансляції? Обчисліть за (5.4) максимальну відстань для $\Delta t = 100$ нс і $t_p = 90$ нс.
13. Порівняйте шахрайство з відстанню, мафіозне і терористичне шахрайство. Яка ймовірність успіху мафіозного шахрайства за 48 раундів для протоколів із ймовірністю вгадування $1/2$ і $3/4$ за раунд?
14. Дослідницьке: для кейсу підрозділу 5.10 побудуйте залежність запасу стійкості ланки від відстані до постановника завад і визначте мінімальну безпечну відстань за кожного набору заходів.
15. Дослідницьке: запропонуйте схему поєднання радіочастотного відбитка з протоколом автентифікації IEEE 802.1X для виявлення клонованих облікових даних і оцініть її ефективність за показниками FAR, FRR і частки істинних тривог (3.6).

РОЗДІЛ 6

Криптографічні механізми безпроводових і мобільних мереж

Криптографія є основним засобом захисту конфіденційності та цілісності в безпроводових мережах: як показано в розділах 1 і 3, обмежити доступ до радіосередовища неможливо, а методи фізичного рівня (розділ 5) дають лише додатковий бар'єр. Водночас історія безпроводових технологій є переліком криптографічних провалів: WEP, A5/2, COMP128, E0, застаріле спарювання Bluetooth — кожен став хрестоматійним прикладом того, як закриті алгоритми, неправильні режими використання і нехтування управлінням ключами руйнують захист. Розділ аналізує вимоги до криптографії в безпроводовому середовищі, уроки історичних помилок, сучасні набори алгоритмів у мобільних мережах і Wi-Fi, ієрархії ключів, автентифіковане шифрування, протоколи автентифікації та узгодження ключів, легковагову криптографію для обмежених пристроїв і перехід до постквантових алгоритмів, а також місце національних криптографічних стандартів України. Конкретні протоколи окремих технологій детально розглянуто в розділах 7–10.

6.1 Вимоги до криптографії в безпроводовому середовищі

6.1.1 Специфічні обмеження

Криптографічні механізми безпроводових мереж мають задовольняти низку обмежень, що рідше трапляються в провідних системах.

Втрати і переупорядкування кадрів. Радіоканал втрачає кадри, а механізми повторного передавання і агрегування можуть змінювати їх порядок. Тому шифрування має бути *самосинхронним* на рівні кадру: кожен кадр дешифрується незалежно, а стан криптографічного механізму визначається явно переданим лічильником або одноразовим значенням. Потокові шифри з неперервним станом, що не відновлюється після втрати, непридатні.

Обмежені ресурси пристроїв. Датчики Інтернету речей, мітки RFID, маяки BLE мають мікроконтролери з частотою в одиниці–десятки мегагерц, кілобайти пам'яті і живлення від батареї на роки. Кожна операція шифрування витрачає енергію, а асиметричні операції можуть займати секунди. Це зумовлює потребу в легковаговій криптографії та протоколах із мінімальною кількістю асиметричних операцій.

Жорсткі вимоги до затримки. Для мобільних мереж алгоритми шифрування користувацької площини реалізуються апаратно на швидкостях у

гігабіти за секунду з затримками в мікросекунди; для передавання обслуговування між базовими станціями виведення нових ключів має займати мілісекунди.

Довгий життєвий цикл. SIM-картки, базові станції, промислові безпроводові пристрої експлуатуються 10–20 років, тому алгоритми мають зберігати стійкість протягом усього строку, а протоколи — підтримувати заміну алгоритмів (криптографічну гнучкість).

Регуляторні вимоги. Експортні обмеження історично змушували використовувати ослаблені алгоритми (A5/2, 40-бітовий WEP); вимоги законного перехоплення впливають на архітектуру (шифрування лише радіоінтерфейсу, а не наскрізне); національні вимоги можуть передбачати використання національних алгоритмів (підрозділ 6.9).

6.1.2 Принципи проєктування

З урахуванням цих обмежень і історичного досвіду сформувалися загальні принципи: використання відкритих, публічно проаналізованих алгоритмів (принцип Керкгоффса); застосування автентифікованого шифрування замість окремих механізмів шифрування і контролю цілісності; розділення ключів за призначенням (окремі ключі для шифрування й цілісності, для сигналізації й даних) і виведення їх через криптографічно стійкі функції; неповторюваність одноразових значень, що забезпечується лічильниками; захист від атак зниження версії через автентифікацію узгоджених параметрів; криптографічна гнучкість — можливість замінити алгоритм без зміни архітектури.

6.2 Уроки історичних помилок

6.2.1 WEP

Протокол WEP (Wired Equivalent Privacy) першої редакції IEEE 802.11 поєднав потоковий шифр RC4 з ключем, утвореним конкатенацією 24-бітового вектора ініціалізації (IV) і спільного секрету (40 або 104 біт), і контрольну суму CRC-32 для «цілісності». Протокол містив кілька незалежних фатальних вад [88]. *Короткий IV*: за (3.12) повторення виникає приблизно після 4800 кадрів, а повторення IV із тим самим ключем дає однаковий ключовий потік. *Лінійна контрольна сума*: CRC-32 лінійна щодо XOR, тому порушник може змінювати біти шифротексту й відповідно коригувати контрольну суму без знання ключа. *Відсутність захисту від повторення*: перехоплені кадри можна повторно вставляти. *Спосіб формування ключа RC4*: Флурер, Мантін і Шамір [140] показали, що для певних «слабких» IV перші байти ключового потоку RC4 розкривають інформацію про ключ; атака Тевса, Вайнманна і Пишкіна [277] відновлює 104-бітовий ключ за кілька десятків тисяч перехоплених кадрів менш ніж за хвилину. *Відсутність управління*

ключами: один спільний ключ для всіх користувачів мережі, що змінюється вручну.

6.2.2 GSM

Архітектура безпеки GSM [64] мала концептуальні вади, розглянуті в розділі 9, і криптографічні. Алгоритм COMP128-1, який багато операторів використовували як A3/A8 для автентифікації і виведення ключа, дозволяв відновити секретний ключ SIM-картки за кілька десятків тисяч запитів, що уможливлювало клонування SIM. Потоковий шифр A5/1 на основі трьох регістрів зсуву з нерегулярним тактуванням виявився вразливим до атак компромісу «час–пам'ять», а в 2009–2010 рр. публічно продемонстровано практичне дешифрування з використанням попередньо обчислених таблиць. Ослаблений експортний варіант A5/2 зламується майже миттєво. Баркан, Біхам і Келлер [76] показали атаку за самим шифротекстом: завадостійке кодування в GSM застосовується *до* шифрування, що дає лінійні співвідношення між бітами шифротексту; крім того, оскільки ключ K_c не залежить від обраного алгоритму, порушник може активно змусити термінал використати A5/2, відновити K_c і застосувати його до перехопленого раніше трафіку, зашифрованого A5/1. Ефективна довжина ключа в багатьох реалізаціях скорочувалася до 54 біт.

6.2.3 Узагальнення

Уроки історичних помилок узагальнено в табл. 6.1. Показово, що більшість вад мали не математичний, а *інженерний* характер: неправильне поєднання надійних примітивів, відсутність розділення ключів, закритість специфікацій, що перешкодила незалежному аналізу.

Таблиця 6.1 — Історичні криптографічні помилки безпроводових систем та уроки

Система	Вада	Урок
WEP	короткий IV; лінійна CRC; слабке формування ключа RC4; спільний статичний ключ	довгі неповторювані одноразові значення; криптографічна цілісність; ієрархія ключів
GSM A5/1, A5/2	короткі ефективні ключі; кодування до шифрування; той самий K_c для різних алгоритмів	розділення ключів за алгоритмом; захист від зниження версії
COMP128-1	закритий слабкий алгоритм автентифікації	відкриті, проаналізовані алгоритми
Bluetooth E0, застаріле спарювання	короткий PIN як єдине джерело ентропії	узгодження ключа на основі Діффі–Геллмана
KASUMI	атака на пов'язаних ключах [114]	запас стійкості примітивів; перевага широко досліджених шифрів
WPA2 (KRACK)	повторне встановлення ключа скидає лічильники	формальна перевірка кінцевих автоматів протоколів

Атака на пов'язаних ключах на KASUMI [114] є показовим прикладом іншого типу: алгоритм, отриманий «спрощенням» надійного шифру MISTY для апаратної ефективності, втратив запас стійкості. Практичної загрози для 3G атака не становила, оскільки режим використання KASUMI в мережі не дає порушникові пов'язаних ключів, проте вона підкреслила ризик модифікації перевірених примітивів.

6.3 Сучасні набори алгоритмів

6.3.1 Стільникові мережі

Починаючи з UMTS, 3GPP застосовує набори алгоритмів конфіденційності та цілісності з явними ідентифікаторами, що дає змогу додавати нові алгоритми без зміни архітектури. Алгоритми розробляються або оцінюються групою ETSI SAGE і публікуються відкрито. Основні набори наведено в табл. 6.2.

Таблиця 6.2 — Алгоритми конфіденційності та цілісності мобільних мереж

Покоління	Ідентифікатори	Примітив і коментар
UMTS	UEA1/UIA1	KASUMI (64-бітовий блок, 128-бітовий ключ)
	UEA2/UIA2	потоковий шифр SNOW 3G [62]
LTE, 5G	EEA0/EIA0, NEA0/NIA0	нульові алгоритми (без захисту); лише для екстрених викликів без автентифікації
	128-EEA1/EIA1, NEA1/NIA1	SNOW 3G
	128-EEA2/EIA2, NEA2/NIA2	AES-128 у режимі лічильника / AES-CMAC [212]
	128-EEA3/EIA3, NEA3/NIA3	потоковий шифр ZUC [63]
5G (перспектива)	256-бітові алгоритми	AES-256, SNOW 5G, ZUC-256 для стійкості в постквантову епоху

Наявність трьох незалежних алгоритмів (на основі різних примітивів) є свідомим рішенням: якщо один буде скомпрометовано, мережа перейде на інший. Код автентифікації повідомлень MAC-I в LTE і 5G має довжину 32 біт, що на перший погляд здається недостатнім. Однак імовірність успішної підробки за q спроб для t-бітового коду

$$P_{\text{підр}} \leq \frac{q}{2^t}, \tag{6.1}$$

і кожна невдала спроба призводить до відкидання повідомлення та може викликати розрив з'єднання, тому порушник не може здійснити багато спроб в одному контексті безпеки. Для $t = 32$ і $q = 10^6$ маємо $P_{\text{підр}} \leq 2{,}3 \cdot 10^{-4}$, і така кількість спроб у реальному з'єднанні недосяжна. Ситуація інша для користувацької площини: у LTE захист її цілісності не передбачений узагалі, що уможливило атаки модифікації трафіку (розділ 9); у 5G він опційний і обмежений максимальною швидкістю передавання даних, для якої термінал підтримує перевірку цілісності.

6.3.2 Бездротові локальні та персональні мережі

У Wi-Fi після WEP використовуються протоколи TKIP (перехідний, на основі RC4 з покращеним формуванням ключа і кодом цілісності Michael; нині застарілий і заборонений у WPA3) і CCMP — AES-128 у режимі CCM [115] з 48-бітовим номером пакета. WPA3-Enterprise у режимі 192-бітової стійкості використовує GCMP-256 — AES-256 у режимі GCM [116]. Для захисту кадрів керування (IEEE 802.11w) застосовують протокол BIP з AES-CMAC або AES-GMAC [171]. У Bluetooth класичний потоковий шифр E0 замінено на AES-CCM у режимі Secure Connections, а в BLE шифрування ґрунтується на AES-CCM з ключами, отриманими через узгодження на еліптичних кри-

вих P-256 [86]. У IEEE 802.15.4 передбачено AES-CCM* з різними довжинами коду цілісності [173].

6.4 Ієрархії ключів і функції виведення

6.4.1 Принцип розділення ключів

Сучасні безпроводові протоколи будують **ієрархію ключів**: з довготривалого секрету (ключа абонента, пароля, ключа, отриманого внаслідок автентифікації) виводяться проміжні ключі, прив'язані до контексту (мережі, сеансу, базової станції), а з них — робочі ключі для конкретних цілей. Виведення здійснюється функцією виведення ключів (KDF) на основі HMAC-SHA-256 [56]:

$$K_{\text{похідний}} = \mathrm{KDF}\big(K_{\text{батьківський}},\ \mathrm{FC} \parallel P_0 \parallel L_0 \parallel P_1 \parallel L_1 \parallel \dots\big), \qquad (6.2)$$

де FC — код функції, що розрізняє призначення ключа; P_i — параметри контексту (ідентифікатор мережі, лічильники, ідентифікатори алгоритмів); L_i — їхні довжини. Включення ідентифікаторів алгоритмів до вхідних даних KDF запобігає атаці, аналогічній атаці на GSM: ключ для слабкого алгоритму відрізнятиметься від ключа для стійкого. Включення ідентифікатора обслуговувальної мережі прив'язує ключ до мережі і не дає змоги використати його в іншій.

6.4.2 Ієрархія ключів 5G

Ієрархію ключів 5G [58] наведено на рис. 6.1. Довготривалий ключ K зберігається лише в USIM і в домашній мережі (функції ARPF/UDM). Після автентифікації (5G-AKA або EAP-AKA') функція автентифікації домашньої мережі AUSF отримує ключ K_{AUSF}, з нього виводиться ключ обслуговувальної мережі K_{SEAF}, прив'язаний до її імені, далі — ключ функції керування доступом і мобільністю K_{AMF}. З K_{AMF} виводяться ключі захисту сигналізації рівня NAS і ключ базової станції K_{gNB}, з якого, своєю чергою, — ключі захисту сигналізації RRC і користувацької площини.

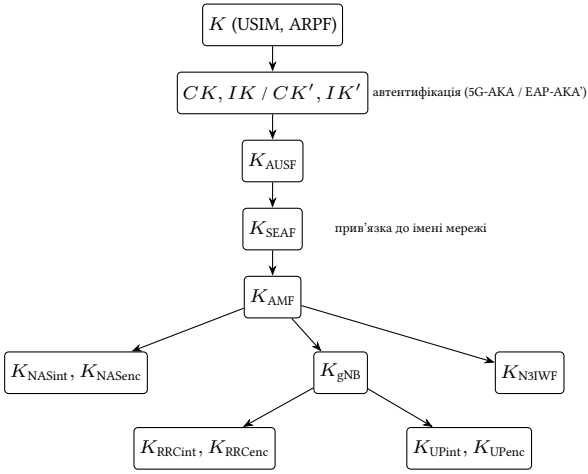


Рис. 6.1 — Ієрархія ключів мережі 5G (за [58])

Така ієрархія забезпечує кілька властивостей. *Ізоляція компрометації*: розкриття K_{gNB} однієї базової станції не розкриває ключів NAS чи інших базових станцій. *Пряма і зворотна ізоляція при передаванні обслуговування*: під час переходу до нової базової станції ключ K^{*}_{gNB} виводиться з урахуванням ідентифікатора цільової комірки; при переходах через ядро використовується новий параметр, отриманий з K_{AMF}, що не дає попередній базовій станції обчислити ключі наступних (пряма ізоляція після одного додаткового кроку). *Прив'язка до мережі*: ключ K_{SEAF} залежить від імені обслуговувальної мережі, тому термінал і домашня мережа погоджуються щодо того, в якій мережі відбулася автентифікація.

6.4.3 Ієрархія ключів Wi-Fi

У IEEE 802.11 з головного парного ключа PMK (отриманого з пароля через SAE або з сеансу EAP) під час чотиристороннього рукостискання виводиться тимчасовий парний ключ

$$\begin{aligned}\text{PTK} = \text{PRF}\big(&\text{PMK},\ \text{«Pairwise key expansion»},\\ &\min(AA, SPA) \parallel \max(AA, SPA) \parallel\\ &\min(N_A, N_S) \parallel \max(N_A, N_S)\big),\end{aligned} \tag{6.3}$$

де AA, SPA — MAC-адреси точки доступу і клієнта; N_A, N_S — одноразові значення, згенеровані ними. PTK розділяється на ключ підтвердження KCK (цілісність повідомлень рукостискання), ключ шифрування ключів

KEK (захист групового ключа) і тимчасовий ключ TK (шифрування даних). Одноразові значення забезпечують свіжість PTK для кожного сеансу, але не дають прямої секретності щодо PMK: якщо PMK виведено з пароля (WPA2-Personal) і пароль розкрито, всі записані сеанси можна дешифрувати. SAE у WPA3 виправляє це, генеруючи PMK через обмін Діффі–Геллмана (розділ 7).

6.5 Автентифіковане шифрування

6.5.1 Означення та властивості

Автентифіковане шифрування з асоційованими даними (AEAD) — схема, що приймає ключ K, одноразове значення N, відкритий текст M і асоційовані дані A (заголовки, що передаються відкрито, але мають бути захищені від модифікації) і повертає шифротекст разом із тегом автентифікації:

$$(C,\, T) = \mathrm{Enc}_K(N, A, M), \qquad \mathrm{Dec}_K(N, A, C, T) \in \{M,\ \perp\}. \tag{6.4}$$

Схема забезпечує конфіденційність M і цілісність та автентичність пари (A, M): будь-яка зміна C, T чи A призводить до відмови ($\perp$) з імовірністю, близькою до 1. У безпроводових протоколах до A включають адреси, номер пакета, ідентифікатор потоку — ті поля, які потрібні для маршрутизації до дешифрування, але модифікація яких дала б змогу перенаправити або повторити кадр.

6.5.2 Критичність неповторюваності одноразових значень

Режими CCM і GCM ґрунтуються на режимі лічильника, тому повторення пари (K, N) розкриває XOR двох відкритих текстів. Для GCM наслідки ще серйозніші: повторення одноразового значення дає змогу відновити ключ автентифікації H і підробляти теги для будь-яких повідомлень. Саме цим пояснюється руйнівність атак повторного встановлення ключа KRACK (розділ 7): змусивши клієнта повторно встановити той самий ключ зі скиданням лічильника пакетів, порушник викликає повторення одноразових значень. Для запобігання використовують: детерміновані лічильники з ненульовою довжиною (48 біт у CCMP дають 2^{48} кадрів на ключ); заборону повторного встановлення вже встановленого ключа; режими, стійкі до повторення одноразових значень (наприклад, AES-GCM-SIV), для застосувань, де неповторюваність важко гарантувати.

6.6 Протоколи автентифікації та узгодження ключів

6.6.1 Автентифікація на основі симетричного ключа: AKA

Протокол автентифікації та узгодження ключів AKA, запроваджений в UMTS і розвинений у LTE та 5G, ґрунтується на довготривалому симетри-

чному ключі K, спільному для USIM і домашньої мережі, і лічильнику послідовності SQN. Узагальнену схему наведено на рис. 6.2. Домашня мережа генерує випадкове число RAND і обчислює за допомогою функцій f_1–f_5 (реалізованих алгоритмами MILENAGE на основі AES або TUAK на основі Keccak) очікувану відповідь XRES, ключі CK, IK, ключ анонімності AK і маркер автентифікації $\mathrm{AUTN} = (\mathrm{SQN} \oplus \mathrm{AK}) \,\|\, \mathrm{AMF} \,\|\, \mathrm{MAC}$. USIM перевіряє MAC (автентифікація мережі) і свіжість SQN (захист від повторення), обчислює RES і ключі.

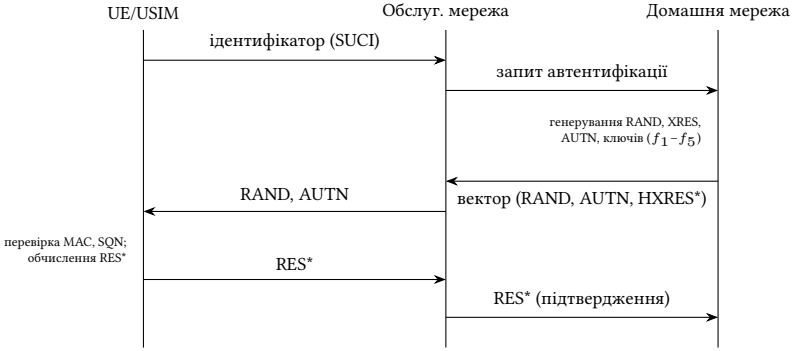


Рис. 6.2 — Узагальнена схема протоколу автентифікації та узгодження ключів 5G-AKA (за [58])

Сильні сторони AKA — взаємна автентифікація, свіжість, легкість обчислень у USIM. Слабкі — відсутність прямої секретності (компрометація K розкриває всі минулі й майбутні сеанси, якщо порушник записав RAND і трафік), залежність від синхронізації SQN (помилки синхронізації використовуються для відстеження абонентів), централізація ключів у домашній мережі (компрометація бази ключів або ланцюга постачання SIM-карток — катастрофічна подія). Формальний аналіз протоколу 5G-AKA виявив низку тонких вад щодо прив'язки сеансів і приватності (розділ 10).

6.6.2 Методи EAP

Розширюваний протокол автентифікації EAP [65] використовується в корпоративному Wi-Fi (IEEE 802.1X) і в 5G для не-3GPP-доступу. Метод EAP-TLS [264] з TLS 1.3 [235] забезпечує взаємну автентифікацію за сертифікатами і пряму секретність; він вважається найстійкішим для корпоративних мереж, але вимагає інфраструктури відкритих ключів для клієнтів. Тунельні методи (PEAP, EAP-TTLS) автентифікують сервер сертифікатом, а клієнта — паролем усередині тунелю; їхня стійкість критично залежить від перевірки сертифіката сервера клієнтом: без неї порушник з точкою доступу-

двійником отримує від клієнта пароль або його геш (для MSCHAPv2 — з можливістю ефективного відновлення). Метод EAP-AKA' [74] переносить AKA в рамку EAP з прив'язкою ключів до імені мережі доступу.

6.6.3 Узгодження ключа на основі пароля: SAE

Протокол SAE (Simultaneous Authentication of Equals) у WPA3 є варіантом парольного узгодження ключа Dragonfly [161]. Пароль відображається на елемент групи еліптичної кривої (метод «полювання і клювання» або, у новіших версіях, пряме хешування до кривої), після чого сторони виконують обмін на основі Діффі–Геллмана, що забезпечує дві ключові властивості: *стійкість до офлайнового підбору* (перехоплений обмін не дає змоги перевіряти кандидатів пароля без взаємодії) і *пряму секретність* (розкриття пароля не розкриває ключів минулих сеансів). Атаки Dragonblood показали, що реалізації методу відображення пароля на криву були вразливі до атак за побічними каналами (час обчислення, доступ до кешу), а перехідний режим WPA2/WPA3 — до атак зниження версії; це зумовило оновлення специфікації (розділ 7).

6.6.4 Узгодження ключа без автентифікації: OWE

Для відкритих мереж (кафе, транспорт) запроваджено режим Opportunistic Wireless Encryption — неавтентифікований обмін Діффі–Геллмана під час асоціації. Він захищає від пасивного перехоплення, але не від активного порушника з точкою доступу-двійником. Це приклад компромісу: краще неавтентифіковане шифрування, ніж жодного, але користувачеві не слід створювати хибного відчуття захищеності.

6.7 Легковагова криптографія

Для пристроїв з обмеженими ресурсами NIST провів багаторічний конкурс алгоритмів легковагової криптографії, за результатами якого стандартизовано сімейство Ascon у спеціальній публікації SP 800-232 [213]: схему автентифікованого шифрування Ascon-AEAD128, геш-функцію Ascon-Hash256 і функції з розширюваним виходом. Ascon ґрунтується на 320-бітовій перестановці і конструкції губки (дуплекс), має малу площу апаратної реалізації, ефективний на 8- і 32-бітових мікроконтролерах і стійкий до низки атак за побічними каналами завдяки простій бітовій структурі.

Енергоспоживання криптографічних операцій на пристрої оцінюють за моделлю

$$E_{\text{крипто}} = N_{\text{байт}} \cdot c_{\text{бт}} \cdot E_{\text{такт}} + N_{\text{асим}} \cdot E_{\text{асим}}, \tag{6.5}$$

де $N_{\text{байт}}$ — обсяг оброблених даних; $c_{\text{бт}}$ — кількість тактів на байт; $E_{\text{такт}}$ — енергія одного такту мікроконтролера; $N_{\text{асим}}$ і $E_{\text{асим}}$ — кількість і енергія

асиметричних операцій. На практиці для датчика, що передає короткі повідомлення, домінує друга складова і енергія радіопередавання, тому ключовими є протоколи з мінімальною кількістю асиметричних операцій і мінімальним обсягом службових даних (довжина тегу, одноразового значення, заголовків). Вибір 64-бітового тегу замість 128-бітового зменшує обсяг кожного повідомлення, але за (6.1) збільшує ймовірність підробки; для пристроїв із обмеженням кількості спроб 64 біти зазвичай достатньо. Застосування легковагової криптографії в протоколах Інтернету речей розглянуто в розділі 12.

6.8 Постквантовий перехід

6.8.1 Вплив квантових обчислень

Квантовий алгоритм Шора розв'язує задачі факторизації і дискретного логарифмування за поліноміальний час, що руйнує RSA, протоколи Діффі–Геллмана на скінченних полях і еліптичних кривих, цифрові підписи ECDSA і EdDSA. Алгоритм Гровера квадратично прискорює перебір ключів симетричних шифрів, тож k-бітовий ключ має ефективну стійкість порядку $k/2$ біт проти квантового порушника — звідси перехід до 256-бітових симетричних алгоритмів у мобільних мережах. Для оцінювання терміновості переходу використовують нерівність Моски [208]:

$$x + y > z, \tag{6.6}$$

де x — час, протягом якого дані мають залишатися конфіденційними; y — час, потрібний на міграцію інфраструктури; z — час до появи криптографічно значущого квантового комп'ютера. Якщо нерівність виконується, організація вже запізнюється: порушник, що записує трафік сьогодні («збирай зараз — дешифруй потім»), зможе розкрити його до спливу строку конфіденційності. Для мобільних мереж з життєвим циклом обладнання понад 10 років і SIM-картками, що використовуються десятиліттями, y є особливо великим.

6.8.2 Стандарти і вплив на безпроводові протоколи

NIST стандартизував механізм інкапсуляції ключа ML-KEM [217], цифрові підписи ML-DSA [216] і SLH-DSA [219]. Вплив на безпроводові технології наведено в табл. 6.3.

Таблиця 6.3 — Вплив постквантового переходу на механізми безпроводових мереж

Механізм	Вразливий елемент	Напрям міграції
Приховування ідентифікатора 5G (SUCI)	ECIES на кривих X25519 / P-256	профілі на основі ML-KEM; вплив на розмір першого повідомлення реєстрації
5G-AKA, EAP-AKA’	симетричні функції (стійкі)	256-бітові ключі та алгоритми
EAP-TLS, TLS 1.3	ECDHE, підписи сертифікатів	гібридний обмін ключами, постквантові сертифікати
WPA3-SAE	обмін на еліптичних кривих	дослідження постквантових PAKE
BLE Secure Connections	ECDH P-256	обмежено ресурсами пристроїв; додаткові симетричні механізми
Захищене оновлення прошивок	підписи ECDSA/RSA	ML-DSA, SLH-DSA, гешові підписи зі станом

Основні практичні проблеми: розмір постквантових відкритих ключів і шифротекстів (сотні байтів–кілобайти), що критично для першого повідомлення реєстрації в радіомережі, обмеженого за розміром, і для кадрів BLE та IEEE 802.15.4; обчислювальні вимоги до SIM-карток і датчиків; необхідність гібридних схем на перехідний період; відсутність стандартизованих постквантових аналогів PAKE для WPA3. Пріоритетом є механізми, що захищають довготривалу конфіденційність (обмін ключами, приховування ідентифікаторів), і механізми з довгим життєвим циклом (корені довіри для оновлення прошивок).

6.9 Національні криптографічні стандарти України

В Україні розроблено власні криптографічні стандарти: блоковий шифр «Калина» (ДСТУ 7624:2014) [8] з блоком 128, 256 і 512 біт; функцію гешування «Купина» (ДСТУ 7564:2014) [9]; потоковий шифр «Струмок» (ДСТУ 8845:2019) [10] з ключами 256 і 512 біт, орієнтований на високошвидкісне шифрування; цифровий підпис на еліптичних кривих (ДСТУ 4145-2002) [7]. Теоретичні основи і практика застосування цих алгоритмів детально висвітлені в [5]. Для безпроводових систем, що обробляють інформацію, вимога щодо захисту якої встановлена законом, використання засобів криптографічного захисту, що мають позитивний висновок державної експертизи, є обов’язковим (розділ 2).

Інтеграція національних алгоритмів у безпроводові технології стикається з тим, що набори алгоритмів у галузевих специфікаціях (3GPP, IEEE 802.11, Bluetooth) фіксовані, а термінали масового ринку підтримують лише стандартні алгоритми. Тому практичні підходи такі: застосування національних алгоритмів на вищих рівнях — у тунелях VPN поверх безпро-

водового каналу, у наскрізному шифруванні застосунків, в електронному підписі; використання спеціалізованих терміналів і модулів для захищених відомчих мереж; для приватних мереж LTE/5G на спеціалізованому обладнанні — включення національних алгоритмів як додаткових ідентифікаторів алгоритмів, що передбачено гнучкою архітектурою 3GPP. Потоковий шифр «Струмок» за своїми характеристиками добре підходить для апаратного шифрування високошвидкісних радіоканалів.

6.10 Кейс: криптографічний профіль корпоративних безпроводових мереж

Організація, віднесена до об'єктів критичної інфраструктури, розгортає корпоративну мережу Wi-Fi і приватну мережу LTE/5G для виробничих пристроїв. Потрібно визначити криптографічний профіль. Рішення, обґрунтовані матеріалом розділу:

1. *Wi-Fi для працівників*: WPA3-Enterprise з EAP-TLS 1.3 і клієнтськими сертифікатами, видаваними корпоративним центром сертифікації; для адміністративних сегментів — режим 192-бітової стійкості (GCMP-256, BIP-GMAC-256); обов'язковий захист кадрів керування; заборона TKIP і WPA2-Personal.
2. *Wi-Fi для пристроїв без підтримки 802.1X*: WPA3-Personal (SAE) з унікальним паролем для кожного пристрою або групи (механізм множинних паролів), ізоляція в окремому сегменті.
3. *Гостьова мережа*: OWE з ізоляцією клієнтів; інформування користувачів, що мережа не захищає від активних атак.
4. *Приватна мережа LTE/5G*: USIM/eUICC з власним ключовим матеріалом, згенерованим і завантаженим у контрольованих умовах; алгоритми NEA2/NIA2 з обов'язковим захистом цілісності користувацької площини в 5G; заборона нульових алгоритмів і 2G/3G; IPsec між базовими станціями і ядром.
5. *Інформація з обмеженим доступом*: додатковий шар шифрування засобами КЗІ з позитивним висновком (національні алгоритми) поверх безпроводового каналу.
6. *Постквантова готовність*: інвентаризація криптографічних залежностей; перевага 256-бітовим симетричним алгоритмам; вимога до постачальників щодо підтримки гібридного обміну ключами в TLS і планів переходу для корінних сертифікатів.

Оцінимо ризик підробки сигнальних повідомлень у приватній мережі LTE за (6.1): при обмеженні в 10 невдалих перевірок цілісності до розриву з'єднання і повторної автентифікації, та припущенні 1000 спроб встановле-

ння з'єднань на добу, річна кількість спроб становить $3{,}65 \cdot 10^6$, і ймовірність хоча б однієї успішної підробки $\leq 8{,}5 \cdot 10^{-4}$. Отже, 32-бітовий MAC-I для сигналізації достатній, але критичним є моніторинг аномальної кількості помилок перевірки цілісності як індикатора атаки (розділ 15).

Висновки до розділу

Криптографія безпроводових і мобільних мереж має задовольняти специфічні вимоги: незалежне дешифрування кожного кадру, обмежені ресурси пристроїв, жорсткі вимоги до затримки, тривалий життєвий цикл обладнання і регуляторні обмеження. Історичні провали — WEP, A5/1 і A5/2, COMP128, застаріле спарювання Bluetooth — мали переважно інженерний характер: неправильне поєднання примітивів, короткі одноразові значення, лінійні контрольні суми, відсутність розділення ключів за алгоритмами, закритість специфікацій. Сучасні системи використовують відкриті набори алгоритмів із явними ідентифікаторами (SNOW 3G, AES, ZUC у мобільних мережах; AES-CCM і AES-GCM у Wi-Fi і Bluetooth), автентифіковане шифрування з асоційованими даними і ієрархії ключів, у яких функції виведення прив'язують ключі до призначення, алгоритму, мережі й сеансу. Неповторюваність одноразових значень є критичною вимогою режимів лічильника, а її порушення (KRACK) руйнує захист попри стійкість примітивів. Протоколи автентифікації — AKA на симетричних ключах, EAP-TLS, SAE, OWE — мають різні гарантії щодо взаємної автентифікації, прямої секретності і стійкості до офлайнового підбору, і їх вибір має відповідати моделі порушника. Легковагова криптографія (Ascon) і постквантовий перехід (ML-KEM, ML-DSA, 256-бітові симетричні алгоритми) визначають розвиток на найближче десятиліття, причому нерівність Моски свідчить, що для мобільних мереж з довгим життєвим циклом перехід потрібно планувати вже зараз. Національні криптографічні стандарти України доцільно застосовувати на вищих рівнях стека і в спеціалізованих мережах.

Питання для самоперевірки

1. Які специфічні обмеження накладає безпроводове середовище на криптографічні механізми? Чому потокові шифри з неперервним станом непридатні для шифрування кадрів?
2. Перелічіть незалежні вади протоколу WEP. Яка з них, на вашу думку, найфундаментальніша і чому?
3. Поясніть атаку Баркана–Біхама–Келлера на GSM. Як ієрархія ключів у LTE і 5G запобігає аналогічній атаці?
4. Чому 3GPP підтримує кілька незалежних алгоритмів конфіденційності та цілісності? Які примітиви лежать в їх основі?

5. Обґрунтуйте достатність 32-бітового MAC-I для сигналізації LTE за формулою (6.1). Чому цей аргумент не переноситься на користувацьку площину?
6. Опишіть ієрархію ключів 5G (рис. 6.1). Які властивості забезпечує прив'язка K_{SEAF} до імені обслуговувальної мережі?
7. Які складові включено до вхідних даних функції виведення PTK (6.3)? Чому WPA2-Personal не забезпечує прямої секретності?
8. Дайте означення AEAD. Які поля кадру доцільно включати до асоційованих даних і чому?
9. Чому повторення одноразового значення в GCM є катастрофічним? Як це пов'язано з атакою KRACK?
10. Порівняйте AKA, EAP-TLS і тунельні методи EAP за взаємною автентифікацією, прямою секретністю і залежністю від дій користувача.
11. Які властивості забезпечує SAE порівняно з PSK-автентифікацією WPA2? Які вади реалізацій виявили атаки Dragonblood?
12. Для чого призначено OWE і від яких атак цей режим не захищає?
13. За моделлю (6.5) поясніть, чому для датчиків Інтернету речей мінімізація кількості асиметричних операцій важливіша за вибір симетричного шифру.
14. Застосуйте нерівність Моски (6.6) до даних про місцезнаходження абонентів, які мають залишатися конфіденційними 15 років, за часу міграції мережі 8 років. Які висновки випливають за різних оцінок z?
15. Дослідницьке: запропонуйте архітектуру інтеграції потокового шифру «Струмок» у приватну мережу 5G відповідно до механізму ідентифікаторів алгоритмів 3GPP і оцініть вимоги до продуктивності апаратної реалізації.

РОЗДІЛ 7

Безпека безпроводових локальних мереж IEEE 802.11

Мережі стандарту IEEE 802.11 (Wi-Fi) є найпоширенішою безпроводовою технологією доступу до інформаційних ресурсів: через них працюють домашні та корпоративні мережі, публічні точки доступу, мережі Інтернету речей, навчальні та медичні заклади. Історія безпеки Wi-Fi — це три покоління механізмів захисту (WEP, WPA/WPA2, WPA3), кожне з яких створювалося у відповідь на вади попереднього, і послідовність досліджень, що виявляли нові класи вразливостей протоколів та їх реалізацій. Розділ розглядає архітектуру мереж IEEE 802.11 з погляду безпеки, еволюцію механізмів захисту, чотиристороннє рукостискання і атаки повторного встановлення ключа, протокол SAE у WPA3 і виявлені в ньому вади, корпоративну автентифікацію на основі IEEE 802.1X і RADIUS, атаки на канальний рівень і кадри керування, питання приватності клієнтів та методику захищеного проєктування корпоративної мережі. Криптографічні примітиви і функції виведення ключів розглянуто в розділі 6, моніторинг ефіру і виявлення вторгнень — у розділі 15.

7.1 Архітектура IEEE 802.11 з погляду безпеки

7.1.1 Основні елементи

Стандарт IEEE 802.11 [171] визначає фізичний рівень і рівень керування доступом до середовища (MAC) безпроводових локальних мереж. Базовим елементом є **базовий набір служб** (BSS) — точка доступу і асоційовані з нею станції, ідентифікований MAC-адресою точки доступу (BSSID). Кілька BSS, об'єднаних розподільчою системою, утворюють **розширений набір служб** (ESS) із єдиним ідентифікатором мережі (SSID). Поколінням технології відповідають поправки до стандарту (802.11n/ac/ax/be, торгові назви Wi-Fi 4–7), які підвищують швидкість, але не змінюють принципів безпеки, закладених у поправці 802.11i та розвинутих у програмах сертифікації WPA2 і WPA3.

Процес підключення станції складається з трьох фаз: *виявлення* (станція знаходить мережі, слухаючи маяки або надсилаючи запити пошуку), *автентифікації та асоціації* (встановлення логічного зв'язку) і, для захищених мереж, *встановлення ключів* (рукостискання, що дає тимчасові ключі шифрування). Принципова особливість Wi-Fi — значна частина кадрів керування (маяки, запити й відповіді пошуку, кадри автентифікації, асоціації

та деавтентифікації) історично передавалася без захисту, що є джерелом цілого класу атак (підрозділ 7.6).

7.1.2 Модель загроз

Модель порушника для Wi-Fi (розділ 1) охоплює пасивного спостерігача в розширеній зоні приймання, активного порушника з власною точкою доступу і можливістю ін'єкції кадрів, а для публічних мереж — зловмисного клієнта тієї самої мережі. Специфічні для Wi-Fi цілі порушника: перехоплення трафіку, отримання доступу до мережі (і через неї — до внутрішніх ресурсів), викрадення облікових даних, підміна точки доступу, порушення доступності, відстеження клієнтів за їхніми пристроями. Оскільки корпоративний Wi-Fi часто є «м'яким підчерев'ям» — шляхом до внутрішньої мережі в обхід периметрового захисту, — його компрометація має високий вплив (розділ 4).

7.2 Еволюція механізмів захисту

Три покоління механізмів захисту Wi-Fi та їхні властивості узагальнено в табл. 7.1. Вади WEP розглянуто в розділі 6; тут наголосимо на логіці еволюції.

Таблиця 7.1 — Покоління механізмів захисту Wi-Fi

Механізм	Шифрування / цілісність	Автентифікація і статус
WEP	RC4 / CRC-32	спільний ключ; зламано, заборонено
WPA (TKIP)	RC4 з ротацією ключа / Michael	PSK або 802.1X; перехідний, застарілий
WPA2	AES-CCMP / CCM	PSK або 802.1X; вразливий до KRACK, підбору PSK
WPA3	AES-CCMP / GCMP-256	SAE або 802.1X; захист кадрів керування обов'язковий
OWE	AES-CCMP	без автентифікації; шифрування відкритих мереж

WPA був перехідним рішенням, що працювало на наявному обладнанні WEP (той самий RC4), але усувало найгостріші вади через ротацію ключів (TKIP) і код цілісності Michael. WPA2 запровадив AES-CCMP — криптографічно надійне автентифіковане шифрування (розділ 6). WPA3 усунув вади, що залишалися: підбір паролів персональних мереж (через SAE), відсутність захисту кадрів керування (обов'язковий 802.11w), відсутність шифрування у відкритих мережах (OWE). Проте, як показує подальший виклад, кожне покоління залишало простір для атак на рівні протоколів встановлення ключів і реалізацій.

7.3 Чотиристоронє рукостискання і атаки на нього

7.3.1 Механізм

Після встановлення головного парного ключа PMK (з пароля через SAE, з сеансу 802.1X або безпосередньо як PSK) точка доступу і станція виконують **чотиристоронє рукостискання** для виведення тимчасового парного ключа PTK (6.3) і встановлення групового ключа. Схему наведено на рис. 7.1. У повідомленні 1 точка доступу надсилає своє одноразове значення N_A; станція обчислює PTK і в повідомленні 2 надсилає своє одноразове значення N_S з кодом цілісності. Точка доступу обчислює PTK, у повідомленні 3 передає груповий ключ і підтвердження; станція встановлює ключі і в повідомленні 4 підтверджує. Лише після цього починається шифрований обмін.

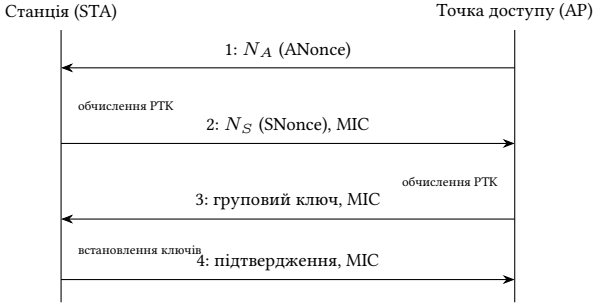


Рис. 7.1 — Чотиристоронє рукостискання IEEE 802.11

7.3.2 Атака повторного встановлення ключа (KRACK)

Ванхоф і Пієссенс [281] виявили, що специфікація не забороняла повторне встановлення вже встановленого ключа. Порушник, перебуваючи між станцією і точкою доступу, може заблокувати повідомлення 4 і змусити точку доступу повторно надіслати повідомлення 3; станція, отримавши його, *повторно встановлює той самий PTK*, скидаючи лічильник пакетів (одноразове значення для шифрування) і лічильник повторення. Як показано в розділі 6, повторення пари (K, N) у режимі лічильника розкриває ключовий потік, тому порушник дешифрує кадри, а в деяких реалізаціях (зокрема певні версії клієнтів на базі wpa_supplicant) міг встановити нульовий ключ. Атака вражала *всі* реалізації WPA2, оскільки була вадою стандарту, а не окремого продукту. Важливий висновок: криптографічна надійність примітивів (AES-CCMP) не рятує за вади кінцевого автомата протоколу; це стало аргументом на користь формальної верифікації протоколів встановлення ключів. Виправлення полягало в забороні повторного встановлення того самого ключа зі скиданням лічильників.

7.3.3 Підбір пароля персональних мереж

У WPA2-Personal PMK виводиться безпосередньо з пароля мережі, тому перехоплення чотиристороннього рукостискання (або лише повідомлень з одноразовими значеннями) дає змогу перевіряти кандидати пароля в режимі офлайн, як описано в розділі 3 (формула (3.13) і табл. 3.2). Порушник може прискорити збирання рукостискання, надіславши кадр деавтентифікації, щоб примусити клієнта повторно підключитися. Крім того, механізм PMKID у деяких точках доступу дає змогу отримати матеріал для підбору без очікування підключення клієнта. Через це WPA2-Personal з паролем, вибраним людиною, забезпечує низьку стійкість, що й обґрунтовує перехід на SAE.

7.4 WPA3 і протокол SAE

7.4.1 Властивості SAE

Протокол SAE (розділ 6) замінює прямий вивід PMK з пароля на парольне узгодження ключа на основі Діффі–Геллмана [161]. Це дає дві властивості, яких бракувало WPA2-Personal: *стійкість до офлайнового підбору* (перехоплений обмін не дає змоги перевіряти кандидати без інтерактивної взаємодії з точкою доступу, тобто атака стає онлайновою і обмежується частотою спроб, яку контролює точка доступу) і *пряму секретність* (розкриття пароля не розкриває ключів раніше записаних сеансів). Кожна невдала спроба автентифікації потребує окремої взаємодії, тому за (3.13) час підбору визначається вже не обчислювальною потужністю порушника, а допустимою частотою спроб; за обмеження 10 спроб/хв перебір навіть словника з мільйона паролів займе понад два місяці, а система виявить аномальну кількість невдалих автентифікацій.

7.4.2 Вразливості Dragonblood

Ванхоф і Ронен [282] показали, що попри теоретичну стійкість, реалізації SAE вразливі. *Атаки за побічними каналами*: у методі відображення пароля на точку кривої «полювання і клювання» кількість ітерацій залежить від пароля, і час обчислення чи характер доступу до кеша розкривають інформацію, що дає змогу звузити простір паролів і зробити офлайновий підбір знову можливим. *Атаки зниження версії*: у перехідному режимі, де точка доступу підтримує і WPA2, і WPA3 з тим самим паролем, порушник з точкою доступу-двійником, що оголошує лише WPA2, змушує клієнта до вразливого WPA2-рукостискання. *Атаки на групи*: використання слабких криптографічних груп. Виправлення включали перехід до методу прямого хешування пароля на криву (SSWU), сталого за часом, і посилення політик щодо перехідного режиму. Урок Dragonblood: стійкий протокол може бути

зламаний через реалізацію, а зворотна сумісність є систематичним джерелом атак зниження версії (розділ 1).

7.4.3 Плутанина SSID

Голльє і Ванхоф [150] показали, що стандарт не завжди включає SSID до захищеного контексту автентифікації, тому за певних умов клієнт може бути введений в оману щодо того, до якої мережі він під'єднався (SSID Confusion), навіть за коректних облікових даних. Наслідок — клієнт може застосувати політики довіри однієї мережі, перебуваючи фактично в іншій (наприклад, вимкнути VPN, вважаючи, що під'єднався до довіреної корпоративної мережі). Захист — обов'язкове включення SSID до автентифікованих даних, що передбачено оновленнями стандарту.

7.5 Корпоративна автентифікація: IEEE 802.1X і RADIUS

7.5.1 Модель контролю доступу

Стандарт IEEE 802.1X [175] реалізує контроль доступу до мережі за принципом «порту»: до успішної автентифікації порт station пропускає лише кадри протоколу EAP, блокуючи решту трафіку. Три ролі: *прохач* (клієнт), *автентифікатор* (точка доступу або контролер) і *сервер автентифікації* (RADIUS). Автентифікатор ретранслює повідомлення EAP між клієнтом і сервером, не втручаючись у їх зміст (EAP-over-LAN між клієнтом і точкою доступу, RADIUS між точкою доступу і сервером). Після успішної автентифікації сервер передає точці доступу головний ключ сеансу, з якого виводиться PMK, і далі виконується звичайне чотиристоронє рукостискання. Схему наведено на рис. 7.2.

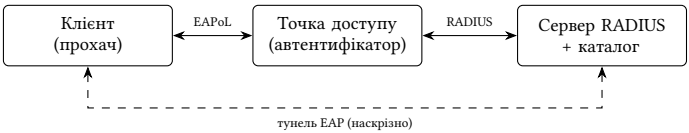


Рис. 7.2 — Архітектура автентифікації IEEE 802.1X

7.5.2 Вибір методу EAP

Стійкість корпоративної мережі критично залежить від методу EAP (розділ 6). EAP-TLS [235] із взаємною автентифікацією за сертифікатами не має спільних секретів, стійкий до підбору й фішингу облікових даних, але потребує інфраструктури клієнтських сертифікатів. Тунельні методи (PEAP, EAP-TTLS) простіші в розгортанні, але їхня стійкість повністю залежить від перевірки клієнтом сертифіката сервера: без цієї перевірки порушник з точкою доступу-двійником і власним RADIUS-сервером отримує від клієнта

облікові дані або їх геш. Тому обов'язковою є *примусова конфігурація* перевірки сертифіката сервера і його імені — через профілі керування пристроями, а не через покладання на користувача. Служба міжнародного освітнього роумінгу eduroam [117] є прикладом масштабної федеративної інфраструктури 802.1X, у якій некоректна конфігурація клієнтів історично була основним джерелом ризику.

7.5.3 Безпека RADIUS

Протокол RADIUS [248] розроблено в 1990-х роках, і він успадкував слабку криптографію: автентифікатор відповідей захищається конструкцією на основі MD5 із спільним секретом. Дослідження BlastRADIUS [147] показало, що атака на колізії MD5 дає змогу порушникові, який контролює мережу між автентифікатором і сервером, підробити відповідь «доступ дозволено» замість «відмовлено». Тому RADIUS-трафік не можна передавати незахищеною мережею: його слід тунелювати в IPsec або переходити на RADIUS over TLS (RadSec) [285]. Це ілюструє загальний принцип: безпека безпроводової мережі залежить не лише від радіоінтерфейсу, а й від захищеності допоміжної інфраструктури автентифікації.

7.6 Атаки на канальний рівень і кадри керування

7.6.1 Деавтентифікація і відмова в обслуговуванні

У мережах без захисту кадрів керування будь-хто може надіслати кадр деавтентифікації або роз'єднання від імені точки доступу чи клієнта (адреси в цих кадрах не автентифіковані), примусово розриваючи з'єднання. Ця атака використовується для примусового повторного підключення (щоб перехопити рукостискання або нав'язати точку доступу-двійника) і як самостійна атака на доступність. Поправка IEEE 802.11w запроваджує захист кадрів керування (протокол BIP, розділ 6) [143] для кадрів деавтентифікації, роз'єднання та деяких кадрів дій; у WPA3 він обов'язковий. Проте частина кадрів (маяки, кадри пошуку до асоціації) захищеною бути не може за визначенням, тому повністю усунути атаки на доступність канального рівня неможливо — потрібні виявлення і локалізація джерела (розділ 15).

7.6.2 Атаки на агрегацію і фрагментацію кадрів

Ванхоф [280] виявив клас вад FragAttacks, пов'язаних з тим, як стандарт і реалізації обробляють агрегацію (об'єднання кадрів) і фрагментацію. Зокрема: біт агрегації в заголовку не автентифікований, тому порушник може змінити його і призвести до інтерпретації даних як заголовка; фрагменти, зашифровані різними ключами, могли змішуватися; нешифровані фрагменти могли прийматися. Частина вад — у стандарті, частина — у реалізаціях (зокрема прийняття відкритих кадрів у захищеній мережі). Дослідження

FramingFrames [256] продемонструвало обхід шифрування через маніпуляцію чергами передавання при переході пристрою в режим енергозбереження: кадри, поставлені в чергу до встановлення ключа, могли бути надіслані незашифрованими або із ключем порушника. Ці роботи показують, що навіть за надійного шифрування складність кінцевого автомата MAC-рівня створює вразливості; захист — оновлення прошивок і драйверів, а для критичних систем — додатковий шар шифрування (VPN) поверх Wi-Fi.

7.6.3 Комбіноване й адаптивне шифрування

Оскільки стандартні механізми Wi-Fi періодично виявляються вразливими, для підвищення стійкості застосовують додаткові шари захисту трафіку. Українські дослідники запропонували адаптивний метод шифрування трафіку в мережах Wi-Fi, що комбінує криптографічні перетворення залежно від умов і типу даних [44]. Такий підхід відповідає загальному принципу ешелонованого захисту: незалежний шар шифрування (наприклад, VPN або наскрізне шифрування застосунків) забезпечує конфіденційність навіть за компрометації механізмів канального рівня, що особливо важливо для доступу до критичних ресурсів через безпроводові й публічні мережі.

7.7 Приватність клієнтів

Пристрій Wi-Fi у режимі пошуку мереж історично надсилав запити пошуку зі своєю сталою MAC-адресою і, у деяких реалізаціях, з переліком імен відомих мереж (список бажаних мереж). Це дає змогу відстежувати пристрій у просторі й часі та визначати місця, які відвідував користувач (домашня, робоча мережі), як показано в розділі 3. Сучасні операційні системи застосовують рандомізацію MAC-адрес у запитах пошуку і, дедалі частіше, у самих з'єднаннях. Проте, як зазначено в розділі 3, рандомізацію можна обійти через інші ознаки: вміст запитів пошуку (набір підтримуваних параметрів утворює відбиток), послідовні номери, часові патерни, радіочастотний відбиток передавача. Ефективний захист приватності потребує одночасно уніфікації вмісту кадрів пошуку, відмови від активного пошуку відомих мереж на користь пасивного слухання і скорочення часу використання одного псевдоніма. Список бажаних мереж не слід зберігати для відкритих мереж, а автоматичне підключення до мереж за іменем варто обмежувати, оскільки воно уможливлює атаку точкою доступу-двійником.

7.8 Небезпечні успадковані функції

Значна частка практичних компрометацій мереж Wi-Fi пов'язана не з новими атаками на сучасні протоколи, а з увімкненими успадкованими функціями. **Wi-Fi Protected Setup** (WPS) — механізм спрощеного підключення

за восьмизначним PIN-кодом — має фатальну ваду проєктування: PIN перевіряється двома половинами, а восьма цифра є контрольною, тому простір підбору скорочується з 10^8 до $10^4 + 10^3 \approx 1{,}1 \cdot 10^4$ варіантів, що робить онлайновий підбір реальним за години. Тому WPS слід вимикати. **TKIP** має вади коду цілісності Michael і залишкові слабкості RC4; його наявність, крім власної вразливості, знижує швидкість мережі та уможливлює атаки зниження версії, тому в сучасних мережах він має бути заборонений. Передавання PMKID точками доступу дає порушникові матеріал для офлайнового підбору без участі клієнта. Гостьові мережі без ізоляції клієнтів дають змогу зловмисному користувачеві атакувати інших. Успадковані швидкості та підтримка лише WPA2 у перехідному режимі відкривають шлях до атак зниження версії SAE (підрозділ 7.4). Загальний принцип керування конфігурацією: вимикати все, що не потрібне, і регулярно перевіряти фактичну конфігурацію проти політики, оскільки успадковані функції часто вмикаються за замовчуванням або відновлюються під час оновлень.

7.9 Публічні мережі, портали та відкрите шифрування

Публічні мережі Wi-Fi (кафе, транспорт, готелі, заклади) створюють особливі ризики: відсутність автентифікації мережі, спільне середовище з невідомими користувачами, використання порталів перехоплення (captive portal). **Портал перехоплення** перенаправляє незахищений HTTP-трафік нового клієнта на сторінку авторизації; сама ця технологія покладається на можливість перехоплення і модифікації трафіку, що суперечить принципам захищеного зв'язку і не сумісна з мережами, де весь трафік шифрується. Основні загрози публічних мереж: пасивне перехоплення (за відсутності шифрування канального рівня); точка доступу-двійник, що імітує відому публічну мережу; підміна сторінки порталу для викрадення облікових даних; атаки на клієнтів у спільному сегменті.

Режим OWE [160] усуває найгострішу ваду — відсутність шифрування у відкритих мережах — через неавтентифікований обмін Діффі–Геллмана під час асоціації, захищаючи від пасивного перехоплення. Проте, як зазначено в розділі 6, OWE не захищає від активного порушника з точкою доступу-двійником, оскільки немає автентифікації точки доступу. Тому для публічних мереж основним засобом захисту залишається *незалежний від мережі* шар: VPN або наскрізне шифрування застосунків (HTTPS, TLS). Користувачам критичних систем слід забороняти доступ до них через публічні мережі без VPN, а самим організаціям — не покладатися на безпеку канального рівня публічних мереж узагалі. Модель довіри тут інвертована порівняно з корпоративною мережею: публічна мережа вважається ворожою за замовчуванням, що прямо відповідає принципу нульової довіри (розділ 11).

7.10 Методика захищеного проєктування корпоративної мережі

Узагальнимо матеріал розділу у вигляді методики проєктування захищеної корпоративної мережі Wi-Fi.

1. *Сегментація за призначенням*: окремі мережі (SSID і VLAN) для працівників, гостей, пристроїв Інтернету речей, критичних систем; ізоляція клієнтів у гостьовій мережі та мережі пристроїв; відсутність прямого доступу з безпроводового сегмента до критичних ресурсів без додаткової авторизації (принцип нульової довіри, розділ 11).
2. *Автентифікація*: для працівників — WPA3-Enterprise з EAP-TLS і клієнтськими сертифікатами; примусова перевірка сертифіката сервера через профілі керування пристроями; для критичних сегментів — режим 192-бітової стійкості; для пристроїв без 802.1X — WPA3-Personal (SAE) з унікальними паролями; для гостей — OWE або портал з обмеженнями.
3. *Цілісність інфраструктури автентифікації*: захист RADIUS через RadSec або IPsec; апаратний захист приватних ключів серверів; регулярна ротація сертифікатів.
4. *Захист канального рівня*: обов'язковий захист кадрів керування (802.11w); вимкнення застарілих механізмів (WEP, TKIP, WPS, PMKID для персональних мереж); своєчасне оновлення прошивок точок доступу і драйверів клієнтів.
5. *Моніторинг*: безпроводова система виявлення вторгнень для виявлення підроблених точок доступу, атак деавтентифікації, аномальних клієнтів; кореляція ознак для зниження частки хибних тривог (розділи 3, 15).
6. *Ешелонування*: незалежний шар шифрування (VPN, наскрізне шифрування) для доступу до критичних ресурсів, що зберігає конфіденційність за компрометації Wi-Fi.
7. *Приватність і відповідність*: конфігурація клієнтів для рандомізації адрес; політики щодо особистих пристроїв; відповідність вимогам захисту персональних даних (розділ 2).

Оцінимо залишковий ризик отримання доступу до внутрішньої мережі через Wi-Fi за такої конфігурації, використовуючи модель дерева атак розділу 4. Основні шляхи — підбір пароля (усунено переходом на EAP-TLS), точка доступу-двійник (імовірність прийняття фальшивого сервера різко знижена примусовою перевіркою сертифіката), компрометація точки доступу чи контролера (знижена оновленнями і сегментацією). Навіть за успішного підключення принцип нульової довіри вимагає окремої авторизації доступу до ресурсів, тому компрометація безпроводового сегмента не дає

прямого доступу до критичних систем. Це ілюструє ключовий принцип: захищеність досягається не окремим механізмом, а поєднанням сильної автентифікації, ешелонування і сегментації.

Висновки до розділу

Безпека мереж IEEE 802.11 пройшла три покоління механізмів, кожне з яких усувало вади попереднього: WEP був зламаний повністю, WPA2 запровадив надійне автентифіковане шифрування, але залишив підбір паролів персональних мереж, відсутність захисту кадрів керування і виявився вразливим до атаки повторного встановлення ключа KRACK, а WPA3 усунув ці вади через SAE, обов'язковий захист кадрів керування і OWE. Проте історія Wi-Fi показує, що навіть криптографічно надійні механізми залишаються вразливими на рівні протоколів встановлення ключів (KRACK), реалізацій (Dragonblood), обробки кадрів (FragAttacks, FramingFrames) і зворотної сумісності (атаки зниження версії). Корпоративна автентифікація на основі IEEE 802.1X і EAP-TLS забезпечує найвищу стійкість, але критично залежить від правильної конфігурації перевірки сертифікатів і від захищеності інфраструктури RADIUS, слабкості якої (BlastRADIUS) можуть звести нанівець захист радіоінтерфейсу. Атаки на кадри керування і приватність клієнтів неможливо повністю усунути протокольними засобами, тому потрібні моніторинг ефіру і мінімізація ідентифікаційних ознак. Методика захищеного проєктування поєднує сегментацію, сильну автентифікацію, цілісність інфраструктури, захист канального рівня, моніторинг і ешелонування; за принципом нульової довіри підключення до Wi-Fi не повинно саме собою давати доступ до критичних ресурсів.

Питання для самоперевірки

1. Опишіть архітектуру IEEE 802.11 (BSS, ESS, BSSID, SSID) і три фази підключення станції. Чому незахищеність кадрів керування є джерелом атак?
2. Порівняйте покоління механізмів захисту Wi-Fi (табл. 7.1) за шифруванням, цілісністю й автентифікацією. Яку ваду усуває кожне наступне покоління?
3. Опишіть чотиристоронне рукостискання. Які ключі виводяться і яку роль відіграють одноразові значення?
4. Поясніть механізм атаки KRACK. Чому надійність AES-CCMP не захищає від неї і який загальний урок це дає?
5. Чому WPA2-Personal вразливий до офлайнового підбору? Як механізми деавтентифікації і PMKID полегшують атаку?

6. Які дві властивості SAE усувають вади WPA2-Personal? Чому підбір пароля стає онлайновим і як це впливає на час атаки?
7. Опишіть три типи вразливостей Dragonblood. Чому перехідний режим WPA2/WPA3 є джерелом атак зниження версії?
8. У чому полягає атака плутанини SSID і які її можливі наслідки для клієнта?
9. Опишіть ролі й потоки повідомлень в IEEE 802.1X. Чому автентифікатор не має доступу до вмісту тунелю EAP?
10. Чому стійкість тунельних методів EAP залежить від перевірки сертифіката сервера? Як забезпечити цю перевірку на практиці?
11. У чому полягає вразливість BlastRADIUS і як захистити RADIUS-інфраструктуру?
12. Порівняйте атаки FragAttacks і FramingFrames за механізмом. Який спільний висновок вони дають щодо складності MAC-рівня?
13. Які ознаки дають змогу відстежувати клієнта попри рандомізацію MAC-адрес? Які заходи потрібні для ефективного захисту приватності?
14. Дослідницьке: спроєктуйте дерево атак на доступ до внутрішньої мережі через корпоративний Wi-Fi для конфігурації підрозділу 7.10 і кількісно оцініть ефект кожного заходу методом розділу 4.
15. Дослідницьке: запропонуйте методику експериментального оцінювання коректності конфігурації перевірки сертифіката сервера на клієнтських пристроях великої організації та метрики для моніторингу цього ризику.

РОЗДІЛ 8

Безпека технологій ближньої дії: Bluetooth, NFC, RFID та IEEE 802.15.4

Технології ближньої дії — Bluetooth і Bluetooth Low Energy, безконтактні технології NFC і RFID, надширокосмугова технологія UWB, мережі на основі IEEE 802.15.4 (Zigbee, Thread) — утворюють «останній метр» безпроводового зв'язку: через них працюють бездротові гарнітури й периферія, платіжні картки й транспортні квитки, електронні ключі й системи контролю доступу, медичні пристрої, датчики розумного будинку та промислові сенсори. Попри малу дальність, ці технології не менш вразливі, ніж мережі дальнього зв'язку: мала дальність не є засобом захисту (розділ 1), а обмежені ресурси пристроїв ускладнюють реалізацію стійкої криптографії. Розділ розглядає моделі спарювання і атаки на Bluetooth і BLE, безпеку безконтактних платежів і контролю доступу на NFC/RFID, атаки ретрансляції та захист відстані, безпеку мереж IEEE 802.15.4 і Zigbee, а також уніфікаційний стандарт Matter. Криптографічні механізми розглянуто в розділі 6, безпечне вимірювання відстані — у розділі 5, застосування в Інтернеті речей — у розділі 12.

8.1 Спільні особливості безпеки технологій ближньої дії

Технології ближньої дії поєднує низка властивостей, що визначають їхню безпеку. *Обмежені ресурси*: пристрої часто мають 8- або 16-розрядні мікроконтролери, кілобайти пам'яті й живлення від малих батарей, що обмежує застосування асиметричної криптографії і ускладнює оновлення. *Модель спарювання*: замість централізованої автентифікації використовується попереднє встановлення довіри між пристроями (спарювання), нерідко за участю людини з обмеженим інтерфейсом (кнопка, короткий код). *Фізична близькість як (хибна) основа довіри*: багато систем неявно припускають, що близький пристрій є довіреним, що робить їх уразливими до атак ретрансляції (розділ 5). *Тривалий життєвий цикл і відсутність оновлень*: замки, картки, промислові сенсори експлуатуються роками без оновлення прошивок. *Масовість*: мільярди пристроїв створюють привабливу ціль і ускладнюють відкликання скомпрометованих ключів. Ці особливості означають, що безпека технологій ближньої дії має закладатися на етапі проєктування (розділ 2) і не може покладатися на оновлення чи мережеві засоби захисту. Порівняння основних технологій наведено в табл. 8.1.

Таблиця 8.1 — Порівняння технологій ближньої дії

Технологія	Діапазон, дальність	Криптографія	Ключові загрози
Bluetooth BR/EDR	2,4 ГГц, до 100 м	AES-CCM; ECDH P-256	зниження ключа (KNOB), підміна (BIAS)
BLE	2,4 ГГц, до 100 м	AES-CCM; ECDH P-256	Just Works, відстеження, підміна (BLESA)
NFC / ISO 14443	13,56 МГц, см	від жодної до AES	клонування, ретрансляція, скімінг
UWB	6–8 ГГц, до 200 м	захищена мітка часу	(засіб захисту від ретрансляції)
IEEE 802.15.4 / Zigbee	2,4 ГГц, десятки м	AES-CCM*	введення пристроїв, єдиний ключ, глушіння

8.2 Bluetooth і Bluetooth Low Energy

8.2.1 Дві технології під однією назвою

Під назвою Bluetooth співіснують дві технічно різні системи [86]: класичний Bluetooth (BR/EDR) для потокових застосувань (аудіо, передавання файлів) і Bluetooth Low Energy (BLE) для періодичного обміну малими обсягами даних з мінімальним енергоспоживанням (носимі пристрої, датчики, маяки, локалізація). Вони мають різні фізичні рівні, різні механізми спарювання і різні набори вразливостей, хоча сучасні пристрої підтримують обидві. Класичний Bluetooth використовує стрибкоподібну зміну частоти по 79 каналах, BLE — по 40 каналах (з них 3 службові). Обидві технології працюють у діапазоні 2,4 ГГц, спільному з Wi-Fi і мікрохвильовими печами, тому вразливі до завад і глушіння (розділ 3).

8.2.2 Моделі спарювання

Спарювання встановлює спільний ключ між пристроями. Історично Bluetooth використовував спарювання на основі PIN-коду, єдиним джерелом ентропії якого був короткий (часто чотиризначний) код, що робило можливим його підбір за перехопленим спарюванням [185]. Сучасний механізм Secure Simple Pairing (SSP) і Secure Connections ґрунтуються на обміні Діффі–Геллмана на еліптичній кривій P-256, що усуває офлайновий підбір і забезпечує захист від пасивного перехоплення. Проте захист від активної атаки «людина посередині» залежить від *моделі асоціації*, яку визначають можливості введення й виведення пристроїв (табл. 8.2).

Таблиця 8.2 — Моделі асоціації Bluetooth та їх захист від атаки «людина посередині»

Модель	Механізм	Захист від MITM
Just Works	без підтвердження користувачем	відсутній
Numeric Comparison	користувач звіряє однакові числа на обох екранах	забезпечено
Passkey Entry	користувач вводить код з одного пристрою в інший	забезпечено
Out of Band	обмін даними через інший канал (NFC)	залежить від каналу

Модель Just Works, що застосовується для пристроїв без екрана й клавіатури (гарнітури, датчики), не захищає від атаки «людина посередині»: порушник може спарувати обидва пристрої з собою. Це фундаментальне обмеження — без довіреного каналу для підтвердження неможливо автентифікувати сторону, — і воно означає, що для пристроїв без інтерфейсу довіру доводиться встановлювати іншими засобами (попереднє завантаження ключів, обмеження контексту, фізичний контроль під час спарювання).

8.2.3 Атаки на узгодження параметрів

Кілька важливих атак експлуатують не криптографічні примітиви, а процедуру узгодження параметрів. Атака KNOB [72] використовує те, що специфікація дозволяла узгоджувати довжину ключа шифрування від 16 до *1* байта, причому узгодження не було захищене від модифікації. Порушник, втручаючись у спарювання, змушує обидва пристрої погодити 1-байтовий (8-бітовий) ключ, який потім підбирається миттєво. Атака вражала майже всі пристрої, оскільки була вадою стандарту; виправлення — встановлення мінімальної довжини ключа (7 байтів). Це прямий аналог атак зниження версії (розділ 1) і GSM-атаки (розділ 6): *незахищене узгодження параметрів безпеки дозволяє зниження до найслабшого варіанта.*

Атака BIAS [70] використовує вади процедури автентифікації при повторному з'єднанні вже спарених пристроїв, дозволяючи порушникові видати себе за раніше спарований пристрій без знання довготривалого ключа. Атака BLESA [71] експлуатує те, що в BLE автентифікація при повторному підключенні була необов'язковою або некоректно реалізованою, дозволяючи підміну сервера. Атака BLURtooth [73] використовує механізм перехресного виведення ключів (Cross-Transport Key Derivation), який дозволяє пристрою, спареному через один транспорт (наприклад, BLE), отримати ключі для іншого (класичного Bluetooth); порушник може перезаписати наявні ключі слабшими. Спільна риса цих атак — вразливості в *кінцевих автоматах* процедур встановлення і відновлення з'єднання, а не в крипто-

графії, що знову підкреслює цінність формальної верифікації протоколів (розділ 7).

8.2.4 Приватність BLE та відстеження

BLE широко використовується для маяків локалізації і носимих пристроїв, які періодично випромінюють повідомлення-об'яви. Якщо адреса пристрою стала, його можна відстежувати (розділ 3). Специфікація передбачає механізм періодично змінюваних випадкових адрес (resolvable private addresses), які можуть бути розпізнані лише пристроями, що мають спільний ключ ідентифікації (IRK). Проте ефективність захисту залежить від коректності реалізації: помилки в синхронізації зміни адреси з іншими ідентифікаторами (лічильниками, характеристиками) дозволяють зв'язування. Для систем, критичних до приватності (медичні пристрої, засоби відстеження контактів), потрібне ретельне проєктування з мінімізацією стабільних ідентифікаторів. Окремий ризик становлять пристрої пошуку загублених речей, які утворюють глобальну мережу локалізації: їх можна зловживати для прихованого стеження за людьми.

8.2.5 Стійкість до глушіння

Стрибкоподібна зміна частоти забезпечує BLE певну стійкість до вузькосмугових завад, а адаптивний варіант виключає уражені канали (розділ 3). Проте, як показують експериментальні дослідження стійкості маяків BLE до глушіння за участю автора посібника [267], широкосмуговий постановник завад здатний повністю заблокувати зв'язок, а мала потужність передавачів BLE (типово 0–4 дБм) робить їх особливо вразливими: за (3.7) навіть маломіцний постановник завад легко перевищує сигнал. Для критичних застосувань (медичні пристрої, сигналізація) це означає необхідність резервних каналів і виявлення факту глушіння як події безпеки.

8.2.6 Моніторинг Bluetooth

Для виявлення атак і аномалій у Bluetooth-середовищі застосовують спеціалізований аналіз трафіку. Українські дослідники запропонували інтегрований підхід до виявлення загроз у Bluetooth-протоколі, що поєднує глибокий аналіз трафіку засобом Wireshark з кореляцією подій у системі керування подіями безпеки Splunk [22]. Такий підхід дозволяє виявляти атаки на відмову в обслуговуванні, спроби підміни й аномальні спарювання; його місце в загальній системі моніторингу розглянуто в розділі 15.

8.3 Безконтактні технології: NFC та RFID

8.3.1 Класифікація і сфери застосування

Технології радіочастотної ідентифікації (RFID) і ближнього поля (NFC) охоплюють широкий спектр систем, що розрізняються за частотою і дальністю: низькочастотні (125 кГц) мітки контролю доступу і ідентифікації тварин; високочастотні (13,56 МГц) картки за стандартом ISO/IEC 14443 [179], що лежить в основі безконтактних платежів, транспортних карток і NFC у смартфонах; надвисокочастотні (860–960 МГц) мітки логістики. Малий радіус (сантиметри для ISO 14443) часто вважають гарантією безпеки, проте це хибне уявлення: дальність *приймання* і *активації* може значно перевищувати номінальну (розділ 1), а атаки ретрансляції знімають обмеження відстані взагалі.

8.3.2 Вразливості успадкованих систем

Багато масових систем контролю доступу й оплати досі використовують криптографічно слабкі технології. Картки MIFARE Classic, поширені в системах контролю доступу і транспорту, використовували закритий потоковий шифр Crypto-1 з 48-бітовим ключем; його реконструкція і криптоаналіз [145] показали, що ключ можна відновити за секунди, а картку — клонувати. Низькочастотні мітки контролю доступу часто взагалі не мають криптографії й лише передають статичний ідентифікатор, який тривіально клонувати. Ці приклади ілюструють загальний урок (розділ 6): закриті алгоритми і короткі ключі не забезпечують безпеки, а масово розгорнуті системи важко оновити. Сучасні захищені рішення (MIFARE DESFire, картки з AES) використовують стандартну криптографію і взаємну автентифікацію.

8.3.3 Безпека безконтактних платежів

Безконтактні платежі за специфікаціями EMV [118] застосовують криптографічну автентифікацію транзакцій: картка динамічно підписує дані транзакції ключем, що не залишає її, тому клонування за перехопленою транзакцією неможливе. Проте залишаються ризики: транзакції малих сум без підтвердження власника (ретрансляція для оплати чужою карткою); атаки на протокольні вади конкретних реалізацій (обхід ліміту суми, плутанина між платіжними системами); скімінг даних, доступних без автентифікації. Основним принциповим захистом від ретрансляції є обмеження відстані (розділ 5); EMV і стандарти карток поступово впроваджують такі механізми. Для мобільних платежів (гаманці у смартфонах) додається токенізація (замість номера картки використовується токен) і підтвердження власника пристроєм (біометрія, код), що суттєво знижує ризики.

8.4 Атаки ретрансляції та безпека відстані

Атаки ретрансляції (розділ 5) є центральною загрозою для всіх систем ближньої дії, що ухвалюють рішення на основі близькості: безконтактних карток [159], систем безключового доступу автомобілів [142], електронних замків, платежів. Порушник розміщує два пристрої — один біля жертви (картки, ключа), другий біля термінала (замка, автомобіля) — і ретранслює сигнали, створюючи ілюзію близькості. Криптографічна автентифікація безсила, бо порушник не змінює повідомлень.

Схему атаки ретрансляції на систему безключового доступу наведено на рис. 8.1.

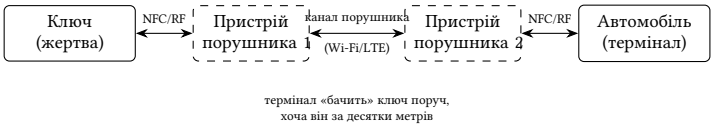


Рис. 8.1 — Атака ретрансляції на систему безключового доступу

Оцінимо можливість атаки. Ретрансляція вносить додаткову затримку $\Delta t_{\text{ретр}}$, зумовлену обробкою й передаванням через канал порушника. Якщо система вимірює час обходу і відкидає відповіді, що перевищують поріг $\Delta t_{\max}$, то атака неможлива за умови

$$\Delta t_{\text{ретр}} > \Delta t_{\max} - \Delta t_{\text{легіт}}, \tag{8.1}$$

де $\Delta t_{\text{легіт}}$ — час обходу для легітимної близької взаємодії. Проблема успадкованих систем у тому, що вони або взагалі не вимірюють час, або мають надто великий поріг (мілісекунди), тоді як ретрансляція вносить лише мікросекунди затримки. Принциповий захист — протоколи обмеження відстані з наносекундною точністю на основі UWB (розділ 5): стандарт IEEE 802.15.4z [174] забезпечує захищене вимірювання відстані, на якому будуються сучасні цифрові автомобільні ключі й безпечний контроль доступу. Проміжні заходи для наявних систем: обмеження суми транзакцій без підтвердження, вимога дії користувача (натискання кнопки на ключі, розблокування смартфона), екранування карток, коли вони не використовуються, зменшення часу активності.

8.5 Мережі IEEE 802.15.4, Zigbee і Thread

8.5.1 Архітектура і механізми безпеки

Стандарт IEEE 802.15.4 [173] визначає фізичний і канальний рівні малопотужних персональних мереж, на яких будуються Zigbee, Thread і промислові протоколи. Він передбачає шифрування й автентифікацію кадрів че-

рез AES-CCM* з ключами 128 біт (розділ 6). Zigbee [290] додає мережевий і прикладний рівні з підтримкою комірчастої топології, у якій пристрої-маршрутизатори ретранслюють кадри, розширюючи покриття. Безпека Zigbee ґрунтується на трьох типах ключів: мережевому (спільному для всієї мережі), ключі зв'язку (між парами пристроїв) і головному ключі. Критичним елементом є **довірчий центр** (координатор), який керує розподілом ключів і допуском пристроїв до мережі.

8.5.2 Проблема введення пристроїв у мережу

Найвразливіший момент — **введення** нового пристрою в мережу (commissioning), коли передається мережевий ключ. Історично Zigbee для сумісності використовував відомий стандартний ключ введення, унаслідок чого перехоплення обміну під час приєднання пристрою розкривало мережевий ключ. Це системна вада: єдиний мережевий ключ означає, що компрометація будь-якого пристрою або перехоплення одного приєднання розкриває захист усієї мережі. Zigbee 3.0 запровадив індивідуальні ключі встановлення (unique install codes) на основі попередньо надрукованого на пристрої коду, що усуває найгострішу ваду, але сумісність зі старими пристроями залишає ризик.

8.5.3 Атаки на комірчасті мережі та ланцюгова реакція

Ронен, Шамір та співавтори [249] продемонстрували атаку «ядерної ланцюгової реакції» на розумні лампи Zigbee: використавши вразливість у процедурі оновлення прошивки (недостатню перевірку автентичності й прив'язки до мережі), вони показали можливість поширення шкідливої прошивки від лампи до лампи, коли щільність пристроїв перевищує критичний поріг. За моделлю поширення в мережі, аналогічною епідемічним моделям, якщо кожен заражений пристрій у середньому заражає більш ніж один інший, зараження охоплює всю мережу:

$$R_0 = \rho \, \pi r^2 > 1, \tag{8.2}$$

де ρ — щільність вразливих пристроїв на одиницю площі; r — радіус зараження. Механізм поширення в комірчастій мережі ілюструє рис. 8.2.

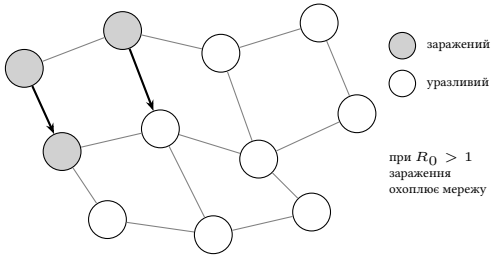


Рис. 8.2 — Поширення зараження в комірчастій мережі пристроїв (за [249])

Ця робота — показовий приклад того, як обмежені ресурси (слабка перевірка оновлень), масовість і комірчаста топологія поєднуються в системний ризик, що не зводиться до вразливості окремого пристрою. Захист — сувора автентифікація і прив'язка оновлень прошивки до мережі (розділ 6), обмеження радіусу дії, сегментація.

8.5.4 Уніфікація: Matter

Фрагментація екосистеми розумного будинку (несумісні протоколи, різні моделі безпеки) призвела до створення стандарту Matter [202], що працює поверх Thread (на основі IEEE 802.15.4) і Wi-Fi. Matter запроваджує уніфіковану модель безпеки: кожен пристрій має унікальний сертифікат виробника (Device Attestation Certificate), що дозволяє перевірити його автентичність під час введення; введення захищене протоколом на основі узгодження ключа з підтвердженням; зв'язок між пристроями автентифікований і зашифрований; підтримується безпечне оновлення прошивок. Matter є прикладом застосування сучасних принципів (сертифікація пристроїв, безпека за замовчуванням, стандартна криптографія) до масової споживчої технології і відповідає вимогам регуляторів до споживчих пристроїв Інтернету речей (розділ 2). Питання безпеки Інтернету речей у ширшому контексті розглянуто в розділі 12.

8.6 Кейс: захист системи контролю доступу організації

Організація використовує систему контролю фізичного доступу на безконтактних картках і планує її модернізацію. Аналіз на основі матеріалу розділу.

Наявний стан. Картки MIFARE Classic зі статичною автентифікацією, зчитувачі без вимірювання часу, єдиний секрет сектора для всіх карток. Ризики: клонування картки за секунди після короткого контакту зі зчитувачем або карткою жертви [145]; атака ретрансляції для проходу без фізичного володіння карткою; компрометація одного секрету розкриває всю систему.

Модель загроз. Порушники: зовнішній з портативним зчитувачем (скімінг у транспорті, ліфті); інсайдер, що клонує картки; порушник, що здійснює ретрансляцію біля входу. Найвищий ризик — клонування через слабку криптографію (реальний, дешевий, масштабований).

Заходи. (1) Заміна карток на MIFARE DESFire з AES і взаємною автентифікацією або на рішення на основі мобільних облікових даних у захищеному елементі смартфона. (2) Диверсифікація ключів: кожна картка має унікальний ключ, виведений з головного ключа й ідентифікатора картки, тому компрометація однієї картки не розкриває інших. (3) Для критичних зон — багатофакторність (картка + PIN або біометрія) і зчитувачі з протоколом обмеження відстані на основі UWB для захисту від ретрансляції. (4) Мобільні облікові дані з підтвердженням власника пристроєм для захисту від використання загубленого носія. (5) Моніторинг аномалій (одна картка у двох місцях, масові невдалі спроби) — розділ 15.

Обґрунтування послідовності. За методикою розділу 4 першочерговою є заміна криптографічно слабких карток (усуває найімовірнішу атаку), потім — захист від ретрансляції для критичних зон (де вплив найвищий). Повне усунення ретрансляції для всіх зон економічно недоцільне; для звичайних зон достатньо організаційних заходів (екранування, скорочення часу активності) і моніторингу. Кейс ілюструє загальний принцип: безпека технологій ближньої дії визначається найслабшою ланкою (криптографія картки), а фізична близькість не є засобом захисту.

Висновки до розділу

Технології ближньої дії, попри малу дальність, потребують повноцінного захисту: мала дальність не запобігає перехопленню, а атаки ретрансляції знімають обмеження відстані взагалі. Bluetooth і BLE еволюціонували від вразливого спарювання на основі короткого PIN до узгодження ключа на еліптичних кривих, проте захист від атаки «людина посередині» залежить від моделі асоціації, а пристрої без інтерфейсу (модель Just Works) залишаються принципово вразливими. Атаки KNOB, BIAS, BLESA і BLURtooth показали, що основним джерелом вразливостей є не криптографічні примітиви, а незахищене узгодження параметрів і вади кінцевих автоматів встановлення й відновлення з'єднання, зокрема можливість зниження довжини ключа. Безконтактні технології NFC і RFID містять як криптографічно слабкі успадковані системи (MIFARE Classic, статичні мітки), так і надійні рішення (EMV, DESFire, токенізовані мобільні платежі); центральною загрозою залишаються атаки ретрансляції, принциповий захист від яких дає лише вимірювання відстані на основі UWB. Мережі IEEE 802.15.4 і Zigbee вразливі насамперед на етапі введення пристроїв і через єдиний мережевий ключ, а комбінація масовості, слабких оновлень і комірчастої топології здатна по-

роджувати системні ризики масштабу всієї мережі. Стандарт Matter застосовує сучасні принципи — сертифікацію пристроїв, безпеку за замовчуванням, стандартну криптографію — до споживчої екосистеми. Спільний висновок: безпека технологій ближньої дії має закладатися на етапі проєктування, спиратися на стандартну криптографію з диверсифікацією ключів і не покладатися на фізичну близькість як гарантію.

Питання для самоперевірки

1. Які спільні особливості визначають безпеку технологій ближньої дії? Чому мала дальність не є засобом захисту?
2. Порівняйте класичний Bluetooth і BLE за призначенням, фізичним рівнем і сферами застосування. Чому вони мають різні набори вразливостей?
3. Опишіть моделі асоціації Bluetooth (табл. 8.2). Чому модель Just Works не захищає від атаки «людина посередині» і як установлюють довіру для пристроїв без інтерфейсу?
4. Поясніть механізм атаки KNOB. Яку загальну ваду вона ілюструє і як вона пов'язана з атаками на GSM і Wi-Fi?
5. Порівняйте атаки BIAS, BLESA і BLURtooth за механізмом. Який спільний висновок вони дають щодо процедур встановлення й відновлення з'єднання?
6. Які механізми забезпечують приватність BLE-пристроїв? Чому їх ефективність залежить від коректності реалізації?
7. Чому маяки BLE особливо вразливі до глушіння? Які заходи потрібні для критичних застосувань?
8. Класифікуйте технології RFID/NFC за частотою і дальністю. Чому малий радіус не гарантує безпеки?
9. Порівняйте безпеку MIFARE Classic і безконтактних платежів EMV. Чому клонування картки EMV за перехопленою транзакцією неможливе?
10. Поясніть механізм атаки ретрансляції та умову (8.1), за якої вона неможлива. Чому успадковані системи вразливі, а UWB забезпечує захист?
11. Опишіть типи ключів у Zigbee і проблему введення пристроїв у мережу. Чому єдиний мережевий ключ є системною вадою?
12. Поясніть механізм «ланцюгової реакції» в мережі Zigbee та умову (8.2). Які заходи запобігають такому поширенню?

13. Які принципи безпеки запроваджує стандарт Matter? Як вони відповідають вимогам регуляторів до споживчих пристроїв Інтернету речей?
14. Дослідницьке: спроєктуйте протокол безпечного введення пристрою без інтерфейсу в мережу розумного будинку, що не покладається на модель Just Works, і оцініть його стійкість до атаки «людина посередині».
15. Дослідницьке: розробіть методику експериментального оцінювання реальної дальності активації та ретрансляції для безконтактної картки контролю доступу і визначте вимоги до порогу вимірювання часу для захисту від ретрансляції.

РОЗДІЛ 9

Безпека стільникових мереж 2G–4G та сигнальної інфраструктури

Стільникові мережі другого–четвертого поколінь (GSM, UMTS, LTE) обслуговують більшість голосового трафіку і значну частину передавання даних, і залишатимуться в експлуатації ще багато років через величезну базу пристроїв і покриття. Їхня безпека визначається двома взаємопов'язаними, але різними за природою складовими: захистом *радіоінтерфейсу* між терміналом і базовою станцією та захистом *сигнальної інфраструктури* — протоколів SS7 і Diameter, якими обмінюються мережі операторів. Історично основну увагу приділяли радіоінтерфейсу, тоді як сигнальна мережа будувалася на припущенні взаємної довіри операторів, що виявилося хибним і призвело до можливості визначення місцезнаходження абонентів, перехоплення повідомлень і викликів у глобальному масштабі. Розділ розглядає еволюцію архітектури безпеки від GSM до LTE, автентифікацію й ієрархію ключів, атаки на радіоінтерфейс (фальшиві базові станції, атаки канального рівня), уразливості сигнальних мереж SS7 і Diameter, а також заходи захисту й український контекст. Криптографічні алгоритми розглянуто в розділі 6, мережі 5G — у розділі 10.

9.1 Еволюція архітектури безпеки

9.1.1 Складові безпеки стільникової мережі

Безпека стільникової мережі складається з кількох доменів (розділ 1): безпека доступу (автентифікація абонента й мережі, шифрування і цілісність радіоінтерфейсу), безпека мережевого домену (захист сигналізації між елементами мережі й між операторами), безпека користувацького домену (захист доступу до USIM), безпека застосунків. Історична еволюція — це поступове усунення вад у кожному з доменів, узагальнене в табл. 9.1.

Таблиця 9.1 — Еволюція механізмів безпеки стільникових мереж

Покоління	Автентифікація	Радіоінтерфейс і вади
GSM (2G)	одностороння (мережа автентифікує абонента)	A5/1, A5/2; фальшиві базові станції; IMSI відкрито; кодування до шифрування
UMTS (3G)	взаємна (AKA); захист цілісності сигналізації	KASUMI (f8/f9); залишкові витоки ідентифікаторів
LTE (4G)	взаємна (EPS-AKA); ієрархія ключів	AES/SNOW/ZUC; немає захисту цілісності користувацької площини

9.1.2 GSM: успадковані вади

Архітектура безпеки GSM [64] мала три концептуальні вади, незалежні від криптографічної слабкості алгоритмів (розділ 6). По-перше, *одностороння автентифікація*: мережа перевіряє абонента, але абонент не перевіряє мережу, що уможливлює фальшиві базові станції. По-друге, *відкрите передавання постійного ідентифікатора* IMSI за певних умов, що дозволяє його перехоплення. По-третє, *відсутність захисту цілісності сигналізації*, що дозволяє маніпуляцію службовими повідомленнями, зокрема командою вимкнути шифрування. Ці вади зумовили цілий клас атак фальшивими базовими станціями («IMSI-кетчери»), які й донині працюють, змушуючи термінали переходити в GSM.

9.1.3 UMTS і LTE: взаємна автентифікація та ієрархія ключів

UMTS запровадив протокол AKA із взаємною автентифікацією (розділ 6): термінал перевіряє маркер AUTN, що містить код автентифікації мережі й лічильник послідовності, чим захищається від фальшивої базової станції, яка не знає ключа абонента. Додано захист цілісності сигналізації (алгоритм f9/KASUMI). LTE розвинув ці механізми: запроваджено багаторівневу ієрархію ключів (розділ 6), що забезпечує ізоляцію компрометації базових станцій, і розділення захисту сигналізації рівня без доступу до радіоресурсів (NAS) і рівня керування радіоресурсами (RRC). Проте LTE зберіг критичну ваду: *захист цілісності користувацької площини не передбачений*, що уможливило атаки маніпуляції трафіком (підрозділ 9.3). Крім того, початкові процедури (до встановлення контексту безпеки) залишаються незахищеними, що є джерелом атак на приватність і доступність.

9.2 Автентифікація і керування ідентифікаторами

Абонент ідентифікується постійним ідентифікатором IMSI (International Mobile Subscriber Identity), що зберігається в USIM і в реєстрі домашньої мережі [52]. Для захисту приватності мережа призначає тимчасові ідентифікатори (TMSI в 2G/3G, GUTI в 4G), які використовуються замість IMSI

у більшості обмінів і періодично оновлюються. Проте механізм має вади: за певних умов (перша реєстрація, збій, запит мережі) термінал передає IMSI відкрито; недостатньо часте оновлення тимчасового ідентифікатора дозволяє його зв'язування; помилки синхронізації лічильника послідовності SQN у процедурі AKA можуть використовуватися для відстеження (мережа розкриває, чи «знайомий» їй абонент). Ці вади усунено лише в 5G шифруванням постійного ідентифікатора (розділ 10), а для 4G і раніше вони залишаються.

Ідентифікатор обладнання IMEI ідентифікує термінал незалежно від абонента. Він використовується для блокування вкрадених апаратів через спільну базу, але його передавання також є ідентифікаційною ознакою. Довготривалий ключ K абонента ніколи не залишає USIM і домашню мережу; його компрометація (через витік бази ключів оператора, атаку на ланцюг постачання SIM-карток або витік ключів у процесі персоналізації) є катастрофічною подією, бо дозволяє клонування й дешифрування, і не виявляється звичайними засобами. Тому захист інфраструктури керування ключами абонентів (центрів автентифікації, процесів персоналізації) є пріоритетом безпеки оператора (розділ 4).

9.3 Атаки на радіоінтерфейс

9.3.1 Фальшиві базові станції

Фальшива базова станція (у літературі — IMSI-catcher, stingray) імітує легітимну базову станцію оператора з привабливими параметрами (висока потужність сигналу, пріоритетна комірка), змушуючи термінали в зоні дії підключитися до неї. Механізм ґрунтується на тому, що термінал обирає комірку за силою сигналу і системною інформацією, яка передається *відкрито й без автентифікації* (розділ 1). Після підключення фальшива станція може: запитати IMSI (деанонімізація й визначення присутності конкретного абонента в зоні); змусити термінал знизити версію до GSM без взаємної автентифікації і перехопити трафік; здійснити відмову в обслуговуванні (не надати послугу, «відкинути» термінал у заборонену зону). У 2G атака особливо ефективна через односторонню автентифікацію; у 3G/4G взаємна автентифікація захищає від перехоплення трафіку, але *початкові* незахищені повідомлення все одно дозволяють деанонімізацію й атаки на доступність [258].

Схему атаки фальшивою базовою станцією зі зниженням версії наведено на рис. 9.1.

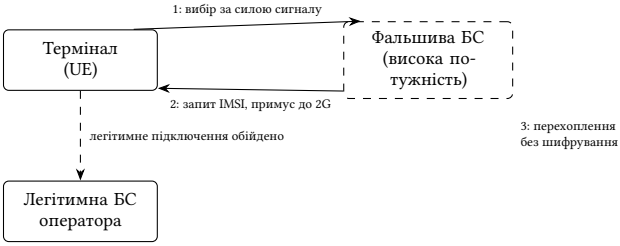


Рис. 9.1 — Атака фальшивою базовою станцією зі зниженням версії

Виявлення фальшивих базових станцій ґрунтується на аналізі аномалій параметрів мережі (розділ 15): невідповідність ідентифікаторів комірок відомій топології, аномально висока потужність, відсутність сусідніх комірок, примус до 2G, незвичні запити ідентифікаторів. Радикальний захід — вимкнення підтримки 2G у терміналі, що усуває найвразливіший режим; сучасні мобільні платформи надають таку опцію.

9.3.2 Атаки канального рівня LTE

Оскільки LTE не захищає цілісність користувацької площини, Руппрехт та співавтори [251] показали атаку aLTEr: порушник-ретранслятор («людина посередині» на радіорівні) може маніпулювати зашифрованим трафіком, змінюючи біти, оскільки шифрування в режимі лічильника не захищає від модифікації без коду цілісності (розділ 6). Це дозволяє, зокрема, перенаправлення DNS-запитів і трафіку жертви. Атака IMP4GT [252] розвинула цей результат до повного видавання себе за абонента в обох напрямках. Ці атаки складні в реалізації (потребують ретранслятора поблизу жертви), але принципові: вони показують, що відсутність захисту цілісності одного домену (користувацької площини) не компенсується захистом інших. У 5G захист цілісності користувацької площини запроваджено (опційно), що усуває клас цих атак (розділ 10).

Ще один клас — атаки, що використовують незахищені широкомовні й службові повідомлення для визначення присутності й приблизного місцезнаходження абонента через процедуру пошуку (paging): знаючи, коли мережа шукає конкретного абонента, порушник може співвіднести це з дією (наприклад, дзвінком) і визначити зону місцезнаходження [194, 148]. Ці атаки не потребують дорогого обладнання і використовують фундаментальну властивість — необхідність незахищеної сигналізації до встановлення контексту безпеки.

9.4 Безпека сигнальної інфраструктури

9.4.1 SS7: спадок довіреного «клубу»

Система сигналізації № 7 (SS7) розроблялася в 1970–1980-х роках для взаємодії між обмеженим колом державних і великих операторів у припущенні *взаємної довіри*: будь-яке повідомлення з мережі-партнера вважалося легітимним. З лібералізацією ринку й появою тисяч операторів, віртуальних операторів і посередників це припущення стало хибним: доступ до сигнальної мережі отримали численні учасники, а деякі — і зловмисники. Енгель [121] та інші дослідники продемонстрували, що через SS7 порушник, який має доступ до сигнальної мережі, може: визначати місцезнаходження абонента в будь-якій точці світу за його номером (запит до реєстру місцезнаходження); перехоплювати SMS (зокрема одноразові коди автентифікації) через маніпуляцію маршрутизацією; перехоплювати й переадресовувати виклики; здійснювати відмову в обслуговуванні. Ці можливості не потребують доступу до радіоінтерфейсу й діють глобально.

Схему сигнальної атаки визначення місцезнаходження наведено на рис. 9.2: порушник з доступом до сигнальної мережі надсилає запит до реєстру домашньої мережі жертви від імені нібито обслуговувального оператора, і мережа, довіряючи запиту, повертає ідентифікатор комірки, у якій перебуває абонент.

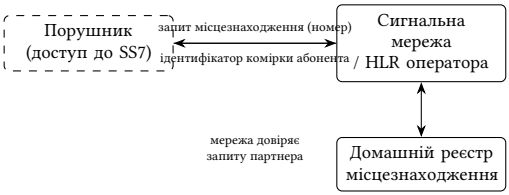


Рис. 9.2 — Сигнальна атака визначення місцезнаходження через SS7 (за [121])

Особливу небезпеку становить перехоплення SMS з одноразовими кодами: багато систем (банки, месенджери) використовують SMS як другий фактор автентифікації, тому доступ до SS7 дозволяє обходити цей захист і викрадати кошти й акаунти. Це прямий аргумент проти використання SMS як фактора автентифікації для критичних систем (розділ 11).

9.4.2 Diameter: ті самі проблеми в новому протоколі

LTE замінив SS7 на протокол Diameter для сигналізації, проте архітектурна проблема залишилася: Diameter теж будувався в припущенні довіри між операторами, і без додаткового захисту дозволяє аналогічні атаки — визначення місцезнаходження, перехоплення, відмову в обслуговуванні [239].

Diameter працює поверх IP, що, з одного боку, дозволяє застосувати IP-захист (IPsec, TLS), а з іншого — розширює поверхню атаки. ENISA в оцінці безпеки сигналізації [125] констатувала, що вразливості SS7 і Diameter є системними для галузі й потребують скоординованих заходів. Огляд систем управління мобільними мережами, зокрема питань їх безпеки, наведено в [13].

9.4.3 Модель ризику сигнальних атак

Особливість сигнальних атак — джерело загрози перебуває поза мережею оператора (в мережах партнерів або посередників), а шкоди зазнають переважно абоненти (розділ 4). Оцінимо очікувану кількість успішних запитів місцезнаходження. Нехай оператор має P роумінгових партнерів, з яких частка ϕ скомпрометована або зловмисна, кожен генерує λ шкідливих запитів на добу, а сигнальний міжмережевий екран блокує частку η таких запитів. Тоді кількість успішних атак на добу

$$N = P\,\phi\,\lambda\,(1-\eta). \tag{9.1}$$

Для $P = 600$, $\phi = 0{,}02$, $\lambda = 50$ і $\eta = 0$ (без захисту) $N = 600$ успішних запитів на добу; сигнальний міжмережевий екран з $\eta = 0{,}95$ знижує їх до 30, а вдосконалена система з аналізом поведінки і $\eta = 0{,}99$ — до 6. Формула показує, що навіть високоефективний фільтр не усуває ризик повністю, тому потрібне поєднання фільтрації з моніторингом і, для критичних застосувань, відмова від SMS-автентифікації.

Основні класи сигнальних атак та заходи протидії узагальнено в табл. 9.2.

Таблиця 9.2 — Класи сигнальних атак і заходи протидії

Клас атаки	Механізм і наслідок	Протидія
Визначення місцезнаходження	запит до реєстру від імені партнера; розкриття комірки	фільтрація запитів за станом абонента
Перехоплення SMS/викликів	маніпуляція маршрутизацією; обхід 2FA	блокування аномальних оновлень маршруту; відмова від SMS-2FA
Відмова в обслуговуванні	скасування реєстрації, вставлення хибних станів	перевірка узгодженості, обмеження частоти
Шахрайство з тарифікацією	маніпуляція записами про послуги	кореляція, аудит

9.4.4 Захист сигнальних мереж

Основні заходи захисту сигнальної інфраструктури [155, 154]: **сигнальний міжмережевий екран** (Signalling Firewall), що аналізує вхідні повідомлення й блокує неприпустимі (наприклад, запит місцезнаходження від мережі, у якій абонент не перебуває в роумінгу; повідомлення, що надходять із неправильного напрямку; аномальні послідовності); категоризація повідомлень за рівнями небезпеки; фільтрація на основі того, чи узгоджується повідомлення з поточним станом абонента; моніторинг і кореляція для виявлення розподілених атак; захист Diameter через IPsec/TLS між партнерами. Ці заходи є частиною вимог до кіберзахисту операторів (розділ 2) і елементом системи моніторингу (розділ 15). Кардинальне розв'язання проблеми — перехід до архітектури 5G із захищеною міжоператорською взаємодією (розділ 10), проте через зворотну сумісність і повільне оновлення сигнальні ризики залишатимуться актуальними ще тривалий час.

9.5 Приватність і законне перехоплення

Стільникові мережі за своєю природою знають місцезнаходження абонента (з точністю до комірки, а під час активного зв'язку — точніше) і зберігають метадані з'єднань. Це створює подвійне питання: захист цих даних від зловмисників (сигнальні атаки, компрометація оператора) і регулювання законного доступу до них. Законне перехоплення — нормативно регламентований доступ уповноважених органів до трафіку й метаданих за встановленою процедурою — вбудоване в архітектуру мереж і є однією з причин, чому шифрування захищає лише радіоінтерфейс, а не є наскрізним: оператор має доступ до відкритого трафіку. Це означає, що для захисту від компрометації самого оператора або зловживання доступом користувачам

потрібне наскрізне шифрування на рівні застосунків (месенджери, VPN), незалежне від мережі. Баланс між законним перехопленням, приватністю абонентів і захистом від зловживань є предметом нормативного регулювання (розділ 2) і має враховуватися в моделі загроз (розділ 4).

9.6 Український контекст

Для України безпека стільникових мереж 2G–4G має особливе значення з кількох причин. *Велика база 2G*: значна частина пристроїв Інтернету речей (лічильники, сигналізація, термінали оплати) і територій покриття досі покладається на 2G, що зберігає вразливість до фальшивих базових станцій і слабкого шифрування; поступове виведення 2G має балансувати безпеку і доступність послуг. *Сигнальні загрози в умовах війни*: держава-агресор має ресурси і мотивацію використовувати сигнальні атаки для визначення місцезнаходження осіб, перехоплення повідомлень і порушення зв'язку, тому захист сигнальної інфраструктури й обмеження роумінгових зв'язків із мережами агресора є питанням національної безпеки. *Фальшиві базові станції поблизу лінії зіткнення*: використовуються для деанонімізації, поширення дезінформації через масові SMS і визначення скупчень абонентів. *Відмова від SMS-автентифікації*: з огляду на сигнальні ризики й можливість перехоплення, критичні системи (банки, державні сервіси) мають переходити на стійкіші фактори (застосунки-автентифікатори, апаратні ключі) — розділ 11. Координацію заходів захисту здійснюють Держспецзв'язку [6] і CERT-UA [93] у взаємодії з операторами; загальні заходи стійкості мереж розглянуто в розділі 16.

9.7 Кейс: захист абонентів оператора від сигнальних і радіоатак

Оператор, віднесений до об'єктів критичної інфраструктури, розробляє програму захисту абонентів. Пріоритезація за методикою розділу 4.

Загрози й вплив. (1) Визначення місцезнаходження й перехоплення SMS через SS7/Diameter — високий вплив (зокрема на осіб під захистом), джерело поза мережею. (2) Фальшиві базові станції — деанонімізація, перехоплення в 2G, дезінформація. (3) Атаки канального рівня LTE — складні, але можливі для цільових осіб. (4) Компрометація центру автентифікації — катастрофічний, але малоймовірний сценарій.

Заходи й обґрунтування. (1) Сигнальний міжмережевий екран для SS7 і Diameter з моніторингом — першочерговий: за (9.1) знижує найімовірнішу масову загрозу на 1–2 порядки. (2) Обмеження й посилений контроль роумінгових зв'язків із мережами високого ризику. (3) Поступове виведення 2G з пріоритетним відключенням у чутливих районах і рекомендаціями абонентам вимикати 2G у терміналах. (4) Заохочення переходу критичних сервісів від SMS-автентифікації до застосунків-автентифікаторів. (5) Захист

центру автентифікації: апаратні модулі безпеки, сегментація, контроль доступу, аудит процесів персоналізації SIM. (6) Моніторинг фальшивих базових станцій через аналіз даних мережі й краудсорсинг від терміналів (розділ 15).

Залишковий ризик. Повне усунення сигнальних атак неможливе через глобальну природу мереж і зворотну сумісність; повне виведення 2G обмежене доступністю послуг. Тому частина ризику приймається явно з компенсацією через моніторинг, інформування абонентів і незалежне наскрізне шифрування критичних застосунків. Кейс ілюструє ключовий висновок розділу: безпека стільникових мереж визначається не лише радіоінтерфейсом, а й захищеністю сигнальної інфраструктури, джерела загроз якої перебувають поза контролем оператора.

Висновки до розділу

Безпека стільникових мереж 2G–4G складається з двох різних за природою частин: захисту радіоінтерфейсу і захисту сигнальної інфраструктури. Радіоінтерфейс еволюціонував від односторонньої автентифікації й слабкого шифрування GSM до взаємної автентифікації AKA, захисту цілісності сигналізації та ієрархії ключів LTE, проте зберіг критичні вади: незахищені початкові повідомлення, що уможливлюють фальшиві базові станції й атаки на приватність, і відсутність захисту цілісності користувацької площини, що уможливлює атаки канального рівня aLTEr та IMP4GT. Сигнальна інфраструктура SS7 і Diameter будувалася в припущенні взаємної довіри операторів, яке стало хибним, унаслідок чого порушник із доступом до сигнальної мережі може глобально визначати місцезнаходження абонентів, перехоплювати SMS і виклики без доступу до радіоінтерфейсу; це робить SMS ненадійним фактором автентифікації. Захист сигнальних мереж через міжмережеві екрани й моніторинг знижує, але не усуває ризик, джерело якого перебуває поза мережею оператора, а шкоди зазнають абоненти. Для України ці питання загострені воєнним контекстом: сигнальні атаки й фальшиві базові станції використовуються державою-агресором, що вимагає захисту сигнальної інфраструктури, обмеження роумінгу з мережами агресора, поступового виведення вразливого 2G і відмови критичних сервісів від SMS-автентифікації. Кардинальне розв'язання частини проблем дає архітектура 5G, проте через зворотну сумісність вразливості 2G–4G залишатимуться актуальними ще тривалий час.

Питання для самоперевірки

1. Назвіть домени безпеки стільникової мережі. Яка складова історично була найменш захищеною і чому?

2. Які три концептуальні вади GSM не залежали від криптографічної слабкості алгоритмів? До яких атак вони призводять?
3. Як взаємна автентифікація AKA захищає від фальшивих базових станцій? Чому цей захист не поширюється на початкові процедури?
4. Яку критичну ваду захисту зберіг LTE? Які атаки вона уможливлює?
5. Опишіть механізм керування ідентифікаторами абонента (IMSI, TMSI/GUTI). Які вади дозволяють відстеження й у якому поколінні їх усунуто?
6. Чому компрометація довготривалого ключа K є катастрофічною і чому вона не виявляється звичайними засобами? Які заходи захищають інфраструктуру ключів?
7. Опишіть механізм роботи фальшивої базової станції. Чому вимкнення 2G у терміналі є ефективним заходом?
8. Поясніть атаку aLTEr. Як вона пов'язана з відсутністю захисту цілісності користувацької площини і з властивостями режиму лічильника (розділ 6)?
9. Чому SS7 дозволяє глобальні атаки на визначення місцезнаходження й перехоплення SMS? Яке хибне припущення лежить в основі проблеми?
10. Чому перехід на Diameter не усунув сигнальних вад? Які можливості дає й які ризики створює робота Diameter поверх IP?
11. За формулою (9.1) обчисліть кількість успішних сигнальних атак на добу для $P = 800$, $\phi = 0{,}015$, $\lambda = 40$ і $\eta = 0{,}98$. Чому фільтр не усуває ризик повністю?
12. Які заходи захищають сигнальну інфраструктуру? Чому потрібне поєднання фільтрації з моніторингом і відмовою від SMS-автентифікації?
13. Чому шифрування в стільникових мережах захищає лише радіоінтерфейс? Що з цього випливає для захисту від компрометації оператора?
14. Дослідницьке: спроєктуйте систему виявлення фальшивих базових станцій на основі краудсорсингу даних від терміналів і визначте ознаки, поріг і очікувану частку хибних тривог за методикою розділу 3.
15. Дослідницьке: розробіть модель ризику для абонентів під захистом в умовах воєнного стану, що враховує сигнальні атаки, фальшиві базові станції й радіомоніторинг, і запропонуйте комплекс технічних та організаційних заходів.

РОЗДІЛ 10

Безпека мереж 5G та приватність абонентів

Мережі п'ятого покоління (5G) є не просто швидшим наступником LTE, а зміною архітектурної парадигми: сервісно-орієнтоване ядро на основі віртуалізованих мережевих функцій, розділення мережі на логічні зрізи під різні сценарії, відкрита архітектура радіодоступу, підтримка мільярдів пристроїв Інтернету речей і критичних застосувань із наднизькою затримкою. Ця архітектура усуває низку вад попередніх поколінь (розділ 9): шифрування постійного ідентифікатора абонента, захищена міжоператорська взаємодія, опційний захист цілісності користувацької площини. Водночас вона створює нові поверхні атаки: віртуалізацію, оркестрацію, програмні інтерфейси між функціями, залежність від постачальників. Розділ розглядає архітектуру безпеки 5G, приховування ідентифікатора абонента і формальний аналіз протоколу автентифікації, безпеку сервісно-орієнтованого ядра й міжоператорської взаємодії, мережеві зрізи, відкриту архітектуру радіодоступу, залишкові загрози приватності й перспективи 6G. Криптографічні механізми та ієрархію ключів розглянуто в розділі 6, нормативні вимоги до 5G — у розділі 2.

10.1 Архітектурні зміни та їх безпекові наслідки

10.1.1 Сервісно-орієнтована архітектура ядра

Ядро 5G (5G Core) побудоване не як набір спеціалізованих вузлів із фіксованими інтерфейсами (як у LTE), а як сукупність **мережевих функцій**, що надають і споживають послуги через уніфікований інтерфейс на основі вебтехнологій (HTTP/2 [82], REST, JSON). Функції керування доступом і мобільністю (AMF), сеансами (SMF), автентифікацією (AUSF), даними абонентів (UDM) взаємодіють через сервісний інтерфейс, а спеціальна функція (NRF) забезпечує їх виявлення й авторизацію. Ця модель дає гнучкість, але переносить у телеком-ядро всі загрози вебсервісів і хмарних середовищ: атаки на програмні інтерфейси, некоректну авторизацію між функціями, вразливості в маркерах доступу. Безпека сервісного інтерфейсу забезпечується взаємним TLS між функціями й авторизацією на основі маркерів OAuth 2.0, які видає NRF [58].

10.1.2 Віртуалізація та хмаризація

Мережеві функції 5G реалізуються як програмне забезпечення на віртуалізованій інфраструктурі (віртуальні машини, контейнери), керованій оркестратором. Це означає, що безпека мережі залежить від безпеки платформи

віртуалізації, оркестрації й ланцюга постачання програмного забезпечення (розділ 12 щодо контейнерів у ширшому контексті). Загрози: компрометація гіпервізора чи оркестратора дає контроль над багатьма функціями; побічні канали між віртуальними функціями на спільному обладнанні; вразливості в образах контейнерів; атаки на площину керування. Програмно-конфігуровані мережі, що лежать в основі транспорту 5G, мають власні загрози, пов'язані з централізованим контролером [47]. Розділення площин керування й даних, мікросегментація й моніторинг є ключовими заходами (розділи 11, 15).

10.1.3 Порівняння з попередніми поколіннями

Основні зміни безпеки 5G щодо LTE узагальнено в табл. 10.1.

Таблиця 10.1 — Порівняння механізмів безпеки LTE і 5G

Механізм	LTE	5G
Ідентифікатор абонента	IMSI (відкрито за умов)	SUCI (шифрований відкритим ключем)
Автентифікація	EPS-AKA	5G-AKA, EAP-AKA', EAP-TLS
Цілісність користувацької площини	відсутня	опційна
Міжоператорська взаємодія	Diameter (довіра)	SEPP, захист N32
Ядро	спеціалізовані вузли	сервісні функції, TLS+OAuth
Радіодоступ	закритий	також відкритий (O-RAN)

10.2 Приховування ідентифікатора абонента

Однією з найважливіших змін 5G є усунення відкритого передавання постійного ідентифікатора. Постійний ідентифікатор SUPI (аналог IMSI) ніколи не передається радіоінтерфейсом у відкритому вигляді. Замість нього термінал обчислює **прихований ідентифікатор** SUCI, шифруючи частину SUPI відкритим ключем домашньої мережі за схемою на основі еліптичних кривих (ECIES) [58]. Лише домашня мережа, що має відповідний приватний ключ, може відновити SUPI. Це усуває атаки IMSI-кетчерів на деанонімізацію (розділ 9) — фальшива базова станція не може отримати постійний ідентифікатор.

Проте захист не є повним. По-перше, підтримується «нульова» схема шифрування (для регуляторних або технічних причин), за якої SUPI передається відкрито; її використання зводить нанівець захист. По-друге, ідентифікатор обладнання (PEI/IMEI) і тимчасові ідентифікатори за певних умов усе ще можуть використовуватися для зв'язування. По-третє, атаки за побічними каналами протоколу автентифікації дозволяють відстеження навіть

за шифрованого ідентифікатора (підрозділ 10.3). Схему обчислення SUCI наведено на рис. 10.1.

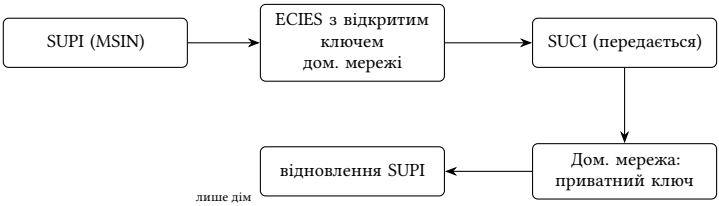


Рис. 10.1 — Приховування ідентифікатора абонента у 5G (SUCI)

10.3 Автентифікація та її формальний аналіз

10.3.1 Уніфікована рамка автентифікації

5G запровадив уніфіковану рамку автентифікації для доступу через мережу 3GPP і не-3GPP (Wi-Fi, дротовий доступ). Підтримуються методи 5G-AKA (розвиток AKA, розділ 6), EAP-AKA’ і EAP-TLS (для приватних мереж). Ключовою відмінністю від LTE є прив’язка результату автентифікації до імені обслуговувальної мережі й повернення домашній мережі криптографічного підтвердження того, що абонент справді автентифікувався в конкретній мережі, що обмежує шахрайство й підвищує контроль домашньої мережі.

10.3.2 Результати формальної верифікації

Протокол 5G-AKA став об’єктом ретельного формального аналізу. Базін та співавтори [79] за допомогою інструмента символьної верифікації показали, що протокол досягає більшості цілей безпеки, але за деяких припущень не гарантує певних властивостей приватності й прив’язки, і сформулювали рекомендації щодо посилення. Кремерс і Денель-Вайлд [103] виявили можливість «плутанини сеансів» за певних припущень про канали між мережевими функціями, показавши, що безпека залежить від припущень, які мають бути явними. Ці роботи — зразок цінності формальних методів (розділ 7): навіть ретельно спроєктований стандартом протокол містить тонкі вади, які виявляються лише строгим аналізом, а не тестуванням.

10.3.3 Залишкові атаки на приватність

Найважливіший практичний результат — атаки на приватність, що зберігаються попри шифрування ідентифікатора. Боргаонкар та співавтори [87] показали, що механізм захисту від повторення в AKA (лічильник послідовності SQN) створює побічний канал: реакція термінала на повторно на-

дислані повідомлення автентифікації розкриває інформацію про значення лічильника, що дозволяє відстежувати активність конкретного абонента (моніторинг присутності, кількості з'єднань) навіть без розкриття ідентифікатора. Ця атака вражає 3G, 4G і 5G-AKA, оскільки використовує фундаментальний елемент протоколу. Повне усунення потребує зміни механізму захисту від повторення. Крім того, наявність фальшивих базових станцій у 5G усе ще можлива для атак на доступність і зниження версії до LTE/2G, тому засоби виявлення IMSI-кетчерів [228] залишаються актуальними (розділ 15).

10.4 Безпека сервісного ядра та міжоператорської взаємодії

10.4.1 Захист сервісного інтерфейсу

У сервісно-орієнтованому ядрі кожна взаємодія між функціями має бути автентифікована й авторизована. Модель безпеки [58]: взаємний TLS забезпечує конфіденційність і автентичність каналу між функціями; авторизація на основі маркерів OAuth 2.0, які видає функція NRF, обмежує, які послуги функція-споживач може викликати. Загрози: некоректна конфігурація авторизації (функція отримує надмірні права); компрометація NRF (видача шкідливих маркерів); вразливості реалізації HTTP/2 і парсерів JSON; атаки на виявлення функцій. Специфікації забезпечення безпеки 3GPP (SCAS) визначають вимоги до кожного класу функцій — gNB [59], AMF [60], SEPP [61] — а схема NESAS/GSMA [157] забезпечує їх оцінювання (розділ 2).

10.4.2 SEPP і захист міжоператорської взаємодії

Кардинальним поліпшенням є захист міжоператорської взаємодії, що усуває клас сигнальних атак SS7/Diameter (розділ 9). Уся взаємодія між ядрами різних операторів проходить через **проксі захисту межі безпеки** (SEPP) [61], який автентифікує партнера, застосовує захист інтерфейсу N32 (шифрування й цілісність повідомлень із можливістю контрольованого посередництва IPX-провайдерів через захищене переписування дозволених полів) і фільтрує неприпустимі повідомлення. Це реалізує на архітектурному рівні те, що для SS7/Diameter доводилося робити додатковими міжмережевими екранами. Проте ефективність залежить від коректного розгортання SEPP усіма операторами й від безпеки самих IPX-провайдерів; на перехідний період зберігається взаємодія зі старими мережами через шлюзи, що успадковують їхні вади.

Спрощену архітектуру сервісного ядра 5G із захистом межі наведено на рис. 10.2.

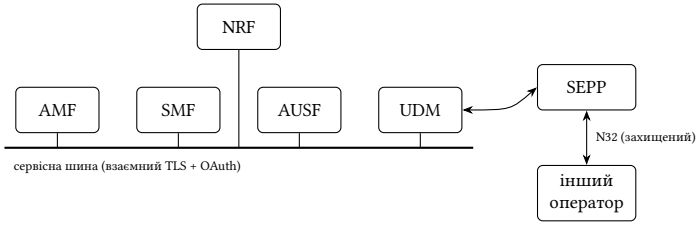


Рис. 10.2 — Сервісне ядро 5G із проксі захисту межі (SEPP)

10.4.3 Модель ризику ланцюга функцій

У сервісному ядрі компрометація однієї функції може поширюватися через надані їй права. Оцінимо ризик, розглядаючи ядро як граф функцій, де компрометація функції відкриває доступ до сусідніх за наданими правами. Якщо середня функція має авторизований доступ до d інших, а компрометація поширюється з імовірністю β на кожну доступну функцію, то критичний поріг некерованого поширення (аналогічно (8.2))

$$\beta\, d > 1. \tag{10.1}$$

Звідси випливає принцип найменших привілеїв для авторизації між функціями: зменшення d (кожна функція має доступ лише до необхідних) утримує систему нижче порога поширення. Це прямий аргумент на користь застосування принципів нульової довіри всередині ядра (розділ 11), а не лише на його межі.

10.5 Мережеві зрізи

Мережевий зріз — логічно ізольована мережа поверх спільної фізичної інфраструктури, налаштована під конкретний сценарій: широкосмуговий доступ, масовий Інтернет речей, критичні застосування з наднизькою затримкою. Зрізи дають гнучкість, але створюють специфічні загрози: *порушення ізоляції* між зрізами (витік даних чи впливу з менш захищеного зрізу на критичний); *атаки на спільні ресурси* (вичерпання ресурсів одним зрізом впливає на інші — «шумний сусід»); *некоректна авторизація доступу* термінала до зрізів. Безпека зрізів вимагає ізоляції на всіх рівнях (радіо, транспорт, ядро), контролю доступу до зрізів і моніторингу споживання ресурсів. Для критичних застосувань (керування енергетикою, транспортом) ізоляція зрізу є вимогою безпеки, а не лише якості послуги, тому потребує гарантій, а не найкращих зусиль. Ця проблематика споріднена з ізоляцією в багатоорендних хмарних середовищах (розділ 12).

10.6 Відкрита архітектура радіодоступу

Ініціатива Open RAN (O-RAN) розділяє традиційно монолітну базову станцію на компоненти з відкритими інтерфейсами, що дозволяє поєднувати обладнання різних постачальників і впроваджувати інтелектуальне керування радіоресурсами. З погляду безпеки це має подвійний ефект. *Позитивний*: диверсифікація постачальників (зниження ризику концентрації, розділ 4), прозорість інтерфейсів, можливість незалежного аудиту. *Негативний*: збільшення поверхні атаки за рахунок нових відкритих інтерфейсів; складність забезпечення безпеки в багатопостачальницькому середовищі (розмивання відповідальності); нові компоненти (інтелектуальні контролери RIC, застосунки xApp/rApp) із власними вразливостями; ризики ланцюга постачання програмних застосунків. Аналіз загроз O-RAN [224] систематизує ці ризики й визначає заходи: автентифікація й авторизація на всіх інтерфейсах, безпека застосунків керування, захист машинного навчання (що використовується для оптимізації радіоресурсів) від атак отруєння. Оцінка загроз 5G від ENISA [127] розглядає O-RAN як один із ключових напрямів.

10.7 Перспективи 6G

Дослідження мереж шостого покоління [242, 163] розглядають безпеку, приватність і стійкість як вбудовані властивості, а не додаткові функції. Очікувані напрями: інтеграція постквантової криптографії з самого початку (розділ 6); широке застосування безпеки фізичного рівня завдяки масивним антенним решіткам та інтелектуальним відбивальним поверхням (розділ 5); вбудована приватність за задумом; використання штучного інтелекту для виявлення загроз (з одночасним захистом самих моделей від атак); інтеграція наземних і супутникових мереж (розділ 14), що ставить нові питання безпеки; посилення довіри до апаратного забезпечення. Водночас застосування штучного інтелекту в керуванні мережею створює нові поверхні атаки (отруєння моделей, змагальні приклади), а конвергенція сенсорики й зв'язку (мережа, що «бачить» середовище) породжує нові загрози приватності. Ці напрями визначатимуть предметну галузь на наступне десятиліття.

10.8 Кейс: безпека приватної мережі 5G промислового підприємства

Промислове підприємство критичної інфраструктури розгортає приватну мережу 5G для автоматизації, робототехніки й датчиків. Аналіз безпеки на основі матеріалу розділу.

Вимоги. Наднизька затримка й висока надійність для керування; ізоляція виробничих систем від корпоративних; захист від зовнішнього й внутрішнього порушника; відповідність вимогам критичної інфраструктури (розділ 2).

Рішення. (1) *Автентифікація*: EAP-TLS з сертифікатами пристроїв замість SIM-карток для промислових пристроїв, що усуває залежність від ланцюга постачання SIM і дає керовану інфраструктуру ключів. (2) *Захист радіоінтерфейсу*: обов'язковий захист цілісності користувацької площини (можливий на обмежених швидкостях, достатніх для керування), заборона нульових алгоритмів. (3) *Ізоляція*: окремі мережеві зрізи для критичного керування й для загального моніторингу з гарантованою ізоляцією ресурсів. (4) *Ядро*: локальне розгортання ядра на майданчику (для затримки й контролю), принцип найменших привілеїв для авторизації між функціями (10.1), взаємний TLS, апаратний захист ключів. (5) *Постачальники*: оцінювання профілю ризику постачальників обладнання (розділ 4), перевага рішенням із незалежним оцінюванням безпеки (NESAS/SCAS). (6) *Моніторинг*: виявлення аномалій у сигналізації й трафіку зрізів, виявлення фальшивих базових станцій (розділ 15). (7) *Постквантова готовність*: вимога до постачальників щодо планів переходу.

Обґрунтування. На відміну від публічної мережі, приватна мережа дозволяє застосувати найсуворіші налаштування (захист цілісності користувацької площини, локальне ядро, власні ключі), оскільки немає обмежень сумісності з масовими терміналами й роумінгу. Ізоляція зрізів і принцип найменших привілеїв обмежують поширення компрометації (10.1). Локальне ядро усуває залежність від зовнішньої сигнальної інфраструктури й пов'язані з нею ризики (розділ 9). Кейс ілюструє, що архітектура 5G надає потужні засоби захисту, ефективність яких залежить від правильної конфігурації опційних механізмів.

Висновки до розділу

Мережі 5G усувають низку фундаментальних вад попередніх поколінь: шифрування постійного ідентифікатора абонента (SUCI) унеможливлює деанонімізацію фальшивими базовими станціями, захищена міжоператорська взаємодія через SEPP усуває клас сигнальних атак SS7/Diameter, опційний захист цілісності користувацької площини закриває атаки канального рівня LTE, а уніфікована рамка автентифікації з прив'язкою до мережі підвищує контроль домашньої мережі. Водночас сервісно-орієнтоване віртуалізоване ядро переносить у телеком загрози вебсервісів, хмар і ланцюга постачання, а відкрита архітектура радіодоступу й мережеві зрізи створюють нові поверхні атаки. Формальний аналіз 5G-AKA показав як досягнення цілей безпеки, так і тонкі вади й залишкові атаки на приватність (побі-

чний канал лічильника послідовності), що зберігаються попри шифрування ідентифікатора. Ефективність захисту 5G критично залежить від конфігурації опційних механізмів і від коректного розгортання всіма учасниками (SEPP, захист цілісності, ненульові алгоритми). Модель поширення компрометації в ядрі обґрунтовує застосування принципу найменших привілеїв і нульової довіри всередині мережі. Приватні мережі 5G дозволяють застосувати найсуворіші налаштування, недоступні в публічних мережах. Напрями 6G — вбудована постквантова криптографія, безпека фізичного рівня, приватність за задумом, штучний інтелект — визначатимуть розвиток галузі, водночас породжуючи нові загрози.

Питання для самоперевірки

1. Чим сервісно-орієнтована архітектура ядра 5G відрізняється від архітектури LTE? Які нові загрози вона переносить у телеком?
2. Як віртуалізація й хмаризація впливають на безпеку мережі 5G? Від чого тепер залежить безпека мережевих функцій?
3. Порівняйте механізми безпеки LTE і 5G (табл. 10.1). Яка зміна, на вашу думку, найважливіша для приватності?
4. Опишіть механізм приховування ідентифікатора SUCI (рис. 10.1). Чому «нульова» схема шифрування зводить нанівець захист?
5. У чому полягає значення формального аналізу 5G-AKA? Наведіть приклади виявлених вад.
6. Поясніть атаку на приватність через лічильник послідовності SQN. Чому вона вражає 3G, 4G і 5G і що потрібно для її усунення?
7. Як забезпечується безпека сервісного інтерфейсу ядра 5G? Які загрози залишаються?
8. Яку проблему попередніх поколінь усуває SEPP і захист інтерфейсу N32? Від чого залежить ефективність цього захисту?
9. За формулою (10.1) поясніть принцип найменших привілеїв для авторизації між функціями ядра. Як зменшення d впливає на поширення компрометації?
10. Які специфічні загрози створюють мережеві зрізи? Чому для критичних застосувань ізоляція зрізу є вимогою безпеки, а не якості послуги?
11. Опишіть подвійний вплив відкритої архітектури радіодоступу на безпеку. Які нові компоненти й ризики вона вносить?
12. Які напрями безпеки розглядаються для мереж 6G? Які нові загрози створює застосування штучного інтелекту в керуванні мережею?

13. Чому приватна мережа 5G дозволяє застосувати суворіші налаштування безпеки, ніж публічна? Наведіть приклади.
14. Дослідницьке: запропонуйте модифікацію механізму захисту від повторення в AKA, що усуває побічний канал лічильника послідовності, і проаналізуйте її вплив на інші властивості протоколу.
15. Дослідницьке: розробіть модель загроз для мережевих зрізів приватної мережі 5G критичної інфраструктури й визначте технічні гарантії ізоляції ресурсів між зрізами та методи їх перевірки.

РОЗДІЛ 11

Безпека мобільних платформ, керування мобільністю та нульова довіра

Смартфон є найпоширенішою кінцевою точкою доступу до інформаційних ресурсів і водночас найскладнішим об'єктом захисту: він постійно підключається до недовірених мереж (розділи 7–10), містить десятки застосунків із доступом до особистих і корпоративних даних, оснащений сенсорами й радіомодулями, є ціллю як масових кампаній, так і цільових атак державного рівня. Захист мобільного доступу неможливо звести до захисту мережі: пристрій може бути скомпрометований, мережа — ворожою, користувач — уведеним в оману. Саме мобільність стала одним із головних чинників переходу до архітектури нульової довіри, у якій довіра не надається за фактом підключення до мережі, а перевіряється для кожного запиту з урахуванням стану пристрою й контексту. Розділ розглядає моделі безпеки мобільних платформ (Android, iOS), безпеку мобільних застосунків, цільові атаки на пристрої, автентифікацію користувачів, керування корпоративною мобільністю, а також принципи й реалізацію архітектури нульової довіри для безпроводового й мобільного доступу. Ризики мобільних пристроїв в організації розглянуто в розділі 4, безпека Інтернету речей — у розділі 12.

11.1 Модель безпеки мобільних платформ

11.1.1 Ізоляція застосунків і дозволи

Сучасні мобільні операційні системи [68, 120] побудовані на принципах, що суттєво відрізняються від настільних систем. *Ізоляція застосунків* (пісочниця): кожен застосунок виконується з власним ідентифікатором і не має доступу до даних інших застосунків без явного механізму обміну. *Модель дозволів*: доступ до чутливих ресурсів (місцезнаходження, камера, мікрофон, контакти, мережа) надається за дозволами, які користувач підтверджує під час використання. *Перевірка походження*: застосунки підписуються розробником, а магазини застосунків здійснюють перевірку перед публікацією. *Захищене завантаження й цілісність системи*: ланцюг довіри від апаратного кореня перевіряє цілісність завантажувача, ядра й системного розділу. *Апаратний захист ключів*: криптографічні ключі й біометричні дані зберігаються в захищеному співпроцесорі, ізольованому від основної системи.

Модель дозволів має відомі обмеження. Дослідження показали, що застосунки часто запитують надмірні дозволи [134], користувачі не розуміють наслідків їх надання, а комбінація дозволів кількох застосунків або міжпроцесна взаємодія можуть створювати непередбачені канали витоку. Крім того, метадані, доступні без спеціальних дозволів (перелік установлених застосунків, характеристики пристрою, дані сенсорів), дозволяють формувати відбиток і відстежувати користувача (розділ 3). Тому модель дозволів є необхідним, але недостатнім механізмом; потрібні також контроль на рівні магазину, аналіз поведінки застосунків і мінімізація даних.

11.1.2 Порівняння підходів платформ

Дві домінівні платформи реалізують схожі принципи з різними акцентами (табл. 11.1), що впливає на моделі загроз і заходи захисту в організації.

Таблиця 11.1 — Порівняння підходів мобільних платформ до безпеки

Аспект	Характеристика
Модель екосистеми	від закритої з єдиним магазином і суворою перевіркою до відкритої з можливістю встановлення з інших джерел
Оновлення	від централізованого швидкого до фрагментованого за виробниками пристроїв
Апаратний корінь довіри	захищений елемент / співпроцесор; довірене середовище виконання
Ізоляція робочих даних	робочі профілі, контейнеризація, керовані застосунки
Поверхня атаки	сторонні джерела застосунків збільшують ризик; закриті екосистеми звужують, але не усувають

Важливий висновок: жодна платформа не є «безпечною» абсолютно. Закриті екосистеми звужують поверхню атаки, але залишаються вразливими до цільових атак «без взаємодії» (підрозділ 11.3); відкриті дають гнучкість, але вимагають додаткового контролю. Вибір і налаштування платформи для організації мають ґрунтуватися на моделі загроз (розділ 4), а не на маркетингових твердженнях.

11.2 Безпека мобільних застосунків

Мобільні застосунки часто є основним каналом доступу до корпоративних і персональних даних, тому їхня безпека критична. Стандарт OWASP MASVS [226] і настанова з тестування MASTG [225] систематизують вимоги за категоріями: захищене зберігання даних (не зберігати чутливе у відкритому вигляді, використовувати апаратне сховище ключів); криптографія (стандартні алгоритми, коректне управління ключами — розділ 6); автентифікація й керування сеансами; захищена мережева взаємодія (TLS з перевіркою сертифіката, закріплення сертифіката проти перехоплення в недо-

вірених мережах); взаємодія з платформою (мінімізація дозволів, безпечна міжпроцесна взаємодія); стійкість до зворотної розробки (для застосунків, що обробляють цінні дані); конфіденційність (мінімізація збору даних).

Типові вади мобільних застосунків: зберігання облікових даних чи токенів у незахищеному вигляді; відсутність перевірки сертифіката сервера, що уможливлює перехоплення в публічних мережах (розділ 7); передавання чутливих даних без шифрування; надмірне журналювання; уразливості в бібліотеках третіх сторін (ланцюг постачання); небезпечна обробка глибоких посилань і міжзастосункової взаємодії. Особливий ризик становлять застосунки, що обробляють дані критичного значення (банківські, медичні, державні сервіси, застосунки для військових), для яких потрібне поглиблене тестування безпеки й, за потреби, апаратне підтвердження цілісності пристрою.

11.3 Цільові атаки на мобільні пристрої

Окремий клас загроз становлять цільові атаки державного рівня з використанням комерційного шпигунського програмного забезпечення. Найвідоміший приклад — експлойти «без взаємодії» (zero-click), що компрометують пристрій без будь-яких дій користувача через обробку спеціально сформованого повідомлення [81, 199]. Такі атаки використовують ланцюги вразливостей у компонентах обробки вхідних даних (парсери зображень, повідомлень), обходять пісочницю й отримують повний контроль над пристроєм, включно з доступом до мікрофона, камери, повідомлень і ключів. Особливості цих атак: вони не потребують помилки користувача, тому традиційні поради («не відкривайте підозрілі посилання») не допомагають; вони цільові, тому масові засоби виявлення можуть їх пропускати; вони використовують невідомі вразливості («нульового дня»), тому оновлення захищає лише після виявлення.

Захист від таких атак складний і багаторівневий: своєчасне оновлення (усуває вразливості після їх виявлення); режими підвищеної безпеки, що вимикають вразливі функції обробки для осіб під загрозою; мінімізація поверхні атаки (менше застосунків, обмеження прийому даних); апаратна ізоляція критичних функцій; для осіб під високою загрозою — використання окремих пристроїв для чутливих комунікацій, фізичний контроль, обмеження зберігання даних. В українському контексті ці загрози є реальними для військових, урядовців, журналістів і активістів, тому обізнаність і відповідні заходи є частиною операційної безпеки (розділ 15).

11.4 Автентифікація користувачів

11.4.1 Слабкість пароля й одноразових кодів

Автентифікація на мобільних пристроях і через них стикається зі специфічними обмеженнями: незручність введення складних паролів, ризик перехоплення в недовірених мережах, вразливість SMS-кодів. Як показано в розділах 3 і 9, паролі, вибрані людиною, мають низьку ентропію й вразливі до підбору, а SMS-коди можуть перехоплюватися через сигнальні атаки SS7 або фальшиві базові станції. Тому SMS не є надійним другим фактором для критичних систем. Проміжним поліпшенням є застосунки-автентифікатори, що генерують одноразові коди локально (за алгоритмом на основі часу), не залежачи від мережі, але вони все ще вразливі до фішингу (користувач може ввести код на підробленому сайті).

Порівняння механізмів автентифікації за стійкістю до основних атак наведено в табл. 11.2.

Таблиця 11.2 — Стійкість механізмів автентифікації до атак

Механізм	Підбір	Перехоплення	Фішинг	Повтор
Пароль	ні	ні	ні	ні
SMS-код	част.	ні	ні	ні
Застосунок-автентифікатор	так	так	ні	так
FIDO2 / passkey	так	так	так	так

Таблиця показує, що лише FIDO2 стійкий до всіх чотирьох класів атак, зокрема до фішингу. Кількісно перевагу можна виразити через імовірність компрометації облікового запису за рік. Якщо для пароля з ентропією H_∞ і SMS-коду ймовірність визначається підбором і перехопленням (розділи 3, 9), то для FIDO2 успіх вимагає компрометації апаратного сховища ключів пристрою:

$$P_{\text{комп}}^{\text{FIDO2}} \approx P_{\text{фіз. доступ}} \cdot P_{\text{обхід сховища}} \ll P_{\text{комп}}^{\text{пароль}}, \tag{11.1}$$

оскільки віддалені атаки (підбір, перехоплення, фішинг), що дають основний внесок у ризик для пароля й SMS, для FIDO2 не застосовні. Це обґрунтовує пріоритет переходу на FIDO2 для захисту критичних облікових записів.

11.4.2 Стійка автентифікація: FIDO2/WebAuthn

Принципове розв'язання дає стандарт FIDO2/WebAuthn [137]: автентифікація на основі асиметричної криптографії з прив'язкою до домену. Пристрій зберігає приватний ключ (у захищеному апаратному сховищі), а сервер — відкритий; під час автентифікації пристрій підписує виклик сервера, при-

чому підпис прив'язаний до конкретного домену, тому *фішинг неможливий* — підпис, створений для підробленого сайту, не підійде для справжнього. Приватний ключ не залишає пристрій і захищений біометрією або кодом. Це усуває цілий клас атак: підбір, перехоплення, повторне використання, фішинг. Ключі доступу (passkeys) роблять цю технологію зручною для масового користувача. Для критичних систем FIDO2 з апаратними ключами є рекомендованим механізмом (захист адміністраторів, розділ 4).

Локальна автентифікація на пристрої (розблокування) поєднує біометрію (відбиток, обличчя) з кодом. Біометрія зручна, але має обмеження: її не можна змінити в разі компрометації, вона вразлива до підробки й може бути застосована примусово. Тому для доступу до критичних даних біометрію доцільно поєднувати з іншими факторами, а для захисту від примусу передбачати механізми екстреного блокування. Паролі та коди, що захищають ключі, слід обробляти пам'яттєстійкими функціями хешування [84].

11.5 Керування корпоративною мобільністю

Організації керують мобільними пристроями через системи керування мобільністю (MDM/EMM/UEM) відповідно до настанов NIST [164]. Функції: розповсюдження конфігурацій і політик безпеки; примусова перевірка сертифікатів для Wi-Fi і VPN (розділ 7); розповсюдження й контроль застосунків; перевірка стану пристрою (актуальність оновлень, відсутність ознак компрометації); дистанційне блокування й стирання; розділення робочих і особистих даних.

Модель розділення робочих і особистих даних на особистому пристрої (контейнеризація) наведено на рис. 11.2.

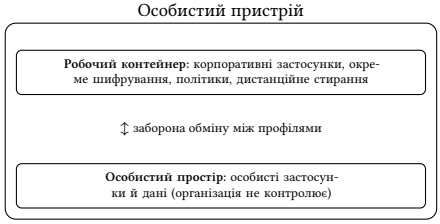


Рис. 11.2 — Контейнеризація робочих даних на особистому пристрої

Ключове проєктне рішення — модель володіння пристроєм. Для *корпоративних* пристроїв можливе повне керування з жорсткими політиками. Для *особистих* пристроїв (BYOD, розділ 4) організація не може повністю контролювати пристрій і застосовує **контейнеризацію** — ізольований робочий профіль, у якому корпоративні дані відокремлені від особистих, шифрую-

ться окремо й можуть бути стерті без впливу на особисті дані, а політики (заборона копіювання між профілями, вимога автентифікації) застосовуються лише до робочого контейнера. Це компроміс між безпекою й приватністю користувача: організація захищає свої дані, не контролюючи особисті. Проте контейнеризація не захищає від компрометації самого пристрою на рівні операційної системи (цільові атаки, підрозділ 11.3), тому для доступу до найкритичніших ресурсів застосовують окремі керовані пристрої й перевірку стану пристрою перед наданням доступу — що є містком до архітектури нульової довіри.

11.6 Архітектура нульової довіри

11.6.1 Принципи

Традиційна модель безпеки припускала довірений внутрішній периметр і недовірене зовнішнє середовище. Мобільність, хмари й безпроводовий доступ зруйнували периметр: користувач працює з будь-якого місця, ресурси розміщені де завгодно, пристрій може бути скомпрометований. **Архітектура нульової довіри** (ZTA) [250, 284] відповідає на це принципом «ніколи не довіряй, завжди перевіряй»: жоден запит не є довіреним за фактом розташування в мережі; кожен запит автентифікується, авторизується й перевіряється з урахуванням контексту (ідентичність користувача, стан пристрою, чутливість ресурсу, поведінка). Ключові принципи NIST [250]: доступ надається до окремих ресурсів, а не до мережі; доступ визначається динамічною політикою з урахуванням багатьох атрибутів; усі ресурси автентифікуються й авторизуються перед доступом; система збирає дані про стан і використовує їх для покращення політик.

11.6.2 Компоненти й механізм рішення

Логічні компоненти ZTA [250]: **точка ухвалення рішень про політику** (обчислює рішення про доступ) і **точка виконання політики** (пропускає або блокує запит). Рішення про доступ ґрунтується на оцінці довіри, що агрегує сигнали: автентифікацію користувача (бажано FIDO2), стан пристрою (оновлення, відповідність політиці, ознаки компрометації), контекст (місце, час, мережа), чутливість ресурсу, поведінкові аномалії. Формально рішення можна подати як порогове правило: доступ до ресурсу r надається, якщо агрегована оцінка довіри перевищує поріг, що залежить від чутливості ресурсу:

$$\sum_{k} w_k \, s_k(\text{запит}) \;\geq\; \theta(r), \tag{11.2}$$

де s_k — сигнали (нормовані), w_k — їхні ваги, $\theta(r)$ — поріг для ресурсу (вищий для критичніших ресурсів). Це узагальнення багатокритеріального

підходу (розділ 4): замість бінарного «в мережі / поза мережею» рішення є неперервною функцією багатьох сигналів, що переоцінюється для кожного запиту. Схему наведено на рис. 11.1.

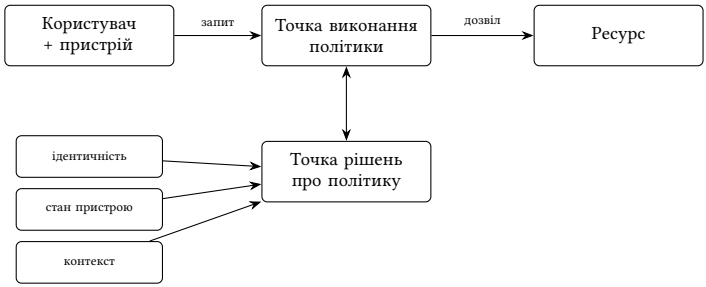


Рис. 11.1 — Логічна архітектура нульової довіри (за [250])

11.6.3 Нульова довіра для безпроводового доступу

Для безпроводових і мобільних мереж ZTA має особливе значення (розділи 7, 10): підключення до корпоративного Wi-Fi чи приватної мережі 5G не повинно саме собою давати доступ до ресурсів. Навіть автентифікований у мережі пристрій отримує доступ до конкретного ресурсу лише після окремої перевірки. Це нейтралізує наслідки компрометації безпроводового сегмента: якщо порушник проникнув у Wi-Fi (розділ 7), він не отримує автоматичного доступу до критичних систем. Практична реалізація [215]: сильна автентифікація (FIDO2), перевірка стану пристрою через MDM, мікросегментація, шифрування незалежне від мережі (розділ 6), безперервний моніторинг. Дослідження застосовності нульової довіри до систем Інтернету речей [21] показує як потенціал, так і обмеження підходу для пристроїв з обмеженими ресурсами, які не можуть виконувати складну автентифікацію (розділ 12).

11.6.4 Обмеження та застереження

Нульова довіра — не продукт, а архітектурний принцип, що вимагає зрілості: надійного керування ідентичністю, інвентаризації ресурсів, здатності оцінювати стан пристроїв, моніторингу. Ризики неправильного впровадження: точка ухвалення рішень стає єдиною точкою відмови й привабливою ціллю; надмірна складність політик призводить до помилок; збирання сигналів про стан і поведінку створює питання приватності. Крім того, для пристроїв, що не можуть надати сигнали про стан (прості пристрої Інтернету речей, гості), потрібні окремі підходи (ізольовані сегменти). Нульова довіра доповнює, а не замінює інші заходи (криптографію, моніторинг, безпеку платформ).

11.7 Кейс: захищений мобільний доступ до ресурсів організації

Організація критичної інфраструктури забезпечує співробітникам мобільний доступ до внутрішніх ресурсів з корпоративних і особистих пристроїв, з офісу й віддалено. Проєктування на основі матеріалу розділу.

Модель загроз. Скомпрометований або втрачений пристрій; доступ із недовіреної мережі (публічний Wi-Fi, фальшива базова станція); фішинг облікових даних; цільова атака на пристрій керівника; зловмисний застосунок.

Рішення. (1) *Автентифікація*: FIDO2/passkeys замість паролів і SMS, що усуває фішинг і перехоплення кодів. (2) *Керування пристроями*: корпоративні пристрої під повним керуванням; особисті — з робочим контейнером; перевірка стану пристрою (оновлення, цілісність) перед доступом. (3) *Нульова довіра*: доступ до кожного ресурсу за динамічною політикою (11.2); підключення до мережі не дає доступу до ресурсів; вищий поріг для критичних ресурсів (додаткове підтвердження, лише керовані пристрої). (4) *Захист каналу*: увесь доступ через шифрований канал незалежно від мережі (розділ 6); закріплення сертифікатів у застосунках. (5) *Захист від цільових атак*: для керівників і осіб під загрозою — режим підвищеної безпеки, окремі пристрої, обмеження застосунків. (6) *Моніторинг*: аналіз поведінки й контексту доступу, виявлення аномалій (розділ 15).

Обґрунтування. FIDO2 усуває найпоширеніший вектор (фішинг і слабкі паролі). Нульова довіра забезпечує, що навіть компрометація мережі чи пристрою обмежується: доступ до критичного ресурсу вимагає керованого пристрою в належному стані й сильної автентифікації (11.2). Контейнеризація балансує безпеку й приватність для BYOD. Залишковий ризик цільових атак на пристрої приймається з компенсацією через окремі пристрої для найчутливіших функцій. Кейс демонструє, що захист мобільного доступу досягається не одним засобом, а поєднанням сильної автентифікації, керування пристроями, нульової довіри й моніторингу.

Висновки до розділу

Мобільні пристрої є найскладнішим об'єктом захисту через постійне підключення до недовірених мереж, велику поверхню атаки й статус головної цілі. Моделі безпеки мобільних платформ (ізоляція застосунків, дозволи, апаратний корінь довіри, захищене сховище ключів) забезпечують суттєвий базовий захист, але модель дозволів має обмеження, а жодна платформа не захищена від цільових атак «без взаємодії». Безпека мобільних застосунків потребує захищеного зберігання, коректної криптографії, перевірки сертифікатів і мінімізації даних згідно з OWASP MASVS. Цільові атаки державного рівня вимагають багаторівневого захисту й окремих заходів для осіб під загрозою. Автентифікація має відходити від паролів і SMS до стійких механізмів FIDO2/WebAuthn, що усувають фішинг завдяки прив'язці

до домену. Керування корпоративною мобільністю балансує безпеку й приватність через контейнеризацію для особистих пристроїв. Мобільність є головним чинником переходу до архітектури нульової довіри, у якій доступ надається до окремих ресурсів за динамічною політикою з урахуванням ідентичності, стану пристрою й контексту, а не за фактом підключення до мережі; це нейтралізує наслідки компрометації безпроводового сегмента. Нульова довіра є архітектурним принципом, що доповнює криптографію, безпеку платформ і моніторинг, а не замінює їх.

Питання для самоперевірки

1. Опишіть принципи безпеки сучасних мобільних платформ. Які обмеження має модель дозволів?
2. Порівняйте підходи мобільних платформ до безпеки (табл. 11.1). Чому жодна платформа не є абсолютно безпечною?
3. Які категорії вимог визначає OWASP MASVS? Наведіть типові вади мобільних застосунків і їх наслідки в недовірених мережах.
4. Що таке атаки «без взаємодії»? Чому традиційні поради користувачам не захищають від них і які заходи потрібні?
5. Чому SMS не є надійним другим фактором? Порівняйте застосунки-автентифікатори і FIDO2 за стійкістю до фішингу.
6. Поясніть, чому FIDO2/WebAuthn унеможливлює фішинг. Яку роль відіграє прив'язка підпису до домену?
7. Порівняйте керування корпоративними й особистими пристроями. Що таке контейнеризація і який компроміс вона забезпечує?
8. Сформулюйте принципи архітектури нульової довіри. Чому мобільність зруйнувала модель периметра?
9. Опишіть логічні компоненти ZTA (рис. 11.1) і механізм ухвалення рішення (11.2). Як поріг залежить від ресурсу?
10. Як нульова довіра нейтралізує наслідки компрометації безпроводового сегмента? Наведіть приклад для корпоративного Wi-Fi.
11. Які ризики має неправильне впровадження нульової довіри? Чому для простих пристроїв Інтернету речей потрібні окремі підходи?
12. Чому біометрія не є повноцінною заміною інших факторів автентифікації? Які її обмеження?
13. Які заходи захисту від цільових атак доцільні для осіб під високою загрозою в українському контексті?
14. Дослідницьке: розробіть функцію оцінки довіри (11.2) для мобільного доступу, визначивши сигнали, їх ваги й пороги для ресурсів різної чутливості, та проаналізуйте її стійкість до маніпуляції сигналами.

15. Дослідницьке: запропонуйте архітектуру нульової довіри для середовища з пристроями Інтернету речей, які не можуть виконувати сильну автентифікацію, і оцініть залишкові ризики (розділ 12).

РОЗДІЛ 12

Безпека Інтернету речей та малопотужних безпроводових мереж

Інтернет речей об'єднує мільярди безпроводових пристроїв — від побутових датчиків і носимої електроніки до промислових контролерів і медичного обладнання, — які збирають дані про фізичний світ і керують ним. Ці пристрої мають спільні риси, що роблять їх безпеку особливо складною: жорсткі обмеження ресурсів, тривалий життєвий цикл без оновлень, фізична доступність, масовість і, часто, нехтування безпекою на етапі проєктування заради здешевлення й швидкості виходу на ринок. Наслідки виявилися системними: масштабні ботнети зі скомпрометованих пристроїв, атаки на критичну інфраструктуру через незахищені сенсори, витоки приватних даних. Розділ розглядає особливості безпеки Інтернету речей, класи загроз і ботнети, безпеку малопотужних глобальних мереж (LoRaWAN, NB-IoT), фізичну безпеку пристроїв і атаки за побічними каналами, механізми захисту й регуляторні вимоги, а також безпеку промислового Інтернету речей. Легковагову криптографію розглянуто в розділі 6, технології ближньої дії — у розділі 8, нульову довіру — у розділі 11.

12.1 Особливості безпеки Інтернету речей

Безпеку пристроїв Інтернету речей визначає поєднання обмежень, що рідко трапляються разом в інших системах (розширюючи спостереження розділів 6 і 8). *Обмежені ресурси*: мікроконтролери з частотою в одиниці–десятки мегагерц, кілобайти оперативної пам'яті, живлення від батареї на роки або від збирання енергії. *Тривалий життєвий цикл без оновлень*: промислові й інфраструктурні пристрої працюють 10–20 років, часто без механізму оновлення прошивки або без його використання. *Фізична доступність*: пристрої розміщені в загальнодоступних місцях, тому порушник може отримати фізичний доступ (розділ 5 щодо побічних каналів). *Масовість і однорідність*: мільйони ідентичних пристроїв означають, що одна вразливість вражає весь клас, а компрометація масштабується. *Гетерогенність протоколів*: різні технології зв'язку (Wi-Fi, BLE, Zigbee, LoRaWAN, стільникові), кожна зі своєю моделлю безпеки. *Слабка керованість*: пристрої часто не мають інтерфейсу для налаштування безпеки й керуються віддалено через хмару, що додає залежність від хмарного сервісу.

Наслідок цих особливостей — принцип, сформульований у настановах NIST і ETSI: безпека пристроїв Інтернету речей має бути *вбудованою за задумом і за замовчуванням*, оскільки її неможливо додати пізніше (розділ 2).

Огляд методів захисту інформації в технологіях Інтернету речей наведено в [15], а систематизацію загроз — у [30].

12.2 Класи загроз і ботнети

12.2.1 Типові вразливості

Найпоширеніші вразливості пристроїв Інтернету речей: універсальні паролі за замовчуванням (однакові для всіх пристроїв моделі); відкриті мережеві служби керування без автентифікації; відсутність шифрування зв'язку; відсутність механізму оновлення або оновлення без перевірки автентичності (розділ 6); зберігання ключів і паролів у прошивці у відкритому вигляді; надмірні привілеї хмарних інтерфейсів; уразливості веб-інтерфейсів керування. Ці вразливості систематизовано в переліках OWASP для Інтернету речей і в базових вимогах ETSI [130].

12.2.2 Ботнет Mirai як показовий приклад

Ботнет Mirai [69] став хрестоматійним прикладом системного ризику. Він поширювався, скануючи Інтернет у пошуках пристроїв (переважно камер відеоспостереження й маршрутизаторів) з відкритим інтерфейсом віддаленого керування й перебираючи невеликий словник заводських паролів за замовчуванням. Скомпрометувавши сотні тисяч пристроїв, ботнет здійснив одні з найпотужніших на той час атак на відмову в обслуговуванні. Уроки Mirai: єдина проста вада (паролі за замовчуванням), помножена на масовість, дає катастрофічний ефект; власники пристроїв не помічають компрометації, оскільки пристрій продовжує працювати; шкоди зазнають не власники, а треті сторони (жертви атак). Це прямий аргумент на користь регуляторних вимог, що забороняють універсальні паролі за замовчуванням (розділ 2), — ринок сам не розв'язує проблему, бо витрати несе не виробник і не власник.

12.2.3 Модель поширення й системний ризик

Динаміку поширення компрометації в популяції пристроїв описують епідемічними моделями (аналогічно (8.2)). Для мережевого поширення базовий репродуктивний коефіцієнт визначає, чи стане компрометація епідемією. Швидкість зростання кількості скомпрометованих пристроїв $I(t)$ на початковій стадії

$$\frac{dI}{dt} = \gamma\, I \left(1 - \frac{I}{N}\right) - \delta\, I, \tag{12.1}$$

де N — загальна кількість уразливих пристроїв; γ — інтенсивність зараження (залежить від швидкості сканування й частки вразливих); δ — інтенсивність усунення (оновлення, вимкнення). Умову виникнення епідемії зру-

чно виражати через базовий репродуктивний коефіцієнт

$$R_0 = \frac{\gamma}{\delta} > 1, \tag{12.2}$$

який показує, скільки нових пристроїв у середньому заражає один скомпрометований до свого усунення. Компрометація поширюється, якщо $\gamma > \delta$, тобто $R_0 > 1$; оскільки для Інтернету речей δ близька до нуля (пристрої рідко оновлюються), навіть повільне зараження зрештою охоплює всю популяцію. Це кількісно пояснює, чому пасивність в оновленнях Інтернету речей є критичною вадою й чому потрібні механізми примусового оновлення й ізоляції (сегментація, розділ 7). Характер зростання за різних R_0 ілюструє рис. 12.2.

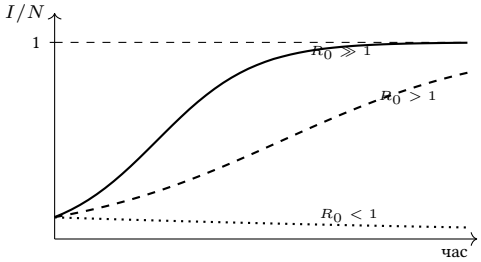


Рис. 12.2 — Динаміка поширення компрометації в популяції пристроїв за різних R_0

12.3 Малопотужні глобальні мережі

Малопотужні глобальні мережі (LPWAN) забезпечують зв'язок на кілометри за мінімального енергоспоживання, що робить їх основою для масового Інтернету речей: лічильники, датчики довкілля, відстеження активів, розумне сільське господарство. Основні технології — LoRaWAN (у неліцензованому спектрі) і стільникові NB-IoT та LTE-M (у ліцензованому). Порівняння наведено в табл. 12.1.

Таблиця 12.1 — Порівняння технологій малопотужних глобальних мереж

Технологія	Спектр, безпека	Особливості й ризики
LoRaWAN	неліцензований; AES-128, дві сесії ключів	серверна архітектура; ризики введення (join), статичні ключі ABP, глушіння
NB-IoT	ліцензований; безпека 3GPP	успадковує механізми стільникових мереж; залежність від оператора
LTE-M	ліцензований; безпека 3GPP	мобільність, вища швидкість; ті самі ризики стільникових мереж
Sigfox	неліцензований; обмежена	наднизька швидкість; слабша безпека

Архітектуру безпеки LoRaWAN із розділенням ключів наведено на рис. 12.1.

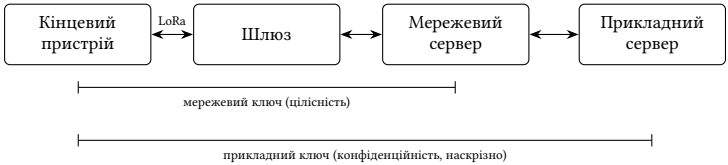


Рис. 12.1 — Розділення ключів у LoRaWAN (за [197])

12.3.1 Безпека LoRaWAN

LoRaWAN [197] застосовує шифрування й контроль цілісності на основі AES-128 з розділенням ключів: мережевий сеансовий ключ захищає цілісність і адресацію, прикладний сеансовий ключ — конфіденційність корисних даних, причому мережевий сервер не має доступу до відкритих даних застосунку (розділення довіри між оператором мережі й власником застосунку). Проте безпека критично залежить від способу введення пристрою в мережу [91]. Режим *з активацією по повітрю* (OTAA) виконує процедуру приєднання, у якій сеансові ключі виводяться з кореневих; це безпечніший режим, але вимагає захисту кореневих ключів і коректної реалізації, а повторення лічильників приєднання може використовуватися для атак. Режим *з активацією за персоналізацією* (ABP) використовує статичні сеансові ключі, зашиті в пристрій, що спрощує розгортання, але створює серйозні ризики: статичні ключі й лічильники вразливі до повторення й, за компрометації, до дешифрування всього трафіку. Додаткові загрози: глушіння (розділ 3) — особливо ефективне через малу потужність і повільну модуляцію; атаки на доступність через вичерпання дозволеного часу передавання; компрометація мережевого чи прикладного сервера.

12.3.2 Стільниковий Інтернет речей

NB-IoT і LTE-M успадковують механізми безпеки стільникових мереж (розділи 9, 10): автентифікацію на основі SIM, шифрування, ієрархію ключів. Це дає сильнішу базову безпеку, ніж LoRaWAN, але створює залежність від оператора й успадковує вади стільникових мереж (фальшиві базові станції, сигнальні атаки). Еволюція безпеки стільникового Інтернету речей для 5G розглядається в дослідженнях 3GPP [49], зокрема оптимізація автентифікації для мільярдів пристроїв і зниження енергоспоживання криптографічних операцій (розділ 6). Для критичних застосувань перевага стільникового Інтернету речей — керованість оператором і вбудований захист — часто переважує вищу вартість.

12.4 Фізична безпека та атаки за побічними каналами

Фізична доступність пристроїв Інтернету речей відкриває клас атак, недоступних для віддаленого порушника. *Витягання прошивки й ключів*: через інтерфейси налагодження (JTAG, SWD), зчитування флеш-пам'яті, аналіз мікросхем. *Атаки за побічними каналами* [221]: вимірювання енергоспоживання або електромагнітного випромінювання під час криптографічних операцій дозволяє відновити ключі, оскільки споживання залежить від оброблюваних даних (розділ 5 щодо ПЕМВН). *Атаки збоями* (fault injection): порушення живлення, тактового сигналу чи опромінення викликають помилки обчислень, які розкривають ключі або обходять перевірки. Ці атаки є практичними для масових пристроїв, оскільки порушник може придбати екземпляр, дослідити його в лабораторії, а потім масштабувати атаку.

Кількісно стійкість до побічних каналів характеризують кількістю вимірювань (трас), потрібних для відновлення ключа. Для незахищеної реалізації диференціальний аналіз енергоспоживання відновлює 128-бітовий ключ AES за тисячі трас; захисні заходи (маскування, приховування, збалансовані реалізації) підвищують цю кількість на порядки, роблячи атаку непрактичною. Захист від фізичних атак: захищені елементи (окремі мікросхеми з протидією фізичному втручанню), маскування криптографічних реалізацій, вимкнення інтерфейсів налагодження у виробничих пристроях, виявлення втручання. Легковагова криптографія Ascon (розділ 6) має простішу структуру, що полегшує захищені реалізації. Для критичних застосувань (лічильники, медичні пристрої, промислові контролери) фізична безпека є обов'язковою вимогою.

12.5 Механізми захисту та регуляторні вимоги

12.5.1 Базові вимоги

Настанови NIST [133, 132] і стандарт ETSI EN 303 645 [130] визначають базові вимоги до споживчих пристроїв Інтернету речей, які стали основою регуляторних вимог ЄС (розділ 2): заборона універсальних паролів за замовчуванням; реалізація політики розкриття вразливостей; захищене й підтримуване оновлення прошивки; захищене зберігання чутливих параметрів і ключів; захищений зв'язок (шифрування, автентифікація); мінімізація відкритих поверхонь атаки; перевірка цілісності програмного забезпечення; захист персональних даних; стійкість до збоїв; полегшення видалення даних користувача. Ці вимоги прямо відображають уроки Mirai та інших інцидентів.

12.5.2 Захищене введення й керування життєвим циклом

Ключовими є два процеси. **Захищене введення** (onboarding): пристрій має бути безпечно приєднаний до мережі з установленням унікальних облікових даних, без покладання на спільні або заводські секрети (розділ 8); стандартизовані протоколи (наприклад, для обмежених мереж [283]) і механізми на основі сертифікатів виробника (як у Matter, розділ 8) розв'язують цю задачу. **Керування життєвим циклом**: безпечне оновлення прошивки з перевіркою автентичності й прив'язки, відкликання скомпрометованих пристроїв, безпечне виведення з експлуатації зі стиранням даних. Обмежені пристрої використовують полегшені протоколи прикладного рівня (CoAP [261]) з захистом на основі DTLS або OSCORE.

12.5.3 Мережеві заходи та нульова довіра

Оскільки самі пристрої часто неможливо повністю захистити, критичну роль відіграють мережеві заходи: *сегментація* — ізоляція пристроїв Інтернету речей в окремих сегментах без прямого доступу до критичних систем (розділ 7); *контроль доступу до мережі* з перевіркою пристроїв; *моніторинг поведінки* — виявлення аномального трафіку, що свідчить про компрометацію (розділ 15); *шлюзи безпеки*, що додають захист для пристроїв, які його не мають. Застосування принципів нульової довіри (розділ 11) до Інтернету речей має обмеження: прості пристрої не можуть виконувати сильну автентифікацію й надавати сигнали про стан, тому довіра до них будується на рівні мережі й шлюзів, а не самих пристроїв (розділ 11). Модель «пристрій за замовчуванням недовірений, ізольований і моніториться» є практичною реалізацією нульової довіри для Інтернету речей.

12.6 Промисловий Інтернет речей

Промисловий Інтернет речей і безпроводові технології в операційних середовищах (розумне виробництво, енергетика, транспорт, комунальне господарство) мають особливості, що підвищують ставки. Тут порушення доступності чи цілісності впливає на фізичні процеси й безпеку людей, а не лише на дані; пристрої мають ще довший життєвий цикл; вимоги реального часу обмежують застосування важкої криптографії; конвергенція інформаційних і операційних технологій розширює поверхню атаки. Стандарт IEC 62443 [170] визначає зонування (розділення на зони безпеки з контрольованими зв'язками), рівні захищеності та вимоги до компонентів. Для безпроводових сегментів промислових мереж критичними є: стійкість до глушіння й завад (розділ 3), оскільки промислове середовище має багато джерел завад, а порушення керування небезпечне; автентифікація й цілісність команд керування; сегментація між рівнями (польові пристрої, керування, диспетчеризація); моніторинг, адаптований до операційних протоколів. Захист критичної інфраструктури, зокрема її операційних технологій, розглянуто також у контексті стійкості (розділ 16).

12.7 Кейс: захист безпроводової сенсорної мережі комунального підприємства

Комунальне підприємство розгортає мережу з тисяч датчиків (лічильники, датчики тиску й якості) на LoRaWAN і частково на NB-IoT для моніторингу й керування. Аналіз безпеки.

Модель загроз. Компрометація датчика (фізичний доступ, витягання ключів); підміна даних вимірювань (шахрайство, дезінформація для керування); глушіння (порушення моніторингу, приховування аварії); ботнет зі скомпрометованих пристроїв; компрометація мережевого/прикладного сервера; порушення приватності (дані споживання).

Рішення. (1) *Введення*: режим OTAA для LoRaWAN з унікальними кореневими ключами для кожного пристрою, захищеними в захищеному елементі; заборона статичних ключів ABP. (2) *Розділення довіри*: прикладні ключі відомі лише власнику застосунку, не оператору мережі. (3) *Фізична безпека*: захищені елементи для ключів, вимкнення інтерфейсів налагодження, виявлення втручання для критичних вузлів (керування засувками). (4) *Цілісність команд*: критичні команди керування — лише через NB-IoT з автентифікацією 3GPP і додатковим підтвердженням; моніторингові дані — через LoRaWAN. (5) *Стійкість до глушіння*: виявлення глушіння як події безпеки, резервні канали для критичних вузлів (розділ 3). (6) *Сегментація й моніторинг*: ізоляція серверів Інтернету речей, виявлення аномалій у трафіку й вимірюваннях (розділ 15). (7) *Життєвий цикл*: механізм безпечного оновлення прошивки, план відкликання й заміни.

Обґрунтування пріоритетів. За методикою розділу 4 найвищий пріоритет — захист команд керування (вплив на фізичний процес) і захищене введення (усуває найпоширеніший клас атак — статичні/спільні ключі). Глушіння моніторингу має нижчий вплив (дані, а не керування), тому для нього достатньо виявлення й резервування критичних вузлів. Повний захист усіх датчиків від фізичних атак економічно недоцільний; для масових недорогих датчиків моніторингу залишковий ризик приймається з компенсацією через перевірку правдоподібності даних і сегментацію. Кейс ілюструє диференційований підхід: рівень захисту відповідає впливу компрометації, а не однаковий для всіх пристроїв.

Висновки до розділу

Безпека Інтернету речей визначається поєднанням обмежень — ресурсів, тривалого життєвого циклу без оновлень, фізичної доступності, масовості й слабкої керованості, — через що безпека має бути вбудованою за задумом, оскільки її неможливо додати пізніше. Типові вразливості (паролі за замовчуванням, відкриті служби, відсутність шифрування й оновлень) у поєднанні з масовістю дають системний ризик, показовим прикладом якого є ботнет Mirai; епідемічні моделі пояснюють, чому за близької до нуля інтенсивності оновлень компрометація зрештою охоплює всю популяцію. Малопотужні глобальні мережі мають різні моделі безпеки: LoRaWAN спирається на AES-128 з розділенням ключів, але критично залежить від способу введення (OTAA проти вразливого ABP), тоді як стільниковий Інтернет речей успадковує сильнішу безпеку 3GPP разом із вадами стільникових мереж. Фізична доступність відкриває атаки за побічними каналами й збоями, що вимагають захищених елементів і захищених реалізацій криптографії. Базові регуляторні вимоги (NIST, ETSI EN 303 645) прямо відображають уроки інцидентів і забороняють найгірші практики. Оскільки самі пристрої часто неможливо повністю захистити, критичну роль відіграють мережеві заходи — сегментація, контроль доступу, моніторинг — і адаптована нульова довіра, у якій довіра будується на рівні мережі й шлюзів. Для промислового Інтернету речей ставки вищі через вплив на фізичні процеси й безпеку людей, що вимагає зонування за IEC 62443 і особливої уваги до стійкості й цілісності керування.

Питання для самоперевірки

1. Які особливості визначають складність безпеки Інтернету речей? Чому безпеку неможливо додати пізніше?
2. Перелічіть типові вразливості пристроїв Інтернету речей. Які з них використовував ботнет Mirai?

3. Які уроки дає ботнет Mirai? Чому ринок сам не розв'язує проблему й потрібні регуляторні вимоги?
4. За моделлю (12.1) поясніть, чому низька інтенсивність оновлень призводить до охоплення всієї популяції. Які заходи змінюють цю динаміку?
5. Порівняйте технології LPWAN (табл. 12.1) за спектром і безпекою. У чому перевага стільникового Інтернету речей?
6. Опишіть розділення ключів у LoRaWAN. Чому режим OTAA безпечніший за ABP?
7. Які специфічні загрози має LoRaWAN? Чому глушіння особливо ефективне проти LPWAN?
8. Які класи фізичних атак застосовні до пристроїв Інтернету речей? Чому фізична доступність робить їх практичними?
9. Як вимірюють стійкість реалізації до атак за побічними каналами? Які заходи підвищують її?
10. Перелічіть базові регуляторні вимоги до споживчих пристроїв Інтернету речей. Як вони пов'язані з уроками інцидентів?
11. Чому захищене введення й керування життєвим циклом є ключовими процесами? Які механізми їх забезпечують?
12. Які обмеження має застосування нульової довіри до Інтернету речей? Як будується довіра до простих пристроїв?
13. Чим безпека промислового Інтернету речей відрізняється від споживчого? Яку роль відіграє зонування за IEC 62443?
14. Дослідницьке: побудуйте епідемічну модель поширення компрометації в мережі LoRaWAN з урахуванням сегментації й механізму оновлення та визначте умови стримування епідемії.
15. Дослідницьке: спроєктуйте схему захищеного введення й керування життєвим циклом для парку з мільйона датчиків з обмеженими ресурсами й оцініть вимоги до інфраструктури ключів та обчислювальні витрати (розділ 6).

РОЗДІЛ 13

Безпека самоорганізованих, комірчастих і відомчих безпроводових мереж

Окремий клас безпроводових систем становлять мережі без централізованої інфраструктури або з особливими вимогами до автономності й стійкості: самоорганізовані (ad hoc) мережі, у яких вузли самі виконують функції маршрутизаторів; комірчасті (mesh) мережі, що покривають територію ретрансляцією; безпроводові сенсорні мережі; тактичні радіомережі й відомчі системи професійного мобільного радіозв'язку (TETRA та подібні), що обслуговують екстрені служби, безпеку й оборону. Ці мережі об'єднує відсутність довіреного централізованого арбітра, що переносить функції автентифікації, розподілу ключів і захисту маршрутизації на самі вузли, а також підвищені вимоги до стійкості в умовах відмов, глушіння й фізичного захоплення вузлів. Розділ розглядає модель загроз самоорганізованих мереж, атаки на маршрутизацію й контрзаходи, безпеку сенсорних і комірчастих мереж, управління ключами в децентралізованому середовищі, безпеку відомчих і тактичних систем, а також особливості застосування в умовах воєнного стану. Атаки на децентралізовані ідентичності (Sybil) розглянуто в контексті розділу 3, безпечне вимірювання відстані — у розділі 5.

13.1 Особливості самоорганізованих мереж як об'єкта захисту

Самоорганізовані мережі мають властивості, що принципово ускладнюють їх захист порівняно з інфраструктурними (розділ 1). *Відсутність централізованого арбітра*: немає довіреного вузла, що виконував би автентифікацію, видавав сертифікати чи ухвалював рішення про допуск, тому ці функції мають бути розподіленими або встановленими заздалегідь. *Кожен вузол — маршрутизатор*: вузли залежать від сусідів у передаванні пакетів, тому скомпрометований або зловмисний вузол впливає не лише на себе, а на весь трафік, що проходить через нього. *Динамічна топологія*: вузли рухаються, з'являються й зникають, тому статичні механізми довіри непридатні. *Обмежені ресурси*: вузли (особливо сенсорні) мають обмежені енергію й обчислення, що обмежує криптографію (розділ 6). *Фізична вразливість*: вузли розміщені в неконтрольованому середовищі й можуть бути захоплені й досліджені (розділ 12). *Кооперативність як припущення*: протоколи припускають, що вузли співпрацюють чесно, але порушник може діяти зсередини.

Наслідок — модель порушника (розділ 4) для самоорганізованих мереж обов'язково включає *внутрішнього* порушника (скомпрометований або зловмисний вузол), тоді як для інфраструктурних мереж основним є

зовнішній. Це змінює пріоритети: захист має спиратися не лише на криптографію периметра, а й на виявлення й ізоляцію зловмисної поведінки вузлів, розподілену довіру й стійкість до часткової компрометації.

13.2 Атаки на маршрутизацію та контрзаходи

13.2.1 Класи атак

Оскільки маршрутизація в самоорганізованих мережах ґрунтується на кооперації вузлів, вона є основною ціллю атак [187]. Основні класи наведено в табл. 13.1.

Таблиця 13.1 — Атаки на маршрутизацію в самоорганізованих мережах

Атака	Механізм і наслідок
Чорна діра	вузол оголошує найкращі маршрути, а потім відкидає пакети; порушення доставки
Сіра діра	вибіркове відкидання пакетів; важче виявити, ніж чорну діру
Тунель (wormhole)	два зговорені вузли тунелюють пакети між віддаленими точками, спотворюючи топологію
Sybil	один вузол видає себе за багато ідентичностей, підриваючи схеми на основі більшості
Rushing	прискорене поширення запитів маршруту для потрапляння в маршрути
Підміна/модифікація	фальсифікація керувальних повідомлень маршрутизації
Виснаження	примус вузлів до зайвих обчислень або передавань для розряджання батарей

Особливо підступними є атаки тунелю (wormhole) [166]: два вузли порушника, з'єднані швидким каналом, ретранслюють пакети так, що віддалені частини мережі здаються сусідніми (рис. 13.1); це спотворює всю топологію й може перехоплювати трафік, навіть якщо порушник не знає ключів. Захист — «повідці» (leashes), що обмежують відстань або час поширення пакета (пов'язано з обмеженням відстані, розділ 5).

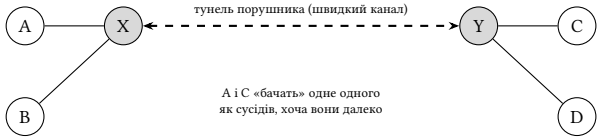


Рис. 13.1 — Атака тунелю (wormhole) у самоорганізованій мережі (за [166])

13.2.2 Захищена маршрутизація

Протоколи захищеної маршрутизації (наприклад, Ariadne [165]) додають автентифікацію керувальних повідомлень, щоб порушник не міг їх підро-

бити чи модифікувати. Механізми: автентифікація кожного переходу (кожен вузол на маршруті підтверджує участь); ефективна автентифікація широкомовних повідомлень через відкладене розкриття ключів (TESLA), що дозволяє автентифікацію без асиметричних операцій на кожному кроці (розділ 6); захист лічильників переходів. Проте автентифікація захищає від зовнішнього порушника й підробки, але не від внутрішнього вузла, що коректно бере участь у протоколі, а потім відкидає пакети (чорна/сіра діра). Для цього потрібні **системи репутації й моніторингу сусідів**: вузли спостерігають за поведінкою сусідів (чи передають вони пакети), знижують репутацію тих, хто відкидає, й уникають їх у маршрутах. Оцінимо ефективність: якщо частка зловмисних вузлів f, а маршрут містить h переходів, то ймовірність, що маршрут не містить жодного зловмисного вузла (за незалежності),

$$P_{\text{чистий}} = (1 - f)^h. \tag{13.1}$$

Для $f = 0{,}1$ і $h = 5$ маємо $P_{\text{чистий}} = 0{,}59$, тобто 41 % маршрутів компрометовані; для $h = 10$ — лише 35 % чистих. Це показує, що в багатоперехідних мережах навіть невелика частка зловмисних вузлів робить більшість маршрутів ненадійними, тому потрібні багатошляхова маршрутизація (передавання через кілька незалежних маршрутів) і виявлення відкидання.

13.3 Безпека сенсорних і комірчастих мереж

13.3.1 Сенсорні мережі

Безпроводові сенсорні мережі мають найжорсткіші обмеження ресурсів, тому потребують спеціалізованих протоколів безпеки. Набір SPINS [231] демонструє принципи: симетрична криптографія замість асиметричної (енергоефективність); автентифікація широкомовлення через відкладене розкриття ключів (TESLA); попередній розподіл ключів. Ключова проблема — **управління ключами**: як установити ключі між вузлами, що заздалегідь не знають одне одного, без централізованого центру? Підходи: попередній розподіл ключів (кожен вузол отримує набір ключів із пулу, і два вузли з високою ймовірністю мають спільний); ключі на основі розташування; використання базової станції як довіреного посередника (де вона є). Компрометація вузла розкриває його ключі, тому схеми мають забезпечувати, щоб це не розкривало зв'язок інших вузлів (стійкість до захоплення).

13.3.2 Комірчасті мережі

Комірчасті мережі (IEEE 802.11s [172], Thread [278], BLE Mesh) розширюють покриття ретрансляцією через вузли-маршрутизатори. Їх безпека поєднує проблеми Wi-Fi/BLE (розділи 7, 8) з проблемами маршрутизації. IEEE 802.11s визначає автентифікацію вузлів mesh і захищені посилання,

Thread будує захищену мережу на основі IEEE 802.15.4 з автентифікацією вузлів і шифруванням. Ключові ризики: компрометація вузла-ретранслятора впливає на маршрути; введення нового вузла (як у Zigbee, розділ 8); атаки на доступність через глушіння критичних вузлів магістралі. Для комірчастих мереж критичних застосувань потрібні резервування маршрутів, виявлення компрометованих вузлів і захищене введення.

13.4 Відомчі та тактичні радіомережі

13.4.1 Професійний мобільний радіозв'язок

Екстрені служби (поліція, рятувальники, медики), безпека й оборона використовують спеціалізовані системи професійного мобільного радіозв'язку, найпоширенішою з яких у Європі є TETRA [128]. Ці системи забезпечують групову комунікацію, прямий зв'язок між пристроями без інфраструктури, пріоритезацію та підвищену стійкість. Безпека TETRA включає автентифікацію, шифрування радіоінтерфейсу й наскрізне шифрування для найчутливіших застосувань. Проте дослідження TETRA:BURST [204] виявило серйозні вади в криптографічних алгоритмах TETRA, які довгий час залишалися закритими: зокрема, один із алгоритмів шифрування мав навмисне ослаблення (зменшення ефективної довжини ключа), що дозволяло практичне дешифрування. Цей випадок — ще одне підтвердження принципу Керкгоффса (розділ 6): закриті алгоритми не забезпечують безпеки, а їх аудит виявляє вади, які роками загрожували критичним комунікаціям. Урок для відомчих систем: використання відкритих, публічно проаналізованих алгоритмів і незалежний аудит є обов'язковими, особливо для систем національної безпеки.

13.4.2 Тактичні радіомережі та стійкість зв'язку

Тактичні радіомережі для оборони поєднують вимоги самоорганізованих мереж (мобільність, відсутність інфраструктури) з екстремальними вимогами до стійкості: захист від глушіння (розділ 5), прихованість зв'язку (низька ймовірність виявлення й перехоплення), стійкість до захоплення вузлів, робота в умовах радіоелектронної боротьби. Ключові технології: розширення спектра з криптографічною послідовністю (стійкість до глушіння й перехоплення); прихований зв'язок з низькою потужністю (розділ 5); наскрізне шифрування з апаратним захистом ключів; механізми знищення ключів при захопленні; автономна робота без централізованого керування. Модель загроз тут включає державного порушника з ресурсами радіоелектронної боротьби й радіорозвідки, тому пріоритетами є доступність (стійкість до глушіння) і прихованість (захист від виявлення й пеленгації, розділ 4).

13.4.3 Попередній розподіл ключів

Класична схема попереднього розподілу ключів розв'язує задачу встановлення спільних ключів без центрального арбітра: кожен вузол завантажується випадковою підмножиною з k ключів, вибраних із загального пулу розміром P. Два вузли можуть встановити захищений зв'язок, якщо мають хоча б один спільний ключ. Імовірність цього

$$p_{\text{спільн}} = 1 - \frac{\binom{P-k}{k}}{\binom{P}{k}} \approx 1 - \left(1 - \frac{k}{P}\right)^{k}. \tag{13.2}$$

Наприклад, для пулу $P = 10\,000$ і $k = 100$ ключів на вузол $p_{\text{спільн}} \approx 1 - (0{,}99)^{100} \approx 0{,}634$: два випадкові вузли з імовірністю 0,63 мають спільний ключ, а зв'язність усієї мережі забезпечується через проміжні вузли. Компроміс: більше k підвищує зв'язність, але й збільшує частку мережі, що розкривається при захопленні одного вузла (стійкість до захоплення). Схеми на основі поліномів і матриць покращують цей компроміс, забезпечуючи, що компрометація до певного порогу вузлів не розкриває ключів інших пар. Схему багатошляхової доставки, що компенсує ненадійність окремих маршрутів (13.1), наведено на рис. 13.2.

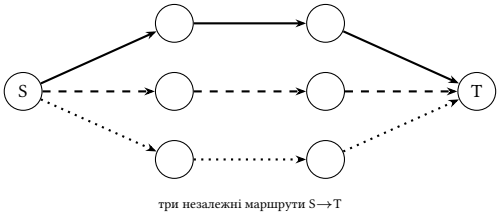


Рис. 13.2 — Багатошляхова маршрутизація для стійкості до компрометації вузлів

13.5 Управління довірою в децентралізованому середовищі

Відсутність централізованого арбітра робить управління довірою центральною проблемою. Підходи: *попереднє встановлення* довіри (ключі й сертифікати завантажуються до розгортання — підходить для керованих відомчих мереж); *розподілені центри сертифікації* (функції центру розподілені між кількома вузлами через порогові схеми, щоб компрометація частини не розкривала систему); *мережі довіри* (вузли поручаються один за одного); *репутаційні системи* (довіра будується на основі спостережуваної поведінки); *ресурсні тести* проти Sybil-атак (доказ володіння ресурсом ускладнює створення багатьох ідентичностей) [113]. Для мереж, що використовують технології розподіленого реєстру для координації без центрального арбі-

тра, актуальні питання масштабування й стійкості [19] і криптоекономічної стійкості [28]. Вибір підходу визначається моделлю мережі: для керованих відомчих мереж — попереднє встановлення з апаратним захистом ключів; для відкритих самоорганізованих — поєднання ресурсних тестів, репутації й розподіленої довіри.

Окрему увагу потребують **приховані канали** [289]: у мережах, де сам факт зв'язку є чутливим, порушник (або інсайдер) може використовувати приховані канали для витоку інформації, а захисник — для непомітного зв'язку; аналіз і контроль прихованих каналів є частиною безпеки чутливих мереж (розділ 5 щодо прихованості).

13.6 Кейс: захищена радіомережа екстреної служби

Регіональна екстрена служба розгортає радіомережу для оперативного зв'язку підрозділів, що має працювати в умовах надзвичайних ситуацій, зокрема за відмови інфраструктури й активної протидії. Аналіз на основі матеріалу розділу.

Вимоги. Групова комунікація; прямий зв'язок за відсутності інфраструктури; висока доступність зокрема під час аварій і атак; конфіденційність оперативної інформації; стійкість до глушіння; захист за захоплення пристрою.

Модель загроз. Перехоплення (кримінальні групи, іноземна розвідка); глушіння (порушення координації під час операції); захоплення пристрою (втрата, викрадення); фальшива інфраструктура; в умовах війни — державний порушник з радіоелектронною боротьбою й радіорозвідкою.

Рішення. (1) *Алгоритми*: лише відкриті, публічно проаналізовані алгоритми (урок TETRA:BURST), стандартна криптографія з достатньою довжиною ключа; за потреби — національні алгоритми з висновком державної експертизи (розділ 6). (2) *Стійкість до глушіння*: розширення спектра з криптографічною послідовністю стрибків, резервні діапазони, прямий зв'язок за відмови інфраструктури (розділ 5). (3) *Прихованість*: для чутливих операцій — режими зниженої потужності й радіодисципліна для захисту від пеленгації (розділ 4). (4) *Управління ключами*: попереднє встановлення з апаратним захистом, наскрізне шифрування груп, механізм дистанційного знищення ключів і блокування за захоплення пристрою. (5) *Стійкість*: автономна робота без централізованого керування, багатошляхова маршрутизація (13.1), резервування критичних вузлів. (6) *Моніторинг*: виявлення глушіння й аномалій (розділ 15).

Обґрунтування. Для екстреної служби доступність і стійкість (робота під час аварій і атак) мають вищий пріоритет, ніж максимальна конфіденційність, тому інвестиції спрямовуються насамперед у стійкість до глушіння й автономність. Урок TETRA:BURST визначає обов'язковість відкритих ал-

горитмів. Механізм знищення ключів обмежує наслідки захоплення пристрою. Багатошляхова маршрутизація компенсує ненадійність окремих переходів (13.1). Кейс ілюструє, що для відомчих і критичних мереж пріоритети безпеки (доступність і стійкість понад усе) відрізняються від корпоративних, а вимоги воєнного часу додають прихованість як самостійну властивість.

Висновки до розділу

Самоорганізовані, комірчасті й відомчі безпроводові мережі відрізняються від інфраструктурних відсутністю централізованого арбітра, залежністю від кооперації вузлів і підвищеними вимогами до автономності й стійкості, через що їх модель порушника обов'язково включає внутрішнього порушника. Маршрутизація, що спирається на кооперацію, є основною ціллю атак (чорні й сірі діри, тунелі, Sybil, виснаження); захищена маршрутизація з автентифікацією повідомлень захищає від підробки, але не від зловмисного вузла, що коректно бере участь у протоколі, тому потрібні системи репутації, моніторинг сусідів і багатошляхова маршрутизація — у багатопереходних мережах навіть невелика частка зловмисних вузлів компрометує більшість маршрутів. Сенсорні мережі потребують енергоефективних симетричних протоколів і схем управління ключами, стійких до захоплення вузлів. Відомчі системи професійного радіозв'язку продемонстрували на прикладі TETRA:BURST небезпеку закритих алгоритмів, підтвердивши обов'язковість відкритих, публічно проаналізованих рішень для критичних комунікацій. Тактичні радіомережі в умовах війни ставлять на перше місце доступність (стійкість до глушіння) і прихованість (захист від виявлення й пеленгації). Управління довірою в децентралізованому середовищі спирається на попереднє встановлення, розподілені центри сертифікації, репутацію й ресурсні тести, а вибір підходу визначається моделлю мережі. Для відомчих і критичних мереж пріоритети безпеки зміщені до доступності й стійкості, що відрізняє їх від корпоративних систем.

Питання для самоперевірки

1. Які властивості самоорганізованих мереж ускладнюють їх захист? Чому їх модель порушника обов'язково включає внутрішнього порушника?
2. Опишіть основні класи атак на маршрутизацію (табл. 13.1). Чому сіру діру важче виявити, ніж чорну?
3. Поясніть механізм атаки тунелю (wormhole). Чому вона працює навіть без знання ключів і як від неї захищають «повідці»?

4. Що забезпечує захищена маршрутизація і від чого вона не захищає? Яку роль відіграють системи репутації й моніторингу сусідів?
5. За формулою (13.1) обчисліть частку чистих маршрутів для $f = 0{,}15$ і $h = 7$. Який висновок для багатоперехідних мереж?
6. Які принципи закладено в набір протоколів SPINS для сенсорних мереж? Чому використовується симетрична криптографія?
7. У чому полягає проблема управління ключами в сенсорних мережах? Опишіть підхід попереднього розподілу ключів і вимогу стійкості до захоплення.
8. Які ризики має компрометація вузла-ретранслятора в комірчастій мережі? Які заходи потрібні для критичних застосувань?
9. Що показало дослідження TETRA:BURST? Який урок воно дає щодо алгоритмів для відомчих систем (зв'яжіть із розділом 6)?
10. Які вимоги до стійкості мають тактичні радіомережі? Чому доступність і прихованість є для них пріоритетними?
11. Порівняйте підходи до управління довірою в децентралізованому середовищі. Який підхід придатний для керованих відомчих мереж, а який — для відкритих?
12. Чому приховані канали є подвійною проблемою в чутливих мережах? Як вони пов'язані з прихованістю зв'язку (розділ 5)?
13. Чому для екстрених служб доступність і стійкість мають вищий пріоритет, ніж максимальна конфіденційність?
14. Дослідницьке: розробіть репутаційну систему для виявлення сірих дір у самоорганізованій мережі, визначте метрики поведінки, поріг і оцініть частку хибних тривог за методикою розділу 3.
15. Дослідницьке: спроєктуйте схему управління ключами для тактичної радіомережі з підтримкою груп, прямого зв'язку й знищення ключів за захоплення, та проаналізуйте її стійкість до компрометації частини вузлів.

РОЗДІЛ 14

Безпека супутникового зв'язку, навігації та безпілотних систем

Супутникові системи зв'язку й навігації та безпілотні платформи утворюють клас безпроводових систем із найбільшою дальністю дії й особливими вимогами безпеки. Глобальні навігаційні супутникові системи (GNSS) забезпечують позиціювання й точний час для транспорту, енергетики, фінансів, зв'язку й оборони, і водночас є однією з найвразливіших технологій через надзвичайно слабкий сигнал і історичну відсутність автентифікації. Супутниковий зв'язок (геостаціонарний і низькоорбітальний) забезпечує глобальне покриття, зокрема там, де немає наземної інфраструктури. Безпілотні літальні апарати покладаються на безпроводові канали керування й навігацію, що робить їх ціллю глушіння й підміни. Розділ розглядає вразливості GNSS і механізми автентифікації навігаційних сигналів, безпеку супутникового зв'язку, безпеку каналів керування й навігації безпілотних систем, а також український контекст — масове застосування радіоелектронної боротьби й безпілотних систем. Безпеку фізичного рівня, зокрема протидію глушінню й безпечне позиціювання, розглянуто в розділі 5, математичні основи глушіння — у розділі 3.

14.1 Глобальні навігаційні супутникові системи

14.1.1 Принцип і фундаментальна вразливість

GNSS (GPS, Galileo, ГЛОНАСС[1] у частині цивільних сигналів, BeiDou) визначає місцезнаходження приймача за часом поширення сигналів від кількох супутників з відомими орбітами. Приймач розв'язує систему рівнянь відносно координат (x, y, z) і зсуву годинника δt:

$$\rho_i = \sqrt{(x - x_i)^2 + (y - y_i)^2 + (z - z_i)^2} + c\,\delta t, \qquad i = 1, \dots, n, \tag{14.1}$$

де ρ_i — виміряна псевдовідстань до i-го супутника з координатами (x_i, y_i, z_i); для розв'язання потрібно щонайменше чотири супутники. Фундаментальна вразливість — надзвичайно слабкий сигнал: як показано в розділі 3, потужність сигналу GPS на поверхні Землі лежить нижче рівня теплового шуму (близько -130 дБм), тому для його глушіння достатньо маломіцного передавача, а відкриті цивільні сигнали історично не мали автентифікації, що робить можливою їх підміну.

[1]Тут згадано лише як факт існування глобальної системи; предметом викладу є GPS і європейська Galileo.

14.1.2 Глушіння та підміна

Глушіння GNSS — створення завади, що перевищує слабкий сигнал (розділ 3), — призводить до втрати позиціювання й часу. Як обчислено в розділі 3, постановник завад потужністю 1 Вт здатен заблокувати приймання на десятки кілометрів. Наслідки серйозні через залежність багатьох систем від GNSS не лише для навігації, а й для синхронізації часу (мережі зв'язку, енергосистеми, фінансові транзакції).

Кількісно дальність глушіння GNSS оцінюють з енергетичного бюджету (розділ 3). Приймання порушується, коли потужність завади на вході приймача перевищує запас над мінімально потрібним сигналом. Для ізотропного постановника завад потужністю P_J у вільному просторі гранична дальність глушіння

$$d_J = \frac{c}{4\pi f}\sqrt{\frac{P_J\, G_J}{P_{\min}}}, \tag{14.2}$$

де f — частота; $P_{\min}$ — мінімальна потужність завади на вході приймача, достатня для придушення (визначається запасом стійкості приймача); G_J — підсилення антени завади. Для $f = 1575$ МГц, $P_J = 1$ Вт, $G_J = 1$ і $P_{\min} = -99$ дБм розрахунок дає дальність порядку десятків кілометрів (розділ 3), що пояснює масштаб впливу навіть маломіцних постановників завад.

Підміна (spoofing) — складніша й небезпечніша атака: порушник передає фальшиві сигнали, що імітують справжні, змушуючи приймач обчислити хибне місцезнаходження або час. Хамфріс та співавтори [168] продемонстрували портативний пристрій підміни, а згодом — захоплення керування безпілотним апаратом і навіть морським судном через поступову підміну [190]. Небезпека підміни в тому, що, на відміну від глушіння, вона не виявляється як втрата сигналу — приймач «вірить» фальшивим даним. Найпідступніша — **узгоджена підміна**, за якої порушник спочатку синхронізує фальшиві сигнали зі справжніми, а потім поступово відводить рішення приймача, залишаючись непоміченим.

Схему узгодженої підміни GNSS наведено на рис. 14.1.

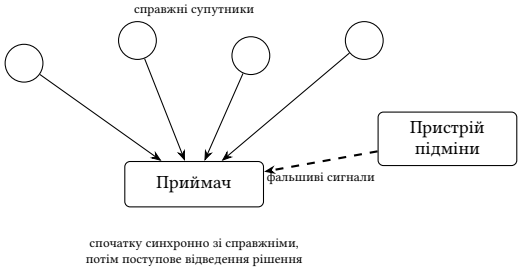


Рис. 14.1 — Узгоджена підміна GNSS (за [168])

14.1.3 Виявлення підміни та захист

Методи виявлення й захисту від підміни [236, 253] узагальнено в табл. 14.1.

Таблиця 14.1 — Методи захисту GNSS від глушіння та підміни

Метод	Принцип і застосовність
Моніторинг потужності	аномально висока потужність свідчить про підміну/глушіння
Перевірка узгодженості	звіряння з інерціальними датчиками, одометрією, картою
Кутовий аналіз (антенні решітки)	справжні сигнали приходять з різних напрямків, фальшиві — з одного
Автентифікація сигналу (OSNMA)	криптографічне підтвердження автентичності навігаційних повідомлень
Множинні системи	порівняння GPS, Galileo, BeiDou ускладнює узгоджену підміну
Захищені приймачі, CRPA	адаптивні антенні решітки придушують завади і фальшиві сигнали

14.1.4 Автентифікація навігаційних сигналів

Принциповим розв'язанням проблеми підміни для цивільних сигналів є криптографічна автентифікація навігаційних повідомлень. Система Galileo впровадила OSNMA (Open Service Navigation Message Authentication) [135, 131]: навігаційні повідомлення автентифікуються через механізм відкладеного розкриття ключів (TESLA, розділ 6), що дозволяє приймачеві переконатися, що повідомлення надійшло від справжнього супутника, а не від пристрою підміни. Механізм не потребує секрету в приймачі й ефективний за обмежених обчислень. Обмеження: OSNMA автентифікує *дані* повідомлення, але сама вимірювана величина (час приходу) все ще може бути маніпульована узгодженою підміною або ретрансляцією; повний захист вимагає поєднання автентифікації з перевіркою узгодженості й антенними методами. Для критичних застосувань (авіація, енергетика) розгортання

автентифікованих сигналів і захищених приймачів є пріоритетом. Незалежним резервом на випадок недоступності GNSS слугують наземні системи точного часу й інерціальна навігація.

14.2 Безпека супутникового зв'язку

Супутниковий зв'язок охоплює геостаціонарні системи (телебачення, VSAT-термінали, магістральні канали) і низькоорбітальні угруповання (широкосмуговий доступ, Інтернет речей). Специфіка безпеки: величезна зона покриття означає, що сигнал можна прийняти на великій території (розділ 1); історично багато систем передавали дані без шифрування. Павур та співавтори [229] показали, що трафік морських і авіаційних VSAT-терміналів можна перехопити недорогим обладнанням на великій відстані, оскільки він часто не шифрувався, розкриваючи чутливі дані. Це ще один приклад хибного покладання на «складність» доступу замість криптографії.

Порівняння класів супутникових систем зв'язку наведено в табл. 14.2.

Таблиця 14.2 — Класи супутникового зв'язку та їх безпекові особливості

Клас	Затримка, покриття	Безпекові особливості
Геостаціонарний (GEO)	велика затримка; широка зона	велика зона перехоплення; історично незашифрований VSAT-трафік
Середньоорбітальний (MEO)	середня	навігаційні системи (GNSS); слабкий сигнал
Низькоорбітальний (LEO)	мала; глобальне угруповання	багато вузлів і міжсупутникові канали; стратегічна роль, стійкість

Загрози супутниковому зв'язку: перехоплення незашифрованого трафіку; глушіння висхідних і низхідних каналів; підміна сигналів; атаки на наземні станції керування; захоплення керування супутником через незахищені телеметричні канали. Захист: наскрізне шифрування трафіку (не покладатися на безпеку радіоканалу); автентифікація й шифрування каналів керування супутником (стандарти захисту космічних каналів даних [92]); захист наземної інфраструктури; для низькоорбітальних угруповань — безпека великої кількості вузлів і міжсупутникових каналів. Низькоорбітальні системи широкосмугового зв'язку, регулювання яких визначають, зокрема, рекомендації МСЕ [243], набули стратегічного значення, зокрема для забезпечення зв'язку в умовах руйнування наземної інфраструктури, що робить їх безпеку й стійкість питанням національної ваги.

14.3 Безпека безпілотних систем

14.3.1 Поверхня атаки

Безпілотний літальний апарат є складною безпроводовою системою з кількома вразливими каналами (рис. 14.2): канал керування (від оператора чи наземної станції), канал телеметрії й відеопередавання, канал супутникової навігації, а для автономних апаратів — бортові сенсори й обчислення. Кожен канал є ціллю [198]: канал керування — глушіння (втрата керування) і підміна команд; навігація — глушіння й підміна GNSS (захоплення, відведення); телеметрія — перехоплення (розвідка) і підміна; сенсори — атаки впровадження сигналів (розділ 5).

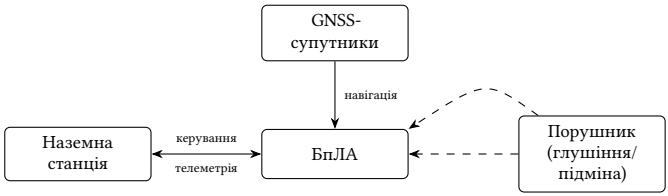


Рис. 14.2 — Канали безпілотного апарата як поверхня атаки

14.3.2 Захист каналів

Захист безпілотних систем [20] поєднує методи, розглянуті в попередніх розділах. *Канал керування*: шифрування й автентифікація команд (розділ 6), стійкість до глушіння через розширення спектра з криптографічною послідовністю та спрямовані антени (розділ 5, кейс у якому детально розбирає цей канал), автономні режими за втрати зв'язку. *Навігація*: автентифіковані сигнали (OSNMA), поєднання з інерціальною навігацією й іншими джерелами для виявлення підміни, антенні решітки. *Телеметрія*: шифрування, мінімізація випромінювання для прихованості. *Ідентифікація*: регуляторні вимоги до дистанційної ідентифікації безпілотних апаратів [99] створюють баланс між безпекою повітряного простору й приватністю операторів. Ключовий принцип — *багаторівнева стійкість*: жоден окремий захід не забезпечує безпеки, потрібне поєднання захисту всіх каналів і здатності до автономної безпечної поведінки за компрометації будь-якого з них.

14.3.3 Протидія ворожим безпілотним апаратам

Зворотний бік — захист від ворожих безпілотних апаратів, що поєднує виявлення (радіолокація, радіочастотне виявлення каналів керування, акустика, оптика), ідентифікацію й нейтралізацію (глушіння каналів керування й навігації, підміна для перехоплення керування, кінетичні засоби). Це є застосуванням методів глушіння й підміни (розділи 3, 5) у захисних цілях. Виявлення каналів керування спирається на аналіз радіочастотного спектра й розпізнавання сигнатур протоколів (розділ 15). Ця сфера швидко розвивається, зокрема в контексті захисту критичної інфраструктури й у воєнному застосуванні.

14.4 Український контекст

Для України безпека супутникових, навігаційних і безпілотних систем має надзвичайну актуальність через масштабне застосування цих технологій і активну протидію в умовах війни. *Радіоелектронна боротьба проти GNSS*: масове глушіння й підміна сигналів GNSS впливають на цивільну авіацію, судноплавство, синхронізацію мереж і роботу безпілотних систем на значних територіях; це зробило стійкість навігації й наявність резервних джерел часу практичним пріоритетом. *Безпілотні системи*: масове застосування безпілотних апаратів усіма сторонами зробило безпеку їхніх каналів керування й навігації, а також протидію ворожим апаратам, критично важливою; постійна «гонка» між засобами глушіння/підміни й засобами захисту (автономність, стійкі канали, інерціальна навігація) визначає розвиток технологій. *Супутниковий зв'язок*: низькоорбітальні системи широкосмугового зв'язку відіграли ключову роль у забезпеченні зв'язку за руйнування наземної інфраструктури, що підкреслило стратегічне значення їх безпеки

й стійкості. *Синхронізація часу*: залежність критичної інфраструктури від GNSS для точного часу зробила захист від його порушення питанням стійкості (розділ 16). Ці виклики стимулюють дослідження й розробки у сфері стійкої навігації, захищених каналів керування та протидії безпілотним загрозам, у яких український досвід є унікальним.

14.5 Кейс: захист безпілотної системи моніторингу критичної інфраструктури

Оператор критичної інфраструктури використовує безпілотні апарати для моніторингу протяжних об'єктів (трубопроводи, лінії електропередач). Апарати діють в умовах можливого глушіння й підміни. Аналіз безпеки.

Модель загроз. Глушіння каналу керування (втрата апарата); підміна GNSS (відведення, захоплення); перехоплення телеметрії й відео (розвідка об'єкта); підміна команд; фізичне захоплення апарата з даними.

Рішення. (1) *Канал керування*: шифрування й автентифікація команд, розширення спектра з криптографічною послідовністю стрибків, спрямовані антени (розділ 5); автономне повернення за втрати зв'язку. (2) *Навігація*: автентифіковані сигнали Galileo OSNMA, інерціальна навігація як резерв і засіб виявлення підміни через перевірку узгодженості (14.1), антенна решітка для придушення завад. (3) *Телеметрія й дані*: наскрізне шифрування, мінімізація зберігання чутливих даних на борту, стирання за виявлення захоплення. (4) *Автономність*: здатність продовжувати місію й безпечно завершувати її за компрометації будь-якого каналу. (5) *Моніторинг*: виявлення глушіння й підміни як подій безпеки (розділ 15).

Обґрунтування. Пріоритет — доступність і цілісність навігації та керування (втрата апарата чи його захоплення — найвищий вплив). Резервування навігації (інерціальна + множинні GNSS + автентифікація) забезпечує стійкість до глушіння й підміни. Автономність обмежує наслідки втрати зв'язку. Шифрування телеметрії захищає розвідувальну цінність. Кейс демонструє інтеграцію методів усіх попередніх розділів — фізичного рівня, криптографії, виявлення — у стійку систему, у якій багаторівневість компенсує неможливість повного захисту окремого каналу.

Висновки до розділу

Супутникові, навігаційні й безпілотні системи є класом безпроводових систем із найбільшою дальністю й особливими вимогами безпеки. GNSS має фундаментальну вразливість — надзвичайно слабкий сигнал і історичну відсутність автентифікації, — що робить її вразливою до глушіння (просте, впливає на позиціювання й синхронізацію часу) і підміни (складніша, небезпечніша, бо не виявляється як втрата сигналу). Захист поєднує моніторинг, перевірку узгодженості з іншими датчиками, антенні решітки, мно-

жинні системи й, принципово, криптографічну автентифікацію навігаційних повідомлень (Galileo OSNMA), яка, проте, не захищає повністю від узгодженої підміни й потребує доповнення. Супутниковий зв'язок історично страждав від передавання незашифрованого трафіку, що вимагає наскрізного шифрування й захисту каналів керування супутниками. Безпілотні системи мають кілька вразливих каналів (керування, телеметрія, навігація, сенсори), захист яких вимагає багаторівневої стійкості й здатності до автономної безпечної поведінки за компрометації будь-якого каналу. Для України ці питання загострені масштабною радіоелектронною боротьбою проти GNSS, масовим застосуванням безпілотних систем і стратегічною роллю супутникового зв'язку в умовах війни, що робить стійку навігацію, захищені канали керування й протидію безпілотним загрозам практичними пріоритетами й напрямами, у яких український досвід є унікальним.

Питання для самоперевірки

1. Опишіть принцип роботи GNSS (14.1). У чому полягає фундаментальна вразливість системи?
2. Порівняйте глушіння й підміну GNSS за складністю, наслідками й виявлюваністю. Чому підміна небезпечніша?
3. Що таке узгоджена підміна? Чому вона найпідступніша?
4. Опишіть методи виявлення підміни GNSS (табл. 14.1). Які з них не потребують змін у сигналі, а які вимагають криптографії?
5. Як працює автентифікація навігаційних повідомлень OSNMA? Що вона захищає й чого не захищає?
6. Чому синхронізація часу через GNSS є критичною залежністю? Які системи від неї залежать і які резерви існують?
7. Які специфічні загрози має супутниковий зв'язок? Чому передавання незашифрованого трафіку є системною вадою?
8. Опишіть канали безпілотного апарата як поверхню атаки (рис. 14.2). Які загрози має кожен канал?
9. Які методи захищають кожен канал безпілотної системи? Чому потрібна багаторівнева стійкість і автономність?
10. Як здійснюється протидія ворожим безпілотним апаратам? Як вона пов'язана з методами глушіння й підміни?
11. Які виклики безпеки супутникових, навігаційних і безпілотних систем загострені в українському контексті?
12. Чому для безпілотної системи критичної інфраструктури пріоритетними є доступність і цілісність навігації та керування?

13. Як інерціальна навігація доповнює GNSS для виявлення підміни? У чому обмеження цього підходу?
14. Дослідницьке: спроєктуйте систему виявлення підміни GNSS для безпілотного апарата, що поєднує автентифікацію OSNMA, інерціальну навігацію й кутовий аналіз, і оцініть її ефективність за показниками виявлення й хибних тривог (розділ 3).
15. Дослідницьке: розробіть архітектуру стійкої навігації й синхронізації часу для об'єкта критичної інфраструктури, що зберігає працездатність за тривалого глушіння GNSS, і обґрунтуйте вибір резервних джерел.

РОЗДІЛ 15

Моніторинг, радіомоніторинг та виявлення вторгнень у безпроводових мережах

Попередні розділи неодноразово показали, що повне запобігання атакам у безпроводовому середовищі неможливе: широкомовність не дає приховати передавання, глушіння не усувається криптографією, частина кадрів принципово незахищена, а пристрої можуть бути скомпрометовані. Тому здатність *виявити* атаку, локалізувати її джерело й вчасно відреагувати є не менш важливою за запобігання й становить окрему функцію системи безпеки. Для безпроводових мереж моніторинг має особливість: об'єктом спостереження є не лише мережевий трафік, а й сам радіочастотний спектр — фізичне середовище, у якому діють глушіння, підроблені передавачі й несанкціоновані пристрої. Розділ розглядає завдання й джерела моніторингу безпроводових мереж, системи виявлення вторгнень і аномалій, радіомоніторинг і аналіз спектра, застосування машинного навчання та його вразливості, локалізацію джерел радіовипромінювання, а також організацію центру моніторингу безпеки. Статистичні основи виявлення розглянуто в розділі 3, реагування на інциденти — у розділі 16.

15.1 Завдання та джерела моніторингу

15.1.1 Специфіка моніторингу безпроводових мереж

Моніторинг безпроводових мереж поєднує три рівні спостереження. *Радіочастотний рівень*: стан спектра, наявність завад і глушіння, несанкціоновані передавачі, підроблені точки доступу й базові станції, аномальні характеристики сигналів. *Канальний і мережевий рівні*: аналіз кадрів і пакетів, виявлення атак на протоколи (деавтентифікація, атаки на рукостискання), аномального трафіку. *Рівень поведінки й контексту*: аномальна поведінка пристроїв і користувачів, невідповідність контексту (незвичне місце, час, обсяг). Особливість — необхідність спеціалізованого обладнання для радіочастотного рівня (сенсори, аналізатори спектра, програмно визначені радіоприймачі), якого немає в традиційних системах моніторингу мереж.

15.1.2 Джерела даних

Джерела даних для моніторингу узагальнено в табл. 15.1. Ключовий принцип — *кореляція* даних з різних джерел, яка, як показано в розділі 3, необхідна для зниження частки хибних тривог до практично прийнятного рівня.

Таблиця 15.1 — Джерела даних для моніторингу безпроводових мереж

Джерело	Що дає
Радіочастотні сенсори	стан спектра, глушіння, несанкціоновані передавачі, відбитки
Точки доступу / базові станції	журнали асоціацій, автентифікацій, аномальні кадри
Мережеві сенсори	трафік, потоки, атаки на протоколи
Дані пристроїв і агентів	стан, поведінка застосунків, ознаки компрометації
Журнали автентифікації	невдалі спроби, аномальні входи
Зовнішня розвідка загроз	індикатори компрометації, сигнатури
Краудсорсинг від терміналів	параметри мережі для виявлення фальшивих базових станцій

15.2 Виявлення вторгнень і аномалій

15.2.1 Сигнатурне й аномальне виявлення

Системи виявлення вторгнень [255] використовують два підходи. *Сигнатурне виявлення* шукає відомі патерни атак; воно точне для відомих загроз (низька частка хибних тривог), але не виявляє нових. *Аномальне виявлення* [94] будує модель нормальної поведінки й сигналізує про відхилення; воно здатне виявляти невідомі атаки, але страждає від хибних тривог, оскільки не всяке відхилення є атакою. Для безпроводових мереж специфічними сигнатурами є, наприклад, сплеск кадрів деавтентифікації (атака на доступність), поява точки доступу з відомим SSID, але іншим передавачем (двійник, розділ 5), аномальні параметри базової станції (фальшива, розділ 9). Емпіричне оцінювання загроз і систем виявлення для мереж 802.11 систематизовано в [192].

15.2.2 Проблема базової частоти на практиці

Як доведено в розділі 3 (формула (3.6)), для рідкісних атак навіть детектор з високою точністю дає переважно хибні тривоги. Це фундаментальне обмеження визначає архітектуру практичних систем: замість одного детектора з високою чутливістю використовують *багатоступеневу* схему. Нехай перший ступінь із високою чутливістю (виявляє майже всі атаки, але з багатьма хибними тривогами) фільтрує потік подій, а другий ступінь із високою специфічністю підтверджує лише справжні. За незалежності ознак сумарна частка хибних тривог

$$P_{FA}^{\Sigma} = P_{FA}^{(1)} \cdot P_{FA}^{(2)}, \tag{15.1}$$

що дозволяє досягти прийнятного рівня, недосяжного одним детектором. Наприклад, два незалежні ступені з $P_{FA} = 0{,}05$ кожен дають $P_{FA}^{\Sigma} = 0{,}0025$, підвищуючи частку істинних тривог на порядок. Це формалізує принцип кореляції: рішення про тривогу ухвалюється лише за узгодження кількох незалежних ознак (наприклад, аномалія трафіку + аномалія радіосигналу).

Порівняння підходів до виявлення наведено в табл. 15.2.

Таблиця 15.2 — Порівняння підходів до виявлення вторгнень

Підхід	Переваги	Недоліки
Сигнатурний	точність для відомих атак; мало хибних тривог	не виявляє нових атак; потребує оновлення сигнатур
Аномальний	виявляє невідомі атаки	багато хибних тривог; потребує моделі норми
На основі специфікацій	точність за формальної моделі протоколу	складність побудови специфікації
Гібридний / кореляційний	баланс через поєднання ознак (15.1)	складність налаштування

15.2.3 Виявлення специфічних атак

Розглянуті в попередніх розділах атаки мають характерні ознаки для виявлення. *Фальшиві базові станції* (розділ 9): аномальні ідентифікатори комірок, надмірна потужність, примус до 2G, незвичні запити ідентифікаторів — виявляються аналізом параметрів мережі й краудсорсингом від терміналів. *Точки доступу-двійники* (розділ 7): збіг SSID/BSSID за різних радіочастотних відбитків або розташування; методи виявлення атаки Evil Twin в умовах щільної забудови досліджено в [3]. *Глушіння* (розділ 3): узгоджена аномалія — низька доставка кадрів за високої потужності. *Компрометовані вузли*: аномальний трафік, відхилення поведінки; методи тестового виявлення й ізоляції заражених вузлів запропоновано в [4].

15.3 Радіомоніторинг та аналіз спектра

Радіомоніторинг — спостереження за радіочастотним спектром для виявлення, ідентифікації й локалізації джерел випромінювання — є специфічним для безпроводової безпеки завданням. Основні функції: виявлення несанкціонованих передавачів (закладних пристроїв, підроблених точок доступу, каналів витоку); виявлення глушіння й визначення його джерела; ідентифікація технологій і протоколів за характеристиками сигналу; виявлення каналів керування безпілотних апаратів (розділ 14). Сучасний радіомоніторинг спирається на програмно визначені радіоприймачі, що дозволяють гнучко аналізувати широкий спектр, і на автоматичну класифікацію сигналів.

Ідентифікація технології за сигналом традиційно ґрунтувалася на аналізі характеристик (ширина смуги, модуляція, структура кадру). Сучасні методи застосовують глибинне навчання безпосередньо до вибірок сигналу [222], досягаючи класифікації типу модуляції й технології навіть за низького відношення сигнал/шум. Це важливо для виявлення прихованих або нестандартних передавачів. Радіочастотний відбиток передавача (розділ 5) доповнює класифікацію, дозволяючи розрізняти окремі пристрої. Для об'єктів технічного захисту інформації радіомоніторинг є частиною контролю ефективності захисту від витоку інформації технічними каналами (розділ 5) і виконується згідно з вимогами системи технічного захисту інформації.

15.4 Локалізація джерел радіовипромінювання

Виявити передавач часто недостатньо — потрібно визначити його місцезнаходження (для нейтралізації закладки, глушилки, ворожого безпілотного апарата). Методи локалізації [233] наведено на рис. 15.1 і включають: *за потужністю* (RSS) — оцінка відстані за рівнем сигналу від кількох сенсорів, проста, але неточна через завмирання; *за різницею часу приходу* (TDOA) — гіперболічна локалізація за різницею моментів приймання сигналу рознесеними сенсорами, точна, але потребує синхронізації; *за кутом приходу* (AOA) — пеленгація напрямку антенними решітками з тріангуляцією; *комбіновані* методи.

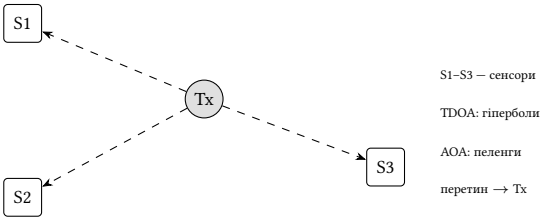


Рис. 15.1 — Локалізація джерела радіовипромінювання рознесеними сенсорами

Для методу TDOA положення джерела визначається з системи рівнянь: різниця відстаней до пар сенсорів пропорційна виміряній різниці часу приходу,

$$\|\mathbf{p} - \mathbf{s}_i\| - \|\mathbf{p} - \mathbf{s}_j\| = c\,(\tau_i - \tau_j), \tag{15.2}$$

де $\mathbf{p}$ — шукане положення джерела; $\mathbf{s}_i$ — положення i-го сенсора; τ_i — момент приймання. Кожне рівняння задає гіперболу (в 2D) чи гіперболоїд (в 3D); перетин кількох дає положення. Точність визначається геометрією розташування сенсорів (аналогічно GDOP у GNSS, розділ 14) і точністю вимірювання часу. Локалізація джерел глушіння дозволяє їх нейтралізацію, а

локалізація каналів керування безпілотних апаратів — протидію їм (розділ 14). В умовах війни радіорозвідка й локалізація джерел випромінювання є критично важливими, а зворотний бік — захист власних передавачів через радіодисципліну й прихованість (розділи 4, 5).

15.5 Машинне навчання та його вразливості

15.5.1 Застосування й обмеження

Машинне навчання широко застосовують у моніторингу безпроводових мереж: класифікація сигналів, виявлення аномалій, ідентифікація пристроїв за відбитком, виявлення атак. Проте Соммер і Паксон [269] сформулювали фундаментальні застереження щодо машинного навчання у виявленні вторгнень: аномалія не тотожна атаці (велика різноманітність нормальної поведінки дає багато хибних тривог); висока ціна помилок; складність інтерпретації рішень; проблема отримання репрезентативних розмічених даних; змінність середовища. Тому машинне навчання доцільне як *доповнення* до детермінованих методів і для задач, де воно має перевагу (класифікація сигналів, виявлення відомих патернів у великих обсягах), а не як універсальна заміна.

15.5.2 Атаки на моделі

Самі моделі машинного навчання є ціллю атак [83]. *Змагальні приклади*: мінімальні збурення входу, що спричиняють хибну класифікацію — для радіосигналів це спеціально сформовані сигнали, що обманюють класифікатор. *Отруєння даних*: маніпуляція навчальними даними для впровадження помилок чи «чорних ходів». *Ухиляння*: адаптація атаки для обходу навченої моделі. Це особливо критично, оскільки моделі використовуються для безпеки, а порушник мотивований їх обманути. Ризик-орієнтоване виявлення кібератак у безпроводових мережах з урахуванням стійкості моделей машинного навчання розглянуто в [27]. Захист: стійке навчання, ансамблі, поєднання з детермінованими правилами, моніторинг самих моделей, обмеження довіри до їх рішень для критичних дій. Загальний принцип: модель машинного навчання, що ухвалює рішення безпеки, сама стає активом і поверхнею атаки, тому потребує захисту й не повинна бути єдиною підставою для критичних рішень.

15.6 Організація моніторингу безпеки

Технічні засоби моніторингу мають бути інтегровані в організаційний процес — центр забезпечення кібербезпеки (SOC) з функціями безперервного моніторингу [106]. Узагальнену схему конвеєра моніторингу наведено на рис. 15.2.

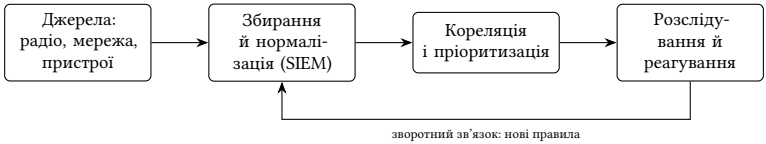


Рис. 15.2 — Конвеєр моніторингу безпеки безпроводової інфраструктури

Ключові елементи: збирання й нормалізація даних з усіх джерел (табл. 15.1) у систему керування подіями безпеки (SIEM); кореляція подій за правилами й моделями (15.1); пріоритезація сповіщень; процедури розслідування; інтеграція з реагуванням (розділ 16); зворотний зв'язок для вдосконалення правил. Для безпроводової безпеки SOC має включати радіочастотний моніторинг, що традиційно був поза увагою мережевих центрів. Метрики ефективності моніторингу — середній час виявлення (MTTD) і час реагування (MTTR) — прямо пов'язані з регуляторними вимогами щодо строків повідомлення про інциденти (розділ 2, співвідношення (2.1)): система моніторингу має забезпечувати MTTD, сумісний із 24-годинним строком раннього попередження NIS 2. Узгодження технік атак з базами знань MITRE ATT&CK, зокрема для мобільних пристроїв [205], забезпечує повноту покриття й спільну мову з реагуванням.

15.7 Кейс: моніторинг безпеки безпроводової інфраструктури підприємства

Підприємство критичної інфраструктури з корпоративним Wi-Fi, приватною мережею 5G і датчиками Інтернету речей будує систему моніторингу. Проєктування на основі матеріалу розділу.

Цілі. Виявлення підроблених точок доступу й фальшивих базових станцій; виявлення глушіння; виявлення компрометованих пристроїв; виявлення закладних передавачів у чутливих приміщеннях; забезпечення MTTD, сумісного з регуляторними вимогами.

Рішення. (1) *Радіочастотні сенсори*: покриття території для виявлення несанкціонованих передавачів, глушіння й підроблених точок доступу; у чутливих приміщеннях — контроль спектра для виявлення закладок (розділ 5). (2) *Мережеві й системні джерела*: журнали точок доступу, ядра 5G, датчиків, агентів на пристроях; краудсорсинг параметрів мережі від терміналів для виявлення фальшивих базових станцій. (3) *Кореляція*: багатоступенева схема (15.1) — підтвердження тривоги за узгодження радіочастотної й мережевої ознак для зниження хибних тривог (3.6). (4) *Локалізація*: сенсори з можливістю TDOA/AOA (15.2) для визначення джерел глушіння й закладок. (5) *Машинне навчання*: для класифікації сигналів і виявлення аномалій — як доповнення до правил, із захистом моделей і без права на критичні

дії без підтвердження. (6) *SOC*: інтеграція в SIEM, правила кореляції, процедури розслідування й реагування (розділ 16), метрики MTTD/MTTR.

Обґрунтування. Радіочастотний моніторинг є обов'язковим для безпроводової інфраструктури й традиційно відсутній у мережевих SOC. Багатоступенева кореляція розв'язує проблему хибних тривог, доведену в розділі 3. Локалізація перетворює виявлення на дієвий захід (нейтралізація джерела). Машинне навчання застосовується обґрунтовано, з урахуванням його обмежень і вразливостей. Кейс демонструє, що ефективний моніторинг безпроводової безпеки вимагає інтеграції радіочастотного, мережевого й поведінкового рівнів, кореляції для зниження хибних тривог і зв'язку з реагуванням.

Висновки до розділу

Оскільки повне запобігання атакам у безпроводовому середовищі неможливе, виявлення, локалізація й реагування є окремою критичною функцією безпеки. Моніторинг безпроводових мереж поєднує три рівні — радіочастотний, мережевий і поведінковий, — причому радіочастотний рівень, що потребує спеціалізованого обладнання, традиційно відсутній у мережевих центрах моніторингу. Системи виявлення вторгнень поєднують сигнатурний підхід (точний для відомих загроз) і аномальний (здатний виявляти нові, але з хибними тривогами); фундаментальна проблема базової частоти, доведена в розділі 3, робить обов'язковою багатоступеневу кореляцію незалежних ознак для досягнення прийнятної частки істинних тривог. Радіомоніторинг і аналіз спектра з автоматичною класифікацією сигналів і радіочастотним відбитком дозволяють виявляти несанкціоновані й приховані передавачі, а локалізація методами RSS, TDOA і AOA перетворює виявлення на дієвий захід. Машинне навчання корисне для класифікації й виявлення аномалій, але має фундаментальні обмеження у виявленні вторгнень і саме є ціллю атак (змагальні приклади, отруєння), тому має доповнювати, а не замінювати детерміновані методи й не бути єдиною підставою критичних рішень. Технічні засоби мають бути інтегровані в центр забезпечення кібербезпеки з кореляцією, розслідуванням і зв'язком із реагуванням, а метрики MTTD/MTTR прямо пов'язані з регуляторними вимогами. Для України радіомоніторинг і локалізація джерел випромінювання мають особливе значення в контексті радіоелектронної боротьби й протидії безпілотним загрозам.

Питання для самоперевірки

1. Які три рівні поєднує моніторинг безпроводових мереж? У чому специфіка радіочастотного рівня?

2. Перелічіть джерела даних для моніторингу (табл. 15.1). Чому кореляція джерел є ключовим принципом?
3. Порівняйте сигнатурне й аномальне виявлення. Які специфічні для безпроводових мереж сигнатури й аномалії ви знаєте?
4. Як проблема базової частоти впливає на архітектуру систем виявлення? За формулою (15.1) обчисліть сумарну частку хибних тривог для трьох незалежних ступенів із $P_{FA} = 0{,}1$ кожен.
5. Які характерні ознаки мають фальшиві базові станції, точки доступу-двійники й глушіння для виявлення?
6. Які функції виконує радіомоніторинг? Як застосовують машинне навчання й радіочастотний відбиток для класифікації сигналів?
7. Опишіть методи локалізації джерел випромінювання (рис. 15.1). Порівняйте RSS, TDOA і AOA за точністю й вимогами.
8. За формулою (15.2) поясніть принцип локалізації TDOA. Від чого залежить її точність?
9. Які застереження щодо машинного навчання у виявленні вторгнень сформулювали Соммер і Паксон? Коли ML доцільне?
10. Опишіть атаки на моделі машинного навчання. Чому вони критичні для систем безпеки і які заходи захисту?
11. Які елементи включає центр забезпечення кібербезпеки для безпроводової інфраструктури? Як MTTD пов'язаний з регуляторними вимогами?
12. Чому радіочастотний моніторинг є обов'язковим, але традиційно відсутнім у мережевих SOC?
13. Як локалізація перетворює виявлення на дієвий захід? Наведіть приклади нейтралізації джерел.
14. Дослідницьке: спроєктуйте багатоступеневу схему виявлення фальшивих базових станцій, що поєднує краудсорсинг від терміналів і радіочастотні сенсори, і оцініть її частку істинних тривог за методикою розділу 3.
15. Дослідницьке: проаналізуйте стійкість класифікатора сигналів на основі глибинного навчання до змагальних прикладів і запропонуйте заходи підвищення його робастності для застосування в моніторингу безпеки.

РОЗДІЛ 16

Стійкість, неперервність та відновлення безпроводових і мобільних мереж

Безпека не вичерпується запобіганням і виявленням атак: система має зберігати працездатність під час несприятливих подій і швидко відновлюватися після них. Для безпроводових і мобільних мереж це питання набуло особливої гостроти. По-перше, вони є критичною інфраструктурою, від якої залежать зв'язок, екстрені служби, керування іншими секторами. По-друге, як показали розділи 1 і 9, найруйнівніші сценарії — не атака на радіоінтерфейс, а масштабна кібератака на інфраструктуру оператора (кейс «Київстар») або фізичне руйнування мережі. По-третє, український досвід функціонування мереж в умовах війни — знеструмлень, руйнувань, радіоелектронної боротьби — дав унікальні уроки стійкості, важливі й для світової практики. Розділ розглядає поняття стійкості безпроводових мереж, кількісні моделі доступності й відмов зі спільної причини, реагування на інциденти й відновлення, забезпечення неперервності, механізм національного роумінгу та енергетичну автономність, а також уроки українського досвіду. Марковські моделі доступності введено в розділі 3, моніторинг — у розділі 15.

16.1 Поняття стійкості безпроводової мережі

Стійкість (resilience) безпроводової мережі — здатність зберігати прийнятний рівень обслуговування за наявності викликів нормальному функціонуванню: відмов, перевантажень, атак, стихійних лих, руйнувань [273]. Стійкість ширша за надійність (стосується випадкових відмов) і за безпеку (стосується навмисних атак), охоплюючи весь спектр загроз функціонуванню [96]. Стратегію стійкості описують циклом: *захист* (запобігання й пом'якшення впливу подій), *виявлення* (розділ 15), *відновлення* (повернення до норми), *адаптація* (вдосконалення за результатами). Ключові властивості стійкої мережі: *надлишковість* (резервні компоненти й шляхи), *різноманітність* (незалежність резервів, щоб уникнути спільних причин відмов), *автономність* (здатність працювати без зовнішніх залежностей), *деградація з гідністю* (плавне зниження якості замість повної відмови).

Цикл стійкості наведено на рис. 16.1.



Рис. 16.1 — Цикл стійкості безпроводової мережі (за [273])

Для безпроводових мереж специфічними викликами стійкості є: залежність від енергопостачання (базові станції потребують живлення); залежність від транспортної мережі (backhaul); залежність від GNSS для синхронізації (розділ 14); вразливість до глушіння (розділ 3); концентрація функцій в ядрі оператора (розділ 9). Стійкість досягається зменшенням цих залежностей і забезпеченням незалежних резервів.

16.2 Кількісні моделі стійкості

16.2.1 Доступність і відмови зі спільної причини

Базові моделі доступності введено в розділі 3. Ключовий для стійкості висновок стосується **відмов зі спільної причини**: надлишковість дає ефект лише за незалежності резервів. Для системи з n резервних елементів за незалежності відмов недоступність $U_{\text{незал}} = U^n$ (де U — недоступність одного елемента) швидко прямує до нуля. Проте за наявності спільної причини (спільне живлення, спільний майданчик, спільна вразливість, масований обстріл) реальна недоступність визначається β-фактором [279]:

$$U_{\text{сис}} = (1-\beta)\,U^n + \beta\,U, \tag{16.1}$$

де $\beta \in [0;1]$ — частка відмов зі спільної причини. Для $U = 10^{-3}$, $n = 3$ і $\beta = 0$ маємо $U_{\text{сис}} = 10^{-9}$, а за $\beta = 0{,}05$ — $U_{\text{сис}} \approx 5 \cdot 10^{-5}$, тобто на чотири порядки гірше. Практичний висновок, підтверджений українським досвідом: реальну стійкість визначає не кратність резервування, а *незалежність* резервів. Інвестиції в незалежність (окреме живлення, географічне рознесення, різні транспортні шляхи, різні постачальники) дають більший ефект, ніж збільшення кількості однотипних резервів.

16.2.2 Час відновлення й цільові показники

Стійкість характеризують не лише доступністю, а й швидкістю відновлення. Ключові показники (розділ 11 щодо ризиків): **цільовий час відновлення** (RTO) — максимально допустимий час відновлення послуги; **цільова точка відновлення** (RPO) — максимально допустимий обсяг втрачених даних. Для мобільного оператора після руйнівної кібератаки (кейс «Київстар») RTO вимірюється днями відновлення послуг, а фактором є наявність

ізольованих резервних копій і планів відновлення. Загальна доступність з урахуванням відновлення пов'язана з частотою й тривалістю відмов через співвідношення $A = \mathrm{MTTF}/(\mathrm{MTTF} + \mathrm{MTTR})$ (розділ 3), тому скорочення MTTR (швидке відновлення) так само важливе, як збільшення MTTF (запобігання).

16.2.3 Стійкість покриття

Для безпроводових мереж специфічним є показник стійкості *покриття*: за виходу з ладу частини базових станцій сусідні можуть частково компенсувати покриття, збільшуючи потужність і радіус (ціною ємності). Це дає деградацію з гідністю: мережа зберігає базовий зв'язок навіть за втрати частини вузлів. Кількісно залишкове покриття за втрати частки q вузлів залежить від щільності розгортання й здатності до адаптації; надлишкове покриття (перекриття зон сусідніх станцій) є формою надлишковості, що підвищує стійкість.

16.3 Реагування на інциденти

Реагування на інциденти [98] — організований процес обробки подій безпеки, що складається з фаз: *підготовка* (плани, засоби, навчання); *виявлення й аналіз* (розділ 15); *стримування* (обмеження поширення); *викорінення* (усунення причини); *відновлення* (повернення до норми); *висновки* (вдосконалення). Для безпроводових і мобільних мереж реагування має особливості. Специфічні інциденти: виявлення фальшивої базової станції чи підробленої точки доступу (стримування — попередження абонентів, локалізація й нейтралізація, розділ 15); глушіння (стримування — перехід на резервні канали, локалізація джерела); компрометація пристрою (ізоляція, стирання); масштабна атака на інфраструктуру оператора (кейс «Київстар» — стримування через відключення для локалізації, відновлення з резервів). Регуляторні вимоги щодо строків повідомлення (розділ 2, співвідношення (2.1)) визначають темп реагування: виявлення й класифікація мають укладатися в 24-годинний строк раннього попередження.

Щорічні звіти про інциденти безпеки телекомунікацій [126] узагальнюють галузевий досвід. Взаємодія з CERT-UA [93] і Держспецзв'язку [6] є обов'язковою для об'єктів критичної інфраструктури й забезпечує обмін індикаторами компрометації та скоординоване реагування на масштабні кампанії. Тестова послідовність виявлення й ізоляції заражених вузлів (розділ 15) є прикладом технічної підтримки фази стримування.

16.4 Відновлення та неперервність

16.4.1 Відновлення після інцидентів

Відновлення [77] — повернення до нормального функціонування після інциденту — вимагає попередньої підготовки: ізольованих резервних копій (недоступних для порушника, що вже в мережі), задокументованих процедур, протестованих планів, резервних середовищ. Кейс «Київстар» [2] показав, що за руйнівної атаки, яка знищує тисячі серверів, швидкість відновлення визначається саме наявністю ізольованих резервів і відпрацьованих процедур; критичною вадою є резервні копії, доступні з тієї самої мережі, які порушник знищує разом з основними системами. Уроки: резервні копії мають бути ізольованими й незмінними; плани відновлення мають бути протестовані; критичні системи мають бути сегментовані, щоб компрометація не поширювалася; взаємодія з іншими операторами (національний роумінг) забезпечує послугу під час відновлення.

16.4.2 Забезпечення неперервності

Управління неперервністю діяльності [177] — системний підхід до забезпечення функціонування критичних процесів під час і після порушень. Для оператора зв'язку це охоплює: аналіз впливу на діяльність (визначення критичних послуг і допустимого часу простою); стратегії неперервності (резервні майданчики, резервне живлення, альтернативні транспортні шляхи, національний роумінг); плани відновлення; регулярне тестування. Неперервність є не лише безпековою, а й регуляторною вимогою (ПРН щодо неперервності, розділ 2) і елементом стійкості національної критичної інфраструктури.

16.5 Національний роумінг та енергетична автономність

16.5.1 Національний роумінг

Національний роумінг — механізм, за якого абоненти одного оператора можуть користуватися мережею іншого оператора в межах країни за недоступності власної мережі. Україна запровадила національний роумінг [35] як захід стійкості: за виходу з ладу мережі одного оператора (через атаку, руйнування чи знеструмлення) його абоненти автоматично обслуговуються мережами інших операторів. Це форма надлишковості на рівні країни, що суттєво підвищує доступність зв'язку для населення в кризових умовах. Технічно національний роумінг вимагає узгодження між операторами, керування навантаженням (мережа-донор не має бути перевантажена), і має враховувати безпекові аспекти (автентифікація абонентів, захист сигналізації між мережами, розділ 9). Схему наведено на рис. 16.2.

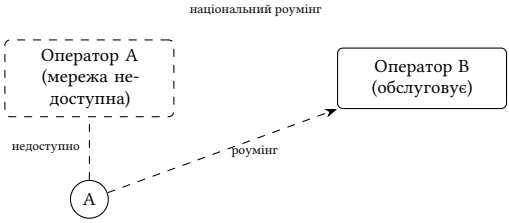


Рис. 16.2 — Національний роумінг як механізм стійкості

Ефект національного роумінгу на доступність можна оцінити: якщо власна мережа має доступність A_1, а роумінг забезпечує обслуговування з доступністю A_2 за незалежності,

$$A_{\text{сис}} = 1 - (1 - A_1)(1 - A_2), \tag{16.2}$$

що для $A_1 = 0{,}95$ (в кризових умовах) і $A_2 = 0{,}9$ дає $A_{\text{сис}} = 0{,}995$. Ключова умова — *незалежність* відмов мереж операторів (окреме живлення, різні майданчики), інакше спільна причина (масоване знеструмлення регіону) знижує ефект (16.1). Український досвід національного роумінгу є цінним внеском у світову практику стійкості мереж.

16.5.2 Енергетична автономність

Як показав досвід масованих ударів по енергетичній інфраструктурі, доступність мобільного зв'язку критично залежить від енергетичної автономності базових станцій [195]. За тривалих знеструмлень базові станції працюють від акумуляторів обмеженої ємності, тому час автономної роботи стає визначальним фактором доступності. Заходи: резервні джерела живлення (акумулятори збільшеної ємності, генератори); пріоритезація живлення критичних вузлів; мобільні базові станції для відновлення покриття; оптимізація енергоспоживання. Час автономної роботи $T_{\text{авт}} = E_{\text{бат}}/P_{\text{спож}}$ (ємність батареї на потужність споживання) визначає, скільки мережа працює після знеструмлення; його збільшення (більші батареї, генератори, зниження споживання) прямо підвищує стійкість. Це приклад того, як фізична стійкість (енергетика) стає складовою безпеки в широкому сенсі.

16.6 Уроки українського досвіду

Функціонування мереж зв'язку в Україні в умовах повномасштабної війни дало унікальні уроки стійкості, узагальнені в табл. 16.1.

Таблиця 16.1 — Уроки українського досвіду стійкості мереж зв'язку

Виклик	Урок і захід
Кібератака на оператора («Київстар»)	ізольовані незмінні резервні копії; сегментація; протестовані плани відновлення
Масовані знеструмлення	енергетична автономність базових станцій; резервне живлення; пріоритизація
Руйнування інфраструктури	географічне рознесення; мобільні базові станції; національний роумінг
Радіоелектронна боротьба	резервні джерела часу; стійка навігація; резервні канали (розділ 14)
Порушення транспорту (backhaul)	альтернативні шляхи; супутниковий backhaul; незалежність
Спільні причини відмов	незалежність резервів важливіша за їх кількість (16.1)

Головний узагальнений урок збігається з висновком кількісних моделей: *стійкість визначається незалежністю й автономністю, а не лише кратністю резервування*. Мережа, що має численні резерви зі спільною причиною відмови (спільне живлення, спільна юрисдикція, спільна вразливість), менш стійка, ніж мережа з меншою кратністю, але незалежними резервами. Український досвід також показав цінність координації на рівні держави (національний роумінг, взаємодія операторів, координація Держспецзв'язку) і важливість фізичної стійкості (енергетика) як складової безпеки. Правовий режим воєнного стану [40] створює рамку для екстрених заходів забезпечення функціонування зв'язку. Ці уроки, що доповнюють галузеві настанови з реагування на лиха та стійкості мереж [156], є внеском України у світову практику стійкості критичної інфраструктури й предметом активних досліджень.

16.7 Кейс: план стійкості мобільного оператора

Мобільний оператор критичної інфраструктури розробляє комплексний план стійкості. Синтез на основі матеріалу розділу.

Аналіз впливу. Критичні послуги: голосовий зв'язок і екстрені виклики (найвищий пріоритет), передавання даних, послуги для критичної інфраструктури. Допустимий час простою — години для повного відновлення, хвилини для базового зв'язку.

Заходи стійкості. (1) *Незалежність резервів* (16.1): географічне рознесення ядра й центрів даних, різні транспортні шляхи, різні постачальники живлення й обладнання. (2) *Захист від кібератак* (уроки «Київстар»): сегментація, ізольовані незмінні резервні копії, EDR, посилений захист адміністративного доступу (розділ 11), протестовані плани відновлення. (3) *Енергетична автономність*: резервне живлення критичних вузлів на

тривалий час, генератори, мобільні базові станції. (4) *Національний роумінг* (16.2): узгодження з іншими операторами, керування навантаженням, захист міжмережевої сигналізації. (5) *Незалежність від GNSS*: резервні джерела часу для синхронізації (розділ 14). (6) *Реагування й моніторинг*: інтеграція з SOC (розділ 15), взаємодія з CERT-UA, регулярні навчання. (7) *Тестування*: регулярні перевірки планів відновлення й національного роумінгу.

Обґрунтування пріоритетів. Аналіз кількісних моделей (16.1) і українського досвіду визначає пріоритет незалежності резервів над їх кратністю. Захист від руйнівних кібератак (кейс «Київстар») має найвищий пріоритет через найвищий вплив. Енергетична автономність і національний роумінг забезпечують доступність за фізичних порушень. Кейс демонструє, що стійкість — інтегральна властивість, що поєднує кібербезпеку, фізичну безпеку, енергетику й координацію, а не окремий технічний захід.

Висновки до розділу

Стійкість безпроводових і мобільних мереж — здатність зберігати прийнятне обслуговування за відмов, перевантажень, атак і руйнувань — є ширшою за надійність і безпеку й охоплює цикл захисту, виявлення, відновлення та адаптації. Кількісні моделі доводять центральний висновок, підтверджений українським досвідом: реальну стійкість визначає не кратність резервування, а незалежність резервів, оскільки відмови зі спільної причини (β-фактор) на порядки погіршують доступність порівняно з ідеалізованою незалежністю. Найруйнівніші сценарії для мобільних мереж — не атаки на радіоінтерфейс, а масштабні кібератаки на інфраструктуру оператора (кейс «Київстар») і фізичні руйнування; захист від них вимагає сегментації, ізольованих незмінних резервних копій і протестованих планів відновлення. Реагування на інциденти й забезпечення неперервності мають бути організованими процесами з урахуванням специфіки безпроводових мереж і регуляторних вимог щодо строків. Національний роумінг є ефективним механізмом стійкості на рівні країни, а енергетична автономність базових станцій — критичним фактором доступності за знеструмлень. Український досвід функціонування мереж в умовах війни дав унікальні уроки: незалежність і автономність важливіші за кратність, фізична стійкість (енергетика) є складовою безпеки, а координація на рівні держави суттєво підвищує стійкість; ці уроки є цінним внеском у світову практику.

Питання для самоперевірки

1. Дайте означення стійкості безпроводової мережі. Чим вона ширша за надійність і безпеку? Опишіть цикл стійкості.

2. Які специфічні виклики стійкості мають безпроводові мережі? Як їх зменшують?
3. Поясніть вплив відмов зі спільної причини (16.1). За $U = 10^{-3}$, $n = 4$ порівняйте недоступність для $\beta = 0$ і $\beta = 0{,}1$.
4. Чому незалежність резервів важливіша за їх кратність? Наведіть приклади незалежності.
5. Що таке RTO і RPO? Чому скорочення MTTR так само важливе, як збільшення MTTF?
6. Що таке стійкість покриття? Як надлишкове покриття забезпечує деградацію з гідністю?
7. Опишіть фази реагування на інциденти. Які специфічні інциденти й дії стримування характерні для безпроводових мереж?
8. Які уроки щодо відновлення дав кейс «Київстар»? Чому ізольованість резервних копій критична?
9. Що охоплює управління неперервністю діяльності для оператора зв'язку?
10. Поясніть механізм національного роумінгу. За формулою (16.2) обчисліть доступність для $A_1 = 0{,}9$, $A_2 = 0{,}85$. Яка ключова умова ефективності?
11. Чому енергетична автономність базових станцій є критичним фактором доступності? Як її підвищують?
12. Узагальніть уроки українського досвіду (табл. 16.1). Який головний висновок збігається з кількісними моделями?
13. Чому стійкість є інтегральною властивістю, а не окремим технічним заходом?
14. Дослідницьке: побудуйте модель доступності мережі регіону з урахуванням корельованих знеструмлень, національного роумінгу й енергетичної автономності та визначте оптимальний розподіл інвестицій між резервуванням і незалежністю.
15. Дослідницьке: розробіть план відновлення мобільного оператора після руйнівної кібератаки за зразком кейсу «Київстар» і визначте вимоги до архітектури резервного копіювання, що забезпечують задані RTO і RPO.

РОЗДІЛ 17

Управління безпекою безпроводових мереж, DevSecOps і напрями наукових досліджень

Заключний розділ інтегрує матеріал посібника в систему управління безпекою й окреслює напрями наукових досліджень. Технічні механізми, розглянуті в попередніх розділах — від безпеки фізичного рівня до захисту 5G, Інтернету речей і супутникових систем, — дають ефект лише як складові керованої системи з політиками, процесами, вимірюванням і безперервним удосконаленням. Для безпроводових і мобільних мереж управління безпекою має враховувати специфіку: динамічність середовища, велику кількість пристроїв, залежність від постачальників, швидку еволюцію загроз і технологій. Розділ розглядає систему управління інформаційною безпекою стосовно безпроводових мереж, вимірювання безпеки й метрики, безпечне розроблення й практики DevSecOps для мережевого програмного забезпечення, безпеку ланцюга постачання, економіку безпеки, а також методологію наукових досліджень і перспективні напрями в предметній галузі. Розділ спирається на нормативну базу (розділ 2), управління ризиками (розділ 4) і всі технічні розділи посібника.

17.1 Система управління інформаційною безпекою

17.1.1 Застосування до безпроводових мереж

Система управління інформаційною безпекою (СУІБ) за ДСТУ EN ISO/IEC 27001 [11] забезпечує системний підхід до управління безпекою через цикл «плануй–виконуй–перевіряй–дій» (рис. 17.1).

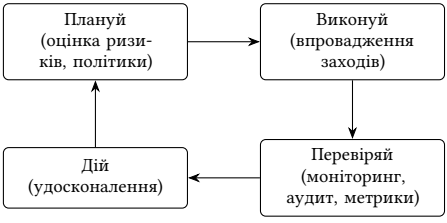


Рис. 17.1 — Цикл СУІБ у застосуванні до безпроводових мереж

Для організації, що експлуатує безпроводові й мобільні мережі, СУІБ інтегрує розглянуті в посібнику елементи: оцінювання ризиків (розділ 4) з урахуванням специфічних активів (радіочастотний ресурс, ключі,

ідентифікатори); вибір заходів (ДСТУ EN ISO/IEC 27002 [12], зокрема заходи щодо безпроводових мереж і мобільних пристроїв); безпеку мереж за ISO/IEC 27033 [184]; моніторинг (розділ 15); реагування й неперервність (розділ 16). Специфіка — необхідність охопити радіочастотний рівень, велику кількість пристроїв поза повним контролем (розділ 11) і залежність від постачальників (розділ 4).

17.1.2 Політики та архітектура безпеки

Управління спирається на політики безпеки, що визначають вимоги до безпроводового доступу, керування пристроями, автентифікації, шифрування, моніторингу. Архітектура безпеки (розділ 11 щодо нульової довіри) реалізує ці політики технічно. Проєктування мережевої інфраструктури з урахуванням вимог кібербезпеки є окремою задачею, підходи до якої, зокрема на базі конкретних платформ, розглянуто в [1]. Ключовий принцип, що проходить через весь посібник: безпека досягається не окремим заходом, а системою — поєднанням технічних механізмів, процесів і людей, керованих на основі оцінювання ризиків.

17.2 Вимірювання безпеки та метрики

Управління неможливе без вимірювання. Настанови ISO/IEC 27004 [181] і NIST SP 800-55 [95] визначають принципи побудови програми вимірювань безпеки. Коректна метрика (розділ 3 щодо метрик захищеності) має бути вимірною, релевантною до рішень, недорогою, чутливою до змін і стійкою до маніпуляцій. Для безпроводових мереж корисні метрики: частка пристроїв з актуальними оновленнями; частка з'єднань зі стійкою автентифікацією (FIDO2, EAP-TLS проти паролів і SMS); MTTD і MTTR для інцидентів (розділ 15); покриття радіочастотним моніторингом; кількість виявлених несанкціонованих передавачів; частка трафіку з наскрізним шифруванням; індекс розриву відповідності (2.2).

Класифікацію метрик наведено в табл. 17.1.

Таблиця 17.1 — Класи метрик безпеки безпроводових мереж

Клас	Приклади
Стану	частка пристроїв з оновленнями; частка з'єднань зі стійкою автентифікацією; покриття радіомоніторингом
Процесу	MTTD, MTTR; час усунення вразливостей; частота навчань
Результату	кількість інцидентів; збитки; кількість виявлених несанкціонованих передавачів
Відповідності	індекс розриву (2.2); виконання обов'язкових вимог

Важливо розрізняти метрики *стану* (частка захищених пристроїв), *процесу* (MTTD, MTTR) і *результату* (кількість інцидентів, збитки). Метрики

мають бути пов'язані з рішеннями: метрика, що не впливає на жодне рішення, є марною. Для узгодження з ризиком метрики зіставляють з цільовими значеннями, а відхилення ініціюють дії. Зведення метрик у панель для керівництва забезпечує видимість стану безпеки й обґрунтування рішень (розділ 4 щодо ROSI).

17.3 Безпечне розроблення та DevSecOps

17.3.1 Безпека мережевого програмного забезпечення

Як показали розділи 10 і 11, сучасні мережі — це значною мірою програмне забезпечення: віртуалізовані функції 5G, контролери програмноконфігурованих мереж, застосунки керування, мобільні застосунки. Тому безпека мереж дедалі більше залежить від безпеки розроблення програмного забезпечення. Рамка безпечного розроблення NIST SSDF [272] визначає практики: підготовка організації (навчання, вимоги), захист програмного забезпечення (безпечне зберігання коду, цілісність), створення захищеного програмного забезпечення (безпечне проєктування, перевірка, тестування), реагування на вразливості.

17.3.2 Практики DevSecOps

DevSecOps [270] інтегрує безпеку в процес розроблення й експлуатації, автоматизуючи перевірки на кожному етапі: аналіз коду, сканування залежностей і образів контейнерів, тестування безпеки, перевірка конфігурацій, моніторинг у виконанні. Для мережевих функцій і застосунків керування це означає, що безпека перевіряється безперервно, а не одноразово. Схему конвеєра наведено на рис. 17.2. Ключові принципи: «зсув уліво» (виявлення проблем якомога раніше, де їх дешевше усунути); автоматизація перевірок; безпека як код (конфігурації й політики у версійованому вигляді); безперервний моніторинг (розділ 15).

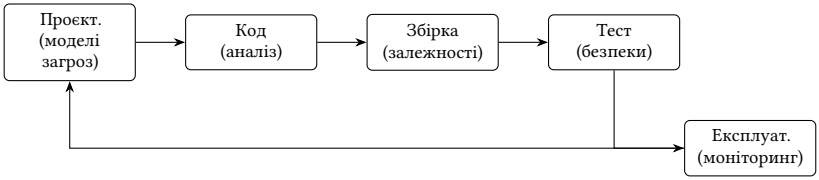


Рис. 17.2 — Конвеєр DevSecOps для мережевого програмного забезпечення

17.3.3 Безпека ланцюга постачання

Розділи 4 і 10 показали критичність ланцюга постачання для мережевого обладнання й програмного забезпечення. Заходи: специфікація складу

програмного забезпечення (SBOM) для прозорості залежностей; перевірка цілісності й походження артефактів (рамка SLSA [275]); підписані оновлення (розділ 6); оцінювання постачальників (розділ 4); для мереж 5G — профіль ризику постачальників (розділ 2). Ланцюг постачання є однією з найскладніших проблем, оскільки організація залежить від безпеки багатьох сторонніх компонентів, які вона не контролює безпосередньо.

17.4 Економіка безпеки

Багато проблем безпеки мають економічну природу [67]. Класичний приклад — ботнет Mirai (розділ 12): виробники дешевих пристроїв не мали стимулу вкладати в безпеку, бо витрати від інцидентів несли треті сторони (*зовнішні ефекти*). Це обґрунтовує регуляторне втручання (розділ 2): вимоги до безпеки пристроїв виправляють ринкову ваду. Інші економічні аспекти: асиметрія інформації (покупець не може оцінити безпеку пристрою); проблема «спільного блага» (безпека мережі залежить від усіх учасників); ROSI для обґрунтування інвестицій (розділ 4); межа Гордона–Лоба для оптимальних інвестицій. Розуміння економіки безпеки важливе для обґрунтування рішень і політик: технічні заходи мають підкріплюватися правильними стимулами, інакше вони не впроваджуються або обходяться.

17.5 Методологія наукових досліджень

Оскільки посібник призначено для магістрантів, окремої уваги потребує методологія досліджень у предметній галузі. Дослідження безпеки безпроводових мереж поєднують кілька підходів. *Проєктна наука* [230]: створення й оцінювання артефактів (протоколів, механізмів, архітектур) — домінівний підхід у інженерії безпеки; артефакт має розв'язувати визначену проблему, а його оцінювання — демонструвати ефективність. *Формальні методи* (розділи 7, 10): математичне доведення властивостей протоколів; символьна й обчислювальна верифікація. *Емпіричні дослідження*: вимірювання, експерименти, аналіз даних — зокрема експериментальне оцінювання стійкості до атак (розділи 3, 8). *Систематичні огляди* [191]: узагальнення наявних знань за визначеною методологією.

Структура наукового дослідження в галузі: постановка проблеми й обґрунтування актуальності; аналіз стану (систематичний огляд); формулювання гіпотези чи задачі; вибір методу (проєктний, формальний, емпіричний); реалізація (артефакт, доведення, експеримент); оцінювання (з явними критеріями, аналізом чутливості й меж застосовності — розділ 3); висновки й напрями подальших досліджень. Ключові вимоги до якості: відтворюваність (опис, що дозволяє повторити); коректність (правильність методу й обчислень); чесність (явні припущення й обмеження); етичність (відповідальне розкриття вразливостей, захист даних). Питання для самопере-

вірки наприкінці кожного розділу посібника навмисно містять дослідницькі завдання, що можуть слугувати відправною точкою для наукової статті чи фрагмента дисертації; результати доцільно публікувати, зокрема, у фахових виданнях предметної галузі [16].

17.6 Перспективні напрями досліджень

На основі матеріалу посібника окреслимо перспективні напрями, узагальнені в табл. 17.2.

Таблиця 17.2 — Перспективні напрями досліджень безпеки безпроводових і мобільних мереж

Напрям	Зміст і виклики
Постквантова міграція	перехід протоколів безпроводових мереж на постквантову криптографію за обмежених ресурсів (розділ 6)
Безпека фізичного рівня в масивних MIMO	практичне застосування секретності й генерування ключів у 5G/6G (розділ 5)
Стійка навігація	захист від глушіння й підміни GNSS, резервні джерела часу (розділ 14)
Безпека O-RAN і 6G	захист відкритої архітектури [223], штучний інтелект у безпеці й проти неї (розділи 10, 15)
Приватність у мобільних мережах	усунення залишкових каналів деанонімізації (розділ 10)
Безпека масового Інтернету речей	масштабоване управління ключами й життєвим циклом (розділ 12)
Стійкість критичної інфраструктури	моделі й механізми на основі українського досвіду (розділ 16)
Робастність машинного навчання	захист моделей моніторингу від змагальних атак (розділ 15)

Особливе значення для України мають напрями, пов’язані з воєнним досвідом: стійкість мереж і навігації в умовах активної протидії, безпека каналів керування безпілотних систем, протидія безпілотним загрозам, радіомоніторинг і локалізація джерел випромінювання. Український науковий доробок у цих сферах, зокрема експериментальні дослідження стійкості безпроводових технологій до атак, є унікальним і затребуваним світовою спільнотою. Дослідники, що працюють у предметній галузі, мають можливість поєднати теоретичну строгість із практичною актуальністю, зумовленою реальними викликами.

17.7 Кейс: побудова програми безпеки безпроводових мереж організації

Організація критичної інфраструктури будує комплексну програму безпеки безпроводових і мобільних мереж, інтегруючи матеріал усього посібника. Синтез.

Управління. СУІБ за ДСТУ EN ISO/IEC 27001 з оцінюванням ризиків (розділ 4), політиками, метриками (MTTD/MTTR, частка стійкої автентифікації, індекс відповідності (2.2)) і безперервним удосконаленням; відповідність нормативним вимогам (розділ 2).

Технічні механізми. Криптографія й ієрархія ключів (розділ 6); захищений Wi-Fi (розділ 7); контроль технологій ближньої дії (розділ 8); захист від сигнальних і радіоатак (розділи 9, 10); нульова довіра для мобільного доступу з FIDO2 (розділ 11); захист Інтернету речей із сегментацією (розділ 12); безпека фізичного рівня для критичних каналів (розділ 5).

Операційна безпека. Моніторинг з радіочастотним рівнем (розділ 15); реагування, неперервність і стійкість з незалежними резервами й енергетичною автономністю (розділ 16); DevSecOps і безпека ланцюга постачання для мережевого програмного забезпечення.

Розвиток. Постквантова готовність (розділ 6); участь у дослідженнях за актуальними напрямами; вимірювання ефективності й адаптація.

Обґрунтування. Програма реалізує наскрізний принцип посібника: безпека безпроводових мереж досягається не окремим механізмом, а системою, що поєднує оцінювання ризиків, багаторівневі технічні механізми, операційну безпеку й управління, з урахуванням специфіки радіосередовища, мобільності, обмежених пристроїв і залежності від постачальників. Кейс демонструє інтеграцію всіх розділів у цілісну програму, керовану на основі ризиків і вимірювань.

Висновки до розділу

Технічні механізми безпеки безпроводових мереж дають ефект лише як складові керованої системи. Система управління інформаційною безпекою інтегрує оцінювання ризиків, вибір заходів, моніторинг, реагування й неперервність у цикл безперервного вдосконалення з урахуванням специфіки безпроводового середовища. Управління неможливе без вимірювання: коректні метрики стану, процесу й результату, пов'язані з рішеннями, забезпечують видимість і обґрунтування. Оскільки сучасні мережі значною мірою є програмним забезпеченням, безпека дедалі більше залежить від безпечного розроблення й практик DevSecOps з інтеграцією безпеки в кожен етап, а також від безпеки ланцюга постачання. Багато проблем безпеки мають економічну природу (зовнішні ефекти, асиметрія інформації), що обґрунтовує регуляторне втручання й важливість правильних стимулів. Методологія наукових досліджень у галузі поєднує проєктну науку, формальні методи, емпіричні дослідження й систематичні огляди з вимогами відтворюваності, коректності, чесності й етичності. Перспективні напрями — постквантова міграція, безпека фізичного рівня, стійка навігація, безпека O-RAN і 6G, приватність, масовий Інтернет речей, стійкість критичної інфра-

структури, робастність машинного навчання, — визначатимуть розвиток галузі [162], причому напрями, пов'язані з українським воєнним досвідом, мають особливе значення й унікальний доробок. Наскрізний висновок посібника: безпека безпроводових і мобільних мереж — це системна властивість, що досягається поєднанням фізичних, криптографічних, мережевих, платформних і організаційних механізмів, керованих на основі оцінювання ризиків і вимірювань, з урахуванням фундаментальних особливостей радіосередовища.

Питання для самоперевірки

1. Як СУІБ інтегрує технічні механізми безпеки безпроводових мереж? Яку специфіку вона має враховувати?
2. Яким вимогам має відповідати коректна метрика безпеки? Наведіть корисні метрики для безпроводових мереж.
3. Розрізніть метрики стану, процесу й результату. Чому метрика має бути пов'язана з рішенням?
4. Чому безпека мереж дедалі більше залежить від безпеки розроблення програмного забезпечення? Які практики визначає рамка SSDF?
5. Опишіть конвеєр DevSecOps (рис. 17.2) і принцип «зсуву вліво». Чому автоматизація перевірок важлива?
6. Які заходи забезпечують безпеку ланцюга постачання? Чому це одна з найскладніших проблем?
7. Поясніть економічну природу проблеми безпеки на прикладі ботнета Mirai. Чому потрібне регуляторне втручання?
8. Які підходи поєднують дослідження безпеки безпроводових мереж? Опишіть структуру наукового дослідження в галузі.
9. Які вимоги до якості наукового дослідження? Що таке відповідальне розкриття вразливостей?
10. Опишіть перспективні напрями досліджень (табл. 17.2). Які з них мають особливе значення для України?
11. Як побудувати комплексну програму безпеки безпроводових мереж організації? Які елементи вона поєднує?
12. Сформулюйте наскрізний висновок посібника про природу безпеки безпроводових і мобільних мереж.
13. Чому безпека є системною властивістю, а не сумою окремих механізмів? Проілюструйте на прикладі будь-якого розділу посібника.
14. Дослідницьке: розробіть систему метрик безпеки безпроводової інфраструктури організації, що охоплює радіочастотний, мережевий і

поведінковий рівні, зіставте метрики з ризиками й обґрунтуйте цільові значення.

15. Дослідницьке: оберіть один із перспективних напрямів (табл. 17.2), виконайте систематичний огляд стану, сформулюйте невирішену наукову задачу й запропонуйте методологію її розв'язання, що може стати основою дисертаційного дослідження.

Список використаних джерел

[1] Абрамов В., Глушак О., Плоха А., Довженко Т. Проєктування мережевої інфраструктури з урахуванням вимог кібербезпеки: підходи та реалізація на базі Cisco. *Кібербезпека: освіта, наука, техніка.* 2025. Т. 1, № 29. С. 59–72. DOI: 10.28925/2663-4023.2025.29.845. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/845.

[2] Атака на «Київстар». СБУ заявила, що російські хакери мали доступ до системи оператора з травня. *Forbes Україна.* 04.01.2024. URL: https://forbes.ua/news/khakeri-perebuvali-v-sistemi-kiivstar-z-travnya-2023-roku-sbu-04012024-18307.

[3] Банах Р. Виявлення атаки Evil Twin на бездротові мережі стандарту IEEE 802.11 в умовах щільної забудови. *Кібербезпека: освіта, наука, техніка.* 2026. Т. 1, № 33. С. 842–856. DOI: 10.28925/2663-4023.2026.33.1279. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/1279.

[4] Ворохоб Н. О., Роскладка А. А. Тестова послідовність виявлення та ізоляції заражених вузлів інфокомунікаційної мережі. *Кібербезпека: освіта, наука, техніка.* 2024. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/1070.

[5] Горбенко І. Д., Горбенко Ю. І. Прикладна криптологія: теорія, практика, застосування: монографія. Харків: Форт, 2012. 878 с.

[6] Державна служба спеціального зв'язку та захисту інформації України: офіційний вебсайт. URL: https://cip.gov.ua/.

[7] ДСТУ 4145-2002. Інформаційні технології. Криптографічний захист інформації. Цифровий підпис, що ґрунтується на еліптичних кривих. Формування та перевіряння. Київ: Держспоживстандарт України, 2003.

[8] ДСТУ 7624:2014. Інформаційні технології. Криптографічний захист інформації. Алгоритм симетричного блокового перетворення. Київ: Мінекономрозвитку України, 2015.

[9] ДСТУ 7564:2014. Інформаційні технології. Криптографічний захист інформації. Функція гешування. Київ: Мінекономрозвитку України, 2015.

[10] ДСТУ 8845:2019. Інформаційні технології. Криптографічний захист інформації. Алгоритм симетричного потокового перетворення. Київ: ДП «УкрНДНЦ», 2019.

[11] ДСТУ EN ISO/IEC 27001:2023. Інформаційна безпека, кібербезпека та захист приватності. Системи керування інформаційною безпекою. Вимоги (EN ISO/IEC 27001:2022, IDT). Київ: ДП «УкрНДНЦ», 2023.

[12] ДСТУ EN ISO/IEC 27002:2023. Інформаційна безпека, кібербезпека та захист приватності. Заходи інформаційної безпеки (EN ISO/IEC 27002:2022, IDT). Київ: ДП «УкрНДНЦ», 2023.

[13] Жураковський Б. Ю., Нєдашківський О. Л. Системи управління мобільними мережами зв'язку. *Кібербезпека: освіта, наука, техніка.* 2022. Т. 3, № 15. С. 6–26. DOI: 10.28925/2663-4023.2022.15.626. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/333.

[14] Загальні вимоги до кіберзахисту об'єктів критичної інфраструктури: затв. постановою Кабінету Міністрів України від 19.06.2019 № 518. URL: https://zakon.rada.gov.ua/laws/show/518-2019-п.

[15] Івкова В. С., Опірський І. Р. Методи захисту інформації в технологіях Інтернету речей. *Кібербезпека: освіта, наука, техніка.* 2025. Т. 3, № 27. С. 204–221. DOI: 10.28925/2663-4023.2025.27.749. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/749.

[16] Кібербезпека: освіта, наука, техніка: електронне фахове наукове видання / Київський столичний університет імені Бориса Грінченка. ISSN 2663-4023. URL: https://csecurity.kubg.edu.ua/.

[17] Корольков Р., Лаптєв С. Натурне моделювання атаки «war driving» на бездротову мережу. *Кібербезпека: освіта, наука, техніка.* 2022. Т. 2, № 18. С. 99–107. DOI: 10.28925/2663-4023.2022.18.99107. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/407.

[18] Костюк Ю., Бебешко Б., Крючкова Л., Литвинов В., Оксанич І., Складанний П., Хорольська К. Захист інформації та безпека обміну даними в безпроводових мобільних мережах з автентифікацією і протоколами обміну ключами. *Кібербезпека: освіта, наука, техніка.* 2024. Т. 1, № 25. С. 229–252. DOI: 10.28925/2663-4023.2024.25.229252. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/653.

[19] Котов М. Деревоподібний шардинг стану для масштабування та балансування навантаження в мультичейн системах. *Кібербезпека: освіта, наука, техніка.* 2024. Т. 2, № 26. С. 392–408. DOI: 10.28925/2663-4023.2024.26.702. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/702.

[20] Крючкова Л. П., Ворохоб Н. О. Захист каналів керування безпілотних літальних апаратів. *Кібербезпека: освіта, наука, техніка.* 2025. Спеціальний випуск. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/987.

[21] Маньковський Б. О., Довбняк В. О., Опірський І. Р. Дослідження можливості реалізації концепції Zero Trust в IoT-системах. *Кібербезпека: освіта, наука, техніка.* 2025. Т. 1, № 29. С. 73–91. DOI: 10.28925/2663-4023.2025.29.864. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/864.

[22] Наконечний Т. Інтегрований підхід до виявлення загроз у Bluetooth-протоколі за допомогою Wireshark та Splunk SIEM. *Кібербезпека: освіта, наука, техніка.* 2024. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/684.

[23] НД ТЗІ 1.1-002-99. Загальні положення щодо захисту інформації в комп'ютерних системах від несанкціонованого доступу. Київ: ДСТСЗІ СБ України, 1999. URL: https://cip.gov.ua/ua/news/normativni-dokumenti-z-pitan-tzi.

[24] НД ТЗІ 2.5-004-99. Критерії оцінки захищеності інформації в комп'ютерних системах від несанкціонованого доступу. Київ: ДСТСЗІ СБ України, 1999.

[25] НД ТЗІ 3.7-003-05. Порядок проведення робіт із створення комплексної системи захисту інформації в інформаційно-телекомунікаційній системі. Київ: ДСТСЗІ СБ України, 2005.

[26] Палко Д., Мирутенко Л. Метод комплексної оцінки ризиків кібербезпеки в розподілених інформаційних системах. *Кібербезпека: освіта, наука, техніка.* 2024. Т. 2, № 26. С. 487–502. DOI: 10.28925/2663-4023.2024.26.731. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/731.

[27] Партика О. Ризик-орієнтоване виявлення кібератак у безпроводових мережах з урахуванням стійкості моделей машинного навчання. *Кібербезпека: освіта, наука, техніка.* 2026. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/1333.

[28] Пархоменко І., Огієвич Р. Криптоекономічна стійкість децентралізованої мережі з використанням випадкових часових челендж-токенів. *Кібербезпека: освіта, наука, техніка.* 2025. Т. 4, № 28. С. 465–477. DOI: 10.28925/2663-4023.2025.28.817. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/817.

[29] Плєхов О., Гринкевич Г., Василенко В. Розширена модель загроз STRIDE для офлайн-застосунків аварійного зв'язку на основі BLE mesh-мереж. *Кібербезпека: освіта, наука, техніка.* 2026. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/1368.

[30] Погасій С. та ін. Проблеми та загрози безпеці IoT пристроїв. *Кібербезпека: освіта, наука, техніка.* 2021. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/231.

[31] Положення про порядок розроблення, виробництва та експлуатації засобів криптографічного захисту інформації: затв. наказом Адміністрації Державної служби спеціального зв'язку та захисту інформації України від 20.07.2007 № 141. URL: https://zakon.rada.gov.ua/laws/show/z0862-07.

[32] Правила забезпечення захисту інформації в інформаційних, електронних комунікаційних та інформаційно-комунікаційних системах: затв. постановою Кабінету Міністрів України від 29.03.2006 № 373. URL: https://zakon.rada.gov.ua/laws/show/373-2006-п.

[33] Прокопович-Ткаченко Д., Хохлачова Ю., Магро В., Черкаський Д., Переметчик Д. Гібридне виявлення несанкціонованих точок доступу у бездротових мережах. *Кібербезпека: освіта, наука, техніка.* 2026. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/1245.

[34] Про електронні комунікації: Закон України від 16.12.2020 № 1089-IX. URL: https://zakon.rada.gov.ua/laws/show/1089-20.

[35] Про затвердження Порядку організації національного роумінгу: рішення Національної комісії, що здійснює державне регулювання у сферах електронних

комунікацій, радіочастотного спектра та надання послуг поштового зв'язку. Київ: НКЕК, 2023. URL: https://nkek.gov.ua/.

[36] Про захист інформації в інформаційно-комунікаційних системах: Закон України від 05.07.1994 № 80/94-ВР. URL: https://zakon.rada.gov.ua/laws/show/80/94-вр.

[37] Про захист персональних даних: Закон України від 01.06.2010 № 2297-VI. URL: https://zakon.rada.gov.ua/laws/show/2297-17.

[38] Про критичну інфраструктуру: Закон України від 16.11.2021 № 1882-IX. URL: https://zakon.rada.gov.ua/laws/show/1882-20.

[39] Про основні засади забезпечення кібербезпеки України: Закон України від 05.10.2017 № 2163-VIII (редакція від 19.10.2025). URL: https://zakon.rada.gov.ua/laws/show/2163-19.

[40] Про правовий режим воєнного стану: Закон України від 12.05.2015 № 389-VIII. URL: https://zakon.rada.gov.ua/laws/show/389-19.

[41] Про рішення Ради національної безпеки і оборони України від 14 травня 2021 року «Про Стратегію кібербезпеки України»: Указ Президента України від 26.08.2021 № 447/2021. URL: https://zakon.rada.gov.ua/laws/show/447/2021.

[42] Про стандартизацію: Закон України від 05.06.2014 № 1315-VII. URL: https://zakon.rada.gov.ua/laws/show/1315-18.

[43] Про технічні регламенти та оцінку відповідності: Закон України від 15.01.2015 № 124-VIII. URL: https://zakon.rada.gov.ua/laws/show/124-19.

[44] Скидан Д., Щебланін Ю. Захист Wi-Fi мереж за допомогою адаптивного методу шифрування. *Кібербезпека: освіта, наука, техніка.* 2026. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/1261.

[45] Соколов В., Складанний П. Методика оцінки комплексних збитків від інциденту інформаційної безпеки. *Кібербезпека: освіта, наука, техніка.* 2023. Т. 1, № 21. С. 99–120. DOI: 10.28925/2663-4023.2023.21.99120. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/498.

[46] Технічний регламент радіообладнання: затв. постановою Кабінету Міністрів України від 24.05.2017 № 355. URL: https://zakon.rada.gov.ua/laws/show/355-2017-п.

[47] Толюпа С. В., Кулько А. А. Забезпечення безпеки програмно-конфігурованих мереж. *Кібербезпека: освіта, наука, техніка.* 2025. Т. 3, № 27. С. 264–278. DOI: 10.28925/2663-4023.2025.27.750. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/750.

[48] Угода про асоціацію між Україною, з однієї сторони, та Європейським Союзом, Європейським співтовариством з атомної енергії і їхніми державами-членами, з іншої сторони: ратифіковано Законом України від 16.09.2014 № 1678-VII. URL: https://zakon.rada.gov.ua/laws/show/984_011.

[49] 3GPP TR 33.861. Study on Evolution of Cellular Internet of Things (IoT) Security for the 5G System. Sophia Antipolis: 3rd Generation Partnership Project. URL: https://www.3gpp.org/DynaReport/33861.htm.

[50] 3GPP TR 33.916. Security Assurance Methodology (SECAM) for 3GPP network products: technical report. Sophia Antipolis: 3rd Generation Partnership Project. URL: https://www.3gpp.org/DynaReport/33916.htm.

[51] 3GPP TR 33.926. Security Assurance Specification (SCAS) threats and critical assets in 3GPP network product classes: technical report. Sophia Antipolis: 3rd Generation Partnership Project. URL: https://www.3gpp.org/DynaReport/33926.htm.

[52] 3GPP TS 23.003. Numbering, Addressing and Identification: technical specification. Sophia Antipolis: 3rd Generation Partnership Project. URL: https://www.3gpp.org /DynaReport/23003.htm.

[53] 3GPP TS 23.501. System Architecture for the 5G System (5GS); Stage 2: technical specification. Sophia Antipolis: 3rd Generation Partnership Project. URL: https:// www.3gpp.org/DynaReport/23501.htm.

[54] 3GPP TS 33.102. 3G Security; Security Architecture: technical specification. Sophia Antipolis: 3rd Generation Partnership Project. URL: https://www.3gpp.org/DynaR eport/33102.htm.

[55] 3GPP TS 33.117. Catalogue of general security assurance requirements: technical specification. Sophia Antipolis: 3rd Generation Partnership Project. URL: https:// www.3gpp.org/DynaReport/33117.htm.

[56] 3GPP TS 33.220. Generic Authentication Architecture (GAA); Generic Bootstrapping Architecture (GBA). Sophia Antipolis: 3rd Generation Partnership Project. URL: https://www.3gpp.org/DynaReport/33220.htm.

[57] 3GPP TS 33.401. 3GPP System Architecture Evolution (SAE); Security Architecture: technical specification. Sophia Antipolis: 3rd Generation Partnership Project. URL: https://www.3gpp.org/DynaReport/33401.htm.

[58] 3GPP TS 33.501. Security Architecture and Procedures for 5G System: technical specification. Sophia Antipolis: 3rd Generation Partnership Project. URL: https: //www.3gpp.org/DynaReport/33501.htm.

[59] 3GPP TS 33.511. Security Assurance Specification (SCAS) for the next generation Node B (gNodeB) network product class. Sophia Antipolis: 3rd Generation Partnership Project. URL: https://www.3gpp.org/DynaReport/33511.htm.

[60] 3GPP TS 33.512. Security Assurance Specification (SCAS) for the Access and Mobility management Function (AMF) network product class. Sophia Antipolis: 3rd Generation Partnership Project. URL: https://www.3gpp.org/DynaReport/33512.ht m.

[61] 3GPP TS 33.517. Security Assurance Specification (SCAS) for the Security Edge Protection Proxy (SEPP) network product class. Sophia Antipolis: 3rd Generation Partnership Project. URL: https://www.3gpp.org/DynaReport/33517.htm.

[62] 3GPP TS 35.215. Specification of the 3GPP Confidentiality and Integrity Algorithms UEA2 & UIA2; Document 1: UEA2 and UIA2 Specifications. Sophia Antipolis: 3rd Generation Partnership Project. URL: https://www.3gpp.org/DynaReport/35215.ht m.

[63] 3GPP TS 35.221. Specification of the 3GPP Confidentiality and Integrity Algorithms EEA3 & EIA3; Document 1: EEA3 and EIA3 Specifications. Sophia Antipolis: 3rd Generation Partnership Project. URL: https://www.3gpp.org/DynaReport/35221.htm.

[64] 3GPP TS 43.020. Security Related Network Functions: technical specification. Sophia Antipolis: 3rd Generation Partnership Project. URL: https://www.3gpp.org/DynaReport/43020.htm.

[65] Aboba B., Blunk L., Vollbrecht J., Carlson J., Levkowetz H. (Ed.). Extensible Authentication Protocol (EAP). RFC 3748. IETF, 2004. DOI: 10.17487/RFC3748. URL: https://www.rfc-editor.org/rfc/rfc3748.

[66] Anderson R. Security Engineering: A Guide to Building Dependable Distributed Systems. 3rd ed. Indianapolis: Wiley, 2020. 1232 p. URL: https://www.cl.cam.ac.uk/~rja14/book.html.

[67] Anderson R., Moore T. The Economics of Information Security. *Science*. 2006. Vol. 314, No. 5799. P. 610–613. DOI: 10.1126/science.1130992.

[68] Android Platform Security Model / R. Mayrhofer, J. V. Stoep, C. Brubaker, N. Kralevich. *ACM Transactions on Privacy and Security*. 2021. Vol. 24, No. 3. Article 19. DOI: 10.1145/3448609.

[69] Antonakakis M. et al. Understanding the Mirai Botnet. *Proceedings of the 26th USENIX Security Symposium*. USENIX Association, 2017. P. 1093–1110.

[70] Antonioli D., Tippenhauer N. O., Rasmussen K. BIAS: Bluetooth Impersonation AttackS. *2020 IEEE Symposium on Security and Privacy (SP)*. San Francisco: IEEE, 2020. P. 549–562. DOI: 10.1109/SP40000.2020.00093.

[71] Antonioli D., Tippenhauer N. O., Rasmussen K. BLESA: Spoofing Attacks against Reconnections in Bluetooth Low Energy. *Proceedings of the 14th USENIX Workshop on Offensive Technologies (WOOT 20)*. USENIX Association, 2020.

[72] Antonioli D., Tippenhauer N. O., Rasmussen K. The KNOB is Broken: Exploiting Low Entropy in the Encryption Key Negotiation of Bluetooth BR/EDR. *Proceedings of the 28th USENIX Security Symposium*. USENIX Association, 2019. P. 1047–1061.

[73] Antonioli D., Tippenhauer N. O., Rasmussen K., Payer M. BLURtooth: Exploiting Cross-Transport Key Derivation in Bluetooth Classic and Bluetooth Low Energy. *Proceedings of the 2022 ACM Asia Conference on Computer and Communications Security (ASIA CCS '22)*. New York: ACM, 2022. DOI: 10.1145/3488932.3523258.

[74] Arkko J., Lehtovirta V., Torvinen V., Eronen P. Improved Extensible Authentication Protocol Method for 3GPP Mobile Network Authentication and Key Agreement (EAP-AKA'). RFC 9048. IETF, 2021. DOI: 10.17487/RFC9048. URL: https://www.rfc-editor.org/rfc/rfc9048.

[75] Axelsson S. The Base-Rate Fallacy and the Difficulty of Intrusion Detection. *ACM Transactions on Information and System Security*. 2000. Vol. 3, No. 3. P. 186–205. DOI: 10.1145/357830.357849.

[76] Barkan E., Biham E., Keller N. Instant Ciphertext-Only Cryptanalysis of GSM Encrypted Communication. *Journal of Cryptology*. 2008. Vol. 21, No. 3. P. 392–429. DOI: 10.1007/s00145-007-9001-y.

[77] Bartock M. et al. Guide for Cybersecurity Event Recovery. NIST SP 800-184. Gaithersburg, MD: NIST, 2016. DOI: 10.6028/NIST.SP.800-184.

[78] Bash B. A., Goeckel D., Towsley D. Limits of Reliable Communication with Low Probability of Detection on AWGN Channels. *IEEE Journal on Selected Areas in Communications*. 2013. Vol. 31, No. 9. P. 1921–1930. DOI: 10.1109/JSAC.2013.130923.

[79] Basin D., Dreier J., Hirschi L., Radomirović S., Sasse R., Stettler V. A Formal Analysis of 5G Authentication. *Proceedings of the 2018 ACM SIGSAC Conference on Computer and Communications Security (CCS '18)*. New York: ACM, 2018. P. 1383–1396. DOI: 10.1145/3243734.3243846.

[80] Beard C., Stallings W. Wireless Communication Networks and Systems. Boston: Pearson, 2016. 624 p.

[81] Beer I., Groß S. A Deep Dive into an NSO Zero-Click iMessage Exploit: Remote Code Execution. Google Project Zero: technical report, 2021.

[82] Belshe M., Peon R., Thomson M. (Ed.). Hypertext Transfer Protocol Version 2 (HTTP/2). RFC 7540. IETF, 2015. DOI: 10.17487/RFC7540. URL: https://www.rfc-editor.org/rfc/rfc7540.

[83] Biggio B., Roli F. Wild Patterns: Ten Years after the Rise of Adversarial Machine Learning. *Pattern Recognition*. 2018. Vol. 84. P. 317–331. DOI: 10.1016/j.patcog.2018.07.023.

[84] Biryukov A., Dinu D., Khovratovich D., Josefsson S. Argon2 Memory-Hard Function for Password Hashing and Proof-of-Work Applications. RFC 9106. IRTF, 2021. DOI: 10.17487/RFC9106. URL: https://www.rfc-editor.org/rfc/rfc9106.

[85] Bloch M., Barros J., Rodrigues M. R. D., McLaughlin S. W. Wireless Information-Theoretic Security. *IEEE Transactions on Information Theory*. 2008. Vol. 54, No. 6. P. 2515–2534. DOI: 10.1109/TIT.2008.921908.

[86] Bluetooth Core Specification. Version 6.0. Kirkland, WA: Bluetooth SIG, 2024. URL: https://www.bluetooth.com/specifications/specs/.

[87] Borgaonkar R., Hirschi L., Park S., Shaik A. New Privacy Threat on 3G, 4G, and Upcoming 5G AKA Protocols. *Proceedings on Privacy Enhancing Technologies*. 2019. Vol. 2019, No. 3. P. 108–127. DOI: 10.2478/popets-2019-0039.

[88] Borisov N., Goldberg I., Wagner D. Intercepting Mobile Communications: The Insecurity of 802.11. *Proceedings of the 7th Annual International Conference on Mobile Computing and Networking (MobiCom '01)*. New York: ACM, 2001. P. 180–189. DOI: 10.1145/381677.381695.

[89] Brands S., Chaum D. Distance-Bounding Protocols. *Advances in Cryptology — EUROCRYPT '93*. Lecture Notes in Computer Science. Vol. 765. Berlin: Springer, 1994. P. 344–359. DOI: 10.1007/3-540-48285-7_30.

[90] Brik V., Banerjee S., Gruteser M., Oh S. Wireless Device Identification with Radiometric Signatures. *Proceedings of the 14th ACM International Conference on Mobile Computing and Networking (MobiCom '08)*. New York: ACM, 2008. P. 116–127. DOI: 10.1145/1409944.1409959.

[91] Butun I., Pereira N., Gidlund M. Security Risk Analysis of LoRaWAN and Future Directions. *Future Internet*. 2019. Vol. 11, No. 1. Article 3. DOI: 10.3390/fi11010003.

[92] CCSDS 355.0-B-2. Space Data Link Security Protocol. Recommended Standard, Blue Book. Washington: Consultative Committee for Space Data Systems, 2022. URL: ht tps://public.ccsds.org/.

[93] CERT-UA: Урядова команда реагування на комп'ютерні надзвичайні події України. URL: https://cert.gov.ua/.

[94] Chandola V., Banerjee A., Kumar V. Anomaly Detection: A Survey. *ACM Computing Surveys*. 2009. Vol. 41, No. 3. Article 15. DOI: 10.1145/1541880.1541882.

[95] Chew E. et al. Performance Measurement Guide for Information Security. NIST SP 800-55, Rev. 2. Gaithersburg, MD: NIST, 2024. DOI: 10.6028/NIST.SP.800-55r2.

[96] Cholda P., Mykkeltveit A., Helvik B. E., Wittner O. J., Jajszczyk A. A Survey of Resilience Differentiation Frameworks in Communication Networks. *IEEE Communications Surveys & Tutorials*. 2007. Vol. 9, No. 4. P. 32–55. DOI: 10.1109/COMST.2007.4444749.

[97] Cichonski J., Franklin J. M., Bartock M. Guide to LTE Security. NIST SP 800-187. Gaithersburg, MD, 2017. DOI: 10.6028/NIST.SP.800-187. URL: https://csrc.nist.gov/pubs/sp/800/187/final.

[98] Cichonski P., Millar T., Grance T., Scarfone K. Computer Security Incident Handling Guide. NIST SP 800-61, Rev. 2. Gaithersburg, MD, 2012. DOI: 10.6028/NIST.SP.800-61r2. URL: https://csrc.nist.gov/pubs/sp/800/61/r2/final.

[99] Commission Delegated Regulation (EU) 2019/945 on unmanned aircraft systems and on third-country operators of unmanned aircraft systems. *Official Journal of the EU*. L 152. P. 1–40. URL: https://eur-lex.europa.eu/eli/reg_del/2019/945/oj.

[100] Commission Delegated Regulation (EU) 2022/30 of 29 October 2021 supplementing Directive 2014/53/EU with regard to the application of the essential requirements referred to in Article 3(3), points (d), (e) and (f), of that Directive. *Official Journal of the EU*. L 7. P. 6–10. URL: https://eur-lex.europa.eu/eli/reg_del/2022/30/oj.

[101] Commission Implementing Regulation (EU) 2024/482 of 31 January 2024 laying down rules for the application of Regulation (EU) 2019/881 as regards the adoption of the European Common Criteria-based cybersecurity certification scheme (EUCC). *Official Journal of the EU*. L series, 07.02.2024. URL: https://eur-lex.europa.eu/eli/reg_impl/2024/482/oj.

[102] Commission Recommendation (EU) 2019/534 of 26 March 2019 Cybersecurity of 5G networks. *Official Journal of the EU*. L 88. P. 42–47. URL: https://eur-lex.europa.eu/eli/reco/2019/534/oj.

[103] Cremers C., Dehnel-Wild M. Component-Based Formal Analysis of 5G-AKA: Channel Assumptions and Session Confusion. *Proceedings of the Network and*

Distributed System Security Symposium (NDSS 2019). San Diego: Internet Society, 2019.

[104] Csiszár I., Körner J. Broadcast Channels with Confidential Messages. *IEEE Transactions on Information Theory*. 1978. Vol. 24, No. 3. P. 339–348. DOI: 10.1109/TIT.1978.1055892.

[105] Danev B., Zanetti D., Čapkun S. On Physical-Layer Identification of Wireless Devices. *ACM Computing Surveys*. 2012. Vol. 45, No. 1. Article 6. DOI: 10.1145/2379776.2379782.

[106] Dempsey K. et al. Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations. NIST SP 800-137. Gaithersburg, MD: NIST, 2011. DOI: 10.6028/NIST.SP.800-137.

[107] Deng M., Wuyts K., Scandariato R., Preneel B., Joosen W. A Privacy Threat Analysis Framework: Supporting the Elicitation and Fulfillment of Privacy Requirements. *Requirements Engineering*. 2011. Vol. 16, No. 1. P. 3–32. DOI: 10.1007/s00766-010-0115-7.

[108] Directive (EU) 2018/1972 of the European Parliament and of the Council of 11 December 2018 establishing the European Electronic Communications Code. *Official Journal of the EU*. L 321. P. 36–214. URL: https://eur-lex.europa.eu/eli/dir/2018/1972/oj.

[109] Directive (EU) 2022/2555 of the European Parliament and of the Council of 14 December 2022 on measures for a high common level of cybersecurity across the Union (NIS 2 Directive). *Official Journal of the EU*. L 333. P. 80–152. URL: https://eur-lex.europa.eu/eli/dir/2022/2555/oj.

[110] Directive 2002/58/EC of the European Parliament and of the Council of 12 July 2002 concerning the processing of personal data and the protection of privacy in the electronic communications sector (Directive on privacy and electronic communications). *Official Journal of the EC*. L 201. P. 37–47. URL: https://eur-lex.europa.eu/eli/dir/2002/58/oj.

[111] Directive 2014/53/EU of the European Parliament and of the Council of 16 April 2014 on the harmonisation of the laws of the Member States relating to the making available on the market of radio equipment (Radio Equipment Directive). *Official Journal of the EU*. L 153. P. 62–106. URL: https://eur-lex.europa.eu/eli/dir/2014/53/oj.

[112] Dolev D., Yao A. On the Security of Public Key Protocols. *IEEE Transactions on Information Theory*. 1983. Vol. 29, No. 2. P. 198–208. DOI: 10.1109/TIT.1983.1056650.

[113] Douceur J. R. The Sybil Attack. *Peer-to-Peer Systems (IPTPS 2002)*. Lecture Notes in Computer Science. Vol. 2429. Berlin: Springer, 2002. P. 251–260. DOI: 10.1007/3-540-45748-8_24.

[114] Dunkelman O., Keller N., Shamir A. A Practical-Time Related-Key Attack on the KASUMI Cryptosystem Used in GSM and 3G Telephony. *Advances in Cryptology — CRYPTO 2010*. Lecture Notes in Computer Science. Vol. 6223. Berlin: Springer, 2010. P. 393–410. DOI: 10.1007/978-3-642-14623-7_21.

[115] Dworkin M. Recommendation for Block Cipher Modes of Operation: The CCM Mode for Authentication and Confidentiality. NIST SP 800-38C. Gaithersburg, MD: NIST, 2004. DOI: 10.6028/NIST.SP.800-38C.

[116] Dworkin M. Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM) and GMAC. NIST SP 800-38D. Gaithersburg, MD: NIST, 2007. DOI: 10.6028/NIST.SP.800-38D.

[117] eduroam: міжнародна служба роумінгу для освітніх і наукових установ. URL: https://eduroam.org/.

[118] EMV Contactless Specifications for Payment Systems. Book C. EMVCo, 2023. URL: https://www.emvco.com/specifications/.

[119] EN 18031-1:2024. Common security requirements for radio equipment — Part 1: Internet connected radio equipment. Brussels: CEN-CENELEC, 2024.

[120] Enck W., Ongtang M., McDaniel P. Understanding Android Security. *IEEE Security & Privacy*. 2009. Vol. 7, No. 1. P. 50–57. DOI: 10.1109/MSP.2009.26.

[121] Engel T. SS7: Locate. Track. Manipulate. *31st Chaos Communication Congress (31C3)*. Hamburg, 2014.

[122] ENISA Threat Landscape 2024. Athens: European Union Agency for Cybersecurity, 2024. URL: https://www.enisa.europa.eu/publications/enisa-threat-landscape-2024.

[123] ENISA Threat Landscape for 5G Networks. Athens: European Union Agency for Cybersecurity, 2019. URL: https://www.enisa.europa.eu/publications/enisa-threat-landscape-for-5g-networks.

[124] ENISA. Security in 5G Specifications: Controls in 3GPP Security Specifications (5G SA). Athens: European Union Agency for Cybersecurity, 2021. URL: https://www.enisa.europa.eu/publications/security-in-5g-specifications.

[125] ENISA. Signalling Security in Telecom SS7/Diameter/5G: EU level assessment of the current situation. Athens: European Union Agency for Cybersecurity, 2018. URL: https://www.enisa.europa.eu/publications/signalling-security-in-telecom-ss7-diameter-5g.

[126] ENISA. Telecom Security Incidents 2023: Annual Report. Athens: European Union Agency for Cybersecurity, 2024. URL: https://www.enisa.europa.eu/publications/annual-report-telecom-security-incidents-2023.

[127] ENISA. Threat Landscape for 5G Networks: Updated threat assessment for the fifth generation of mobile telecommunications networks (5G). Athens: European Union Agency for Cybersecurity, 2020. URL: https://www.enisa.europa.eu/publications/enisa-threat-landscape-report-for-5g-networks.

[128] ETSI EN 300 392-7. Terrestrial Trunked Radio (TETRA); Voice plus Data (V+D); Part 7: Security. Sophia Antipolis: ETSI.

[129] ETSI EN 303 645 V2.1.1 (2020-06). CYBER; Cyber Security for Consumer Internet of Things: Baseline Requirements. Sophia Antipolis: ETSI, 2020. URL: https://www.etsi.org/deliver/etsi_en/303600_303699/303645/02.01.01_60/en_303645v020101p.pdf.

[130] ETSI EN 303 645 V2.1.1 (2020-06). CYBER; Cyber Security for Consumer Internet of Things: Baseline Requirements. Sophia Antipolis: ETSI, 2020.

[131] European Union Agency for the Space Programme (EUSPA). Galileo Open Service Navigation Message Authentication (OSNMA) User ICD. Prague: EUSPA, 2023. URL: https://www.gsc-europa.eu/.

[132] Fagan M. et al. Profile of the IoT Core Baseline for Consumer IoT Products. NIST IR 8425. Gaithersburg, MD: NIST, 2022. DOI: 10.6028/NIST.IR.8425.

[133] Fagan M., Megas K. N., Scarfone K., Smith M. Foundational Cybersecurity Activities for IoT Device Manufacturers. NIST Internal Report 8259. Gaithersburg, MD: NIST, 2020. DOI: 10.6028/NIST.IR.8259.

[134] Felt A. P., Chin E., Hanna S., Song D., Wagner D. Android Permissions Demystified. *Proceedings of the 18th ACM Conference on Computer and Communications Security (CCS '11)*. New York: ACM, 2011. P. 627–638. DOI: 10.1145/2046707.2046779.

[135] Fernández-Hernández I., Rijmen V., Seco-Granados G., Simon J., Rodríguez I., Calle J. D. A Navigation Message Authentication Proposal for the Galileo Open Service. *NAVIGATION: Journal of the Institute of Navigation*. 2016. Vol. 63, No. 1. P. 85–102. DOI: 10.1002/navi.125.

[136] Ferrag M. A., Maglaras L., Argyriou A., Kosmanos D., Janicke H. Security for 4G and 5G Cellular Networks: A Survey of Existing Authentication and Privacy-Preserving Schemes. *Journal of Network and Computer Applications*. 2018. Vol. 101. P. 55–82. DOI: 10.1016/j.jnca.2017.10.017.

[137] FIDO Alliance. FIDO2: WebAuthn and CTAP Specifications. URL: https://fidoalliance.org/fido2/.

[138] FIRST. Common Vulnerability Scoring System Version 4.0: Specification Document. Forum of Incident Response and Security Teams, 2023. URL: https://www.first.org/cvss/v4.0/specification-document.

[139] FIRST. Exploit Prediction Scoring System (EPSS). Forum of Incident Response and Security Teams. URL: https://www.first.org/epss/.

[140] Fluhrer S., Mantin I., Shamir A. Weaknesses in the Key Scheduling Algorithm of RC4. *Selected Areas in Cryptography (SAC 2001)*. Lecture Notes in Computer Science. Vol. 2259. Berlin: Springer, 2001. P. 1–24. DOI: 10.1007/3-540-45537-X_1.

[141] Forsberg D., Horn G., Moeller W.-D., Niemi V. LTE Security. 2nd ed. Chichester: Wiley, 2012. 344 p.

[142] Francillon A., Danev B., Čapkun S. Relay Attacks on Passive Keyless Entry and Start Systems in Modern Cars. *Proceedings of the Network and Distributed System Security Symposium (NDSS 2011)*. San Diego: Internet Society, 2011.

[143] Frankel S., Eydt B., Owens L., Scarfone K. Establishing Wireless Robust Security Networks: A Guide to IEEE 802.11i. NIST Special Publication 800-97. Gaithersburg, MD: NIST, 2007. DOI: 10.6028/NIST.SP.800-97. URL: https://csrc.nist.gov/pubs/sp/800/97/final.

[144] Freund J., Jones J. Measuring and Managing Information Risk: A FAIR Approach. Oxford: Butterworth-Heinemann, 2014. 408 p.

[145] Garcia F. D., de Koning Gans G., Muijrers R., van Rossum P., Verdult R., Schreur R. W., Jacobs B. Dismantling MIFARE Classic. *Computer Security — ESORICS 2008*. Lecture Notes in Computer Science. Vol. 5283. Berlin: Springer, 2008. P. 97–114. DOI: 10.1007/978-3-540-88313-5_7.

[146] Goel S., Negi R. Guaranteeing Secrecy using Artificial Noise. *IEEE Transactions on Wireless Communications*. 2008. Vol. 7, No. 6. P. 2180–2189. DOI: 10.1109/TWC.2008.060848.

[147] Goldberg S., Haller M., Heninger N., Milano M., Shumow D., Stevens M., Suhl A. RADIUS/UDP Considered Harmful. *Proceedings of the 33rd USENIX Security Symposium*. USENIX Association, 2024.

[148] Golde N., Redon K., Seifert J.-P. Let Me Answer That For You: Exploiting Broadcast Information in Cellular Networks. *Proceedings of the 22nd USENIX Security Symposium*. USENIX Association, 2013. P. 33–48.

[149] Goldsmith A. Wireless Communications. Cambridge: Cambridge University Press, 2005. 644 p.

[150] Gollier H., Vanhoef M. SSID Confusion: Making Wi-Fi Clients Connect to the Wrong Network. *Proceedings of the 17th ACM Conference on Security and Privacy in Wireless and Mobile Networks (WiSec '24)*. New York: ACM, 2024.

[151] Gordon L. A., Loeb M. P. The Economics of Information Security Investment. *ACM Transactions on Information and System Security*. 2002. Vol. 5, No. 4. P. 438–457. DOI: 10.1145/581271.581274.

[152] GSMA FS.11. SS7 Interconnect Security Monitoring and Firewall Guidelines. London: GSM Association.

[153] GSMA FS.13. Network Equipment Security Assurance Scheme — Overview. London: GSM Association.

[154] GSMA FS.19. Diameter Interconnect Security. London: GSM Association.

[155] GSMA IR.82. Security SS7 Guidelines. London: GSM Association.

[156] GSMA. Disaster Response and Mobile Networks: resilience and roaming guidelines. London: GSM Association.

[157] GSMA. Network Equipment Security Assurance Scheme (NESAS): Overview and CVD process. London: GSM Association. URL: https://www.gsma.com/security/network-equipment-security-assurance-scheme/.

[158] Haenggi M. Stochastic Geometry for Wireless Networks. Cambridge: Cambridge University Press, 2012. 284 p.

[159] Hancke G. P. A Practical Relay Attack on ISO 14443 Proximity Cards: technical report. University of Cambridge, 2005.

[160] Harkins D. (Ed.), Kumari W. (Ed.). Opportunistic Wireless Encryption. RFC 8110. IETF, 2017. DOI: 10.17487/RFC8110. URL: https://www.rfc-editor.org/rfc/rfc8110.

[161] Harkins D. (Ed.). Dragonfly Key Exchange. RFC 7664. IRTF, 2015. DOI: 10.17487/RFC7664. URL: https://www.rfc-editor.org/rfc/rfc7664.

[162] Hexa-X-II. Deliverable on Security and Privacy for 6G: project report. European 6G flagship project, 2024. URL: https://hexa-x-ii.eu/.

[163] Hexa-X. Deliverable on 6G Architecture and Security Enablers: project report. European 6G flagship project, 2023. URL: https://hexa-x.eu/.

[164] Howell G., Franklin J. M., Sritapan V., Souppaya M., Scarfone K. Guidelines for Managing the Security of Mobile Devices in the Enterprise. NIST SP 800-124, Rev. 2. Gaithersburg, MD, 2023. DOI: 10.6028/NIST.SP.800-124r2. URL: https://csrc.nist.gov/pubs/sp/800/124/r2/final.

[165] Hu Y.-C., Perrig A., Johnson D. B. Ariadne: A Secure On-Demand Routing Protocol for Ad Hoc Networks. *Wireless Networks*. 2005. Vol. 11, No. 1–2. P. 21–38. DOI: 10.1007/s11276-004-4744-y.

[166] Hu Y.-C., Perrig A., Johnson D. B. Packet Leashes: A Defense against Wormhole Attacks in Wireless Networks. *IEEE INFOCOM 2003*. San Francisco: IEEE, 2003. Vol. 3. P. 1976–1986. DOI: 10.1109/INFCOM.2003.1209219.

[167] Hubbard D. W., Seiersen R. How to Measure Anything in Cybersecurity Risk. Hoboken: Wiley, 2016. 278 p.

[168] Humphreys T. E., Ledvina B. M., Psiaki M. L., O'Hanlon B. W., Kintner P. M. Assessing the Spoofing Threat: Development of a Portable GPS Civilian Spoofer. *Proceedings of the 21st International Technical Meeting of the Satellite Division of ION (ION GNSS 2008)*. Savannah: ION, 2008. P. 2314–2325.

[169] IEC 31010:2019. Risk management — Risk assessment techniques. Geneva: IEC, 2019.

[170] IEC 62443-3-3:2013. Industrial communication networks — Network and system security — Part 3-3: System security requirements and security levels. Geneva: IEC, 2013. URL: https://webstore.iec.ch/publication/7033.

[171] IEEE Std 802.11-2024. IEEE Standard for Information Technology — Telecommunications and Information Exchange between Systems — Local and Metropolitan Area Networks — Specific Requirements — Part 11: Wireless LAN Medium Access Control (MAC) and Physical Layer (PHY) Specifications. New York: IEEE, 2025. URL: https://standards.ieee.org/standard/802_11-2024.html.

[172] IEEE Std 802.11s-2011. IEEE Standard for Information Technology — Local and Metropolitan Area Networks — Amendment 10: Mesh Networking. New York: IEEE, 2011.

[173] IEEE Std 802.15.4-2020. IEEE Standard for Low-Rate Wireless Networks. New York: IEEE, 2020. DOI: 10.1109/IEEESTD.2020.9144691.

[174] IEEE Std 802.15.4z-2020. IEEE Standard for Low-Rate Wireless Networks — Amendment 1: Enhanced Ultra Wideband (UWB) Physical Layers (PHYs) and Associated Ranging Techniques. New York: IEEE, 2020.

[175] IEEE Std 802.1X-2020. IEEE Standard for Local and Metropolitan Area Networks — Port-Based Network Access Control. New York: IEEE, 2020. URL: https://standards.ieee.org/ieee/802.1X/7345/.

[176] ISO 22301:2019. Security and resilience — Business continuity management systems — Requirements. Geneva: ISO, 2019. URL: https://www.iso.org/standard/75106.html.

[177] ISO 22301:2019. Security and resilience — Business continuity management systems — Requirements. Geneva: ISO, 2019.

[178] ISO 31000:2018. Risk management — Guidelines. Geneva: ISO, 2018. URL: https://www.iso.org/standard/65694.html.

[179] ISO/IEC 14443-1:2018. Cards and security devices for personal identification — Contactless proximity objects — Part 1: Physical characteristics. Geneva: ISO, 2018.

[180] ISO/IEC 15408-1:2022. Information security, cybersecurity and privacy protection — Evaluation criteria for IT security — Part 1: Introduction and general model. Geneva: ISO, 2022. URL: https://www.iso.org/standard/72891.html.

[181] ISO/IEC 27004:2016. Information technology — Security techniques — Information security management — Monitoring, measurement, analysis and evaluation. Geneva: ISO, 2016.

[182] ISO/IEC 27005:2022. Information security, cybersecurity and privacy protection — Guidance on managing information security risks. Geneva: ISO, 2022. URL: https://www.iso.org/standard/80585.html.

[183] ISO/IEC 27011:2016. Information technology — Security techniques — Code of practice for Information security controls based on ISO/IEC 27002 for telecommunications organizations. Geneva: ISO, 2016.

[184] ISO/IEC 27033-1:2015. Information technology — Security techniques — Network security — Part 1: Overview and concepts. Geneva: ISO, 2015.

[185] Jakobsson M., Wetzel S. Security Weaknesses in Bluetooth. *Topics in Cryptology — CT-RSA 2001*. Lecture Notes in Computer Science. Vol. 2020. Berlin: Springer, 2001. P. 176–191. DOI: 10.1007/3-540-45353-9_14.

[186] Jana S., Premnath S. N., Clark M., Kasera S. K., Patwari N., Krishnamurthy S. V. On the Effectiveness of Secret Key Extraction from Wireless Signal Measurements. *Proceedings of the 15th ACM International Conference on Mobile Computing and Networking (MobiCom '09)*. New York: ACM, 2009. P. 321–332. DOI: 10.1145/1614320.1614356.

[187] Karlof C., Wagner D. Secure Routing in Wireless Sensor Networks: Attacks and Countermeasures. *Ad Hoc Networks*. 2003. Vol. 1, No. 2–3. P. 293–315. DOI: 10.1016/S1570-8705(03)00008-8.

[188] Kay S. M. Fundamentals of Statistical Signal Processing. Vol. II: Detection Theory. Upper Saddle River: Prentice Hall, 1998. 560 p.

[189] Kent S., Seo K. Security Architecture for the Internet Protocol. RFC 4301. IETF, 2005. DOI: 10.17487/RFC4301. URL: https://www.rfc-editor.org/rfc/rfc4301.

[190] Kerns A. J., Shepard D. P., Bhatti J. A., Humphreys T. E. Unmanned Aircraft Capture and Control via GPS Spoofing. *Journal of Field Robotics*. 2014. Vol. 31, No. 4. P. 617–636. DOI: 10.1002/rob.21513.

[191] Kitchenham B., Charters S. Guidelines for Performing Systematic Literature Reviews in Software Engineering. EBSE Technical Report EBSE-2007-01. Keele University, 2007.

[192] Kolias C., Kambourakis G., Stavrou A., Gritzalis S. Intrusion Detection in 802.11 Networks: Empirical Evaluation of Threats and a Public Dataset. *IEEE Communications Surveys & Tutorials*. 2016. Vol. 18, No. 1. P. 184–208. DOI: 10.1109/COMST.2015.2402161.

[193] Kordy B., Piètre-Cambacédès L., Schweitzer P. DAG-based Attack and Defense Modeling: Don't Miss the Forest for the Attack Trees. *Computer Science Review*. 2014. Vol. 13–14. P. 1–38. DOI: 10.1016/j.cosrev.2014.07.001.

[194] Kune D. F., Koelndorfer J., Hopper N., Kim Y. Location Leaks on the GSM Air Interface. *Proceedings of the Network and Distributed System Security Symposium (NDSS 2012)*. San Diego: Internet Society, 2012.

[195] Kwasinski A. Effects of Notable Natural Disasters on Communications Networks Power Supply and Lessons Learned. *2020 IEEE International Telecommunications Energy Conference (INTELEC)*. IEEE, 2020.

[196] Leung-Yan-Cheong S. K., Hellman M. E. The Gaussian Wire-Tap Channel. *IEEE Transactions on Information Theory*. 1978. Vol. 24, No. 4. P. 451–456. DOI: 10.1109/TIT.1978.1055917.

[197] LoRaWAN L2 1.0.4 Specification (TS001-1.0.4). Fremont, CA: LoRa Alliance, 2020. URL: https://lora-alliance.org/resource_hub/lorawan-104-specification-package/.

[198] Manesh M. R., Kaabouch N. Cyber-Attacks on Unmanned Aerial System Networks: Detection, Countermeasure, and Future Directions. *Computers & Security*. 2019. Vol. 85. P. 386–401. DOI: 10.1016/j.cose.2019.05.003.

[199] Marczak B., Scott-Railton J. et al. FORCEDENTRY: NSO Group iMessage Zero-Click Exploit Captured in the Wild. The Citizen Lab, University of Toronto, 2021. URL: https://citizenlab.ca/.

[200] Martin J., Mayberry T., Donahue C., Foppe L., Brown L., Riggins C., Rye E. C., Brown D. A Study of MAC Address Randomization in Mobile Devices and When it Fails. *Proceedings on Privacy Enhancing Technologies*. 2017. Vol. 2017, No. 4. P. 365–383. DOI: 10.1515/popets-2017-0054.

[201] Mathur S., Trappe W., Mandayam N., Ye C., Reznik A. Radio-telepathy: Extracting a Secret Key from an Unauthenticated Wireless Channel. *Proceedings of the 14th ACM International Conference on Mobile Computing and Networking (MobiCom '08)*. New York: ACM, 2008. P. 128–139. DOI: 10.1145/1409944.1409960.

[202] Matter Specification. Version 1.3. Connectivity Standards Alliance, 2024. URL: https://csa-iot.org/all-solutions/matter/.

[203] Maurer U. M. Secret Key Agreement by Public Discussion from Common Information. *IEEE Transactions on Information Theory*. 1993. Vol. 39, No. 3. P. 733–742. DOI: 10.1109/18.256484.

[204] Meijer C., Verdult R., Wetzels W. All Cops Are Broadcasting: TETRA Under Scrutiny. *Proceedings of the 32nd USENIX Security Symposium*. USENIX Association, 2023.

[205] MITRE ATT&CK for Mobile: Tactics and Techniques. The MITRE Corporation. URL: https://attack.mitre.org/matrices/mobile/.

[206] MITRE ATT&CK®: Adversarial Tactics, Techniques, and Common Knowledge (Enterprise and Mobile matrices). The MITRE Corporation. URL: https://attack.mitre.org/.

[207] MITRE FiGHT™: 5G Hierarchy of Threats. The MITRE Corporation. URL: https://fight.mitre.org/.

[208] Mosca M. Cybersecurity in an Era with Quantum Computers: Will We Be Ready? *IEEE Security & Privacy*. 2018. Vol. 16, No. 5. P. 38–41. DOI: 10.1109/MSP.2018.3761723.

[209] Mukherjee A., Fakoorian S. A. A., Huang J., Swindlehurst A. L. Principles of Physical Layer Security in Multiuser Wireless Networks: A Survey. *IEEE Communications Surveys & Tutorials*. 2014. Vol. 16, No. 3. P. 1550–1573. DOI: 10.1109/SURV.2014.012314.00178.

[210] NIS Cooperation Group. Cybersecurity of 5G networks: EU Toolbox of risk mitigating measures. CG Publication 01/2020. Brussels: European Commission, 2020. URL: https://digital-strategy.ec.europa.eu/en/library/cybersecurity-5g-networks-eu-toolbox-risk-mitigating-measures.

[211] NIS Cooperation Group. EU coordinated risk assessment of the cybersecurity of 5G networks: report. Brussels: European Commission, 2019.

[212] NIST. Advanced Encryption Standard (AES). FIPS 197 (updated 2023). Gaithersburg, MD, 2001. DOI: 10.6028/NIST.FIPS.197-upd1. URL: https://csrc.nist.gov/pubs/fips/197/final.

[213] NIST. Ascon-Based Lightweight Cryptography Standards for Constrained Devices. NIST SP 800-232. Gaithersburg, MD: NIST, 2025. DOI: 10.6028/NIST.SP.800-232.

[214] NIST. Guide for Conducting Risk Assessments. NIST SP 800-30, Rev. 1. Gaithersburg, MD, 2012. DOI: 10.6028/NIST.SP.800-30r1. URL: https://csrc.nist.gov/pubs/sp/800/30/r1/final.

[215] NIST. Implementing a Zero Trust Architecture. NIST Special Publication 1800-35. Gaithersburg, MD: NIST, 2025. URL: https://www.nccoe.nist.gov/projects/implementing-zero-trust-architecture.

[216] NIST. Module-Lattice-Based Digital Signature Standard. FIPS 204. Gaithersburg, MD, 2024. DOI: 10.6028/NIST.FIPS.204. URL: https://csrc.nist.gov/pubs/fips/204/final.

[217] NIST. Module-Lattice-Based Key-Encapsulation Mechanism Standard. FIPS 203. Gaithersburg, MD, 2024. DOI: 10.6028/NIST.FIPS.203. URL: https://csrc.nist.gov/pubs/fips/203/final.

[218] NIST. Security Requirements for Cryptographic Modules. FIPS 140-3. Gaithersburg, MD, 2019. DOI: 10.6028/NIST.FIPS.140-3. URL: https://csrc.nist.gov/pubs/fips/140-3/final.

[219] NIST. Stateless Hash-Based Digital Signature Standard. FIPS 205. Gaithersburg, MD: NIST, 2024. DOI: 10.6028/NIST.FIPS.205.

[220] NIST. The NIST Cybersecurity Framework (CSF) 2.0. NIST CSWP 29. Gaithersburg, MD, 2024. DOI: 10.6028/NIST.CSWP.29. URL: https://csrc.nist.gov/pubs/cswp/29/the-nist-cybersecurity-framework-20/final.

[221] O'Flynn C. A Framework for Embedded Hardware Security Analysis. PhD Thesis. Dalhousie University, 2017.

[222] O'Shea T. J., Roy T., Clancy T. C. Over-the-Air Deep Learning Based Radio Signal Classification. *IEEE Journal of Selected Topics in Signal Processing*. 2018. Vol. 12, No. 1. P. 168–179. DOI: 10.1109/JSTSP.2018.2797022.

[223] O-RAN Alliance. O-RAN Security Requirements and Controls Specification. O-RAN ALLIANCE e.V., 2024.

[224] O-RAN Alliance. O-RAN Security Threat Modeling and Remediation Analysis: technical specification. O-RAN ALLIANCE e.V., 2024. URL: https://www.o-ran.org/specifications.

[225] OWASP Mobile Application Security Testing Guide (MASTG). OWASP Foundation. URL: https://mas.owasp.org/MASTG/.

[226] OWASP Mobile Application Security Verification Standard (MASVS) v2. OWASP Foundation. URL: https://mas.owasp.org/MASVS/.

[227] Padgette J., Bahr J., Holtzclaw M., Batra M., Chen L., Smithbey R., Scarfone K. Guide to Bluetooth Security. NIST SP 800-121, Rev. 2. Gaithersburg, MD, 2017. DOI: 10.6028/NIST.SP.800-121r2. URL: https://csrc.nist.gov/pubs/sp/800/121/r2/upd1/final.

[228] Park S., Shaik A., Borgaonkar R., Seifert J.-P. White-Stingray: Evaluating IMSI Catchers Detection Applications. *Proceedings of the 11th USENIX Workshop on Offensive Technologies (WOOT 17)*. USENIX Association, 2017.

[229] Pavur J., Moser D., Strohmeier M., Lenders V., Martinovic I. A Tale of Sea and Sky: On the Security of Maritime VSAT Communications. *2020 IEEE Symposium on Security and Privacy (SP)*. San Francisco: IEEE, 2020. P. 1384–1400. DOI: 10.1109/SP40000.2020.00056.

[230] Peffers K., Tuunanen T., Rothenberger M. A., Chatterjee S. A Design Science Research Methodology for Information Systems Research. *Journal of Management Information Systems*. 2007. Vol. 24, No. 3. P. 45–77. DOI: 10.2753/MIS0742-1222240302.

[231] Perrig A., Szewczyk R., Tygar J. D., Wen V., Culler D. E. SPINS: Security Protocols for Sensor Networks. *Wireless Networks*. 2002. Vol. 8, No. 5. P. 521–534. DOI: 10.1023/A:1016598314198.

[232] Pinto P. C., Barros J., Win M. Z. Secure Communication in Stochastic Wireless Networks — Part I: Connectivity. *IEEE Transactions on Information Forensics and Security*. 2012. Vol. 7, No. 1. P. 125–138.

[233] Poisel R. A. Electronic Warfare Target Location Methods. 2nd ed. Norwood: Artech House, 2012.

[234] Poisel R. A. Modern Communications Jamming Principles and Techniques. 2nd ed. Norwood: Artech House, 2011.

[235] Preuß Mattsson J., Sethi M. EAP-TLS 1.3: Using the Extensible Authentication Protocol with TLS 1.3. RFC 9190. IETF, 2022. DOI: 10.17487/RFC9190. URL: https://www.rfc-editor.org/rfc/rfc9190.

[236] Psiaki M. L., Humphreys T. E. GNSS Spoofing and Detection. *Proceedings of the IEEE*. 2016. Vol. 104, No. 6. P. 1258–1270. DOI: 10.1109/JPROC.2016.2526658.

[237] Pöpper C., Strasser M., Čapkun S. Anti-jamming Broadcast Communication using Uncoordinated Spread Spectrum Techniques. *IEEE Journal on Selected Areas in Communications*. 2010. Vol. 28, No. 5. P. 703–715. DOI: 10.1109/JSAC.2010.100608.

[238] Radio Regulations. Edition of 2024. Geneva: International Telecommunication Union, 2024. URL: https://www.itu.int/pub/R-REG-RR.

[239] Rao S. P., Holtmanns S., Aura T. Threat Modeling Diameter Security. *2018 IEEE International Conference on Communications Workshops (ICC Workshops)*. Kansas City: IEEE, 2018.

[240] Rappaport T. S. Wireless Communications: Principles and Practice. 2nd ed. Upper Saddle River: Prentice Hall, 2002. 707 p.

[241] Recommendation ITU-R M.2083-0. IMT Vision — Framework and overall objectives of the future development of IMT for 2020 and beyond. Geneva: ITU, 2015. URL: https://www.itu.int/rec/R-REC-M.2083.

[242] Recommendation ITU-R M.2160-0. Framework and overall objectives of the future development of IMT for 2030 and beyond. Geneva: ITU, 2023. URL: https://www.itu.int/rec/R-REC-M.2160.

[243] Recommendation ITU-R S.1503. Functional description to be used in developing software tools for determining conformity of non-geostationary-satellite orbit fixed-satellite service systems. Geneva: ITU.

[244] Recommendation ITU-T X.805 (10/2003). Security architecture for systems providing end-to-end communications. Geneva: ITU, 2003. URL: https://www.itu.int/rec/T-REC-X.805.

[245] Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data (General Data Protection Regulation). *Official Journal of the EU*. L 119. P. 1–88. URL: https://eur-lex.europa.eu/eli/reg/2016/679/oj.

[246] Regulation (EU) 2019/881 of the European Parliament and of the Council of 17 April 2019 on ENISA and on information and communications technology cybersecurity certification (Cybersecurity Act). *Official Journal of the EU*. L 151. P. 15–69. URL: https://eur-lex.europa.eu/eli/reg/2019/881/oj.

[247] Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements (Cyber Resilience Act). *Official Journal of the EU*. L series, 20.11.2024. URL: https://eur-lex.europa.eu/eli/reg/2024/2847/oj.

[248] Rigney C., Willens S., Rubens A., Simpson W. Remote Authentication Dial In User Service (RADIUS). RFC 2865. IETF, 2000. DOI: 10.17487/RFC2865. URL: https://www.rfc-editor.org/rfc/rfc2865.

[249] Ronen E., Shamir A., Weingarten A.-O., O'Flynn C. IoT Goes Nuclear: Creating a ZigBee Chain Reaction. *2017 IEEE Symposium on Security and Privacy (SP)*. San Jose: IEEE, 2017. P. 195–212. DOI: 10.1109/SP.2017.14.

[250] Rose S., Borchert O., Mitchell S., Connelly S. Zero Trust Architecture. NIST Special Publication 800-207. Gaithersburg, MD, 2020. DOI: 10.6028/NIST.SP.800-207. URL: https://csrc.nist.gov/pubs/sp/800/207/final.

[251] Rupprecht D., Kohls K., Holz T., Pöpper C. Breaking LTE on Layer Two. *2019 IEEE Symposium on Security and Privacy (SP)*. San Francisco: IEEE, 2019. P. 1121–1136. DOI: 10.1109/SP.2019.00006.

[252] Rupprecht D., Kohls K., Holz T., Pöpper C. IMP4GT: IMPersonation Attacks in 4G NeTworks. *Proceedings of the Network and Distributed System Security Symposium (NDSS 2020)*. San Diego: Internet Society, 2020.

[253] Sathaye H., LaMountain G., Closas P., Ranganathan A. SemperFi: Anti-spoofing GPS Receiver for UAVs. *Proceedings of the Network and Distributed System Security Symposium (NDSS 2022)*. San Diego: Internet Society, 2022.

[254] Sauter M. From GSM to LTE-Advanced Pro and 5G: An Introduction to Mobile Networks and Mobile Broadband. 4th ed. Chichester: Wiley, 2021.

[255] Scarfone K., Mell P. Guide to Intrusion Detection and Prevention Systems (IDPS). NIST SP 800-94. Gaithersburg, MD, 2007. DOI: 10.6028/NIST.SP.800-94. URL: https://csrc.nist.gov/pubs/sp/800/94/final.

[256] Schepers D., Ranganathan A., Vanhoef M. Framing Frames: Bypassing Wi-Fi Encryption by Manipulating Transmit Queues. *Proceedings of the 32nd USENIX Security Symposium*. USENIX Association, 2023.

[257] Schneier B. Attack Trees. *Dr. Dobb's Journal*. 1999. Vol. 24, No. 12. P. 21–29.

[258] Shaik A., Borgaonkar R., Asokan N., Niemi V., Seifert J.-P. Practical Attacks Against Privacy and Availability in 4G/LTE Mobile Communication Systems. *Proceedings of the Network and Distributed System Security Symposium (NDSS 2016)*. San Diego: Internet Society, 2016.

[259] Shannon C. E. A Mathematical Theory of Communication. *Bell System Technical Journal*. 1948. Vol. 27, No. 3. P. 379–423. DOI: 10.1002/j.1538-7305.1948.tb01338.x.

[260] Shannon C. E. Communication Theory of Secrecy Systems. *Bell System Technical Journal*. 1949. Vol. 28, No. 4. P. 656–715. DOI: 10.1002/j.1538-7305.1949.tb00928.x.

[261] Shelby Z., Hartke K., Bormann C. The Constrained Application Protocol (CoAP). RFC 7252. IETF, 2014. DOI: 10.17487/RFC7252. URL: https://www.rfc-editor.org/rfc/rfc7252.

[262] Shirey R. Internet Security Glossary, Version 2. RFC 4949. IETF, 2007. DOI: 10.17487/RFC4949. URL: https://www.rfc-editor.org/rfc/rfc4949.

[263] Shostack A. Threat Modeling: Designing for Security. Indianapolis: Wiley, 2014. 624 p.

[264] Simon D., Aboba B., Hurst R. The EAP-TLS Authentication Protocol. RFC 5216. IETF, 2008. DOI: 10.17487/RFC5216. URL: https://www.rfc-editor.org/rfc/rfc5216.

[265] Simon M. K., Omura J. K., Scholtz R. A., Levitt B. K. Spread Spectrum Communications Handbook. Revised ed. New York: McGraw-Hill, 2002.

[266] Sokolov V. et al. Jump-Stay Jamming Attack on Wi-Fi Systems. *2023 IEEE 18th International Conference on Computer Science and Information Technologies (CSIT)*. Lviv: IEEE, 2023.

[267] Sokolov V., Skladannyi P., Astapenya V. Bluetooth Low-Energy Beacon Resistance to Jamming Attack. *2023 IEEE 13th International Conference on Electronics and Information Technologies (ELIT)*. Lviv: IEEE, 2023.

[268] Sokolov V., Skladannyi P., Korshun N. ZigBee Network Resistance to Jamming Attacks. *2023 IEEE International Conference on Information and Telecommunication Technologies and Radio Electronics (UkrMiCo)*. Kyiv: IEEE, 2023.

[269] Sommer R., Paxson V. Outside the Closed World: On Using Machine Learning for Network Intrusion Detection. *2010 IEEE Symposium on Security and Privacy (SP)*. Oakland: IEEE, 2010. P. 305–316. DOI: 10.1109/SP.2010.25.

[270] Souppaya M., Morello J., Scarfone K. Implementing a Zero Trust Architecture. NIST SP 1800-35; DevSecOps practices. Gaithersburg, MD: NIST.

[271] Souppaya M., Scarfone K. Guidelines for Securing Wireless Local Area Networks (WLANs). NIST SP 800-153. Gaithersburg, MD, 2012. DOI: 10.6028/NIST.SP.800-153. URL: https://csrc.nist.gov/pubs/sp/800/153/final.

[272] Souppaya M., Scarfone K., Dodson D. Secure Software Development Framework (SSDF) Version 1.1. NIST SP 800-218. Gaithersburg, MD: NIST, 2022. DOI: 10.6028/NIST.SP.800-218.

[273] Sterbenz J. P. G., Hutchison D., Çetinkaya E. K., Jabbar A., Rohrer J. P., Schöller M., Smith P. Resilience and Survivability in Communication Networks: Strategies, Principles, and a Survey of Disciplines. *Computer Networks*. 2010. Vol. 54, No. 8. P. 1245–1265. DOI: 10.1016/j.comnet.2010.03.005.

[274] Strasser M., Pöpper C., Čapkun S., Čagalj M. Jamming-resistant Key Establishment using Uncoordinated Frequency Hopping. *2008 IEEE Symposium on Security and Privacy*. Oakland: IEEE, 2008. P. 64–78. DOI: 10.1109/SP.2008.9.

[275] Supply-chain Levels for Software Artifacts (SLSA) Framework. Version 1.0. Open Source Security Foundation, 2023. URL: https://slsa.dev/.

[276] Sweeney L. k-Anonymity: A Model for Protecting Privacy. *International Journal of Uncertainty, Fuzziness and Knowledge-Based Systems*. 2002. Vol. 10, No. 5. P. 557–570. DOI: 10.1142/S0218488502001648.

[277] Tews E., Weinmann R.-P., Pyshkin A. Breaking 104 Bit WEP in Less Than 60 Seconds. *Information Security Applications (WISA 2007)*. Lecture Notes in Computer Science. Vol. 4867. Berlin: Springer, 2007. P. 188–202. DOI: 10.1007/978-3-540-77535-5_14.

[278] Thread Specification. Version 1.3. Thread Group, 2023. URL: https://www.threadgroup.org/.

[279] Trivedi K. S., Bobbio A. Reliability and Availability Engineering: Modeling, Analysis, and Applications. Cambridge: Cambridge University Press, 2017. 730 p.

[280] Vanhoef M. Fragment and Forge: Breaking Wi-Fi Through Frame Aggregation and Fragmentation. *Proceedings of the 30th USENIX Security Symposium*. USENIX Association, 2021. P. 161–178.

[281] Vanhoef M., Piessens F. Key Reinstallation Attacks: Forcing Nonce Reuse in WPA2. *Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security (CCS '17)*. New York: ACM, 2017. P. 1313–1328. DOI: 10.1145/3133956.3134027.

[282] Vanhoef M., Ronen E. Dragonblood: Analyzing the Dragonfly Handshake of WPA3 and EAP-pwd. *2020 IEEE Symposium on Security and Privacy (SP)*. San Francisco: IEEE, 2020. P. 517–533. DOI: 10.1109/SP40000.2020.00031.

[283] Vučinić M. (Ed.) et al. Constrained Join Protocol (CoJP) for 6TiSCH. RFC 9031. IETF, 2021. DOI: 10.17487/RFC9031. URL: https://www.rfc-editor.org/rfc/rfc9031.

[284] Ward R., Beyer B. BeyondCorp: A New Approach to Enterprise Security. *;login:*. 2014. Vol. 39, No. 6. P. 6–11. USENIX Association.

[285] Winter S., McCauley M., Venaas S., Wierenga K. Transport Layer Security (TLS) Encryption for RADIUS. RFC 6614. IETF, 2012. DOI: 10.17487/RFC6614. URL: https://www.rfc-editor.org/rfc/rfc6614.

[286] WPA3™ Specification. Austin, TX: Wi-Fi Alliance. URL: https://www.wi-fi.org/discover-wi-fi/security.

[287] Wyner A. D. The Wire-Tap Channel. *Bell System Technical Journal*. 1975. Vol. 54, No. 8. P. 1355–1387. DOI: 10.1002/j.1538-7305.1975.tb02040.x.

[288] Xu W., Trappe W., Zhang Y., Wood T. The Feasibility of Launching and Detecting Jamming Attacks in Wireless Networks. *Proceedings of the 6th ACM International Symposium on Mobile Ad Hoc Networking and Computing (MobiHoc '05)*. New York: ACM, 2005. P. 46–57. DOI: 10.1145/1062689.1062697.

[289] Zander S., Armitage G., Branch P. A Survey of Covert Channels and Countermeasures in Computer Network Protocols. *IEEE Communications Surveys & Tutorials*. 2007. Vol. 9, No. 3. P. 44–57. DOI: 10.1109/COMST.2007.4317620.

[290] Zigbee Specification. Revision 22. Davis, CA: Connectivity Standards Alliance, 2017.

[291] Zou Y., Zhu J., Wang X., Hanzo L. A Survey on Wireless Security: Technical Challenges, Recent Advances, and Future Trends. *Proceedings of the IEEE*. 2016. Vol. 104, No. 9. P. 1727–1765. DOI: 10.1109/JPROC.2016.2558521.

[292] Čapkun S. Physical Layer and Telecommunications Security Knowledge Area. Version 1.0.1. *The Cyber Security Body of Knowledge (CyBOK)*. © Crown Copyright, The National Cyber Security Centre, 2021. Licensed under the Open Government Licence v3.0. URL: https://www.cybok.org/.

[293] Čapkun S., Hubaux J.-P. Secure Positioning in Wireless Networks. *IEEE Journal on Selected Areas in Communications*. 2006. Vol. 24, No. 2. P. 221–232. DOI: 10.1109/JSAC.2005.861380.

Додаток. Завдання для самостійної роботи

Завдання згруповано за тематичними блоками посібника. Для кожної теми зазначено зміст роботи та форму подання результату. Результати доцільно оформлювати як фрагменти дослідницької роботи магістранта: з постановкою задачі, обґрунтуванням методу, числовими результатами та висновками. Багато завдань спираються на дослідницькі питання самоперевірки відповідних розділів.

Блок I. Засади

1. **Аналіз безпроводової мережі як об'єкта захисту** (розділ 1). Для обраної реальної мережі визначити класи технологій, домени довіри, побудувати багаторівневу поверхню атаки та модель порушника. *Форма:* аналітична записка зі схемами.
2. **Визначення застосовних нормативних вимог** (розділ 2). Для оператора або виробника безпроводового обладнання скласти реєстр обов'язкових і добровільних вимог, обчислити індекс розриву відповідності. *Форма:* реєстр вимог і розрахунок.
3. **Оцінювання захищеності безпроводової ланки** (розділ 3). Для заданої мережі виконати розрахунок зони перехоплення, стійкості автентифікації, частки істинних тривог і стійкості до глушіння. *Форма:* розрахунково-аналітична записка.
4. **Моделювання загроз і оцінювання ризиків** (розділ 4). Побудувати модель загроз (STRIDE, LINDDUN), дерево атак і кількісну оцінку ризику з обґрунтуванням заходів. *Форма:* модель загроз і реєстр ризиків.

Блок II. Механізми та технології захисту радіоінтерфейсів

5. **Безпека фізичного рівня** (розділ 5). Дослідити методи протидії глушінню для заданого каналу, розрахувати запас стійкості й секретну пропускну здатність. *Форма:* звіт з розрахунками.
6. **Криптографічний профіль мережі** (розділ 6). Спроєктувати криптографічний профіль корпоративної безпроводової мережі з обґрунтуванням алгоритмів, ієрархії ключів і постквантової готовності. *Форма:* проєктне рішення.
7. **Проєктування захищеної мережі Wi-Fi** (розділ 7). Розробити конфігурацію корпоративної мережі з автентифікацією, сегментацією й мо-

ніторингом; побудувати дерево атак і оцінити ефект заходів. *Форма:* проєкт і оцінка.

8. **Аналіз безпеки технологій ближньої дії** (розділ 8). Проаналізувати систему контролю доступу або платежів на NFC/Bluetooth, визначити вразливості та заходи. *Форма:* аналітичний звіт.
9. **Захист від сигнальних і радіоатак** (розділ 9). Розробити програму захисту абонентів оператора від атак SS7/Diameter і фальшивих базових станцій. *Форма:* програма заходів.
10. **Безпека приватної мережі 5G** (розділ 10). Спроєктувати безпеку приватної мережі 5G промислового підприємства з обґрунтуванням конфігурації опційних механізмів. *Форма:* проєктне рішення.

Блок III. Платформи, пристрої та спеціалізовані мережі

11. **Захищений мобільний доступ і нульова довіра** (розділ 11). Розробити функцію оцінки довіри для мобільного доступу, визначити сигнали, ваги й пороги. *Форма:* модель і обґрунтування.
12. **Захист сенсорної мережі Інтернету речей** (розділ 12). Спроєктувати захист безпроводової сенсорної мережі з диференційованим підходом за впливом компрометації. *Форма:* проєкт і модель поширення.
13. **Управління довірою в самоорганізованій мережі** (розділ 13). Розробити репутаційну систему або схему управління ключами для самоорганізованої чи відомчої мережі. *Форма:* схема й аналіз стійкості.
14. **Стійка навігація й захист безпілотної системи** (розділ 14). Спроєктувати систему виявлення підміни GNSS або захисту каналів безпілотного апарата. *Форма:* архітектура й оцінка.

Блок IV. Операційна безпека та управління

15. **Моніторинг безпеки безпроводової інфраструктури** (розділ 15). Спроєктувати багатоступеневу схему виявлення атак з кореляцією й локалізацією; оцінити частку істинних тривог. *Форма:* проєкт системи моніторингу.
16. **План стійкості мобільного оператора** (розділ 16). Розробити план стійкості з обґрунтуванням незалежності резервів, енергетичної автономності й національного роумінгу. *Форма:* план і модель доступності.
17. **Програма безпеки та наукове дослідження** (розділ 17). Розробити систему метрик безпеки безпроводової інфраструктури або виконати систематичний огляд за обраним перспективним напрямом як основу дисертаційного дослідження. *Форма:* система метрик або огляд із постановкою наукової задачі.